

CIS Microsoft Windows 8 Benchmark [imported]

v1.0.0 – 02-01-2013

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

ARCHIVE

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	14
Intended Audience.....	14
Consensus Guidance	15
Typographical Conventions.....	16
Recommendation Definitions.....	17
Title.....	17
Assessment Status.....	17
Automated	17
Manual.....	17
Profile	17
Description.....	17
Rationale Statement	17
Impact Statement.....	18
Audit Procedure.....	18
Remediation Procedure.....	18
Default Value.....	18
References	18
CIS Critical Security Controls® (CIS Controls®)	18
Additional Information.....	18
Profile Definitions	19
Acknowledgements	20
Recommendations	21
1 Computer Configuration	21
1.1 Security Settings.....	21
1.1.1 Account Policies	21
1.1.1.1 Set 'Account lockout threshold' to '5 invalid logon attempt(s)' (Automated)	22
1.1.1.2 Set 'Account lockout duration' to '15 or more minute(s)' (Automated)	24
1.1.1.3 Set 'Reset account lockout counter after' to '15 minute(s)' (Automated)	26
1.1.1.4 Set 'Minimum password length' to '14 or more character(s)' (Automated)	28
1.1.1.5 Set 'Enforce password history' to '24 or more password(s)' (Automated)	30
1.1.1.6 Set 'Password must meet complexity requirements' to 'Enabled' (Automated)	32
1.1.1.7 Set 'Store passwords using reversible encryption' to 'Disabled' (Automated)	34
1.1.1.8 Set 'Minimum password age' to '1 or more day(s)' (Automated)	36
1.1.1.9 Set 'Maximum password age' to '60 or fewer days' (Automated)	38
1.1.2 Advanced Audit Policy Configuration.....	40

1.1.2.1 Set 'Audit Policy: Privilege Use: Sensitive Privilege Use' to 'Success and Failure' (Automated).....	41
1.1.2.2 Set 'Audit Policy: Account Management: Other Account Management Events' to 'Success and Failure' (Automated).....	43
1.1.2.3 Set 'Audit Policy: Logon-Logoff: IPsec Quick Mode' to 'No Auditing' (Automated)	45
1.1.2.4 Set 'Audit Policy: Detailed Tracking: RPC Events' to 'No Auditing' (Automated)	47
1.1.2.5 Set 'Audit Policy: DS Access: Directory Service Access' to 'No Auditing' (Automated)	49
1.1.2.6 Set 'Audit Policy: Policy Change: MPSSVC Rule-Level Policy Change' to 'No Auditing' (Automated)	51
1.1.2.7 Set 'Audit Policy: Account Management: Distribution Group Management' to 'No Auditing' (Automated)	53
1.1.2.8 Set 'Audit Policy: Detailed Tracking: Process Termination' to 'No Auditing' (Automated).....	55
1.1.2.9 Set 'Audit Policy: Object Access: Detailed File Share' to 'No Auditing' (Automated)	57
1.1.2.10 Set 'Audit Policy: Account Management: User Account Management' to 'Success and Failure' (Automated)	59
1.1.2.11 Set 'Audit Policy: Account Management: Computer Account Management' to 'No Auditing' (Automated)	61
1.1.2.12 Set 'Audit Policy: System: Security System Extension' to 'Success and Failure' (Automated).....	63
1.1.2.13 Set 'Audit Policy: System: Security State Change' to 'Success and Failure' (Automated).....	65
1.1.2.14 Set 'Audit Policy: Logon-Logoff: Network Policy Server' to 'No Auditing' (Automated)	67
1.1.2.15 Set 'Audit Policy: Detailed Tracking: DPAPI Activity' to 'No Auditing' (Automated)	69
1.1.2.16 Set 'Audit Policy: System: IPsec Driver' to 'Success and Failure' (Automated)	71
1.1.2.17 Set 'Audit Policy: Account Management: Security Group Management' to 'Success and Failure' (Automated)	73
1.1.2.18 Set 'Audit Policy: Account Logon: Other Account Logon Events' to 'No Auditing' (Automated).....	75
1.1.2.19 Set 'Audit Policy: Object Access: Registry' to 'No Auditing' (Automated)	77
1.1.2.20 Set 'Audit Policy: Privilege Use: Other Privilege Use Events' to 'No Auditing' (Automated)	79
1.1.2.21 Set 'Audit Policy: Policy Change: Filtering Platform Policy Change' to 'No Auditing' (Automated)	81
1.1.2.22 Set 'Audit Policy: Object Access: Central Access Policy Staging' to 'No Auditing' (Automated).....	84
1.1.2.23 Set 'Audit Policy: Policy Change: Authorization Policy Change' to 'No Auditing' (Automated)	86
1.1.2.24 Set 'Audit Policy: Account Logon: Kerberos Authentication Service' to 'No Auditing' (Automated).....	88
1.1.2.25 Set 'Audit Policy: Logon-Logoff: Logoff' to 'Success' (Automated)	90
1.1.2.26 Set 'Audit Policy: Account Management: Application Group Management' to 'No Auditing' (Automated)	92
1.1.2.27 Set 'Audit Policy: DS Access: Directory Service Changes' to 'No Auditing' (Automated)	94
1.1.2.28 Set 'Audit Policy: Object Access: Kernel Object' to 'No Auditing' (Automated).....	96
1.1.2.29 Set 'Audit Policy: Policy Change: Other Policy Change Events' to 'No Auditing' (Automated)	98
1.1.2.30 Set 'Audit Policy: Object Access: Application Generated' to 'No Auditing' (Automated)	100
1.1.2.31 Set 'Audit Policy: Logon-Logoff: Account Lockout' to 'No Auditing' (Automated).....	102
1.1.2.32 Set 'Audit Policy: Policy Change: Audit Policy Change' to 'Success and Failure' (Automated)	104
1.1.2.33 Set 'Audit Policy: Object Access: File Share' to 'No Auditing' (Automated)	106
1.1.2.34 Set 'Audit Policy: System: System Integrity' to 'Success and Failure' (Automated).....	108
1.1.2.35 Set 'Audit Policy: System: Other System Events' to 'No Auditing' (Automated)	110
1.1.2.36 Set 'Audit Policy: Logon-Logoff: Other Logon/Logoff Events' to 'No Auditing' (Automated)	112
1.1.2.37 Set 'Audit Policy: DS Access: Directory Service Replication' to 'No Auditing' (Automated).....	114
1.1.2.38 Set 'Audit Policy: Object Access: Filtering Platform Packet Drop' to 'No Auditing' (Automated)	116
1.1.2.39 Set 'Audit Policy: DS Access: Detailed Directory Service Replication' to 'No Auditing' (Automated)	118
1.1.2.40 Set 'Audit Policy: Object Access: Other Object Access Events' to 'No Auditing' (Automated).....	120
1.1.2.41 Set 'Audit Policy: Object Access: Filtering Platform Connection' to 'No Auditing' (Automated)	122
1.1.2.42 Set 'Audit Policy: Privilege Use: Non Sensitive Privilege Use' to 'No Auditing' (Automated)	124
1.1.2.43 Set 'Audit Policy: Object Access: Certification Services' to 'No Auditing' (Automated).....	126
1.1.2.44 Set 'Audit Policy: Logon-Logoff: Special Logon' to 'Success' (Automated)	128
1.1.2.45 Set 'Audit Policy: Object Access: Handle Manipulation' to 'No Auditing' (Automated)	130

1.1.2.46 Set 'Audit Policy: Object Access: Removable Storage' to 'No Auditing' (Automated).....	132
1.1.2.47 Set 'Audit Policy: Logon-Logoff: IPsec Main Mode' to 'No Auditing' (Automated)	134
1.1.2.48 Set 'Audit Policy: Account Logon: Credential Validation' to 'Success and Failure' (Automated) .	136
1.1.2.49 Set 'Audit Policy: Account Logon: Kerberos Service Ticket Operations' to 'No Auditing' (Automated)	138
1.1.2.50 Set 'Audit Policy: Logon-Logoff: Logon' to 'Success and Failure' (Automated)	140
1.1.2.51 Set 'Audit Policy: Detailed Tracking: Process Creation' to 'Success' (Automated)	142
1.1.2.52 Set 'Audit Policy: Logon-Logoff: IPsec Extended Mode' to 'No Auditing' (Automated)	144
1.1.2.53 Set 'Audit Policy: Object Access: SAM' to 'No Auditing' (Automated).....	146
1.1.2.54 Set 'Audit Policy: Object Access: File System' to 'No Auditing' (Automated).....	148
1.1.2.55 Set 'Audit Policy: Policy Change: Authentication Policy Change' to 'Success' (Automated)	150
1.1.3 Security Options.....	152
1.1.3.1.1 Set 'Accounts: Block Microsoft accounts' to 'Users can't add or log on with Microsoft accounts' (Automated)	153
1.1.3.1.2 Configure 'Accounts: Rename guest account' (Automated)	155
1.1.3.1.3 Set 'Accounts: Administrator account status' to 'Disabled' (Automated).....	156
1.1.3.1.4 Configure 'Accounts: Rename administrator account' (Automated)	158
1.1.3.1.5 Set 'Accounts: Guest account status' to 'Disabled' (Automated)	160
1.1.3.1.6 Set 'Accounts: Limit local account use of blank passwords to console logon only' to 'Enabled' (Automated)	162
1.1.3.2.1 Set 'Audit: Shut down system immediately if unable to log security audits' to 'Disabled' (Automated)	165
1.1.3.2.2 Set 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' to 'Enabled' (Automated)	167
1.1.3.2.3 Configure 'Audit: Audit the use of Backup and Restore privilege' (Manual)	169
1.1.3.2.4 Configure 'Audit: Audit the access of global system objects' (Manual).....	171
1.1.3.3.1 Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual).....	174
1.1.3.3.2 Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual).....	176
1.1.3.4.1 Configure 'Devices: Allow undock without having to log on' (Manual).....	180
1.1.3.4.2 Configure 'Devices: Restrict floppy access to locally logged-on user only' (Manual)	182
1.1.3.4.3 Set 'Devices: Allowed to format and eject removable media' to 'Administrators and Interactive Users' (Automated)	184
1.1.3.4.4 Configure 'Devices: Restrict CD-ROM access to locally logged-on user only' (Manual)	186
1.1.3.4.5 Configure 'Devices: Prevent users from installing printer drivers' (Manual)	188
1.1.3.5.1 Set 'Domain member: Require strong (Windows 2000 or later) session key' to 'Enabled' (Automated)	191
1.1.3.5.2 Set 'Domain member: Digitally sign secure channel data (when possible)' to 'Enabled' (Automated)	193
1.1.3.5.3 Set 'Domain member: Digitally encrypt secure channel data (when possible)' to 'Enabled' (Automated)	196
1.1.3.5.4 Set 'Domain member: Maximum machine account password age' to '30 or fewer day(s)' (Automated)	198
1.1.3.5.5 Set 'Domain member: Digitally encrypt or sign secure channel data (always)' to 'Enabled' (Automated)	200
1.1.3.5.6 Set 'Domain member: Disable machine account password changes' to 'Disabled' (Automated).....	203
1.1.3.6.1 Set 'Interactive logon: Machine account lockout threshold' to 10 or fewer invalid logon attempts (Automated)	206
1.1.3.6.2 Set 'Interactive logon: Smart card removal behavior' to 'Lock Workstation' (Automated).....	209
1.1.3.6.3 Configure 'Interactive logon: Require smart card' (Manual)	210
1.1.3.6.4 Set 'startup (minutes)' to '10 or more minute(s)' (Automated)	212
1.1.3.6.5 Set 'Interactive logon: Do not display last user name' to 'Enabled' (Automated)	214

1.1.3.6.6 Set 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' to '4 or fewer logon(s)' (Automated)	216
1.1.3.6.7 Set 'Interactive logon: Require Domain Controller authentication to unlock workstation' to 'Disabled' (Automated)	218
1.1.3.6.8 Set 'Interactive logon: Prompt user to change password before expiration' to '14 or more day(s)' (Automated)	220
1.1.3.6.9 Set 'Interactive logon: Do not require CTRL+ALT+DEL' to 'Disabled' (Automated)	222
1.1.3.6.10 Configure 'Interactive logon: Message text for users attempting to log on' (Automated)	224
1.1.3.6.11 Set 'Interactive logon: Machine inactivity limit' to '900 or fewer seconds' (Automated)	226
1.1.3.6.12 Configure 'Interactive logon: Message title for users attempting to log on' (Automated)	227
1.1.3.6.13 Configure 'Interactive logon: Display user information when the session is locked' (Manual) ..	229
1.1.3.7.1 Set 'Microsoft network client: Send unencrypted password to third-party SMB servers' to 'Disabled' (Automated)	232
1.1.3.7.2 Set 'Microsoft network client: Digitally sign communications (always)' to 'Enabled' (Automated)	234
1.1.3.7.3 Set 'Microsoft network client: Digitally sign communications (if server agrees)' to 'Enabled' (Automated)	236
1.1.3.8.1 Set 'Microsoft network server: Disconnect clients when logon hours expire' to 'Enabled' (Automated)	239
1.1.3.8.2 Set 'Microsoft network server: Amount of idle time required before suspending session' to '15 or fewer minute(s)' (Automated)	241
1.1.3.8.3 Set 'Microsoft network server: Digitally sign communications (if client agrees)' to 'Enabled' (Automated)	243
1.1.3.8.4 Set 'Microsoft network server: Server SPN target name validation level' to 'Accept if provided by client' (Automated)	245
1.1.3.8.5 Set 'Microsoft network server: Digitally sign communications (always)' to 'Enabled' (Automated)	247
1.1.3.9.1 Configure 'MSS: (AutoShareWks) Enable Administrative Shares (recommended except for highly secure environments)' (Manual)	250
1.1.3.9.2 Set 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' to 'Enabled' (Automated)	252
1.1.3.9.3 Configure 'MSS: (NtfsDisable8dot3NameCreation) Enable the computer to stop generating 8.3 style filenames' (Manual)	254
1.1.3.9.4 Set 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' to 'Disabled' (Automated)	256
1.1.3.9.5 Set 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' to '0.9 or less' (Automated)	258
1.1.3.9.6 Set 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)	260
1.1.3.9.7 Set 'MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)' to 'Not Defined' (Automated)	262
1.1.3.9.8 Configure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' (Manual)	264
1.1.3.9.9 Configure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' (Manual)	266
1.1.3.9.10 Configure 'MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic.' (Manual)	268
1.1.3.9.11 Configure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' (Manual)	270
1.1.3.9.12 Configure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' (Manual)	272
1.1.3.9.13 Configure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' (Manual)	274
1.1.3.9.14 Configure 'MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)' (Manual)	276

1.1.3.9.15 Set 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' to '0' (Automated).....	278
1.1.3.9.16 Set 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)	280
1.1.3.9.17 Configure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' (Manual)	282
1.1.3.10.1 Set 'Network access: Let Everyone permissions apply to anonymous users' to 'Disabled' (Automated)	285
1.1.3.10.2 Set 'Network access: Allow anonymous SID/Name translation' to 'Disabled' (Automated)	287
1.1.3.10.3 Set 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' to 'Enabled' (Automated)	289
1.1.3.10.4 Configure 'Network access: Named Pipes that can be accessed anonymously' (Manual)	291
1.1.3.10.5 Set 'Network access: Restrict anonymous access to Named Pipes and Shares' to 'Enabled' (Automated)	293
1.1.3.10.6 Set 'Network access: Sharing and security model for local accounts' to 'Classic - local users authenticate as themselves' (Automated)	295
1.1.3.10.7 Set 'Network access: Remotely accessible registry paths and sub-paths' to the following list (Automated)	297
1.1.3.10.8 Set 'Network access: Shares that can be accessed anonymously' to 'Not Defined' (Automated)	299
1.1.3.10.9 Set 'Network access: Do not allow anonymous enumeration of SAM accounts' to 'Enabled' (Automated)	301
1.1.3.10.10 Set 'Network access: Remotely accessible registry paths' to the following list (Automated)	303
1.1.3.10.11 Configure 'Network access: Do not allow storage of passwords and credentials for network authentication' (Manual)	305
1.1.3.11.1 Set 'Network security: Do not store LAN Manager hash value on next password change' to 'Enabled' (Automated)	308
1.1.3.11.2 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' to 'Require NTLMv2 session security,Require 128-bit encryption' (Automated)	310
1.1.3.11.3 Set 'Network security: Allow Local System to use computer identity for NTLM' to 'Enabled' (Automated)	312
1.1.3.11.4 Set 'Network security: Allow LocalSystem NULL session fallback' to 'Disabled' (Automated)	314
1.1.3.11.5 'Network Security: Restrict NTLM: NTLM authentication in this domain' (Manual)	315
1.1.3.11.6 Configure 'Network Security: Restrict NTLM: Add server exceptions in this domain' (Manual)	317
1.1.3.11.7 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' to 'Require NTLMv2 session security,Require 128-bit encryption' (Automated)	319
1.1.3.11.8 Configure 'Network Security: Restrict NTLM: Outgoing NTLM traffic to remote servers' (Manual)	321
1.1.3.11.9 Configure 'Network Security: Restrict NTLM: Add remote server exceptions for NTLM authentication' (Manual)	323
1.1.3.11.10 Set 'Network Security: Restrict NTLM: Audit Incoming NTLM Traffic' to 'Not Defined' (Automated)	325
1.1.3.11.11 Set 'Network security: LAN Manager authentication level' to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)	327
1.1.3.11.12 Set 'Network Security: Allow PKU2U authentication requests to this computer to use online identities' to 'Disabled' (Automated)	331
1.1.3.11.13 Configure 'Network Security: Restrict NTLM: Audit NTLM authentication in this domain' (Manual)	333
1.1.3.11.14 Configure 'Network Security: Restrict NTLM: Incoming NTLM traffic' (Manual)	335
1.1.3.11.15 Set 'Network Security: Configure encryption types allowed for Kerberos' to 'RC4/AES128/AES256/Future types' (Automated)	337
1.1.3.11.16 Set 'Network security: LDAP client signing requirements' to 'Negotiate signing' (Automated)	339
1.1.3.11.17 Configure 'Network security: Force logoff when logon hours expire' (Manual)	341
1.1.3.12.1 Set 'Recovery console: Allow automatic administrative logon' to 'Disabled' (Automated)	343
1.1.3.12.2 Set 'Recovery console: Allow floppy copy and access to all drives and all folders' to 'Disabled' (Automated)	345

1.1.3.13.1 Set 'Shutdown: Clear virtual memory pagefile' to 'Disabled' (Automated)	348
1.1.3.13.2 Set 'Shutdown: Allow system to be shut down without having to log on' to 'Enabled' (Automated)	350
1.1.3.14.1 Configure 'System cryptography: Force strong key protection for user keys stored on the computer' (Manual)	353
1.1.3.14.2 Set 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing' to 'Enabled' (Automated)	355
1.1.3.15.1 Set 'System objects: Strengthen default permissions of internal system objects (e.g' Symbolic Links)' to 'Enabled' (Automated)	359
1.1.3.15.2 Set 'System objects: Require case insensitivity for non-Windows subsystems' to 'Enabled' (Automated)	361
1.1.3.16.1 Configure 'System settings: Optional subsystems' (Manual)	364
1.1.3.16.2 Configure 'System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies' (Manual)	366
1.1.3.17.1 Set 'User Account Control: Admin Approval Mode for the Built-in Administrator account' to 'Enabled' (Automated)	369
1.1.3.17.2 Set 'User Account Control: Detect application installations and prompt for elevation' to 'Enabled' (Automated)	371
1.1.3.17.3 Set 'User Account Control: Behavior of the elevation prompt for standard users' to 'Automatically deny elevation requests' (Automated)	373
1.1.3.17.4 Set 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' to 'Prompt for consent on the secure desktop' (Automated)	375
1.1.3.17.5 Set 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' to 'Enabled' (Automated)	377
1.1.3.17.6 Set 'User Account Control: Virtualize file and registry write failures to per-user locations' to 'Enabled' (Automated)	379
1.1.3.17.7 Set 'User Account Control: Switch to the secure desktop when prompting for elevation' to 'Enabled' (Automated)	381
1.1.3.17.8 Set 'User Account Control: Allow UIAccess applications to prompt for elevation without using the secure desktop' to 'Disabled' (Automated)	382
1.1.3.17.9 Set 'User Account Control: Only elevate executables that are signed and validated' to 'Disabled' (Automated)	384
1.1.3.17.10 Set 'User Account Control: Run all administrators in Admin Approval Mode' to 'Enabled' (Automated)	386
1.1.4 User Rights Assignment	388
1.1.4.1 Configure 'Allow log on through Remote Desktop Services' (Manual)	389
1.1.4.2 Set 'Deny log on through Remote Desktop Services' to 'Guests' (Automated)	391
1.1.4.3 Set 'Deny access to this computer from the network' to 'Guests' (Automated)	393
1.1.4.4 Set 'Create a pagefile' to 'Administrators' (Automated)	395
1.1.4.5 Set 'Create permanent shared objects' to 'No One' (Automated)	396
1.1.4.6 Set 'Increase scheduling priority' to 'Administrators' (Automated)	397
1.1.4.7 Set 'Access this computer from the network' to 'Users, Administrators' (Automated)	398
1.1.4.8 Set 'Force shutdown from a remote system' to 'Administrators' (Automated)	400
1.1.4.9 Set 'Change the time zone' to 'LOCAL SERVICE, Administrators, Users' (Automated)	402
1.1.4.10 Set 'Create global objects' to 'Administrators, SERVICE, LOCAL SERVICE, NETWORK SERVICE' (Automated)	403
1.1.4.11 Set 'Enable computer and user accounts to be trusted for delegation' to 'No One' (Automated)	405
1.1.4.12 Set 'Profile single process' to 'Administrators' (Automated)	406
1.1.4.13 Set 'Shut down the system' to 'Administrators, Users' (Automated)	408
1.1.4.14 Set 'Take ownership of files or other objects' to 'Administrators' (Automated)	410
1.1.4.15 Set 'Create symbolic links' to 'Administrators' (Automated)	411
1.1.4.16 Set 'Act as part of the operating system' to 'No One' (Automated)	413
1.1.4.17 Set 'Modify firmware environment values' to 'Administrators' (Automated)	414
1.1.4.18 Set 'Back up files and directories' to 'Administrators' (Automated)	415
1.1.4.19 Set 'Debug programs' to 'Administrators' (Automated)	417

1.1.4.20 Set 'Access Credential Manager as a trusted caller' to 'No One' (Automated)	419
1.1.4.21 Set 'Deny log on locally' to 'Guests' (Automated)	420
1.1.4.22 Set 'Profile system performance' to 'NT SERVICE\WdiServiceHost,Administrators' (Automated)	422
1.1.4.23 Set 'Restore files and directories' to 'Administrators' (Automated)	424
1.1.4.24 Set 'Perform volume maintenance tasks' to 'Administrators' (Automated)	426
1.1.4.25 Set 'Impersonate a client after authentication' to 'Administrators, SERVICE, Local Service, Network Service' (Automated)	427
1.1.4.26 Configure 'Log on as a batch job' (Manual)	429
1.1.4.27 Set 'Adjust memory quotas for a process' to 'Administrators, Local Service, Network Service' (Automated)	431
1.1.4.28 Set 'Manage auditing and security log' to 'Administrators' (Automated)	433
1.1.4.29 Set 'Deny log on as a batch job' to 'Guests' (Automated)	434
1.1.4.30 Set 'Bypass traverse checking' to 'Users, NETWORK SERVICE, LOCAL SERVICE, Administrators' (Automated)	436
1.1.4.31 Set 'Increase a process working set' to 'Administrators, Local Service' (Automated)	438
1.1.4.32 Set 'Change the system time' to 'LOCAL SERVICE, Administrators' (Automated)	440
1.1.4.33 Configure 'Deny log on as a service' (Manual)	443
1.1.4.34 Configure 'Log on as a service' (Manual)	445
1.1.4.35 Set 'Generate security audits' to 'Local Service, Network Service' (Automated)	447
1.1.4.36 Set 'Allow log on locally' to 'Administrators, Users' (Automated)	448
1.1.4.37 Set 'Lock pages in memory' to 'No One' (Automated)	450
1.1.4.38 Set 'Load and unload device drivers' to 'Administrators' (Automated)	451
1.1.4.39 Configure 'Remove computer from docking station' (Manual)	453
1.1.4.40 Set 'Replace a process level token' to 'Local Service, Network Service' (Automated)	455
1.1.4.41 Set 'Create a token object' to 'No One' (Automated)	457
1.1.4.42 Set 'Modify an object label' to 'No one' (Automated)	459
1.1.5 Windows Firewall With Advanced Security	460
1.1.5.1.1 Set 'Windows Firewall: Domain: Display a notification' to 'Yes (default)' (Automated)	461
1.1.5.1.2 Set 'Windows Firewall: Domain: Logging: Size limit (KB)' to '16384 KB or greater ' (Automated)	463
1.1.5.1.3 Set 'Windows Firewall: Domain: Logging: Name' to '%SYSTEMROOT%\System32\logfiles\firewall\domainfw.log' (Automated)	464
1.1.5.1.4 Set 'Windows Firewall: Domain: Apply local firewall rules' to 'Yes (default)' (Automated)	465
1.1.5.1.5 Set 'Windows Firewall: Domain: Apply local connection security rules' to 'Yes (default)' (Automated)	467
1.1.5.1.6 Set 'Windows Firewall: Domain: Allow unicast response' to 'No' (Automated)	469
1.1.5.1.7 Set 'Windows Firewall: Domain: Outbound connections' to 'Allow (default)' (Automated)	471
1.1.5.1.8 Set 'Windows Firewall: Domain: Logging: Log dropped packets' to 'Yes' (Automated)	473
1.1.5.1.9 Set 'Windows Firewall: Domain: Logging: Log successful connections' to 'Yes' (Automated)	474
1.1.5.1.10 Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)	475
1.1.5.1.11 Set 'Windows Firewall: Domain: Firewall state' to 'On (recommended)' (Automated)	477
1.1.5.2.1 Set 'Windows Firewall: Private: Firewall state' to 'On (recommended)' (Automated)	479
1.1.5.2.2 Set 'Windows Firewall: Private: Outbound connections' to 'Allow (default)' (Automated)	480
1.1.5.2.3 Set 'Windows Firewall: Private: Apply local firewall rules' to 'Yes (default)' (Automated)	482
1.1.5.2.4 Set 'Windows Firewall: Private: Logging: Size limit (KB)' to '16384 KB or greater' (Automated)	484
1.1.5.2.5 Set 'Windows Firewall: Private: Apply local connection security rules' to 'Yes (default)' (Automated)	485
1.1.5.2.6 Set 'Windows Firewall: Private: Display a notification' to 'Yes (default)' (Automated)	487
1.1.5.2.7 Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)	489
1.1.5.2.8 Set 'Windows Firewall: Private: Logging: Name' to '%SYSTEMROOT%\System32\logfiles\firewall\privatefw.log' (Automated)	491
1.1.5.2.9 Set 'Windows Firewall: Private: Allow unicast response' to 'No' (Automated)	492

1.1.5.2.10 Set 'Windows Firewall: Private: Logging: Log successful connections' to 'Yes' (Automated) ...	494
1.1.5.2.11 Set 'Windows Firewall: Private: Logging: Log dropped packets' to 'Yes' (Automated)	495
1.1.5.3.1 Set 'Windows Firewall: Public: Outbound connections' to 'Allow (default)' (Automated)	497
1.1.5.3.2 Set 'Windows Firewall: Public: Apply local firewall rules' to 'Yes (default)' (Automated)	499
1.1.5.3.3 Set 'Windows Firewall: Public: Apply local connection security rules' to 'No' (Automated).....	501
1.1.5.3.4 Set 'Windows Firewall: Public: Logging: Log dropped packets' to 'Yes' (Automated).....	502
1.1.5.3.5 Set 'Windows Firewall: Public: Display a notification' to 'No' (Automated)	503
1.1.5.3.6 Set 'Windows Firewall: Public: Allow unicast response' to 'No' (Automated).....	505
1.1.5.3.7 Set 'Windows Firewall: Public: Logging: Name' to '%SYSTEMROOT%\System32\logfiles\firewall\publicfw.log' (Automated)	507
1.1.5.3.8 Set 'Windows Firewall: Public: Logging: Log successful connections' to 'Yes' (Automated)	508
1.1.5.3.9 Set 'Windows Firewall: Public: Logging: Size limit (KB)' to '16384 KB or greater' (Automated) .	509
1.1.5.3.10 Set 'Windows Firewall: Public: Firewall state' to 'On (recommended)' (Automated)	510
1.1.5.3.11 Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated).....	511
1.2 Administrative Templates	513
1.2.1 Network	513
1.2.1.1 Configure 'Set IP Stateless Autoconfiguration Limits State' (Manual)	514
1.2.1.2 Configure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' (Manual).....	515
1.2.1.3 Configure 'Prohibit connection to non-domain networks when connected to domain authenticated network' (Manual).....	517
1.2.2 Printers	519
1.2.2.1 Configure 'Point and Print Restrictions' (Manual)	520
1.2.3 System.....	522
1.2.3.1.1 Configure 'Turn off access to the Store' (Manual)	524
1.2.3.1.2 Set 'Turn off downloading of print drivers over HTTP' to 'Enabled' (Automated)	525
1.2.3.1.3 Set 'Turn off Windows Update device driver searching' to 'Enabled' (Automated)	527
1.2.3.1.4 Set 'Turn off the "Publish to Web" task for files and folders' to 'Enabled' (Automated).....	529
1.2.3.1.5 Set 'Turn off the Windows Messenger Customer Experience Improvement Program' to 'Enabled' (Automated)	530
1.2.3.1.6 Set 'Turn off Search Companion content file updates' to 'Enabled' (Automated)	531
1.2.3.1.7 Configure 'Turn off Event Viewer "Events.asp" links' (Manual)	533
1.2.3.1.8 Set 'Turn off Internet download for Web publishing and online ordering wizards' to 'Enabled' (Automated)	535
1.2.3.1.9 Set 'Turn off printing over HTTP' to 'Enabled' (Automated)	536
1.2.3.2.1 Set 'Turn on PIN sign-in' to 'Disabled' (Automated).....	539
1.2.3.2.2 Configure 'Do not process the run once list' (Manual)	540
1.2.3.2.3 Configure 'Do not process the legacy run list' (Manual)	542
1.2.3.2.4 Set 'Do not enumerate connected users on domain-joined computers' to 'Enabled' (Automated)	544
1.2.3.2.5 Configure 'Turn off app notifications on the lock screen' (Manual)	545
1.2.3.2.6 Set 'Enumerate local users on domain-joined computers' to 'Disabled' (Automated)	546
1.2.3.3.1 Configure 'Turn Off the Display (seconds):' (Manual).....	548
1.2.3.3.2 Configure 'Turn Off the Display (seconds):' (Manual).....	549
1.2.3.3.3 Set 'Require a Password When a Computer Wakes (Plugged In)' to 'Enabled' (Automated).....	550
1.2.3.3.4 Set 'Require a Password When a Computer Wakes (On Battery)' to 'Enabled' (Automated).....	551
1.2.3.4.1 Set 'Configure Solicited Remote Assistance' to 'Disabled' (Automated).....	553
1.2.3.4.2 Set 'Configure Offer Remote Assistance' to 'Disabled' (Automated)	555
1.2.3.4.3 Configure 'Customize Warning Messages' (Manual).....	557
1.2.3.5 Set 'RPC Runtime Unauthenticated Client Restriction to Apply:' to 'Enabled:Authenticated' (Automated)	559
1.2.3.6 Set 'Enable RPC Endpoint Mapper Client Authentication' to 'Disabled' (Automated)	561
1.2.3.7 Set 'Do not apply during periodic background processing' to 'Enabled:FALSE' (Automated)	563

1.2.3.8 Set 'Process even if the Group Policy objects have not changed' to 'Enabled:TRUE' (Automated)	565
1.2.3.9 Set 'Choose the boot-start drivers that can be initialized:' to 'Enabled:Good, unknown and bad but critical' (Automated)	567
1.2.3.10 Configure 'Detect compatibility issues for applications and drivers' (Manual)	569
1.2.3.11 Set 'Select update server:' to 'Enabled:Search Managed Server' (Automated)	571
1.2.3.12 Configure 'Specify settings for optional component installation and component repair' (Manual)	573
1.2.3.13 Set 'Prevent installation of devices using drivers that match these device setup classes' to 'Enabled' (Automated)	575
1.2.3.14 Set 'Also apply to matching devices that are already installed' to 'True' (Automated)	576
1.2.3.15 Configure 'Prevent installation of devices using drivers for these device setup classes:' (Manual)	577
1.2.4 Windows Components	578
1.2.4.1.1 Set 'Turn off Autoplay on' to 'Enabled:All drives' (Automated)	579
1.2.4.2.1.1 Set 'Configure use of hardware-based encryption for fixed data drives' to 'Enabled' (Automated)	582
1.2.4.2.1.2 Configure 'Enforce drive encryption type on fixed data drives' (Manual)	584
1.2.4.2.1.3 Set 'Configure use of passwords for fixed data drives' to 'Disabled' (Automated)	586
1.2.4.2.1.4 Set 'Recovery Key' to 'Allow 256-bit recovery key' (Automated)	588
1.2.4.2.1.5 Set 'Recovery Password' to 'Allow 48-digit recovery password' (Automated)	590
1.2.4.2.1.6 Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)	592
1.2.4.2.1.7 Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)	594
1.2.4.2.1.8 Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)	596
1.2.4.2.1.9 Set 'Allow data recovery agent' to 'True' (Automated)	598
1.2.4.2.1.10 Set 'Choose how BitLocker-protected fixed drives can be recovered' to 'Enabled' (Automated)	600
1.2.4.2.1.11 Set 'Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives' to 'False' (Automated)	602
1.2.4.2.1.12 Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Backup recovery passwords and key packages' (Automated)	604
1.2.4.2.1.13 Set 'Save BitLocker recovery information to AD DS for fixed data drives' to 'False' (Automated)	606
1.2.4.2.1.14 Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)	608
1.2.4.2.1.15 Set 'Configure use of smart cards on fixed data drives' to 'Enabled' (Automated)	610
1.2.4.2.1.16 Set 'Require use of smart cards on fixed data drives' to 'True' (Automated)	612
1.2.4.2.1.17 Configure 'Deny write access to fixed drives not protected by BitLocker' (Manual)	613
1.2.4.2.1.18 Set 'Allow access to BitLocker-protected fixed data drives from earlier versions of Windows' to 'Disabled' (Automated)	615
1.2.4.2.2.1 Set 'Configure use of hardware-based encryption for operating system drives' to 'Enabled' (Automated)	618
1.2.4.2.2.2 Configure 'Enforce drive encryption type on operating system drives' (Manual)	620
1.2.4.2.2.3 Set 'Configure use of passwords for operating system drives' to 'Disabled' (Automated)	622
1.2.4.2.2.4 Set 'Recovery Key' to 'Do not allow 256-bit recovery key' (Automated)	624
1.2.4.2.2.5 Set 'Recovery Password' to 'Require 48-digit recovery password' (Automated)	626
1.2.4.2.2.6 Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)	628
1.2.4.2.2.7 Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)	630
1.2.4.2.2.8 Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)	632
1.2.4.2.2.9 Set 'Allow data recovery agent' to 'False' (Automated)	634

1.2.4.2.2.10 Set 'Choose how BitLocker-protected operating system drives can be recovered' to 'Enabled' (Automated)	636
1.2.4.2.2.11 Set 'Do not enable BitLocker until recovery information is stored to AD DS for operating system drives' to 'True' (Automated)	638
1.2.4.2.2.12 Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Store recovery passwords and key packages' (Automated)	640
1.2.4.2.2.13 Set 'Save BitLocker recovery information to AD DS for operating system drives' to 'True' (Automated)	642
1.2.4.2.2.14 Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)	644
1.2.4.2.2.15 Set 'Require additional authentication at startup' to 'Enabled' (Automated)	646
1.2.4.2.2.16 Set 'Allow BitLocker without a compatible TPM' to 'False' (Automated)	648
1.2.4.2.2.17 Set 'Configure TPM startup key and PIN:' to 'Do not allow startup key and PIN with TPM' (Automated)	650
1.2.4.2.2.18 Set 'Configure TPM startup PIN:' to 'Require startup PIN with TPM' (Automated)	652
1.2.4.2.2.19 Set 'Configure TPM startup:' to 'Do not allow TPM' (Automated)	654
1.2.4.2.2.20 Set 'Configure TPM startup key:' to 'Do not allow startup key with TPM' (Automated)	656
1.2.4.2.2.21 Configure 'Use enhanced Boot Configuration Data validation profile' (Manual)	658
1.2.4.2.2.22 Configure 'Enable use of BitLocker authentication requiring preboot keyboard input on slates' (Manual)	660
1.2.4.2.2.23 Configure 'Configure TPM platform validation profile for BIOS-based firmware configurations' (Manual)	662
1.2.4.2.2.24 Configure 'Configure TPM platform validation profile for native UEFI firmware configurations' (Manual)	664
1.2.4.2.2.25 Set 'Allow enhanced PINs for startup' to 'Enabled' (Automated)	666
1.2.4.2.2.26 Configure 'Disallow standard users from changing the PIN or password' (Manual)	668
1.2.4.2.2.27 Set 'Allow Secure Boot for integrity validation' to 'Enabled' (Automated)	669
1.2.4.2.2.28 Set 'Minimum characters:' to 'Enabled:7 or more characters' (Automated)	671
1.2.4.2.2.29 Configure 'Allow network unlock at startup' (Manual)	672
1.2.4.2.2.30 Configure 'Reset platform validation data after BitLocker recovery' (Manual)	674
1.2.4.2.3.1 Set 'Configure use of hardware-based encryption for removable data drives' to 'Enabled' (Automated)	676
1.2.4.2.3.2 Configure 'Enforce drive encryption type on removable data drives' (Manual)	678
1.2.4.2.3.3 Set 'Configure use of passwords for removable data drives' to 'Disabled' (Automated)	680
1.2.4.2.3.4 Set 'Recovery Key' to 'Do not allow 256-bit recovery key' (Automated)	682
1.2.4.2.3.5 Set 'Recovery Password' to 'Do not allow 48-digit recovery password' (Automated)	684
1.2.4.2.3.6 Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)	686
1.2.4.2.3.7 Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)	688
1.2.4.2.3.8 Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)	690
1.2.4.2.3.9 Set 'Allow data recovery agent' to 'True' (Automated)	692
1.2.4.2.3.10 Set 'Choose how BitLocker-protected removable drives can be recovered' to 'Enabled' (Automated)	694
1.2.4.2.3.11 Set 'Do not enable BitLocker until recovery information is stored to AD DS for removable data drives' to 'False' (Automated)	696
1.2.4.2.3.12 Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Backup recovery passwords and key packages' (Automated)	698
1.2.4.2.3.13 Set 'Save BitLocker recovery information to AD DS for removable data drives' to 'False' (Automated)	700
1.2.4.2.3.14 Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)	702
1.2.4.2.3.15 Set 'Configure use of smart cards on removable data drives' to 'Enabled' (Automated)	704
1.2.4.2.3.16 Set 'Require use of smart cards on removable data drives' to 'True' (Automated)	706
1.2.4.2.3.17 Set 'Deny write access to removable drives not protected by BitLocker' to 'Enabled' (Automated)	708

1.2.4.2.3.18 Set 'Allow access to BitLocker-protected removable data drives from earlier versions of Windows' to 'Disabled' (Automated).....	710
1.2.4.2.3.19 Configure 'Control use of BitLocker on removable drives' (Manual).....	712
1.2.4.2.3.20 Set 'Do not allow write access to devices configured in another organization' to 'True' (Automated).....	714
1.2.4.2.4 Configure 'Validate smart card certificate usage rule compliance' (Manual).....	715
1.2.4.2.5 Set 'Select the encryption method:' to 'Enabled:AES 256-bit' (Automated).....	716
1.2.4.2.6 Configure 'Prevent memory overwrite on restart' (Manual).....	718
1.2.4.2.7 Configure 'Choose default folder for recovery password' (Manual).....	719
1.2.4.2.8 Configure 'Provide the unique identifiers for your organization' (Manual).....	720
1.2.4.2.9 Set 'Allow Standby States (S1-S3) When Sleeping (On Battery)' to 'Disabled' (Automated).....	722
1.2.4.2.10 Set 'Allow Standby States (S1-S3) When Sleeping (Plugged In)' to 'Disabled' (Automated)....	723
1.2.4.3.1 Configure 'Require trusted path for credential entry' (Manual).....	725
1.2.4.3.2 Configure 'Do not display the password reveal button' (Manual).....	727
1.2.4.3.3 Set 'Enumerate administrator accounts on elevation' to 'Disabled' (Automated).....	729
1.2.4.4.1 Set 'Security: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated).....	732
1.2.4.4.2 Set 'System: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated).....	734
1.2.4.4.3 Set 'Security: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated).....	735
1.2.4.4.4 Set 'Application: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated).....	736
1.2.4.4.5 Set 'System: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated).....	738
1.2.4.4.6 Set 'Application: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated).....	740
1.2.4.5.1 Set 'Do not allow drive redirection' to 'Enabled' (Automated).....	742
1.2.4.5.2 Configure 'Allow users to connect remotely by using Remote Desktop Services' (Manual).....	744
1.2.4.5.3 Set 'Encryption Level' to 'Enabled:High Level' (Automated).....	746
1.2.4.5.4 Set 'Always prompt for password upon connection' to 'Enabled' (Automated).....	748
1.2.4.5.5 Set 'Do not allow passwords to be saved' to 'Enabled' (Automated).....	750
1.2.4.6.1 Set 'Disallow Digest authentication' to 'Enabled' (Automated).....	753
1.2.4.6.2 Set 'Allow Basic authentication' to 'Disabled' (Automated).....	754
1.2.4.6.3 Set 'Allow Basic authentication' to 'Disabled' (Automated).....	755
1.2.4.6.4 Set 'Disallow WinRM from storing RunAs credentials' to 'Enabled' (Automated).....	756
1.2.4.6.5 Set 'Allow unencrypted traffic' to 'Disabled' (Automated).....	758
1.2.4.6.6 Set 'Allow unencrypted traffic' to 'Disabled' (Automated).....	759
1.2.4.7.1 Configure 'Specify intranet Microsoft update service location' (Manual).....	761
1.2.4.7.2 Set 'Reschedule Automatic Updates scheduled installations' to 'Enabled' (Automated).....	763
1.2.4.7.3 Set 'Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows dialog box' to 'Disabled' (Automated).....	765
1.2.4.7.4 Set 'Configure Automatic Updates' to 'Enabled' (Automated).....	767
1.2.4.7.5 Set 'Configure automatic updating' to '3 - Auto download and notify for install' (Automated).....	769
1.2.4.7.6 Set 'Scheduled install day' to '0 - Every day' (Automated).....	771
1.2.4.7.7 Set 'No auto-restart with logged on users for scheduled automatic updates installations' to 'Disabled' (Automated).....	773
1.2.4.7.8 Set 'Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box' to 'Disabled' (Automated).....	775
1.2.4.8 Configure 'Allow the use of biometrics' (Manual).....	777
1.2.4.9 Set 'Turn off Data Execution Prevention for Explorer' to 'Disabled' (Automated).....	778
1.2.4.10 Configure 'Turn off the Store application' (Manual).....	779
1.2.4.11 Set 'Always install with elevated privileges' to 'Disabled' (Automated).....	780
1.2.4.12 Configure 'Allow deployment operations in special profiles' (Manual).....	782
1.2.4.13 Configure 'Allow all trusted apps to install' (Manual).....	783
1.2.4.14 Set 'Pick one of the following settings' to 'Enabled:Require approval from an administrator before running downloaded unknown software' (Automated).....	785

1.2.4.15 Configure 'Turn off Automatic Download of updates' (Manual)	787
1.2.4.16 Set 'Allow Remote Shell Access' to 'Enabled' (Automated).....	788
1.2.4.17 Configure 'Turn off location' (Manual)	790
1.2.4.18 Configure 'Prevent the computer from joining a homegroup' (Manual)	791
1.2.4.19 Configure 'Turn off Windows Location Provider' (Manual)	793
2 User Configuration	794
2.1 Configure 'Disable regedit from running silently?' (Manual)	795
2.2 Configure 'Prevent Codec Download' (Manual)	797
2.3 Set 'Notify antivirus programs when opening attachments' to 'Enabled' (Automated)	798
2.4 Set 'Do not preserve zone information in file attachments' to 'Disabled' (Automated).....	800
2.5 Configure 'Hide mechanisms to remove zone information' (Manual)	802
2.6 Configure 'Remove CD Burning features' (Manual)	804
2.7 Configure 'Remove Security tab' (Manual).....	805
2.8 Set 'Password protect the screen saver' to 'Enabled' (Automated)	806
2.9 Set 'Enable screen saver' to 'Enabled' (Automated)	807
2.10 Set 'Seconds' to 'Enabled:900 or fewer seconds' (Automated)	809
2.11 Set 'Screen saver executable name' to 'Enabled:scrnsave.scr' (Automated)	811
2.12 Configure 'Prevent changing screen saver' (Manual).....	813
2.13 Configure 'Turn off toast notifications on the lock screen' (Manual)	814
Appendix: Summary Table	815
Appendix: Change History	849

Overview

This is the archive of the CIS Microsoft Windows 8 [imported] v1.0.0 Benchmark. CIS encourages you to migrate to a more recent, supported version of this technology.

All CIS Benchmarks focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system for vulnerabilities and quickly updating with the latest security patches
- Monitoring applications and libraries for vulnerabilities and quickly updating with the latest security patches

In the end, the CIS Benchmarks are designed as a key **component** of a comprehensive cybersecurity program.

This document, CIS Microsoft Windows 8 Benchmark v1.0.0, provides prescriptive guidance for establishing a secure configuration posture for Microsoft Windows 8. To obtain the latest version of this guide, please visit <http://benchmarks.cisecurity.org>. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft Windows 8.

Consensus Guidance

This CIS Benchmark was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<i><italic font in brackets></i>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

Items in this profile intend to:

- be practical and prudent;
- provide a clear security benefit; and
- not negatively inhibit the utility of the technology beyond acceptable means.

- **Level 1 + BitLocker**

This profile extends the "Level 1" profile and includes BitLocker-related recommendations

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

The configuration recommendations contained in this document reflect consensus between Microsoft Corporation, The National Institute of Standards and Technology (NIST), and the Center for Internet Security (CIS). At the request of Microsoft and the Center for Internet Security, the National Security Agency Information Assurance Directorate participated in the review of these recommendations and provided comments that were incorporated into the final published version. We would like to thank our customers, partners and government agencies worldwide for their participation and feedback.

Contributor

Jordan Rakoske

Recommendations

1 Computer Configuration

1.1 Security Settings

1.1.1 Account Policies

ARCHIVE

1.1.1.1 Set 'Account lockout threshold' to '5 invalid logon attempt(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the number of failed logon attempts before a lock occurs. Authorized users can lock themselves out of an account by mistyping their password or by remembering it incorrectly, or by changing their password on one computer while logged on to another computer. The computer with the incorrect password will continuously try to authenticate the user, and because the password it uses to authenticate is incorrect, a lock occurs. To avoid accidental lockout of authorized users, set the account lockout threshold to a high number. The default value for this policy setting is 0 invalid logon attempts, which disables the account lockout feature. Because it is possible for an attacker to use this lockout state as a denial of service (DoS) by triggering a lockout on a large number of accounts, your organization should determine whether to use this policy setting based on identified threats and the risks you want to mitigate. There are two options to consider for this policy setting. - Configure the value for Account lockout threshold to 0 to ensure that accounts will not be locked out. This setting value will prevent a DoS attack that attempts to lock out accounts in your organization. It will also reduce help desk calls, because users will not be able to lock themselves out of their accounts accidentally. However, this setting value will not prevent a brute force attack. The following defenses should also be considered: - A password policy that forces all users to have complex passwords made up of 8 or more characters. - A robust auditing mechanism, which will alert administrators when a series of account lockouts occurs in the environment. For example, the auditing solution should monitor for security event 539, which is a logon failure. This event identifies that there was a lock on the account at the time of the logon attempt. The second option is: - Configure the value for Account lockout threshold to a value that provides users with the ability to mistype their password several times, but locks out the account if a brute force password attack occurs. This configuration will prevent accidental account lockouts and reduce help desk calls, but will not prevent a DoS attack. The recommended state for this setting is: 5 invalid logon attempt(s).

Rationale:

Password attacks can use automated methods to try millions of password combinations for any user account. The effectiveness of such attacks can be almost eliminated if you limit the number of failed logons that can be performed. However, a DoS attack could be performed on a domain that has an account lockout threshold configured. An attacker could programmatically attempt a series of password attacks against all users in the organization. If the number of attempts is greater than the account lockout threshold, the attacker might be able to lock out every account.

Impact:

If this policy setting is enabled, a locked-out account will not be usable until it is reset by an administrator or until the account lockout duration expires. This setting will likely generate a number of additional help desk calls. In fact, locked accounts cause the greatest number of calls to the help desk in many organizations. If you enforce this setting an attacker could cause a denial of service condition by deliberately generating failed logons for multiple user, therefore you should also configure the Account Lockout Duration to a relatively low value such as 15 minutes. If you configure the Account Lockout Threshold to 0, there is a possibility that an attacker's attempt to discover passwords with a brute force password attack might go undetected if a robust audit mechanism is not in place.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 5 invalid logon attempt(s).

Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Account lockout threshold

Default Value:

0 invalid logon attempts

References:

1. CCE-21671-3

1.1.1.2 Set 'Account lockout duration' to '15 or more minute(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the length of time that must pass before a locked account is unlocked and a user can try to log on again. The setting does this by specifying the number of minutes a locked out account will remain unavailable. If the value for this policy setting is configured to 0, locked out accounts will remain locked out until an administrator manually unlocks them. Although it might seem like a good idea to configure the value for this policy setting to a high value, such a configuration will likely increase the number of calls that the help desk receives to unlock accounts locked by mistake. Users should be aware of the length of time a lock remains in place, so that they realize they only need to call the help desk if they have an extremely urgent need to regain access to their computer. The recommended state for this setting is: 15 or more minute(s).

Rationale:

A denial of service (DoS) condition can be created if an attacker abuses the Account lockout threshold and repeatedly attempts to log on with a specific account. Once you configure the Account lockout threshold setting, the account will be locked out after the specified number of failed attempts. If you configure the Account lockout duration setting to 0, then the account will remain locked out until an administrator unlocks it manually.

Impact:

Although it may seem like a good idea to configure this policy setting to never automatically unlock an account, such a configuration can increase the number of requests that your organization's help desk receives to unlock accounts that were locked by mistake.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 15 or more minute(s).

Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Account lockout duration
--

Default Value:

Not defined

References:

1. CCE-22402-2

ARCHIVE

1.1.1.3 Set 'Reset account lockout counter after' to '15 minute(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the length of time before the Account lockout threshold resets to zero. The default value for this policy setting is Not Defined. If the Account lockout threshold is defined, this reset time must be less than or equal to the value for the Account lockout duration setting. If you leave this policy setting at its default value or configure the value to an interval that is too long, your environment could be vulnerable to a DoS attack. An attacker could maliciously perform a number of failed logon attempts on all users in the organization, which will lock out their accounts. If no policy were determined to reset the account lockout, it would be a manual task for administrators. Conversely, if a reasonable time value is configured for this policy setting, users would be locked out for a set period until all of the accounts are unlocked automatically. The recommended state for this setting is: 15 minute(s).

Rationale:

Users can accidentally lock themselves out of their accounts if they mistype their password multiple times. To reduce the chance of such accidental lockouts, the Reset account lockout counter after setting determines the number of minutes that must elapse before the counter that tracks failed logon attempts and triggers lockouts is reset to 0.

Impact:

If you do not configure this policy setting or if the value is configured to an interval that is too long, a DoS attack could occur. An attacker could maliciously attempt to log on to each user's account numerous times and lock out their accounts as described in the preceding paragraphs. If you do not configure the Reset account lockout counter after setting, administrators would have to manually unlock all accounts. If you configure this policy setting to a reasonable value the users would be locked out for some period, after which their accounts would unlock automatically. Be sure that you notify users of the values used for this policy setting so that they will wait for the lockout timer to expire before they call the help desk about their inability to log on.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 15 minute(s).

Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Reset account lockout counter after

Default Value:

0

References:

1. CCE-22541-7

1.1.1.4 Set 'Minimum password length' to '14 or more character(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the least number of characters that make up a password for a user account. There are many different theories about how to determine the best password length for an organization, but perhaps "pass phrase" is a better term than "password." In Microsoft Windows 2000 or later, pass phrases can be quite long and can include spaces. Therefore, a phrase such as "I want to drink a \$5 milkshake" is a valid pass phrase; it is a considerably stronger password than an 8 or 10 character string of random numbers and letters, and yet is easier to remember. Users must be educated about the proper selection and maintenance of passwords, especially with regard to password length. The recommended state for this setting is: `14 or more character(s)`.

Rationale:

Types of password attacks include dictionary attacks (which attempt to use common words and phrases) and brute force attacks (which try every possible combination of characters). Also, attackers sometimes try to obtain the account database so they can use tools to discover the accounts and passwords.

Impact:

Requirements for extremely long passwords can actually decrease the security of an organization, because users might leave the information in an insecure location or lose it. If very long passwords are required, mistyped passwords could cause account lockouts and increase the volume of help desk calls. If your organization has issues with forgotten passwords due to password length requirements, consider teaching your users about pass phrases, which are often easier to remember and, due to the larger number of character combinations, much harder to discover.

Note: Older versions of Windows such as Windows 98 and Windows NT 4.0 do not support passwords that are longer than 14 characters. Computers that run these older operating systems are unable to authenticate with computers or domains that use accounts that require long passwords.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 14 or more character(s).

Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Minimum password length
--

Default Value:

0 characters

References:

1. CCE-22921-1

ARCHIVE

1.1.1.5 Set 'Enforce password history' to '24 or more password(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the number of renewed, unique passwords that have to be associated with a user account before you can reuse an old password. The value for this policy setting must be between 0 and 24 passwords. The default value for Windows Vista is 0 passwords, but the default setting in a domain is 24 passwords. To maintain the effectiveness of this policy setting, use the Minimum password age setting to prevent users from repeatedly changing their password. The recommended state for this setting is: `24 or more password(s)`.

Rationale:

The longer a user uses the same password, the greater the chance that an attacker can determine the password through brute force attacks. Also, any accounts that may have been compromised will remain exploitable for as long as the password is left unchanged. If password changes are required but password reuse is not prevented, or if users continually reuse a small number of passwords, the effectiveness of a good password policy is greatly reduced. If you specify a low number for this policy setting, users will be able to use the same small number of passwords repeatedly. If you do not also configure the Minimum password age setting, users might repeatedly change their passwords until they can reuse their original password.

Impact:

The major impact of this configuration is that users must create a new password every time they are required to change their old one. If users are required to change their passwords to new unique values, there is an increased risk of users who write their passwords somewhere so that they do not forget them. Another risk is that users may create passwords that change incrementally (for example, password01, password02, and so on) to facilitate memorization but make them easier to guess. Also, an excessively low value for the Minimum password age setting will likely increase administrative overhead, because users who forget their passwords might ask the help desk to reset them frequently.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 24 or more password(s).

Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy\Enforce password history

Default Value:

24 passwords remembered

References:

1. CCE-22909-6

ARCHIVE

1.1.1.6 Set 'Password must meet complexity requirements' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting checks all new passwords to ensure that they meet basic requirements for strong passwords. When this policy is enabled, passwords must meet the following minimum requirements: - Not contain the user's account name or parts of the user's full name that exceed two consecutive characters - Be at least six characters in length - Contain characters from three of the following four categories: - English uppercase characters (A through Z) - English lowercase characters (a through z) - Base 10 digits (0 through 9) - Non-alphabetic characters (for example, !, \$, #, %) - A catch-all category of any Unicode character that does not fall under the previous four categories. This fifth category can be regionally specific. Each additional character in a password increases its complexity exponentially. For instance, a seven-character, all lower-case alphabetic password would have 26⁷ (approximately 8 x 10⁹ or 8 billion) possible combinations. At 1,000,000 attempts per second (a capability of many password-cracking utilities), it would only take 133 minutes to crack. A seven-character alphabetic password with case sensitivity has 52⁷ combinations. A seven-character case-sensitive alphanumeric password without punctuation has 62⁷ combinations. An eight-character password has 26⁸ (or 2 x 10¹¹) possible combinations. Although this might seem to be a large number, at 1,000,000 attempts per second it would take only 59 hours to try all possible passwords. Remember, these times will significantly increase for passwords that use ALT characters and other special keyboard characters such as "!" or "@". Proper use of the password settings can help make it difficult to mount a brute force attack. The recommended state for this setting is: `Enabled`.

Rationale:

Passwords that contain only alphanumeric characters are extremely easy to discover with several publicly available tools.

Impact:

If the default password complexity configuration is retained, additional help desk calls for locked-out accounts could occur because users might not be accustomed to passwords that contain non-alphabetic characters. However, all users should be able to comply with the complexity requirement with minimal difficulty. If your organization has more stringent security requirements, you can create a custom version of the Passfilt.dll file that allows the use of arbitrarily complex password strength rules. For example, a custom password filter might require the use of non-upper row characters. (Upper row characters are those that require you to hold down the SHIFT key and press any of the digits between 1 and 0.) A custom password filter might also perform a dictionary check to verify that the proposed password does not contain common dictionary words or fragments. Also, the use of ALT key character combinations can greatly enhance the complexity of a password. However, such stringent password requirements can result in unhappy users and an extremely busy help desk. Alternatively, your organization could consider a requirement for all administrator passwords to use ALT characters in the 01280159 range. (ALT characters outside of this range can represent standard alphanumeric characters that would not add additional complexity to the password.)

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy>Password must meet complexity requirements

Default Value:

Disabled

References:

1. CCE-22567-2

1.1.1.7 Set 'Store passwords using reversible encryption' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the operating system stores passwords in a way that uses reversible encryption, which provides support for application protocols that require knowledge of the user's password for authentication purposes. Passwords that are stored with reversible encryption are essentially the same as plaintext versions of the passwords. The recommended state for this setting is: *Disabled*.

Rationale:

Enabling this policy setting allows the operating system to store passwords in a weaker format that is much more susceptible to compromise and weakens your system security.

Impact:

If your organization uses either the CHAP authentication protocol through remote access or IAS services or Digest Authentication in IIS, you must configure this policy setting to Enabled. This setting is extremely dangerous to apply through Group Policy on a user-by-user basis, because it requires the appropriate user account object to be opened in Active Directory Users and Computers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Store passwords using reversible encryption

Default Value:

Disabled

References:

1. CCE-21910-5

ARCHIVE

1.1.1.8 Set 'Minimum password age' to '1 or more day(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the number of days that you must use a password before you can change it. The range of values for this policy setting is between 1 and 999 days. (You may also set the value to 0 to allow immediate password changes.) The default value for this setting is 0 days. The recommended state for this setting is: 1 or more day(s).

Rationale:

Users may have favorite passwords that they like to use because they are easy to remember and they believe that their password choice is secure from compromise. Unfortunately, passwords are compromised and if an attacker is targeting a specific individual user account, with foreknowledge of data about that user, reuse of old passwords can cause a security breach. To address password reuse a combination of security settings is required. Using this policy setting with the Enforce password history setting prevents the easy reuse of old passwords. For example, if you configure the Enforce password history setting to ensure that users cannot reuse any of their last 12 passwords, they could change their password 13 times in a few minutes and reuse the password they started with, unless you also configure the Minimum password age setting to a number that is greater than 0. You must configure this policy setting to a number that is greater than 0 for the Enforce password history setting to be effective.

Impact:

If an administrator sets a password for a user but wants that user to change the password when the user first logs on, the administrator must select the User must change password at next logon check box, or the user will not be able to change the password until the next day.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 1 or more day(s).

Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Minimum password age

Default Value:

0 days

References:

1. CCE-21414-8

ARCHIVE

1.1.1.9 Set 'Maximum password age' to '60 or fewer days' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting defines how long a user can use their password before it expires. Values for this policy setting range from 0 to 999 days. If you set the value to 0, the password will never expire. The default value for this policy setting is 42 days. Because attackers can crack passwords, the more frequently you change the password the less opportunity an attacker has to use a cracked password. However, the lower this value is set, the higher the potential for an increase in calls to help desk support due to users having to change their password or forgetting which password is current. The recommended state for this setting is: 60 or fewer days.

Rationale:

The longer a password exists the higher the likelihood that it will be compromised by a brute force attack, by an attacker gaining general knowledge about the user, or by the user sharing the password. Configuring the Maximum password age setting to 0 so that users are never required to change their passwords is a major security risk because that allows a compromised password to be used by the malicious user for as long as the valid user is authorized access.

Impact:

If the Maximum password age setting is too low, users are required to change their passwords very often. Such a configuration can reduce security in the organization, because users might write their passwords in an insecure location or lose them. If the value for this policy setting is too high, the level of security within an organization is reduced because it allows potential attackers more time in which to discover user passwords or to use compromised accounts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 60 or fewer days.

Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Maximum password age

Default Value:

42 days

References:

1. CCE-22592-0

ARCHIVE

1.1.2 Advanced Audit Policy Configuration

ARCHIVE

1.1.2.1 Set 'Audit Policy: Privilege Use: Sensitive Privilege Use' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a user account or service uses a sensitive privilege. A sensitive privilege includes the following user rights: Act as part of the operating system, Back up files and directories, Create a token object, Debug programs, Enable computer and user accounts to be trusted for delegation, Generate security audits, Impersonate a client after authentication, Load and unload device drivers, Manage auditing and security log, Modify firmware environment values, Replace a process-level token, Restore files and directories, and Take ownership of files or other objects. Auditing this subcategory will create a high volume of events. Events for this subcategory include: 4672: Special privileges assigned to new logon. 4673: A privileged service was called. 4674: An operation was attempted on a privileged object. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Privilege Use\Audit Policy: Privilege  
Use: Sensitive Privilege Use
```

Default Value:

No auditing

References:

1. CCE-22624-1

1.1.2.2 Set 'Audit Policy: Account Management: Other Account Management Events' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports other account management events. Events for this subcategory include: 4782: The password hash an account was accessed. 4793: The Password Policy Checking API was called. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Management\Audit Policy: Account Management: Other Account Management Events

Default Value:

No auditing

References:

1. CCE-23036-7

1.1.2.3 Set 'Audit Policy: Logon-Logoff: IPsec Quick Mode' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the results of IKE protocol and AuthIP during Quick Mode negotiations. 4654: An IPsec Quick Mode negotiation failed. Events for this subcategory include: 4977: During Quick Mode negotiation, IPsec received an invalid negotiation packet. If this problem persists, it could indicate a network issue or an attempt to modify or replay this negotiation. 5451: An IPsec Quick Mode security association was established. 5452: An IPsec Quick Mode security association ended. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff: IPsec Quick Mode

Default Value:

No auditing

References:

1. CCE-21855-2

1.1.2.4 Set 'Audit Policy: Detailed Tracking: RPC Events' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports remote procedure call (RPC) connection events. Events for this subcategory include: 5712: A Remote Procedure Call (RPC) was attempted. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Detailed Tracking\Audit Policy: Detailed Tracking: RPC Events

Default Value:

No auditing

References:

1. CCE-21820-6

1.1.2.5 Set 'Audit Policy: DS Access: Directory Service Access' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when an AD DS object is accessed. Only objects with SACLs cause audit events to be generated, and only when they are accessed in a manner that matches their SACL. These events are similar to the directory service access events in previous versions of Windows Server. This subcategory applies only to domain controllers. Events for this subcategory include: 4662 : An operation was performed on an object. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\DS Access\Audit Policy: DS Access:  
Directory Service Access
```

Default Value:

No auditing

References:

1. CCE-22534-2

1.1.2.6 Set 'Audit Policy: Policy Change: MPSSVC Rule-Level Policy Change' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports changes in policy rules used by the Microsoft Protection Service (MPSSVC.exe). This service is used by Windows Firewall and by Microsoft OneCare. Events for this subcategory include: 4944: The following policy was active when the Windows Firewall started. 4945: A rule was listed when the Windows Firewall started. 4946: A change has been made to Windows Firewall exception list. A rule was added. 4947: A change has been made to Windows Firewall exception list. A rule was modified. 4948: A change has been made to Windows Firewall exception list. A rule was deleted. 4949: Windows Firewall settings were restored to the default values. 4950: A Windows Firewall setting has changed. 4951: A rule has been ignored because its major version number was not recognized by Windows Firewall. 4952: Parts of a rule have been ignored because its minor version number was not recognized by Windows Firewall. The other parts of the rule will be enforced. 4953: A rule has been ignored by Windows Firewall because it could not parse the rule. 4954: Windows Firewall Group Policy settings have changed. The new settings have been applied. 4956: Windows Firewall has changed the active profile. 4957: Windows Firewall did not apply the following rule: 4958: Windows Firewall did not apply the following rule because the rule referred to items not configured on this computer: Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Policy Change\Audit Policy: Policy  
Change: MPSSVC Rule-Level Policy Change
```

Default Value:

No auditing

References:

1. CCE-22630-8

1.1.2.7 Set 'Audit Policy: Account Management: Distribution Group Management' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports each event of distribution group management, such as when a distribution group is created, changed, or deleted or when a member is added to or removed from a distribution group. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of group accounts. Events for this subcategory include: 4744: A security-disabled local group was created. 4745: A security-disabled local group was changed. 4746: A member was added to a security-disabled local group. 4747: A member was removed from a security-disabled local group. 4748: A security-disabled local group was deleted. 4749: A security-disabled global group was created. 4750: A security-disabled global group was changed. 4751: A member was added to a security-disabled global group. 4752: A member was removed from a security-disabled global group. 4753: A security-disabled global group was deleted. 4759: A security-disabled universal group was created. 4760: A security-disabled universal group was changed. 4761: A member was added to a security-disabled universal group. 4762: A member was removed from a security-disabled universal group. 4763: A security-disabled universal group was deleted. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Account Management\Audit Policy: Account  
Management: Distribution Group Management
```

Default Value:

No auditing

References:

1. CCE-23096-1

1.1.2.8 Set 'Audit Policy: Detailed Tracking: Process Termination' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a process terminates. Events for this subcategory include: 4689: A process has exited. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Detailed Tracking\Audit Policy: Detailed Tracking: Process Termination

Default Value:

No auditing

References:

1. CCE-23604-2

1.1.2.9 Set 'Audit Policy: Object Access: Detailed File Share' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to audit attempts to access files and folders on a shared folder. The Detailed File Share setting logs an event every time a file or folder is accessed, whereas the File Share setting only records one event for any connection established between a client and file share. Detailed File Share audit events include detailed information about the permissions or other criteria used to grant or deny access. If you configure this policy setting, an audit event is generated when an attempt is made to access a file or folder on a share. The administrator can specify whether to audit only successes, only failures, or both successes and failures. Note: There are no system access control lists (SACLs) for shared folders. If this policy setting is enabled, access to all shared files and folders on the system is audited. Volume: High on a file server or domain controller because of SYSVOL network access required by Group Policy. The recommended state for this setting is: `No Auditing`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: Detailed File Share

Default Value:

No auditing

References:

1. CCE-23288-4

1.1.2.10 Set 'Audit Policy: Account Management: User Account Management' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports each event of user account management, such as when a user account is created, changed, or deleted; a user account is renamed, disabled, or enabled; or a password is set or changed. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of user accounts. Events for this subcategory include: 4720: A user account was created. 4722: A user account was enabled. 4723: An attempt was made to change an account's password. 4724: An attempt was made to reset an account's password. 4725: A user account was disabled. 4726: A user account was deleted. 4738: A user account was changed. 4740: A user account was locked out. 4765: SID History was added to an account. 4766: An attempt to add SID History to an account failed. 4767: A user account was unlocked. 4780: The ACL was set on accounts which are members of administrators groups. 4781: The name of an account was changed. 4794: An attempt was made to set the Directory Services Restore Mode. 5376: Credential Manager credentials were backed up. 5377: Credential Manager credentials were restored from a backup. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Account Management\Audit Policy: Account  
Management: User Account Management
```

Default Value:

Success

References:

1. CCE-22890-8

1.1.2.11 Set 'Audit Policy: Account Management: Computer Account Management' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports each event of computer account management, such as when a computer account is created, changed, deleted, renamed, disabled, or enabled. Events for this subcategory include: 4741: A computer account was created. 4742: A computer account was changed. 4743: A computer account was deleted. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Management\Audit Policy: Account Management: Computer Account Management

Default Value:

No auditing

References:

1. CCE-21905-5

1.1.2.12 Set 'Audit Policy: System: Security System Extension' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the loading of extension code such as authentication packages by the security subsystem. Events for this subcategory include: 4610: An authentication package has been loaded by the Local Security Authority. 4611: A trusted logon process has been registered with the Local Security Authority. 4614: A notification package has been loaded by the Security Account Manager. 4622: A security package has been loaded by the Local Security Authority. 4697: A service was installed in the system. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System\Audit Policy: System: Security System Extension

Default Value:

No auditing

References:

1. CCE-23073-0

1.1.2.13 Set 'Audit Policy: System: Security State Change' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports changes in security state of the system, such as when the security subsystem starts and stops. Events for this subcategory include: 4608: Windows is starting up. 4609: Windows is shutting down. 4616: The system time was changed. 4621: Administrator recovered system from CrashOnAuditFail. Users who are not administrators will now be allowed to log on. Some auditable activity might not have been recorded. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System\Audit Policy: System: Security State Change

Default Value:

Success

References:

1. CCE-22876-7

1.1.2.14 Set 'Audit Policy: Logon-Logoff: Network Policy Server' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports events generated by RADIUS (IAS) and Network Access Protection (NAP) user access requests. These requests can be Grant, Deny, Discard, Quarantine, Lock, and Unlock. Auditing this setting will result in a medium or high volume of records on NPS and IAS servers. Events for this subcategory include: Note All the events in the Network Policy Server subcategory are available only in Windows Vista Service Pack 1 and in Windows Server 2008. 6272: Network Policy Server granted access to a user. 6273: Network Policy Server denied access to a user. 6274: Network Policy Server discarded the request for a user. 6275: Network Policy Server discarded the accounting request for a user. 6276: Network Policy Server quarantined a user. 6277: Network Policy Server granted access to a user but put it on probation because the host did not meet the defined health policy. 6278: Network Policy Server granted full access to a user because the host met the defined health policy. 6279: Network Policy Server locked the user account due to repeated failed authentication attempts. 6280: Network Policy Server unlocked the user account. 8191: Network Policy Server unlocked the user account. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff:  
Network Policy Server
```

Default Value:

Success and Failure

References:

1. CCE-23313-0

1.1.2.15 Set 'Audit Policy: Detailed Tracking: DPAPI Activity' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports encrypt or decrypt calls into the data protections application interface (DPAPI). DPAPI is used to protect secret information such as stored password and key information. Events for this subcategory include: 4692: Backup of data protection master key was attempted. 4693: Recovery of data protection master key was attempted. 4694: Protection of auditable protected data was attempted. 4695: Unprotection of auditable protected data was attempted. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Detailed Tracking\Audit Policy: Detailed Tracking: DPAPI Activity

Default Value:

No auditing

References:

1. CCE-23076-3

1.1.2.16 Set 'Audit Policy: System: IPsec Driver' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports on the activities of the Internet Protocol security (IPsec) driver. Events for this subcategory include: 4960: IPsec dropped an inbound packet that failed an integrity check. If this problem persists, it could indicate a network issue or that packets are being modified in transit to this computer. Verify that the packets sent from the remote computer are the same as those received by this computer. This error might also indicate interoperability problems with other IPsec implementations. 4961: IPsec dropped an inbound packet that failed a replay check. If this problem persists, it could indicate a replay attack against this computer. 4962: IPsec dropped an inbound packet that failed a replay check. The inbound packet had too low a sequence number to ensure it was not a replay. 4963: IPsec dropped an inbound clear text packet that should have been secured. This is usually due to the remote computer changing its IPsec policy without informing this computer. This could also be a spoofing attack attempt. 4965: IPsec received a packet from a remote computer with an incorrect Security Parameter Index (SPI). This is usually caused by malfunctioning hardware that is corrupting packets. If these errors persist, verify that the packets sent from the remote computer are the same as those received by this computer. This error may also indicate interoperability problems with other IPsec implementations. In that case, if connectivity is not impeded, then these events can be ignored. 5478: IPsec Services has started successfully. 5479: IPsec Services has been shut down successfully. The shutdown of IPsec Services can put the computer at greater risk of network attack or expose the computer to potential security risks. 5480: IPsec Services failed to get the complete list of network interfaces on the computer. This poses a potential security risk because some of the network interfaces may not get the protection provided by the applied IPsec filters. Use the IP Security Monitor snap-in to diagnose the problem. 5483: IPsec Services failed to initialize RPC server. IPsec Services could not be started. 5484: IPsec Services has experienced a critical failure and has been shut down. The shutdown of IPsec Services can put the computer at greater risk of network attack or expose the computer to potential security risks. 5485: IPsec Services failed to process some IPsec filters on a plug-and-play event for network interfaces. This poses a potential security risk because some of the network interfaces may not get the protection provided by the applied IPsec filters. Use the IP Security Monitor snap-in to diagnose the problem. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System\Audit Policy: System: IPsec Driver
```

Default Value:

No auditing

References:

1. CCE-23505-1

1.1.2.17 Set 'Audit Policy: Account Management: Security Group Management' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports each event of security group management, such as when a security group is created, changed, or deleted or when a member is added to or removed from a security group. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of security group accounts. Events for this subcategory include: 4727: A security-enabled global group was created. 4728: A member was added to a security-enabled global group. 4729: A member was removed from a security-enabled global group. 4730: A security-enabled global group was deleted. 4731: A security-enabled local group was created. 4732: A member was added to a security-enabled local group. 4733: A member was removed from a security-enabled local group. 4734: A security-enabled local group was deleted. 4735: A security-enabled local group was changed. 4737: A security-enabled global group was changed. 4754: A security-enabled universal group was created. 4755: A security-enabled universal group was changed. 4756: A member was added to a security-enabled universal group. 4757: A member was removed from a security-enabled universal group. 4758: A security-enabled universal group was deleted. 4764: A group's type was changed. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: `Success and Failure`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Account Management\Audit Policy: Account  
Management: Security Group Management
```

Default Value:

Success

References:

1. CCE-22381-8

1.1.2.18 Set 'Audit Policy: Account Logon: Other Account Logon Events' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the events that occur in response to credentials submitted for a user account logon request that do not relate to credential validation or Kerberos tickets. These events occur on the computer that is authoritative for the credentials. For domain accounts, the domain controller is authoritative, whereas for local accounts, the local computer is authoritative. In domain environments, most of the Account Logon events occur in the Security log of the domain controllers that are authoritative for the domain accounts. However, these events can occur on other computers in the organization when local accounts are used to log on. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Logon\Audit Policy: Account Logon: Other Account Logon Events

Default Value:

No auditing

References:

1. CCE-22351-1

1.1.2.19 Set 'Audit Policy: Object Access: Registry' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when registry objects are accessed. Only registry objects with SACLs cause audit events to be generated, and only when they are accessed in a manner matching their SACL. By itself, this policy setting will not cause auditing of any events. It determines whether to audit the event of a user who accesses a registry object that has a specified system access control list (SACL), effectively enabling auditing to take place. A SACL is comprised of access control entries (ACEs). Each ACE contains three pieces of information: - The security principal (user, computer, or group) to be audited. - The specific access type to be audited, called an access mask. - A flag to indicate whether to audit failed access events, successful access events, or both. If you configure the Audit object access setting to Success, an audit entry is generated each time that a user successfully accesses an object with a specified SACL. If you configure this policy setting to Failure, an audit entry is generated each time that a user fails in an attempt to access an object with a specified SACL. Organizations should define only the actions they want enabled when they configure SACLs. For example, you might want to enable the Write and Append Data auditing setting on executable files to track when they are changed or replaced, because computer viruses, worms, and Trojan horses typically target executable files. Similarly, you might want to track when sensitive documents are accessed or changed. Events for this subcategory include: 4657 : A registry value was modified. 5039: A registry key was virtualized. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: Registry
```

Default Value:

No auditing

References:

1. CCE-21996-4

1.1.2.20 Set 'Audit Policy: Privilege Use: Other Privilege Use Events' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory is not used. The recommended state for this setting is: `No Auditing`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Privilege Use\Audit Policy: Privilege Use: Other Privilege Use Events

Default Value:

No auditing

References:

1. CCE-22124-2

1.1.2.21 Set 'Audit Policy: Policy Change: Filtering Platform Policy Change' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the addition and removal of objects from WFP, including startup filters. These events can be very high in volume. Events for this subcategory include: 4709: IPsec Services was started. 4710: IPsec Services was disabled. 4711: May contain any one of the following: - PASTore Engine applied locally cached copy of Active Directory storage IPsec policy on the computer. - PASTore Engine applied Active Directory storage IPsec policy on the computer. - PASTore Engine applied local registry storage IPsec policy on the computer. - PASTore Engine failed to apply locally cached copy of Active Directory storage IPsec policy on the computer. - PASTore Engine failed to apply Active Directory storage IPsec policy on the computer. - PASTore Engine failed to apply local registry storage IPsec policy on the computer. - PASTore Engine failed to apply some rules of the active IPsec policy on the computer. - PASTore Engine failed to load directory storage IPsec policy on the computer. - PASTore Engine loaded directory storage IPsec policy on the computer. - PASTore Engine failed to load local storage IPsec policy on the computer. - PASTore Engine loaded local storage IPsec policy on the computer. - PASTore Engine polled for changes to the active IPsec policy and detected no changes. 4712: IPsec Services encountered a potentially serious failure. 5040: A change has been made to IPsec settings. An Authentication Set was added. 5041: A change has been made to IPsec settings. An Authentication Set was modified. 5042: A change has been made to IPsec settings. An Authentication Set was deleted. 5043: A change has been made to IPsec settings. A Connection Security Rule was added. 5044: A change has been made to IPsec settings. A Connection Security Rule was modified. 5045: A change has been made to IPsec settings. A Connection Security Rule was deleted. 5046: A change has been made to IPsec settings. A Crypto Set was added. 5047: A change has been made to IPsec settings. A Crypto Set was modified. 5048: A change has been made to IPsec settings. A Crypto Set was deleted. 5440: The following callout was present when the Windows Filtering Platform Base Filtering Engine started. 5441: The following filter was present when the Windows Filtering Platform Base Filtering Engine started. 5442: The following provider was present when the Windows Filtering Platform Base Filtering Engine started. 5443: The following provider context was present when the Windows Filtering Platform Base Filtering Engine started. 5444 : The following sub-layer was present when the Windows Filtering Platform Base Filtering Engine started. 5446: A Windows Filtering Platform callout has been changed. 5448: A Windows Filtering Platform provider has been changed.

5449: A Windows Filtering Platform provider context has been changed. 5450: A Windows Filtering Platform sub-layer has been changed. 5456: PASTore Engine applied Active Directory storage IPsec policy on the computer. 5457: PASTore Engine failed to apply Active Directory storage IPsec policy on the computer. 5458 : PASTore Engine applied locally cached copy of Active Directory storage IPsec policy on the computer. 5459: PASTore Engine failed to apply locally cached copy of Active Directory storage IPsec policy on the computer. 5460: PASTore Engine applied local registry storage IPsec policy on the computer. 5461: PASTore Engine failed to apply local registry storage IPsec policy on the computer. 5462: PASTore Engine failed to apply some rules of the active IPsec policy on the computer. Use the IP Security Monitor snap-in to diagnose the problem. 5463: PASTore Engine polled for changes to the active IPsec policy and detected no changes. 5464: PASTore Engine polled for changes to the active IPsec policy, detected changes, and applied them to IPsec Services. 5465: PASTore Engine received a control for forced reloading of IPsec policy and processed the control successfully. 5466: PASTore Engine polled for changes to the Active Directory IPsec policy, determined that Active Directory cannot be reached, and will use the cached copy of the Active Directory IPsec policy instead. Any changes made to the Active Directory IPsec policy since the last poll could not be applied. 5467: PASTore Engine polled for changes to the Active Directory IPsec policy, determined that Active Directory can be reached, and found no changes to the policy. The cached copy of the Active Directory IPsec policy is no longer being used. 5468: PASTore Engine polled for changes to the Active Directory IPsec policy, determined that Active Directory can be reached, found changes to the policy, and applied those changes. The cached copy of the Active Directory IPsec policy is no longer being used. 5471: PASTore Engine loaded local storage IPsec policy on the computer. 5472: PASTore Engine failed to load local storage IPsec policy on the computer. 5473: PASTore Engine loaded directory storage IPsec policy on the computer. 5474: PASTore Engine failed to load directory storage IPsec policy on the computer. 5477: PASTore Engine failed to add quick mode filter. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Policy Change\Audit Policy: Policy  
Change: Filtering Platform Policy Change
```

Default Value:

No auditing

References:

1. CCE-22210-9

1.1.2.22 Set 'Audit Policy: Object Access: Central Access Policy Staging' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to audit access requests where the permission granted or denied by a proposed policy differs from the current central access policy on an object. If you configure this policy setting, an audit event is generated each time a user accesses an object and the permission granted by the current central access policy on the object differs from that granted by the proposed policy. The resulting audit event will be generated as follows: 1) Success audits, when configured, records access attempts when the current central access policy grants access but the proposed policy denies access. 2) Failure audits when configured records access attempts when: a) The current central access policy does not grant access but the proposed policy grants access. b) A principal requests the maximum access rights they are allowed and the access rights granted by the current central access policy are different than the access rights granted by the proposed policy. Volume: Potentially high on a file server when the proposed policy differs significantly from the current central access policy. The recommended state for this setting is: `No Auditing`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Object Access\Audit Policy: Object  
Access: Central Access Policy Staging
```

Default Value:

No auditing

References:

1. CCE-23207-4

1.1.2.23 Set 'Audit Policy: Policy Change: Authorization Policy Change' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports changes in authorization policy including permissions (DACL) changes. Events for this subcategory include: 4704: A user right was assigned. 4705: A user right was removed. 4706: A new trust was created to a domain. 4707: A trust to a domain was removed. 4714: Encrypted data recovery policy was changed. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Policy Change\Audit Policy: Policy Change: Authorization Policy Change

Default Value:

No auditing

References:

1. CCE-22204-2

1.1.2.24 Set 'Audit Policy: Account Logon: Kerberos Authentication Service' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports events generated by the Kerberos Authentication Server. These events occur on the computer that is authoritative for the credentials. Events for this subcategory include: 4768: A Kerberos authentication ticket (TGT) was requested. 4771: Kerberos pre-authentication failed. 4772: A Kerberos authentication ticket request failed. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Logon\Audit Policy: Account Logon: Kerberos Authentication Service

Default Value:

No auditing

References:

1. CCE-22178-8

1.1.2.25 Set 'Audit Policy: Logon-Logoff: Logoff' to 'Success' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a user logs off from the system. These events occur on the accessed computer. For interactive logons, the generation of these events occurs on the computer that is logged on to. If a network logon takes place to access a share, these events generate on the computer that hosts the accessed resource. If you configure this setting to No auditing, it is difficult or impossible to determine which user has accessed or attempted to access organization computers. Events for this subcategory include: 4634: An account was logged off. 4647: User initiated logoff. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: `Success`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff:  
Logoff
```

Default Value:

Success

References:

1. CCE-22565-6

1.1.2.26 Set 'Audit Policy: Account Management: Application Group Management' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports each event of application group management on a computer, such as when an application group is created, changed, or deleted or when a member is added to or removed from an application group. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of application group accounts. Events for this subcategory include: 4783: A basic application group was created. 4784: A basic application group was changed. 4785: A member was added to a basic application group. 4786: A member was removed from a basic application group. 4787: A non-member was added to a basic application group. 4788: A non-member was removed from a basic application group. 4789: A basic application group was deleted. 4790: An LDAP query group was created. 4791: A basic application group was changed. 4792: An LDAP query group was deleted. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Account Management\Audit Policy: Account  
Management: Application Group Management
```

Default Value:

No auditing

References:

1. CCE-23336-1

1.1.2.27 Set 'Audit Policy: DS Access: Directory Service Changes' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports changes to objects in Active Directory Domain Services (AD DS). The types of changes that are reported are create, modify, move, and undelete operations that are performed on an object. DS Change auditing, where appropriate, indicates the old and new values of the changed properties of the objects that were changed. Only objects with SACLs cause audit events to be generated, and only when they are accessed in a manner that matches their SACL. Some objects and properties do not cause audit events to be generated due to settings on the object class in the schema. This subcategory applies only to domain controllers. Events for this subcategory include: 5136 : A directory service object was modified. 5137 : A directory service object was created. 5138 : A directory service object was undeleted. 5139 : A directory service object was moved. Note The following event in the Directory Service Changes subcategory is available only in Windows Vista Service Pack 1 and in Windows Server 2008. 5141: A directory service object was deleted. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\DS Access\Audit Policy: DS Access:  
Directory Service Changes
```

Default Value:

No auditing

References:

1. CCE-21956-8

1.1.2.28 Set 'Audit Policy: Object Access: Kernel Object' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when kernel objects such as processes and mutexes are accessed. Only kernel objects with SACLs cause audit events to be generated, and only when they are accessed in a manner matching their SACL. Typically kernel objects are only given SACLs if the AuditBaseObjects or AuditBaseDirectories auditing options are enabled. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Object Access\Audit Policy: Object  
Access: Kernel Object
```

Default Value:

No auditing

References:

1. CCE-22184-6

1.1.2.29 Set 'Audit Policy: Policy Change: Other Policy Change Events' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports other types of security policy changes such as configuration of the Trusted Platform Module (TPM) or cryptographic providers. Events for this subcategory include: 4909: The local policy settings for the TBS were changed. 4910: The group policy settings for the TBS were changed. 5063: A cryptographic provider operation was attempted. 5064: A cryptographic context operation was attempted. 5065: A cryptographic context modification was attempted. 5066: A cryptographic function operation was attempted. 5067: A cryptographic function modification was attempted. 5068: A cryptographic function provider operation was attempted. 5069: A cryptographic function property operation was attempted. 5070: A cryptographic function property modification was attempted. 5447: A Windows Filtering Platform filter has been changed. 6144: Security policy in the group policy objects has been applied successfully. 6145: One or more errors occurred while processing security policy in the group policy objects. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Policy Change\Audit Policy: Policy  
Change: Other Policy Change Events
```

Default Value:

No auditing

References:

1. CCE-22798-3

1.1.2.30 Set 'Audit Policy: Object Access: Application Generated' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when applications attempt to generate audit events by using the Windows auditing application programming interfaces (APIs). Events for this subcategory include: 4665: An attempt was made to create an application client context. 4666: An application attempted an operation. 4667: An application client context was deleted. 4668: An application was initialized. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: Application Generated

Default Value:

No auditing

References:

1. CCE-23565-5

1.1.2.31 Set 'Audit Policy: Logon-Logoff: Account Lockout' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a user's account is locked out as a result of too many failed logon attempts. Events for this subcategory include: 4625: An account failed to log on. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff: Account Lockout

Default Value:

Success

References:

1. CCE-22859-3

1.1.2.32 Set 'Audit Policy: Policy Change: Audit Policy Change' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports changes in audit policy including SACL changes. Events for this subcategory include: 4715: The audit policy (SACL) on an object was changed. 4719: System audit policy was changed. 4902: The Per-user audit policy table was created. 4904: An attempt was made to register a security event source. 4905: An attempt was made to unregister a security event source. 4906: The CrashOnAuditFail value has changed. 4907: Auditing settings on object were changed. 4908: Special Groups Logon table modified. 4912: Per User Audit Policy was changed. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Policy Change\Audit Policy: Policy Change: Audit Policy Change

Default Value:

Success

References:

1. CCE-22854-4

1.1.2.33 Set 'Audit Policy: Object Access: File Share' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a file share is accessed. By itself, this policy setting will not cause auditing of any events. It determines whether to audit the event of a user who accesses a file share object that has a specified system access control list (SACL), effectively enabling auditing to take place. A SACL is comprised of access control entries (ACEs). Each ACE contains three pieces of information: - The security principal (user, computer, or group) to be audited. - The specific access type to be audited, called an access mask. - A flag to indicate whether to audit failed access events, successful access events, or both. If you configure the Audit object access setting to Success, an audit entry is generated each time that a user successfully accesses an object with a specified SACL. If you configure this policy setting to Failure, an audit entry is generated each time that a user fails in an attempt to access an object with a specified SACL. Organizations should define only the actions they want enabled when they configure SACLs. For example, you might want to enable the Write and Append Data auditing setting on executable files to track when they are changed or replaced, because computer viruses, worms, and Trojan horses typically target executable files. Similarly, you might want to track when sensitive documents are accessed or changed. Events for this subcategory include: 5140: A network share object was accessed. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Object Access\Audit Policy: Object  
Access: File Share
```

Default Value:

No auditing

References:

1. CCE-21844-6

1.1.2.34 Set 'Audit Policy: System: System Integrity' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports on violations of integrity of the security subsystem. Events for this subcategory include: 4612 : Internal resources allocated for the queuing of audit messages have been exhausted, leading to the loss of some audits. 4615 : Invalid use of LPC port. 4618 : A monitored security event pattern has occurred. 4816 : RPC detected an integrity violation while decrypting an incoming message. 5038 : Code integrity determined that the image hash of a file is not valid. The file could be corrupt due to unauthorized modification or the invalid hash could indicate a potential disk device error. 5056: A cryptographic self test was performed. 5057: A cryptographic primitive operation failed. 5060: Verification operation failed. 5061: Cryptographic operation. 5062: A kernel-mode cryptographic self test was performed. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: Success and Failure.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\System\Audit Policy: System: System  
Integrity
```

Default Value:

Success and Failure

References:

1. CCE-23558-0

1.1.2.35 Set 'Audit Policy: System: Other System Events' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports on other system events. Events for this subcategory include: 5024 : The Windows Firewall Service has started successfully. 5025 : The Windows Firewall Service has been stopped. 5027 : The Windows Firewall Service was unable to retrieve the security policy from the local storage. The service will continue enforcing the current policy. 5028 : The Windows Firewall Service was unable to parse the new security policy. The service will continue with currently enforced policy. 5029: The Windows Firewall Service failed to initialize the driver. The service will continue to enforce the current policy. 5030: The Windows Firewall Service failed to start. 5032: Windows Firewall was unable to notify the user that it blocked an application from accepting incoming connections on the network. 5033 : The Windows Firewall Driver has started successfully. 5034 : The Windows Firewall Driver has been stopped. 5035 : The Windows Firewall Driver failed to start. 5037 : The Windows Firewall Driver detected critical runtime error. Terminating. 5058: Key file operation. 5059: Key migration operation. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\System\Audit Policy: System: Other System  
Events
```

Default Value:

Success and Failure

References:

1. CCE-23028-4

1.1.2.36 Set 'Audit Policy: Logon-Logoff: Other Logon/Logoff Events' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports other logon/logoff-related events, such as Terminal Services session disconnects and reconnects, using RunAs to run processes under a different account, and locking and unlocking a workstation. Events for this subcategory include: 4649: A replay attack was detected. 4778: A session was reconnected to a Window Station. 4779: A session was disconnected from a Window Station. 4800: The workstation was locked. 4801: The workstation was unlocked. 4802: The screen saver was invoked. 4803: The screen saver was dismissed. 5378: The requested credentials delegation was disallowed by policy. 5632: A request was made to authenticate to a wireless network. 5633: A request was made to authenticate to a wired network. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff:  
Other Logon/Logoff Events
```

Default Value:

No auditing

References:

1. CCE-22723-1

1.1.2.37 Set 'Audit Policy: DS Access: Directory Service Replication' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when replication between two domain controllers begins and ends. Events for this subcategory include: 4932: Synchronization of a replica of an Active Directory naming context has begun. 4933: Synchronization of a replica of an Active Directory naming context has ended. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\DS Access\Audit Policy: DS Access:  
Directory Service Replication
```

Default Value:

No auditing

References:

1. CCE-22437-8

1.1.2.38 Set 'Audit Policy: Object Access: Filtering Platform Packet Drop' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when packets are dropped by Windows Filtering Platform (WFP). These events can be very high in volume. Events for this subcategory include: 5152: The Windows Filtering Platform blocked a packet. 5153: A more restrictive Windows Filtering Platform filter has blocked a packet. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Object Access\Audit Policy: Object  
Access: Filtering Platform Packet Drop
```

Default Value:

No auditing

References:

1. CCE-22558-1

1.1.2.39 Set 'Audit Policy: DS Access: Detailed Directory Service Replication' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports detailed information about the information replicating between domain controllers. These events can be very high in volume. Events for this subcategory include: 4928: An Active Directory replica source naming context was established. 4929 : An Active Directory replica source naming context was removed. 4930 : An Active Directory replica source naming context was modified. 4931 : An Active Directory replica destination naming context was modified. 4934 : Attributes of an Active Directory object were replicated. 4935 : Replication failure begins. 4936 : Replication failure ends. 4937 : A lingering object was removed from a replica. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\DS Access\Audit Policy: DS Access: Detailed Directory Service Replication

Default Value:

No auditing

References:

1. CCE-21471-8

1.1.2.40 Set 'Audit Policy: Object Access: Other Object Access Events' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports other object access-related events such as Task Scheduler jobs and COM+ objects. Events for this subcategory include: 4671: An application attempted to access a blocked ordinal through the TBS. 4691: Indirect access to an object was requested. 4698: A scheduled task was created. 4699: A scheduled task was deleted. 4700: A scheduled task was enabled. 4701: A scheduled task was disabled. 4702: A scheduled task was updated. 5888: An object in the COM+ Catalog was modified. 5889: An object was deleted from the COM+ Catalog. 5890: An object was added to the COM+ Catalog. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: Other Object Access Events

Default Value:

No auditing

References:

1. CCE-22206-7

1.1.2.41 Set 'Audit Policy: Object Access: Filtering Platform Connection' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when connections are allowed or blocked by WFP. These events can be high in volume. Events for this subcategory include: 5031: The Windows Firewall Service blocked an application from accepting incoming connections on the network. 5154: The Windows Filtering Platform has permitted an application or service to listen on a port for incoming connections. 5155 : The Windows Filtering Platform has blocked an application or service from listening on a port for incoming connections. 5156: The Windows Filtering Platform has allowed a connection. 5157: The Windows Filtering Platform has blocked a connection. 5158: The Windows Filtering Platform has permitted a bind to a local port. 5159: The Windows Filtering Platform has blocked a bind to a local port. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Object Access\Audit Policy: Object  
Access: Filtering Platform Connection
```

Default Value:

No auditing

References:

1. CCE-22577-1

1.1.2.42 Set 'Audit Policy: Privilege Use: Non Sensitive Privilege Use' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a user account or service uses a non-sensitive privilege. A non-sensitive privilege includes the following user rights: Access Credential Manager as a trusted caller, Access this computer from the network, Add workstations to domain, Adjust memory quotas for a process, Allow log on locally, Allow log on through Terminal Services, Bypass traverse checking, Change the system time, Create a pagefile, Create global objects, Create permanent shared objects, Create symbolic links, Deny access this computer from the network, Deny log on as a batch job, Deny log on as a service, Deny log on locally, Deny log on through Terminal Services, Force shutdown from a remote system, Increase a process working set, Increase scheduling priority, Lock pages in memory, Log on as a batch job, Log on as a service, Modify an object label, Perform volume maintenance tasks, Profile single process, Profile system performance, Remove computer from docking station, Shut down the system, and Synchronize directory service data. Auditing this subcategory will create a very high volume of events. Events for this subcategory include: 4672: Special privileges assigned to new logon. 4673: A privileged service was called. 4674: An operation was attempted on a privileged object. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Privilege Use\Audit Policy: Privilege  
Use: Non Sensitive Privilege Use
```

Default Value:

No auditing

References:

1. CCE-21816-4

1.1.2.43 Set 'Audit Policy: Object Access: Certification Services' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when Certification Services operations are performed. Events for this subcategory include: 4868: The certificate manager denied a pending certificate request. 4869: Certificate Services received a resubmitted certificate request. 4870: Certificate Services revoked a certificate. 4871: Certificate Services received a request to publish the certificate revocation list (CRL). 4872: Certificate Services published the certificate revocation list (CRL). 4873: A certificate request extension changed. 4874: One or more certificate request attributes changed. 4875: Certificate Services received a request to shut down. 4876: Certificate Services backup started. 4877: Certificate Services backup completed. 4878: Certificate Services restore started. 4879: Certificate Services restore completed. 4880: Certificate Services started. 4881: Certificate Services stopped. 4882: The security permissions for Certificate Services changed. 4883: Certificate Services retrieved an archived key. 4884: Certificate Services imported a certificate into its database. 4885: The audit filter for Certificate Services changed. 4886: Certificate Services received a certificate request. 4887: Certificate Services approved a certificate request and issued a certificate. 4888: Certificate Services denied a certificate request. 4889: Certificate Services set the status of a certificate request to pending. 4890: The certificate manager settings for Certificate Services changed. 4891: A configuration entry changed in Certificate Services. 4892: A property of Certificate Services changed. 4893: Certificate Services archived a key. 4894: Certificate Services imported and archived a key. 4895: Certificate Services published the CA certificate to Active Directory Domain Services. 4896: One or more rows have been deleted from the certificate database. 4897: Role separation enabled. 4898: Certificate Services loaded a template. 4899: A Certificate Services template was updated. 4900: Certificate Services template security was updated. 5120: OCSP Responder Service Started. 5121: OCSP Responder Service Stopped. 5122: A Configuration entry changed in the OCSP Responder Service. 5123: A configuration entry changed in the OCSP Responder Service. 5124: A security setting was updated on OCSP Responder Service. 5125: A request was submitted to OCSP Responder Service. 5126: Signing Certificate was automatically updated by the OCSP Responder Service. 5127: The OCSP Revocation Provider successfully updated the revocation information. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: Certification Services
```

Default Value:

No auditing

References:

1. CCE-21726-5

1.1.2.44 Set 'Audit Policy: Logon-Logoff: Special Logon' to 'Success' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a special logon is used. A special logon is a logon that has administrator-equivalent privileges and can be used to elevate a process to a higher level. Events for this subcategory include: 4964 : Special groups have been assigned to a new logon. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: `Success`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff:  
Special Logon
```

Default Value:

Success

References:

1. CCE-21798-4

1.1.2.45 Set 'Audit Policy: Object Access: Handle Manipulation' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a handle to an object is opened or closed. Only objects with SACLs cause these events to be generated, and only if the attempted handle operation matches the SACL. Handle Manipulation events are only generated for object types where the corresponding Object Access subcategory is enabled, for example File System or Registry. Events for this subcategory include: 4656: A handle to an object was requested. 4658: The handle to an object was closed. 4690: An attempt was made to duplicate a handle to an object. Refer to the Microsoft Knowledgebase article <http://support.microsoft.com/default.aspx/kb/947226> for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Object Access\Audit Policy: Object  
Access: Handle Manipulation
```

Default Value:

No auditing

References:

1. CCE-22465-9

1.1.2.46 Set 'Audit Policy: Object Access: Removable Storage' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to audit user attempts to access file system objects on a removable storage device. A security audit event is generated only for all objects for all types of access requested. If you configure this policy setting, an audit event is generated each time an account accesses a file system object on a removable storage. Success audits record successful attempts and Failure audits record unsuccessful attempts. If you do not configure this policy setting, no audit event is generated when an account accesses a file system object on a removable storage. The recommended state for this setting is: `No Auditing`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: Removable Storage

Default Value:

No auditing

References:

1. CCE-21659-8

1.1.2.47 Set 'Audit Policy: Logon-Logoff: IPsec Main Mode' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the results of Internet Key Exchange (IKE) protocol and Authenticated Internet Protocol (AuthIP) during Main Mode negotiations. Events for this subcategory include: 4646: IKE DoS-prevention mode started. 4650: An IPsec Main Mode security association was established. Extended Mode was not enabled. Certificate authentication was not used. 4651: An IPsec Main Mode security association was established. Extended Mode was not enabled. A certificate was used for authentication. 4652: An IPsec Main Mode negotiation failed. 4653: An IPsec Main Mode negotiation failed. 4655: An IPsec Main Mode security association ended. 4976: During Main Mode negotiation, IPsec received an invalid negotiation packet. If this problem persists, it could indicate a network issue or an attempt to modify or replay this negotiation. 5049: An IPsec Security Association was deleted. 5453: An IPsec negotiation with a remote computer failed because the IKE and AuthIP IPsec Keying Modules (IKEEXT) service is not started. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff:  
IPsec Main Mode
```

Default Value:

No auditing

References:

1. CCE-22378-4

1.1.2.48 Set 'Audit Policy: Account Logon: Credential Validation' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the results of validation tests on credentials submitted for a user account logon request. These events occur on the computer that is authoritative for the credentials. For domain accounts, the domain controller is authoritative, whereas for local accounts, the local computer is authoritative. In domain environments, most of the Account Logon events occur in the Security log of the domain controllers that are authoritative for the domain accounts. However, these events can occur on other computers in the organization when local accounts are used to log on. Events for this subcategory include: 4774: An account was mapped for logon. 4775: An account could not be mapped for logon. 4776: The domain controller attempted to validate the credentials for an account. 4777: The domain controller failed to validate the credentials for an account. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: `Success and Failure`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Account Logon\Audit Policy: Account  
Logon: Credential Validation
```

Default Value:

No auditing

References:

1. CCE-23198-5

1.1.2.49 Set 'Audit Policy: Account Logon: Kerberos Service Ticket Operations' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports generated by Kerberos ticket request processes on the domain controller that is authoritative for the domain account. Events for this subcategory include: 4769: A Kerberos service ticket was requested. 4770: A Kerberos service ticket was renewed. 4773: A Kerberos service ticket request failed. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Logon\Audit Policy: Account Logon: Kerberos Service Ticket Operations

Default Value:

No auditing

References:

1. CCE-23241-3

1.1.2.50 Set 'Audit Policy: Logon-Logoff: Logon' to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when a user attempts to log on to the system. These events occur on the accessed computer. For interactive logons, the generation of these events occurs on the computer that is logged on to. If a network logon takes place to access a share, these events generate on the computer that hosts the accessed resource. If you configure this setting to No auditing, it is difficult or impossible to determine which user has accessed or attempted to access organization computers. Events for this subcategory include: 4624: An account was successfully logged on. 4625: An account failed to log on. 4648: A logon was attempted using explicit credentials. 4675: SIDs were filtered. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: `Success and Failure`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success and Failure.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff: Logon

Default Value:

Success

References:

1. CCE-22438-6

1.1.2.51 Set 'Audit Policy: Detailed Tracking: Process Creation' to 'Success' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the creation of a process and the name of the program or user that created it. Events for this subcategory include: 4688: A new process has been created. 4696: A primary token was assigned to process. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: `Success`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Detailed Tracking\Audit Policy: Detailed Tracking: Process Creation

Default Value:

No auditing

References:

1. CCE-22905-4

1.1.2.52 Set 'Audit Policy: Logon-Logoff: IPsec Extended Mode' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports the results of AuthIP during Extended Mode negotiations. Events for this subcategory include: 4978: During Extended Mode negotiation, IPsec received an invalid negotiation packet. If this problem persists, it could indicate a network issue or an attempt to modify or replay this negotiation. 4979: IPsec Main Mode and Extended Mode security associations were established. 4980: IPsec Main Mode and Extended Mode security associations were established. 4981: IPsec Main Mode and Extended Mode security associations were established. 4982: IPsec Main Mode and Extended Mode security associations were established. 4983: An IPsec Extended Mode negotiation failed. The corresponding Main Mode security association has been deleted. 4984: An IPsec Extended Mode negotiation failed. The corresponding Main Mode security association has been deleted. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a denial of service (DoS). If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit  
Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff:  
IPsec Extended Mode
```

Default Value:

No auditing

References:

1. CCE-22902-1

1.1.2.53 Set 'Audit Policy: Object Access: SAM' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when SAM objects are accessed. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting:

<http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: SAM

Default Value:

No auditing

References:

1. CCE-22906-2

1.1.2.54 Set 'Audit Policy: Object Access: File System' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports when file system objects are accessed. Only file system objects with SACLs cause audit events to be generated, and only when they are accessed in a manner matching their SACL. By itself, this policy setting will not cause auditing of any events. It determines whether to audit the event of a user who accesses a file system object that has a specified system access control list (SACL), effectively enabling auditing to take place. A SACL is comprised of access control entries (ACEs). Each ACE contains three pieces of information: - The security principal (user, computer, or group) to be audited. - The specific access type to be audited, called an access mask. - A flag to indicate whether to audit failed access events, successful access events, or both. If you configure the Audit object access setting to Success, an audit entry is generated each time that a user successfully accesses an object with a specified SACL. If you configure this policy setting to Failure, an audit entry is generated each time that a user fails in an attempt to access an object with a specified SACL. Organizations should define only the actions they want enabled when they configure SACLs. For example, you might want to enable the Write and Append Data auditing setting on executable files to track when they are changed or replaced, because computer viruses, worms, and Trojan horses typically target executable files. Similarly, you might want to track when sensitive documents are accessed or changed. Events for this subcategory include: 4664: An attempt was made to create a hard link. 4985: The state of a transaction has changed. 5051: A file was virtualized. Refer to the Microsoft Knowledgebase article [Description of security events in Windows Vista and in Windows Server 2008](http://support.microsoft.com/default.aspx/kb/947226) for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: No Auditing.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No Auditing**.

```
Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Policy: Object Access: File System
```

Default Value:

No auditing

References:

1. CCE-22156-4

1.1.2.55 Set 'Audit Policy: Policy Change: Authentication Policy Change' to 'Success' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This subcategory reports changes in authentication policy. Events for this subcategory include: 4706: A new trust was created to a domain. 4707: A trust to a domain was removed. 4713: Kerberos policy was changed. 4716: Trusted domain information was modified. 4717: System security access was granted to an account. 4718: System security access was removed from an account. 4739: Domain Policy was changed. 4864: A namespace collision was detected. 4865: A trusted forest information entry was added. 4866: A trusted forest information entry was removed. 4867: A trusted forest information entry was modified. Refer to the Microsoft Knowledgebase article Description of security events in Windows Vista and in Windows Server 2008 for the most recent information about this setting: <http://support.microsoft.com/default.aspx/kb/947226>. The recommended state for this setting is: `Success`.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Success.

Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Policy Change\Audit Policy: Policy Change: Authentication Policy Change

Default Value:

Success

References:

1. CCE-23454-2

1.1.3 Security Options

1.1.3.1 Accounts

ARCHIVE

1.1.3.1.1 Set 'Accounts: Block Microsoft accounts' to 'Users can't add or log on with Microsoft accounts' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting prevents users from adding new Microsoft accounts on this computer. If you select the "Users can't add Microsoft accounts" option, users will not be able to create new Microsoft accounts on this computer, switch a local account to a Microsoft account, or connect a domain account to a Microsoft account. This is the preferred option if you need to limit the use of Microsoft accounts in your enterprise. If you select the "Users can't add or log on with Microsoft accounts" option, existing Microsoft account users will not be able to log on to Windows. Selecting this option might make it impossible for an existing administrator on this computer to log on and manage the system. If you disable or do not configure this policy (recommended), users will be able to use Microsoft accounts with Windows. The recommended state for this setting is: Users can't add or log on with Microsoft accounts.

Rationale:

Organizations that want to effectively implement identity management policies and maintain firm control of what accounts are used to log onto their computers will probably want to block Microsoft accounts. Organizations may also need to block Microsoft accounts in order to meet the requirements of compliance standards that apply to their information systems.

Impact:

Users will not be able to log onto the computer with their Microsoft account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\NoConnectedUser
--

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Users can't add or log on with Microsoft accounts`.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Block Microsoft accounts
--

Default Value:

Not defined

References:

1. CCE-21665-5

ARCHIVE

1.1.3.1.2 Configure 'Accounts: Rename guest account' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The built-in local guest account is another well-known name to attackers. It is recommended to rename this account to something that does not indicate its purpose. Even if you disable this account, which is recommended, ensure that you rename it for added security.

Rationale:

The Guest account exists on all computers that run the Windows 2000, Windows Server 2003, or Windows XP Professional operating systems. If you rename this account, it is slightly more difficult for unauthorized persons to guess this privileged user name and password combination.

Impact:

There should be little impact, because the Guest account is disabled by default.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following UI path:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Rename guest account
```

Default Value:

Guest

References:

1. CCE-21399-1

1.1.3.1.3 Set 'Accounts: Administrator account status' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting enables or disables the Administrator account during normal operation. When a computer is booted into safe mode, the Administrator account is always enabled, regardless of how this setting is configured. Note that this setting will have no impact when applied to the domain controller organizational unit via group policy because domain controllers have no local account database. It can be configured at the domain level via group policy, similar to account lockout and password policy settings. The recommended state for this setting is: *Disabled*.

Rationale:

In some organizations, it can be a daunting management challenge to maintain a regular schedule for periodic password changes for local accounts. Therefore, you may want to disable the built-in Administrator account instead of relying on regular password changes to protect it from attack. Another reason to disable this built-in account is that it cannot be locked out no matter how many failed logons it accrues, which makes it a prime target for brute force attacks that attempt to guess passwords. Also, this account has a well-known security identifier (SID) and there are third-party tools that allow authentication by using the SID rather than the account name. This capability means that even if you rename the Administrator account, an attacker could launch a brute force attack by using the SID to log on.

Impact:

Maintenance issues can arise under certain circumstances if you disable the Administrator account. For example, if the secure channel between a member computer and the domain controller fails in a domain environment for any reason and there is no other local Administrator account, you must restart in safe mode to fix the problem that broke the secure channel. If the current Administrator password does not meet the password requirements, you will not be able to re-enable the Administrator account after it is disabled. If this situation occurs, another member of the Administrators group must set the password on the Administrator account with the Local Users and Groups tool.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Administrator account status

Default Value:

Disabled

References:

1. CCE-22297-6

ARCHIVE

1.1.3.1.4 Configure 'Accounts: Rename administrator account' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The built-in local administrator account is a well-known account name that attackers will target. It is recommended to choose another name for this account, and to avoid names that denote administrative or elevated access accounts. Be sure to also change the default description for the local administrator (through the Computer Management console).

Rationale:

The Administrator account exists on all computers that run the Windows 2000, Windows Server 2003, or Windows XP Professional operating systems. If you rename this account, it is slightly more difficult for unauthorized persons to guess this privileged user name and password combination. The built-in Administrator account cannot be locked out, regardless of how many times an attacker might use a bad password. This capability makes the Administrator account a popular target for brute force attacks that attempt to guess passwords. The value of this countermeasure is lessened because this account has a well-known SID, and there are third-party tools that allow authentication by using the SID rather than the account name. Therefore, even if you rename the Administrator account, an attacker could launch a brute force attack by using the SID to log on.

Impact:

You will have to inform users who are authorized to use this account of the new account name. (The guidance for this setting assumes that the Administrator account was not disabled, which was recommended earlier in this chapter.)

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following UI path:

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Rename administrator account

Default Value:

Administrator

References:

1. CCE-22097-0

ARCHIVE

1.1.3.1.5 Set 'Accounts: Guest account status' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the Guest account is enabled or disabled. The Guest account allows unauthenticated network users to gain access to the system. Note that this setting will have no impact when applied to the domain controller organizational unit via group policy because domain controllers have no local account database. It can be configured at the domain level via group policy, similar to account lockout and password policy settings. The recommended state for this setting is: *Disabled*.

Rationale:

The default Guest account allows unauthenticated network users to log on as Guest with no password. These unauthorized users could access any resources that are accessible to the Guest account over the network. This capability means that any network shares with permissions that allow access to the Guest account, the Guests group, or the Everyone group will be accessible over the network, which could lead to the exposure or corruption of data.

Impact:

All network users will need to authenticate before they can access shared resources. If you disable the Guest account and the Network Access: Sharing and Security Model option is set to Guest Only, network logons, such as those performed by the Microsoft Network Server (SMB Service), will fail. This policy setting should have little impact on most organizations because it is the default setting in Microsoft Windows 2000, Windows XP, and Windows Server™ 2003.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Guest account status
--

Default Value:

Disabled

References:

1. CCE-22548-2

ARCHIVE

1.1.3.1.6 Set 'Accounts: Limit local account use of blank passwords to console logon only' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether local accounts that are not password protected can be used to log on from locations other than the physical computer console. If you enable this policy setting, local accounts that have blank passwords will not be able to log on to the network from remote client computers. Such accounts will only be able to log on at the keyboard of the computer. The recommended state for this setting is:

Enabled.

Rationale:

Blank passwords are a serious threat to computer security and should be forbidden through both organizational policy and suitable technical measures. In fact, the default settings for Active Directory domains require complex passwords of at least seven characters. However, if users with the ability to create new accounts bypass your domain-based password policies, they could create accounts with blank passwords. For example, a user could build a stand-alone computer, create one or more accounts with blank passwords, and then join the computer to the domain. The local accounts with blank passwords would still function. Anyone who knows the name of one of these unprotected accounts could then use it to log on.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\LimitBlankPasswordUse

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Limit local account use of blank passwords to console logon only

Default Value:

Enabled

References:

1. CCE-23264-5

ARCHIVE

1.1.3.2 Audit

ARCHIVE

1.1.3.2.1 Set 'Audit: Shut down system immediately if unable to log security audits' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the system shuts down if it is unable to log Security events. It is a requirement for Trusted Computer System Evaluation Criteria (TCSEC)-C2 and Common Criteria certification to prevent auditable events from occurring if the audit system is unable to log them. Microsoft has chosen to meet this requirement by halting the system and displaying a stop message if the auditing system experiences a failure. When this policy setting is enabled, the system will be shut down if a security audit cannot be logged for any reason. If the Audit: Shut down system immediately if unable to log security audits setting is enabled, unplanned system failures can occur. Therefore, this policy setting is configured to Not Defined for both of the environments that are discussed in this chapter. The recommended state for this setting is: *Disabled*.

Rationale:

If the computer is unable to record events to the Security log, critical evidence or important troubleshooting information may not be available for review after a security incident. Also, an attacker could potentially generate a large volume of Security log events to purposely force a computer shutdown.

Impact:

If you enable this policy setting, the administrative burden can be significant, especially if you also configure the Retention method for the Security log to Do not overwrite events (clear log manually). This configuration causes a repudiation threat (a backup operator could deny that they backed up or restored data) to become a denial of service (DoS) vulnerability, because a server could be forced to shut down if it is overwhelmed with logon events and other security events that are written to the Security log. Also, because the shutdown is not graceful, it is possible that irreparable damage to the operating system, applications, or data could result. Although the NTFS file system guarantees its integrity when an ungraceful computer shutdown occurs, it cannot guarantee that every data file for every application will still be in a usable form when the computer restarts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\crashonauditfail
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Audit: Shut down system immediately if unable to log security audits
```

Default Value:

Disabled

References:

1. CCE-22303-2

1.1.3.2.2 Set 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows administrators to enable the more precise auditing capabilities present in Windows Vista. The Audit Policy settings available in Windows Server 2003 Active Directory do not yet contain settings for managing the new auditing subcategories. To properly apply the auditing policies prescribed in this baseline, the Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings setting needs to be configured to Enabled. The recommended state for this setting is: `Enabled`.

Rationale:

Prior to the introduction of auditing subcategories in Windows Vista, it was difficult to track events at a per-system or per-user level. The larger event categories created too many events and the key information that needed to be audited was difficult to find.

Impact:

The individual audit policy subcategories that are available in Windows Vista are not exposed in the interface of Group Policy tools. Administrators can deploy a custom audit policy that applies detailed security auditing settings to Windows Vista-based client computers in a Windows Server 2003 domain or in a Windows 2000 domain. If after enabling this setting, you attempt to modify an auditing setting by using Group Policy, the Group Policy auditing setting will be ignored in favor of the custom policy setting. To modify auditing settings by using Group Policy, you must first disable this key. Important Be very cautious about audit settings that can generate a large volume of traffic. For example, if you enable either success or failure auditing for all of the Privilege Use subcategories, the high volume of audit events generated can make it difficult to find other types of entries in the Security log. Such a configuration could also have a significant impact on system performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\scenarioapplylegacyaudit  
policy
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Audit: Force audit policy subcategory settings  
(Windows Vista or later) to override audit policy category settings
```

Default Value:

Not defined

References:

1. CCE-22973-2

1.1.3.2.3 Configure 'Audit: Audit the use of Backup and Restore privilege' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether to audit the use of all user privileges, including Backup and Restore, when the Audit privilege use setting is in effect. If you enable both policies, an audit event will be generated for every file that is backed up or restored. If the `Audit: Audit the use of Backup and Restore privilege` setting is enabled, a very large number of security events could quickly fill the Security event log. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

When back up and restore is used it creates a copy of the file system that is identical to the target of the backup. Making regular backups and restore volumes is an important part of a your incident response plan, but a malicious user could use a legitimate backup copy to get access to information or spoof a legitimate network resource to compromise your enterprise.

Impact:

If you enable this policy setting, a large number of security events could be generated, which could cause servers to respond slowly and force the Security event log to record numerous events of little significance. If you increase the Security log size to reduce the chances of a system shutdown, an excessively large log file may affect system performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\fullprivilegeauditing

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Audit: Audit the use of Backup and Restore privilege

Default Value:

Disabled

References:

1. CCE-22806-4

ARCHIVE

1.1.3.2.4 Configure 'Audit: Audit the access of global system objects' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting creates a default system access control list (SACL) for system objects such as mutexes (mutual exclusive), events, semaphores, and MS-DOS devices, and causes access to these system objects to be audited. If the Audit: Audit the access of global system objects setting is enabled, a very large number of security events could quickly fill the Security event log. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

A globally visible named object, if incorrectly secured, could be acted upon by malicious software that knows the name of the object. For instance, if a synchronization object such as a mutex had a poorly chosen discretionary access control list (DACL), then malicious software could access that mutex by name and cause the program that created it to malfunction. However, the risk of such an occurrence is very low.

Impact:

If you enable the Audit: Audit the access of global system objects setting, a large number of security events could be generated, especially on busy domain controllers and application servers. Such an occurrence could cause servers to respond slowly and force the Security log to record numerous events of little significance. This policy setting can only be enabled or disabled, and there is no way to choose which events are recorded. Even organizations that have the resources to analyze events that are generated by this policy setting would not likely have the source code or a description of what each named object is used for. Therefore, it is unlikely that many organizations could benefit by enabling this policy setting.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\AuditBaseObjects
--

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Audit: Audit the access of global system objects

Default Value:

Disabled

References:

1. CCE-21999-8

ARCHIVE

1.1.3.3 DCOM

ARCHIVE

1.1.3.3.1 Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users or groups might launch or activate DCOM applications remotely or locally. This setting is used to control the attack surface of the computer for DCOM applications. You can use this Group Policy setting to grant access to all the computers to particular users for DCOM application in the enterprise. When you define this setting, and specify the users or groups that are to be given permission, the security descriptor field is populated with the Security Descriptor Definition Language representation of those groups and privileges. If the security descriptor is left blank, the policy setting is defined in the template, but it is not enforced. Users and groups can be given explicit Allow or Deny privileges on local launch, remote launch, local activation, and remote activation. The registry settings that are created as a result of this policy take precedence over the previous registry settings in this area. RpcSs checks the new registry keys in the Policies section for the computer restrictions; these entries take precedence over the existing registry keys under OLE. The possible values for this Group Policy setting are:

- Blank. This represents the local security policy way of deleting the policy enforcement key. This value deletes the policy and then sets it to Not defined state. The Blank value is set by using the ACL editor and emptying the list, and then pressing OK.
- SDDL. This is the Security Descriptor Definition Language representation of the groups and privileges you specify when you enable this policy.
- Not Defined. This is the default value.

Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Note: If the administrator is denied access to activate and launch DCOM applications due to the changes made to DCOM in SP2, this policy setting can be used for controlling the DCOM activation and launch to the computer. The administrator can specify which users and groups can launch and activate DCOM applications on the computer both locally and remotely by using the DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax policy setting. This restores control of the DCOM application to the administrator and specified users. To do this, open the DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax setting, and click Edit Security. Specify the groups you want to include and the computer launch permissions for those groups.

Rationale:

Many COM applications include some security-specific code (for example, to call `CoInitializeSecurity`) but use weak settings that often allow unauthenticated access to the process. Administrators cannot override these settings to force stronger security in earlier versions of Windows without modifying the application. An attacker could attempt to exploit weak security in an individual application by attacking it through COM calls. Also, COM infrastructure includes the RPCSS, a system service that runs during computer startup and always runs after that. This service manages activation of COM objects and the running object table and provides helper services to DCOM remoting. It exposes RPC interfaces that can be called remotely. Because some COM servers allow unauthenticated remote component activation

Impact:

Windows operating systems implement default COM ACLs when they are installed. Modifying these ACLs from the default may cause some applications or components that communicate by using DCOM to fail. If you implement a COM server and you override the default security settings, confirm that the application-specific launch permissions ACL assigns activation permission to appropriate users. If it does not, you need to change your application-specific launch permission ACL to provide appropriate users with activation rights so that applications and Windows components that use DCOM do not fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\windows  
NT\DCOM\MachineLaunchRestriction
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Defined`.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\DCOM: Machine Launch Restrictions in Security  
Descriptor Definition Language (SDDL) syntax
```

Default Value:

Not defined

References:

1. CCE-23142-3

1.1.3.3.2 Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users or groups might access DCOM application remotely or locally. This setting is used to control the attack surface of the computer for DCOM applications. You can use this policy setting to specify access permissions to all the computers to particular users for DCOM applications in the enterprise. When you specify the users or groups that are to be given permission, the security descriptor field is populated with the Security Descriptor Definition Language representation of those groups and privileges. If the security descriptor is left blank, the policy setting is defined in the template, but it is not enforced. Users and groups can be given explicit Allow or Deny privileges on both local access and remote access. The registry settings that are created as a result of enabling the DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax policy setting take precedence over (have higher priority) the previous registry settings in this area. RpcSs checks the new registry keys in the Policies section for the computer restrictions, and these registry entries take precedence over the existing registry keys under OLE. This means that previously existing registry settings are no longer effective, and if you make changes to the existing settings, the computer access permissions for any users are not changed. You should take care to correctly configure their list of users and groups. The possible values for this policy setting are:

- Blank. This represents the local security policy way of deleting the policy enforcement key. This value deletes the policy and then sets it as Not defined state. The Blank value is set by using the ACL editor and emptying the list, and then pressing OK.
- SDDL. This is the Security Descriptor Definition Language representation of the groups and privileges you specify when you enable this policy.
- Not Defined. This is the default value.

Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Note: If the administrator is denied permission to access DCOM applications due to the changes made to DCOM in SP2, the administrator can use the DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax policy setting to manage DCOM access to the computer. The administrator can specify which users and groups can access the DCOM application on the computer both locally and remotely by using this setting. This will restore control of the DCOM application to the administrator and users. To do this, open the DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax setting, and click Edit Security. Specify the groups you want to include and the computer access permissions for those groups.

Rationale:

Many COM applications include some security-specific code (for example, to call `CoInitializeSecurity`) but use weak settings that often allow unauthenticated access to the process. Administrators cannot override these settings to force stronger security in earlier versions of Windows without modifying the application. An attacker could attempt to exploit weak security in an individual application by attacking it through COM calls. Also, COM infrastructure includes the Remote Procedure Call System Service (RPCSS), a system service that runs during computer startup and always runs after that. This service manages activation of COM objects and the running object table, and provides helper services to DCOM remoting. It exposes RPC interfaces that can be called remotely. Because some COM servers allow unauthenticated remote access, these interfaces can be called by anyone, including unauthenticated users. As a result, RPCSS can be attacked by malicious users who use remote, unauthenticated computers.

Impact:

Windows operating systems implement default COM ACLs when they are installed. Modifying these ACLs from the default may cause some applications or components that communicate by using DCOM to fail. If you implement a COM server and you override the default security settings, confirm that the application-specific call permissions ACL assigns correct permission to appropriate users. If it does not, you need to change your application-specific permission ACL to provide appropriate users with activation rights so that applications and Windows components that use DCOM do not fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\windows  
NT\DCOM\MachineAccessRestriction
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\DCOM: Machine Access Restrictions in Security  
Descriptor Definition Language (SDDL) syntax
```

Default Value:

Not defined

References:

1. CCE-22416-2

ARCHIVE

1.1.3.4 Devices

ARCHIVE

1.1.3.4.1 Configure 'Devices: Allow undock without having to log on' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether a portable computer can be undocked if the user does not log on to the system. Enable this policy setting to eliminate a Logon requirement and allow use of an external hardware eject button to undock the computer. If you disable this policy setting, a user must log on and have been assigned the Remove computer from docking station user right to undock the computer. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

If this policy setting is enabled, anyone with physical access to portable computers in docking stations could remove them and possibly tamper with them.

Impact:

Users who have docked their computers will have to log on to the local console before they can undock their computers. For computers that do not have docking stations, this policy setting will have no impact.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\undockwithoutlogon
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Devices: Allow undock without having to log on
```

Default Value:

Enabled

References:

1. CCE-22727-2

ARCHIVE

1.1.3.4.2 Configure 'Devices: Restrict floppy access to locally logged-on user only' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether removable floppy media are accessible to both local and remote users simultaneously. If you enable this policy setting, only the interactively logged-on user is allowed to access removable floppy media. If this policy setting is enabled and no one is logged on interactively, the floppy media is accessible over the network. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

A remote user could potentially access a mounted floppy that contains sensitive information. This risk is small because floppy disk drives are not automatically shared; administrators must deliberately choose to share the drive. However, administrators may wish to deny network users the ability to view data or run applications from removable media on the server.

Impact:

Users who connect to the server over the network will not be able to use any floppy disk drives that are installed on the server whenever anyone is logged on to the local console of the server. System tools that require access to floppy disk drives will fail. For example, the Volume Shadow Copy service attempts to access all CD-ROM and floppy disk drives present on the computer when it initializes, and if the service cannot access one of these drives it will fail. This condition will cause the Windows Backup tool to fail if volume shadow copies were specified for the backup job. Any non-Microsoft backup products that use volume shadow copies will also fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\AllocateFloppies
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Devices: Restrict floppy access to locally logged-  
on user only
```

Default Value:

Not defined

References:

1. CCE-21829-7

ARCHIVE

1.1.3.4.3 Set 'Devices: Allowed to format and eject removable media' to 'Administrators and Interactive Users' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines who is allowed to format and eject removable media. You can use this policy setting to prevent unauthorized users from removing data on one computer to access it on another computer on which they have local administrator privileges. The recommended state for this setting is: Administrators and Interactive Users.

Rationale:

Users may be able to move data on removable disks to a different computer where they have administrative privileges. The user could then take ownership of any file, grant themselves full control, and view or modify any file. The fact that most removable storage devices will eject media by pressing a mechanical button diminishes the advantage of this policy setting.

Impact:

Only Administrators will be able to format and eject removable media. If users are in the habit of using removable media for file transfers and storage, they will need to be informed of the change in policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\AllocatedDASD
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators and Interactive Users.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Devices: Allowed to format and eject removable  
media
```

Default Value:

Not defined

References:

1. CCE-23193-6

ARCHIVE

1.1.3.4.4 Configure 'Devices: Restrict CD-ROM access to locally logged-on user only' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether a CD-ROM is accessible to both local and remote users simultaneously. If you enable this policy setting, only the interactively logged-on user is allowed to access removable CD-ROM media. When this policy setting is enabled and no one is logged on interactively, the CD-ROM is accessible over the network. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

A remote user could potentially access a mounted CD that contains sensitive information. This risk is small, because CD drives are not automatically made available as shared drives; administrators must deliberately choose to share the drive. However, administrators may wish to deny network users the ability to view data or run applications from removable media on the server.

Impact:

Users who connect to the server over the network will not be able to use any CD drives that are installed on the server whenever anyone is logged on to the local console of the server. System tools that require access to the CD drive will fail. For example, the Volume Shadow Copy service attempts to access all CD and floppy disk drives that are present on the computer when it initializes, and if the service cannot access one of these drives, it will fail. This condition will cause the Windows Backup tool to fail if volume shadow copies were specified for the backup job. Any non-Microsoft backup products that use volume shadow copies will also fail. This policy setting would not be suitable for a computer that serves as a CD jukebox for network users.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\AllocateCDRoms
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Devices: Restrict CD-ROM access to locally logged-on user only

Default Value:

Not defined

References:

1. CCE-22590-4

ARCHIVE

1.1.3.4.5 Configure 'Devices: Prevent users from installing printer drivers' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

It is feasible for an attacker to disguise a Trojan horse program as a printer driver. The program may appear to users as if they must use it to print, but such a program could unleash malicious code on your computer network. To reduce the possibility of such an event, only administrators should be allowed to install printer drivers. However, because laptops are mobile devices, laptop users may occasionally need to install a printer driver from a remote source to continue their work. Therefore, this policy setting should be disabled for laptop users, but always enabled for desktop users. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

It may be appropriate in some organizations to allow users to install printer drivers on their own workstations. However, you should allow only Administrators, not users, to do so on servers, because printer driver installation on a server may unintentionally cause the computer to become less stable. A malicious user could install inappropriate printer drivers in a deliberate attempt to damage the computer, or a user might accidentally install malicious software that masquerades as a printer driver.

Impact:

Only users with Administrative, Power User, or Server Operator privileges will be able to install printers on the servers. If this policy setting is enabled but the driver for a network printer already exists on the local computer, users can still add the network printer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Print\Providers\LanMan  
Print Services\Servers\AddPrinterDrivers
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Devices: Prevent users from installing printer  
drivers
```

Default Value:

Disabled

References:

1. CCE-22756-1

ARCHIVE

1.1.3.5 Domain member

ARCHIVE

1.1.3.5.1 Set 'Domain member: Require strong (Windows 2000 or later) session key' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

When this policy setting is enabled, a secure channel can only be established with domain controllers that are capable of encrypting secure channel data with a strong (128-bit) session key. To enable this policy setting, all domain controllers in the domain must be able to encrypt secure channel data with a strong key, which means all domain controllers must be running Microsoft Windows 2000 or later. The recommended state for this setting is: *Enabled*.

Rationale:

Session keys that are used to establish secure channel communications between domain controllers and member computers are much stronger in Windows 2000 than they were in previous Microsoft operating systems. Whenever possible, you should take advantage of these stronger session keys to help protect secure channel communications from attacks that attempt to hijack network sessions and eavesdropping. (Eavesdropping is a form of hacking in which network data is read or altered in transit. The data can be modified to hide or change the sender, or be redirected.)

Impact:

Computers that have this policy setting enabled will not be able to join Windows NT 4.0 domains, and trusts between Active Directory domains and Windows NT-style domains may not work properly. Also, computers that do not support this policy setting will not be able to join domains in which the domain controllers have this policy setting enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\requirestrongkey
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Domain member: Require strong (Windows 2000 or  
later) session key
```

Default Value:

Disabled

References:

1. CCE-23007-8

ARCHIVE

1.1.3.5.2 Set 'Domain member: Digitally sign secure channel data (when possible)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether a domain member should attempt to negotiate whether all secure channel traffic that it initiates must be digitally signed. Digital signatures protect the traffic from being modified by anyone who captures the data as it traverses the network. The recommended state for this setting is: `Enabled`.

Rationale:

When a computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the domain controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticated—and sensitive information such as passwords are encrypted—but the channel is not integrity-checked, and not all information is encrypted. If a computer is configured to always encrypt or sign secure channel data but the domain controller cannot sign or encrypt any portion of the secure channel data, the computer and domain controller cannot establish a secure channel. If the computer is configured to encrypt or sign secure channel data when possible, a secure channel can be established, but the level of encryption and signing is negotiated.

Impact:

Digital encryption and signing of the “secure channel” is a good idea where it is supported. The secure channel protects domain credentials as they are sent to the domain controller. However, only Windows NT 4.0 with Service Pack 6a (SP6a) and subsequent versions of the Windows operating system support digital encryption and signing of the secure channel. Windows 98 Second Edition clients do not support it unless they have the Dsclient installed. Therefore, you cannot enable the Domain member: Digitally encrypt or sign secure channel data (always) setting on domain controllers that support Windows 98 clients as members of the domain. Potential impacts can include the following:

- The ability to create or delete trust relationships with clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled.
- Logons from clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled.
- The ability to authenticate other domains' users from a domain controller running a version of Windows earlier than Windows NT 4.0 with SP6a in a trusted domain will be disabled.
- You can enable this policy setting after you eliminate all Windows 9x clients from the domain and upgrade all Windows NT 4.0 servers and domain controllers from trusted/trusting domains to Windows NT 4.0 with SP6a. You can enable the other two policy settings, Domain member: Digitally encrypt secure channel data (when possible) and Domain member: Digitally encrypt sign channel data (when possible), on all computers in the domain that support them and clients running versions of Windows earlier than Windows NT 4.0 with SP6a and applications that run on these versions of Windows will not be affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\sign  
securechannel
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Domain member: Digitally sign secure channel data  
(when possible)
```

Default Value:

Enabled

References:

1. CCE-22386-7

ARCHIVE

1.1.3.5.3 Set 'Domain member: Digitally encrypt secure channel data (when possible)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether a domain member should attempt to negotiate encryption for all secure channel traffic that it initiates. If you enable this policy setting, the domain member will request encryption of all secure channel traffic. If you disable this policy setting, the domain member will be prevented from negotiating secure channel encryption. The recommended state for this setting is: *Enabled*.

Rationale:

When a Windows Server 2003, Windows XP, Windows 2000, or Windows NT computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the domain controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticated—and sensitive information such as passwords are encrypted—but the channel is not integrity-checked, and not all information is encrypted. If a computer is configured to always encrypt or sign secure channel data but the domain controller cannot sign or encrypt any portion of the secure channel data, the computer and domain controller cannot establish a secure channel. If the computer is configured to encrypt or sign secure channel data when possible, a secure channel can be established, but the level of encryption and signing is negotiated.

Impact:

Digital encryption and signing of the “secure channel” is a good idea where it is supported. The secure channel protects domain credentials as they are sent to the domain controller. However, only Windows NT 4.0 Service Pack 6a (SP6a) and subsequent versions of the Windows operating system support digital encryption and signing of the secure channel. Windows 98 Second Edition clients do not support it unless they have the Dsclient installed. Therefore, you cannot enable the Domain member: Digitally encrypt or sign secure channel data (always) setting on domain controllers that support Windows 98 clients as members of the domain. Potential impacts can include the following:

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\seal  
securechannel
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Domain member: Digitally encrypt secure channel  
data (when possible)
```

Default Value:

Enabled

References:

1. CCE-22611-8

1.1.3.5.4 Set 'Domain member: Maximum machine account password age' to '30 or fewer day(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the maximum allowable age for a computer account password. By default, domain members automatically change their domain passwords every 30 days. If you increase this interval significantly or set it to 0 so that the computers no longer change their passwords, an attacker would have more time to undertake a brute force attack against one of the computer accounts. The recommended state for this setting is: 30 or fewer day(s).

Rationale:

In Active Directory–based domains, each computer has an account and password just like every user. By default, the domain members automatically change their domain password every 30 days. If you increase this interval significantly, or set it to 0 so that the computers no longer change their passwords, an attacker will have more time to undertake a brute force attack to guess the password of one or more computer accounts.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to 30 or fewer day(s).

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Maximum machine account password age

Default Value:

30 days

References:

1. CCE-21621-8

ARCHIVE

1.1.3.5.5 Set 'Domain member: Digitally encrypt or sign secure channel data (always)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether all secure channel traffic that is initiated by the domain member must be signed or encrypted. If a system is set to always encrypt or sign secure channel data, it cannot establish a secure channel with a domain controller that is not capable of signing or encrypting all secure channel traffic, because all secure channel data must be signed and encrypted. The recommended state for this setting is: Enabled.

Rationale:

When a computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the domain controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticated—and sensitive information such as passwords are encrypted—but the channel is not integrity-checked, and not all information is encrypted. If a computer is configured to always encrypt or sign secure channel data but the domain controller cannot sign or encrypt any portion of the secure channel data, the computer and domain controller cannot establish a secure channel. If the computer is configured to encrypt or sign secure channel data when possible, a secure channel can be established, but the level of encryption and signing is negotiated.

Impact:

Digital encryption and signing of the “secure channel” is a good idea where it is supported. The secure channel protects domain credentials as they are sent to the domain controller. However, only Windows NT 4.0 with Service Pack 6a (SP6a) and subsequent versions of the Windows operating system support digital encryption and signing of the secure channel. Windows 98 Second Edition clients do not support it unless they have the Dsclient installed. Therefore, you cannot enable the Domain member: Digitally encrypt or sign secure channel data (always) setting on domain controllers that support Windows 98 clients as members of the domain. Potential impacts can include the following:

- The ability to create or delete trust relationships with clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled.
- Logons from clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled.
- The ability to authenticate other domains' users from a domain controller running a version of Windows earlier than Windows NT 4.0 with SP6a in a trusted domain will be disabled.

You can enable this policy setting after you eliminate all Windows 9x clients from the domain and upgrade all Windows NT 4.0 servers and domain controllers from trusted/trusting domains to Windows NT 4.0 with SP6a. You can enable the other two policy settings, Domain member: Digitally encrypt secure channel data (when possible) and Domain member: Digitally encrypt sign channel data (when possible), on all computers in the domain that support them and clients running versions of Windows earlier than Windows NT 4.0 with SP6a and applications that run on these versions of Windows will not be affected.

Digital encryption and signing of the “secure channel” is a good idea where it is supported. The secure channel protects domain credentials as they are sent to the domain controller. However, only Windows NT 4.0 with Service Pack 6a (SP6a) and subsequent versions of the Windows operating system support digital encryption and signing of the secure channel. Windows 98 Second Edition clients do not support it unless they have the Dsclient installed. Therefore, you cannot enable the Domain member: Digitally encrypt or sign secure channel data (always) setting on domain controllers that support Windows 98 clients as members of the domain. Potential impacts can include the following:

- The ability to create or delete trust relationships with clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled.
- Logons from clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled.
- The ability to authenticate other domains' users from a domain controller running a version of Windows earlier than Windows NT 4.0 with SP6a in a trusted domain will be disabled.

- You can enable this policy setting after you eliminate all Windows 9x clients from the domain and upgrade all Windows NT 4.0 servers and domain controllers from trusted/trusting domains to Windows NT 4.0 with SP6a. You can enable the other two policy settings, Domain member: Digitally encrypt secure channel data (when possible) and Domain member: Digitally encrypt sign channel data (when possible), on all computers in the domain that support them and clients running versions of Windows earlier than Windows NT 4.0 with SP6a and applications that run on these versions of Windows will not be affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\requireseal
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Digitally encrypt or sign secure channel data (always)
```

Default Value:

Enabled

References:

1. CCE-22707-4

1.1.3.5.6 Set 'Domain member: Disable machine account password changes' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether a domain member can periodically change its computer account password. If you enable this policy setting, the domain member will be prevented from changing its computer account password. If you disable this policy setting, the domain member can change its computer account password as specified by the Domain Member: Maximum machine account password age setting, which by default is every 30 days. Computers that cannot automatically change their account passwords are potentially vulnerable, because an attacker might be able to determine the password for the system's domain account. The recommended state for this setting is: `Disabled`.

Rationale:

The default configuration for Windows Server 2003–based computers that belong to a domain is that they are automatically required to change the passwords for their accounts every 30 days. If you disable this policy setting, computers that run Windows Server 2003 will retain the same passwords as their computer accounts. Computers that are no longer able to automatically change their account password are at risk from an attacker who could determine the password for the computer's domain account.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\disablepasswordchange
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Disable machine account password changes

Default Value:

Disabled

References:

1. CCE-22359-4

ARCHIVE

1.1.3.6 Interactive logon

ARCHIVE

1.1.3.6.1 Set 'Interactive logon: Machine account lockout threshold' to 10 or fewer invalid logon attempts (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The machine lockout policy is enforced only on those machines that have BitLocker enabled for protecting OS volumes. Please ensure that appropriate recovery password backup policies are enabled. This security setting determines the number of failed logon attempts that causes the machine to be locked out. A locked out machine can only be recovered by providing recovery key at console. You can set the value between 1 and 999 failed logon attempts. If you set the value to 0, the machine will never be locked out. Values from 1 to 3 will be interpreted as 4. Failed password attempts against workstations or member servers that have been locked using either CTRL+ALT+DELETE or password protected screen savers counts as failed logon attempts. The machine lockout policy is enforced only on those machines that have BitLocker enabled for protecting OS volumes. Please ensure that the appropriate recovery password backup policies are enabled. The recommended state for this setting is: 10 or fewer invalid logon attempts.

Rationale:

This policy setting determines the number of failed logon attempts before a lock occurs. Authorized users can lock themselves out of the computer by mistyping their password or by remembering it incorrectly, or by changing their password on one computer while logged on to another computer. The computer with the incorrect password will continuously try to authenticate the user, and because the password it uses to authenticate is incorrect, a lock occurs. To avoid accidental lockout of authorized users, set the account lockout threshold to a high number. The default value for this policy setting is 0 invalid logon attempts, which disables the machine lockout feature. There are two options to consider for this policy setting.

- Configure the value for Machine lockout threshold to 0 to ensure that accounts will not be locked out. This setting value will reduce help desk calls, because users will not be able to lock themselves out of their accounts accidentally. However, this setting value will not prevent a brute force attack. The following defenses should also be considered:
- A password policy that forces all users to have complex passwords made up of 8 or more characters.
- A robust auditing mechanism, which will alert administrators when a series of account lockouts occurs in the environment. For example, the auditing solution should monitor for security event 539, which is a logon failure. This event identifies that there was a lock on the account at the time of the logon attempt.
- The second option is:
- Configure the value for Machine lockout threshold to a value that provides users with the ability to mistype their password several times, but locks out the account if a brute force password attack occurs. This configuration will prevent accidental account lockouts and reduce help desk calls.

Impact:

Because vulnerabilities can exist when this value is configured as well as when it is not configured, two distinct countermeasures are defined. Any organization should weigh the choice between the two based on their identified threats and the risks that they want to mitigate. The two countermeasure options are:

- Configure the Machine Lockout Threshold setting to 0. This configuration ensures that accounts will not be locked out, and also helps reduce help desk calls because users cannot accidentally lock themselves out of their accounts. Because it will not prevent a brute force attack, this configuration should only be chosen if both of the following criteria are explicitly met:
- The password policy requires all users to have complex passwords of 8 or more characters.
- A robust audit mechanism is in place to alert administrators when a series of failed logons occur in the environment.
- Configure the Machine Lockout Threshold setting to a sufficiently high value to provide users with the ability to accidentally mistype their password several times before the machine is locked, but ensure that a brute force password attack will still lock the account. A good recommendation for such a configuration is 50 invalid logon attempts, which will prevent accidental account lockouts and reduce the number of help desk calls. This option is recommended if your organization does not have complex password requirements and an audit policy that alerts administrators to a series of failed logon attempts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\MaxDevicePasswordFailedAttempts
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 10 or fewer invalid logon attempts.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Machine account lockout threshold
```

Default Value:

Not defined

References:

1. CCE-22731-4

1.1.3.6.2 Set 'Interactive logon: Smart card removal behavior' to 'Lock Workstation' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines what happens when the smart card for a logged-on user is removed from the smart card reader. The recommended state for this setting is: `Lock Workstation`.

Rationale:

Users sometimes forget to lock their workstations when they are away from them, allowing the possibility for malicious users to access their computers. If smart cards are used for authentication, the computer should automatically lock itself when the card is removed to ensure that only the user with the smart card is accessing resources using those credentials.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\scremoveoption
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Lock Workstation`.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Interactive logon: Smart card removal behavior
```

Default Value:

No Action

References:

1. CCE-22168-9

1.1.3.6.3 Configure 'Interactive logon: Require smart card' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines if a user is required log on to a computer with a smart card. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

It can be difficult to make users choose strong passwords, and even strong passwords are vulnerable to brute-force attacks if an attacker has sufficient time and computing resources.

Impact:

All users of a computer with this setting enabled will have to use smart cards to log onto the local computer, which means that the organization will need a reliable public key infrastructure (PKI) as well as smart cards and smart card readers for these users. These requirements are significant challenges, because expertise and resources are required to plan for and deploy these technologies. However, Windows Server 2003 includes Certificate Services, a highly advanced service for implementing and managing certificates. When Certificate Services is combined with Windows XP or Windows Vista, features such as automatic user and computer enrollment and renewal become available. For more information about deploying Smart Cards with Windows Vista see the paper "Windows Vista Smart Card Infrastructure" available for download at the Microsoft Web site (<http://www.microsoft.com/downloads/details.aspx?FamilyID=ac201438-3317-44d3-9638-07625fe397b9&displaylang=en>).

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\scforceoption
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Require smart card

Default Value:

Disabled

References:

1. CCE-22663-9

ARCHIVE

1.1.3.6.4 Set 'startup (minutes)' to '10 or more minute(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the amount of time before previously scheduled Automatic Update installations will proceed after system startup. If you configure this policy setting to Enabled, a previously scheduled installation will begin after a specified number of minutes when you next start the computer. If you configure this policy setting to Disabled or Not configured, previously scheduled installations will occur during the next regularly scheduled installation time. Note: This policy setting only works when Automatic Updates is configured to perform scheduled update installations. If the Configure Automatic Updates setting is Disabled, the Reschedule Automatic Updates scheduled installations setting has no effect. You can enable the latter two settings to ensure that previously missed installations will be scheduled to install each time the computer restarts. The recommended state for this setting is: '10 or more minute(s)'.

Rationale:

If Automatic Updates is not forced to wait a few minutes after a restart, computers in your environment might not have enough time to completely start all of their applications and services. If you specify enough time after a restart, new update installations should not conflict with the computer's startup procedures.

Impact:

Automatic Updates will not start until 10 minutes after the computer restarts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\RescheduleWaitTime
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to '10 or more minute(s)'.

```
Computer Configuration\Administrative Templates\Windows Components\Windows  
Update\Reschedule Automatic Updates scheduled installations: startup  
(minutes)
```

Default Value:

Not defined

ARCHIVE

1.1.3.6.5 Set 'Interactive logon: Do not display last user name' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the account name of the last user to log on to the client computers in your organization will be displayed in each computer's respective Windows logon screen. Enable this policy setting to prevent intruders from collecting account names visually from the screens of desktop or laptop computers in your organization. The recommended state for this setting is: *Enabled*.

Rationale:

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the server through Terminal Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

Impact:

Users will not see their user name or domain name when unlocking their computer, they will have to enter that information.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
DontDisplayLastUserName
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Do not display last user name
```

Default Value:

Disabled

References:

1. CCE-22615-9

ARCHIVE

1.1.3.6.6 Set 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' to '4 or fewer logon(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether a user can log on to a Windows domain using cached account information. Logon information for domain accounts can be cached locally to allow users to log on even if a domain controller cannot be contacted. This policy setting determines the number of unique users for whom logon information is cached locally. If this value is set to 0, the logon cache feature is disabled. An attacker who is able to access the file system of the server could locate this cached information and use a brute force attack to determine user passwords. The recommended state for this setting is: `4 or fewer logon(s)`.

Rationale:

The number that is assigned to this policy setting indicates the number of users whose logon information the servers will cache locally. If the number is set to 10, then the server caches logon information for 10 users. When an eleventh user logs on to the computer, the server overwrites the oldest cached logon session. Users who access the server console will have their logon credentials cached on that server. An attacker who is able to access the file system of the server could locate this cached information and use a brute force attack to attempt to determine user passwords. To mitigate this type of attack, Windows encrypts the information and obscures its physical location.

Impact:

Users will be unable to log on to any computers if there is no domain controller available to authenticate them. Organizations may want to configure this value to 2 for end-user computers, especially for mobile users. A configuration value of 2 means that the user's logon information will still be in the cache, even if a member of the IT department has recently logged on to their computer to perform system maintenance. This method allows users to log on to their computers when they are not connected to the organization's network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\cachedlogonscount
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 4 or fewer logon(s).

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Interactive logon: Number of previous logons to  
cache (in case domain controller is not available)
```

Default Value:

10 logons

References:

1. CCE-22102-8

1.1.3.6.7 Set 'Interactive logon: Require Domain Controller authentication to unlock workstation' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Logon information is required to unlock a locked computer. For domain accounts, the Interactive logon: Require Domain Controller authentication to unlock workstation setting determines whether it is necessary to contact a domain controller to unlock a computer. If you enable this setting, a domain controller must authenticate the domain account that is being used to unlock the computer. If you disable this setting, logon information confirmation with a domain controller is not required for a user to unlock the computer. However, if you configure the Interactive logon: Number of previous logons to cache (in case domain controller is not available) setting to a value that is greater than zero, then the user's cached credentials will be used to unlock the computer. Note: This setting applies to Windows 2000 computers, but it is not available through the Security Configuration Manager tools on these computers. The recommended state for this setting is: `Disabled`.

Rationale:

By default, the computer caches in memory the credentials of any users who are authenticated locally. The computer uses these cached credentials to authenticate anyone who attempts to unlock the console. When cached credentials are used, any changes that have recently been made to the account—such as user rights assignments, account lockout, or the account being disabled—are not considered or applied after the account is authenticated. User privileges are not updated, and (more importantly) disabled accounts are still able to unlock the console of the computer.

Impact:

When the console on a computer is locked, either by a user or automatically by a screen saver time-out, the console can only be unlocked if the user is able to re-authenticate to the domain controller. If no domain controller is available, then users cannot unlock their workstations. If you configure the Interactive logon: Number of previous logons to cache (in case domain controller is not available) setting to 0, users whose domain controllers are unavailable (such as mobile or remote users) will not be able to log on.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\ForceUnlockLogon
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Interactive logon: Require Domain Controller  
authentication to unlock workstation
```

Default Value:

Disabled

References:

1. CCE-23063-1

1.1.3.6.8 Set 'Interactive logon: Prompt user to change password before expiration' to '14 or more day(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines how far in advance users are warned that their password will expire. It is recommended that you configure this policy setting to 14 days to sufficiently warn users when their passwords will expire. The recommended state for this setting is: 14 or more day(s).

Rationale:

Users will need to be warned that their passwords are going to expire, or they may inadvertently be locked out of the computer when their passwords expire. This condition could lead to confusion for users who access the network locally, or make it impossible for users to access your organization's network through dial-up or virtual private network (VPN) connections.

Impact:

Users will see a dialog box prompt to change their password each time that they log on to the domain when their password is configured to expire in 14 or fewer days.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\passwordexpirywarning
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 14 or more day(s).

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Interactive logon: Prompt user to change password  
before expiration
```

Default Value:

14 days

References:

1. CCE-21892-5

ARCHIVE

1.1.3.6.9 Set 'Interactive logon: Do not require CTRL+ALT+DEL' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether users must press CTRL+ALT+DEL before they log on. If you enable this policy setting, users can log on without this key combination. If you disable this policy setting, users must press CTRL+ALT+DEL before they log on to Windows unless they use a smart card for Windows logon. A smart card is a tamper-proof device that stores security information. The recommended state for this setting is: Disabled.

Rationale:

Microsoft developed this feature to make it easier for users with certain types of physical impairments to log on to computers that run Windows. If users are not required to press CTRL+ALT+DEL, they are susceptible to attacks that attempt to intercept their passwords. If CTRL+ALT+DEL is required before logon, user passwords are communicated by means of a trusted path. An attacker could install a Trojan horse program that looks like the standard Windows logon dialog box and capture the user's password. The attacker would then be able to log on to the compromised account with whatever level of privilege that user has.

Impact:

Unless they use a smart card to log on, users will have to simultaneously press three keys before the logon dialog box will display.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\DisableCAD
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Do not require CTRL+ALT+DEL
--

Default Value:

Not defined

References:

1. CCE-23522-6

ARCHIVE

1.1.3.6.10 Configure 'Interactive logon: Message text for users attempting to log on' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies a text message that displays to users when they log on. Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Rationale:

Displaying a warning message before logon may help prevent an attack by warning the attacker about the consequences of their misconduct before it happens. It may also help to reinforce corporate policy by notifying employees of the appropriate policy during the logon process. This text is often used for legal reasons—for example, to warn users about the ramifications of misusing company information or to warn them that their actions may be audited.

Note: Any warning that you display should first be approved by your organization's legal and human resources representatives.

Impact:

Users will see a message in a dialog box before they can log on to the server console. Note Windows Vista and Windows XP Professional support logon banners that can exceed 512 characters in length and that can also contain carriage-return line-feed sequences. However, Windows 2000-based clients cannot interpret and display these messages. You must use a Windows 2000-based computer to create a logon message policy that applies to Windows 2000-based computers. If you inadvertently create a logon message policy on a Windows Vista-based or Windows XP Professional-based computer and you discover that it does not display properly on Windows 2000-based computers, do the following: Change the setting to Not Defined, and then change the setting to the desired value by using a Windows 2000-based computer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\LegalNoticeText
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Message text for users attempting to log on
```

Default Value:

Not defined

References:

1. CCE-23427-8

1.1.3.6.11 Set 'Interactive logon: Machine inactivity limit' to '900 or fewer seconds' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Windows notices inactivity of a logon session, and if the amount of inactive time exceeds the inactivity limit, then the screen saver will run, locking the session. The recommended state for this setting is: 900 or fewer seconds.

Rationale:

If a user forgets to lock their computer when they walk away its possible that a passerby will hijack it.

Impact:

The screen saver will automatically activate when the computer has been unattended for the amount of time specified. The impact should be minimal since the screen saver is enabled by default.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\InactivityTimeoutSecs
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 900 or fewer seconds.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Machine inactivity limit
```

Default Value:

Not defined

References:

1. CCE-21920-4

1.1.3.6.12 Configure 'Interactive logon: Message title for users attempting to log on' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows text to be specified in the title bar of the window that users see when they log on to the system. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Displaying a warning message before logon may help prevent an attack by warning the attacker about the consequences of their misconduct before it happens. It may also help to reinforce corporate policy by notifying employees of the appropriate policy during the logon process.

Impact:

Users will see a message in a dialog box before they can log on to the server console. Note Windows Vista and Windows XP Professional support logon banners that can exceed 512 characters in length and that can also contain carriage-return line-feed sequences. However, Windows 2000-based clients cannot interpret and display these messages. You must use a Windows 2000-based computer to create a logon message policy that applies to Windows 2000-based computers. If you inadvertently create a logon message policy on a Windows Vista-based or Windows XP Professional-based computer and you discover that it does not display properly on Windows 2000-based computers, do the following: Change the setting to Not Defined, and then change the setting to the desired value by using a Windows 2000-based computer. Important If you do not reconfigure this setting to Not Defined before reconfiguring the setting using a Windows 2000-based computer, the changes will not take effect properly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\LegalNoticeCaption
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Message title for users attempting to log on

Default Value:

Not defined

References:

1. CCE-21856-0

ARCHIVE

1.1.3.6.13 Configure 'Interactive logon: Display user information when the session is locked' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the account name of the last user to log on to the client computers in your organization can display in each computer's respective Windows logon screen. If you enable this policy setting, intruders cannot collect account names visually from the screens of desktop or laptop computers in your organization. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the server through Terminal Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

Impact:

Users will always have to type their user names when they log on to the servers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
DontDisplayLockedUserId
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Display user information when
the session is locked
```

Default Value:

Not defined

References:

1. CCE-22391-7

ARCHIVE

1.1.3.7 Microsoft network client

ARCHIVE

1.1.3.7.1 Set 'Microsoft network client: Send unencrypted password to third-party SMB servers' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Disable this policy setting to prevent the SMB redirector from sending plaintext passwords during authentication to third-party SMB servers that do not support password encryption. It is recommended that you disable this policy setting unless there is a strong business case to enable it. If this policy setting is enabled, unencrypted passwords will be allowed across the network. The recommended state for this setting is: `Disabled`.

Rationale:

If you enable this policy setting, the server can transmit passwords in plaintext across the network to other computers that offer SMB services. These other computers may not use any of the SMB security mechanisms that are included with Windows Server 2003.

Impact:

Some very old applications and operating systems such as MS-DOS, Windows for Workgroups 3.11, and Windows 95a may not be able to communicate with the servers in your organization by means of the SMB protocol.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parameters\EnablePlainTextPassword
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Disabled`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network client: Send unencrypted password to third-party SMB servers
```

Default Value:

`Disabled`

References:

1. CCE-22405-5

ARCHIVE

1.1.3.7.2 Set 'Microsoft network client: Digitally sign communications (always)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether packet signing is required by the SMB client component. If you enable this policy setting, the Microsoft network client computer cannot communicate with a Microsoft network server unless that server agrees to sign SMB packets. In mixed environments with legacy client computers, set this option to Disabled because these computers will not be able to authenticate or gain access to domain controllers. However, you can use this policy setting in Windows 2000 or later environments. Note When Windows Vista–based computers have this policy setting enabled and they connect to file or print shares on remote servers, it is important that the setting is synchronized with its companion setting, Microsoft network server: Digitally sign communications (always), on those servers. For more information about these settings, see the "Microsoft network client and server: Digitally sign communications (four related settings)" section in Chapter 5 of the Threats and Countermeasures guide. The recommended state for this setting is: `Enabled`.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: <http://support.microsoft.com/default.aspx/kb/950876/>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parameters\RequireSecuritySignature
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network client: Digitally sign communications (always)
```

Default Value:

Disabled

References:

1. CCE-22428-7

1.1.3.7.3 Set 'Microsoft network client: Digitally sign communications (if server agrees)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the SMB client will attempt to negotiate SMB packet signing. The implementation of digital signing in Windows-based networks helps to prevent sessions from being hijacked. If you enable this policy setting, the Microsoft network client will use signing only if the server with which it communicates accepts digitally signed communication. The recommended state for this setting is: *Enabled*.

Note: Enabling this policy setting on SMB clients on your network makes them fully effective for packet signing with all clients and servers in your environment.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: <http://support.microsoft.com/default.aspx/kb/950876/>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parameters\EnableSecuritySignature
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network client: Digitally sign communications (if server agrees)
```

Default Value:

Enabled

References:

1. CCE-21863-6

1.1.3.8 Microsoft network server

ARCHIVE

1.1.3.8.1 Set 'Microsoft network server: Disconnect clients when logon hours expire' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether to disconnect users who are connected to the local computer outside their user account's valid logon hours. It affects the SMB component. If you enable this policy setting, client sessions with the SMB service will be forcibly disconnected when the client's logon hours expire. If you disable this policy setting, established client sessions will be maintained after the client's logon hours expire. If you enable this policy setting you should also enable Network security: Force logoff when logon hours expire. If your organization configures logon hours for users, it makes sense to enable this policy setting. The recommended state for this setting is:

Enabled.

Rationale:

If your organization configures logon hours for users, then it makes sense to enable this policy setting. Otherwise, users who should not have access to network resources outside of their logon hours may actually be able to continue to use those resources with sessions that were established during allowed hours.

Impact:

If logon hours are not used in your organization, this policy setting will have no impact. If logon hours are used, existing user sessions will be forcibly terminated when their logon hours expire.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\enableforcedlogoff
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Disconnect clients when logon hours expire

Default Value:

Enabled

References:

1. CCE-21516-0

ARCHIVE

1.1.3.8.2 Set 'Microsoft network server: Amount of idle time required before suspending session' to '15 or fewer minute(s)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to specify the amount of continuous idle time that must pass in an SMB session before the session is suspended because of inactivity. Administrators can use this policy setting to control when a computer suspends an inactive SMB session. If client activity resumes, the session is automatically reestablished. A value of 0 will disconnect an idle session as quickly as possible. The maximum value is 99999, which is 208 days; in effect, this value disables the setting. The recommended state for this setting is: 15 or fewer minute(s).

Rationale:

Each SMB session consumes server resources, and numerous null sessions will slow the server or possibly cause it to fail. An attacker could repeatedly establish SMB sessions until the server's SMB services become slow or unresponsive.

Impact:

There will be little impact because SMB sessions will be re-established automatically if the client resumes activity.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\autodisconnect
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 15 or fewer minute(s).

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Amount of idle time required before suspending session

Default Value:

15 minutes

References:

1. CCE-21523-6

ARCHIVE

1.1.3.8.3 Set 'Microsoft network server: Digitally sign communications (if client agrees)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines if the server side SMB service is able to sign SMB packets if it is requested to do so by a client that attempts to establish a connection. If no signing request comes from the client, a connection will be allowed without a signature if the Microsoft network server: Digitally sign communications (always) setting is not enabled. Note Enable this policy setting on SMB clients on your network to make them fully effective for packet signing with all clients and servers in your environment. The recommended state for this setting is: *Enabled*.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: <http://support.microsoft.com/default.aspx/kb/950876/>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\enablesecuritysignature
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Digitally sign communications (if client agrees)
```

Default Value:

Disabled

References:

1. CCE-22538-3

1.1.3.8.4 Set 'Microsoft network server: Server SPN target name validation level' to 'Accept if provided by client' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the level of validation a computer with shared folders or printers (the server) performs on the service principal name (SPN) that is provided by the client computer when it establishes a session using the server message block (SMB) protocol. The server message block (SMB) protocol provides the basis for file and print sharing and other networking operations, such as remote Windows administration. The SMB protocol supports validating the SMB server service principal name (SPN) within the authentication blob provided by a SMB client to prevent a class of attacks against SMB servers referred to as SMB relay attacks. This setting will affect both SMB1 and SMB2. This security setting determines the level of validation a SMB server performs on the service principal name (SPN) provided by the SMB client when trying to establish a session to an SMB server. The recommended state for this setting is: Accept if provided by client.

Rationale:

The identity of a computer can be spoofed to gain unauthorized access to network resources.

Impact:

All Windows operating systems support both a client-side SMB component and a server-side SMB component. This setting affects the server SMB behavior, and its implementation should be carefully evaluated and tested to prevent disruptions to file and print serving capabilities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\SMBServerNameHardeningLevel
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Accept` if provided by client.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Server SPN target name validation level

Default Value:

Not defined

References:

1. CCE-21959-2

ARCHIVE

1.1.3.8.5 Set 'Microsoft network server: Digitally sign communications (always)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines if the server side SMB service is required to perform SMB packet signing. Enable this policy setting in a mixed environment to prevent downstream clients from using the workstation as a network server. The recommended state for this setting is: `Enabled`.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: <http://support.microsoft.com/default.aspx/kb/950876/>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\
requiresecuritysignature
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network server: Digitally sign
communications (always)
```

Default Value:

Disabled

References:

1. CCE-21791-9

1.1.3.9 MSS

ARCHIVE

1.1.3.9.1 Configure 'MSS: (AutoShareWks) Enable Administrative Shares (recommended except for highly secure environments)' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This entry appears as `MSS: (AutoShareWks) Enable Administrative Shares (recommended except for highly secure environments)` in the SCE. By default, when Windows networking is active on a server, Windows will create hidden administrative shares. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Because these built-in administrative shares are well-known and present on most Windows computers, malicious users often target them for brute-force attacks to guess passwords as well as other types of attacks.

Impact:

If you delete these shares you could cause problems for administrators and programs or services that rely on these shares. For example, both Microsoft Systems Management Server (SMS) and Microsoft Operations Manager require administrative shares for correct installation and operation. Also, many third-party network backup applications require administrative shares.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanServer\Parameters\AutoShareWks
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (AutoShareWks) Enable Administrative Shares (recommended except for highly secure environments)

Default Value:

Not defined

References:

1. CCE-22160-6

ARCHIVE

1.1.3.9.2 Set 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `SafeDllSearchMode` was added to the template file in the `HKEY\LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager\` registry key. The entry appears as `MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)` in the SCE. The DLL search order can be configured to search for DLLs that are requested by running processes in one of two ways:

- Search folders specified in the system path first, and then search the current working folder.
- Search current working folder first, and then search the folders specified in the system path.

When enabled, the registry value is set to 1. With a setting of 1, the system first searches the folders that are specified in the system path and then searches the current working folder. When disabled the registry value is set to 0 and the system first searches the current working folder and then searches the folders that are specified in the system path. The recommended state for this setting is: `Enabled`.

Rationale:

If a user unknowingly executes hostile code that was packaged with additional files that include modified versions of system DLLs, the hostile code could load its own versions of those DLLs and potentially increase the type and degree of damage the code can render.

Impact:

Applications will be forced to search for DLLs in the system path first. For applications that require unique versions of these DLLs that are included with the application, this entry could cause performance or stability problems.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session  
Manager\SafeDllSearchMode
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\MSS: (SafeDllSearchMode) Enable Safe DLL search  
mode (recommended)
```

Default Value:

Not defined

References:

1. CCE-22060-8

1.1.3.9.3 Configure 'MSS: (NtfsDisable8dot3NameCreation) Enable the computer to stop generating 8.3 style filenames' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Windows Server operating systems support 8.3 file name formats for backward compatibility with 16-bit applications. The 8.3 file name convention is a naming format that allows file names up to eight characters long. The registry value entry `NtfsDisable8dot3NameCreation` was added to the template file in the `HKEY\_LOCAL\_MACHINE\\System\\CurrentControlSet\\Control\\FileSystem\\` registry key. The entry appears as `MSS: (NtfsDisable8dot3NameCreation) Enable the computer to stop generating 8.3 style filenames` in the SCE. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

There's no known vulnerability associated with this feature at the time of this writing, however directory enumeration performance is improved if you disable short name generation on an NTFS file system (NTFS) partition.

Impact:

The 16-bit applications in your organization will not be able to access files that are not named with the 8.3 format. Some 32-bit applications also rely on the presence of short names, because short names tend not to contain embedded spaces and therefore do not require quotation marks when used in command lines. The installation routines for some programs may fail; those that are designed to run on multiple CPU architectures are likely to be 16-bit applications. The installation of Exchange 2000 SP2 will fail if this entry is enabled. The installation of service packs for SQL 2000 will fail if this entry is enabled and the path for the system variable `%temp%` includes a space; a simple workaround for this problem is to redefine the variable to a path without spaces (for example, `C:\temp`). Note: If you apply this entry to a server that already has files with auto-generated 8.3 file names, it does not remove them. To remove existing 8.3 file names, you will need to copy those files off the server, delete the files from the original location, and then copy the files back to their original locations.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\FileSystem\NtfsDisable8dot3NameCreation
```

Remediation:

Configure this setting in a manner that is consistent with the security and operational requirements of your or

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (NtfsDisable8dot3NameCreation) Enable the computer to stop generating 8.3 style filenames
```

Default Value:

Disabled

References:

1. CCE-21769-5

1.1.3.9.4 Set 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `AutoAdminLogon` was added to the template file in the `HKEY\LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\` registry key. The entry appears as `MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)` in the Security Configuration Editor. This setting is separate from the Welcome screen feature in Windows XP and Windows Vista; if that feature is disabled, this setting is not disabled. If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks to which the computer is connected. Also, if you enable automatic logon, the password is stored in the registry in plaintext, and the specific registry key that stores this value is remotely readable by the Authenticated Users group. For additional information, see the Knowledge Base article 315231, "How to turn on automatic logon in Windows XP." The recommended state for this setting is: Disabled.

Rationale:

If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks that the computer is connected to. Also, if you enable automatic logon, the password is stored in the registry in plaintext. The specific registry key that stores this setting is remotely readable by the Authenticated Users group. As a result, this entry is appropriate only if the computer is physically secured and if you ensure that untrusted users cannot remotely see the registry.

Impact:

None. By default this entry is not enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\AutoAdminLogon
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\MSS: (AutoAdminLogon) Enable Automatic Logon (not  
recommended)
```

Default Value:

Not defined

References:

1. CCE-22349-5

1.1.3.9.5 Set 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' to '0.9 or less' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `WarningLevel` was added to the template file in the `HKEY\LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Eventlog\Security` registry key. The entry appears as `MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning` in the SCE. This setting can generate a security audit in the Security event log when the log reaches a user-defined threshold. The recommended state for this setting is: 0.9 or less.

Note: If log settings are configured to Overwrite events as needed or Overwrite events older than x days, this event will not be generated.

Rationale:

If the Security log reaches 90 percent of its capacity and the computer has not been configured to overwrite events as needed, more recent events will not be written to the log. If the log reaches its capacity and the computer has been configured to shut down when it can no longer record events to the Security log, the computer will shut down and will no longer be available to provide network services.

Impact:

This setting will generate an audit event when the Security log reaches the 90 percent-full threshold unless the log is configured to overwrite events as needed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Eventlog\Security\WarningLevel
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 0.9 or less.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning

Default Value:

Not defined

References:

1. CCE-23100-1

1.1.3.9.6 Set 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `DisableIPSourceRouting` was added to the template file in the `HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\ registry key`. The entry appears as `MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)` in the SCE. IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should take through the network. It is recommended to configure this setting to Not Defined for enterprise environments and to Highest Protection for high security environments to completely disable source routing. The recommended state for this setting is: Highest protection, source routing is completely disabled.

Rationale:

An attacker could use source routed packets to obscure their identity and location. Source routing allows a computer that sends a packet to specify the route that the packet takes.

Impact:

If you configure this value to 2, all incoming source routed packets will be dropped.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\DisableIPSourceRouting
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Highest protection, source routing is completely disabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)

Default Value:

Not defined

References:

1. CCE-23103-5

ARCHIVE

1.1.3.9.7 Set 'MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)' to 'Not Defined' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This entry appears as `MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)` in the SCE. This entry, when enabled, permits a server to automatically reboot after a fatal crash. It is enabled by default, which is undesirable on highly secure servers. You can add this registry value to the template file in the `HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\CrashControl` subkey. The recommended state for this setting is: `Not Defined`.

Rationale:

There is some concern that a computer could get stuck in an endless loop of failures and reboots. However, the alternative to this entry may not be much more appealing—the computer will simply stop running.

Impact:

The computer will no longer reboot automatically after a failure.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\CrashControl\AutoReboot
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Defined`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)
```

Default Value:

Not defined

References:

1. CCE-22295-0

ARCHIVE

1.1.3.9.8 Configure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `TcpMaxDataRetransmissions` was added to the template file in the `HKEY\LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\` registry key. The entry appears as `MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)` in the SCE. This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection. Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Rationale:

A malicious user could exhaust a target computer's resources if it never sent any acknowledgment messages for data that was transmitted by the target computer.

Impact:

TCP starts a retransmission timer when each outbound segment is passed to the IP. If no acknowledgment is received for the data in a given segment before the timer expires, then the segment is retransmitted up to three times.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

<code>HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\TcpMaxDataRetransmissions</code>
--

Remediation:

Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)

Default Value:

5

References:

1. CCE-23327-0

1.1.3.9.9 Configure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `EnableICMPRedirect` was added to the template file in the `HKEY\LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\` registry key. The entry appears as `MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes` in the SCE. Internet Control Message Protocol (ICMP) redirects cause the stack to plumb host routes. These routes override the Open Shortest Path First (OSPF)–generated routes. It is recommended to configure this setting to Not Defined for enterprise environments and to Disabled for high security environments. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

This behavior is expected. The problem is that the 10 minute time-out period for the ICMP redirect-plumbed routes temporarily creates a network situation in which traffic will no longer be routed properly for the affected host.

Impact:

When Routing and Remote Access Service (RRAS) is configured as an autonomous system boundary router (ASBR), it does not correctly import connected interface subnet routes. Instead, this router injects host routes into the OSPF routes. However, the OSPF router can not be used as an ASBR router, and when connected interface subnet routes are imported into OSPF the result is confusing routing tables with strange routing paths.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\EnableICMPRedirect
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\MSS: (EnableICMPRedirect) Allow ICMP redirects to  
override OSPF generated routes
```

Default Value:

Enabled

References:

1. CCE-23058-1

ARCHIVE

1.1.3.9.10 Configure 'MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic.' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `NoDefaultExempt` was added to the template file in the `HKEY\LOCAL_MACHINE\System\CurrentControlSet\Services\IPSEC\` registry key. The entry appears as `MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic` in the SCE.

The default exemptions to IPsec policy filters are documented in the online help for the specific operating system. These filters make it possible for Internet Key Exchange (IKE) and the Kerberos authentication protocol to function. The filters also make it possible for the network Quality of Service (QoS) to be signaled (RSVP) when the data traffic is secured by IPsec, and for traffic that IPsec might not secure such as multicast and broadcast traffic.

IPsec is increasingly used for basic host-firewall packet filtering, particularly in Internet-exposed scenarios, and the affect of these default exemptions has not been fully understood. Therefore, some IPsec administrators may create IPsec policies that they think are secure, but are not actually secure against inbound attacks that use the default exemptions.

For additional information, see the Knowledge Base article 811832, "IPSec Default Exemptions Can Be Used to Bypass IPsec Protection in Some Scenarios." Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

As IPsec is increasingly used for basic host-firewall packet filtering, particularly in Internet-exposed scenarios, the affect of these default exemptions has not been fully understood. Some IPsec administrators may create IPsec policies that they think are secure, but are not actually secure against inbound attacks that use the default exemptions. Attackers could forge network traffic that appears to consist of legitimate IKE, RSVP, or Kerberos protocol packets but direct them to other network services on the host.

Impact:

After you enable this entry, security policies that already exist may have to be changed to work correctly. For details, refer to the Microsoft Knowledge Base article "IPSec Default Exemptions Can Be Used to Bypass IPsec Protection in Some Scenarios" at <http://support.microsoft.com/default.aspx?kbid=811832>, which was referenced earlier in this section.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\IPSEC\NoDefaultExempt
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic.
```

Default Value:

Not defined

References:

1. CCE-21562-4

1.1.3.9.11 Configure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `KeepAliveTime` was added to the template file in the `HKEY\LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\` registry key. The entry appears as `MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds (300,000 is recommended)` in the SCE. This value controls how often TCP attempts to verify that an idle connection is still intact by sending a keep-alive packet. If the remote computer is still reachable, it acknowledges the keep-alive packet. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

An attacker who is able to connect to network applications could establish numerous connections to cause a DoS condition.

Impact:

Keep-alive packets are not sent by default by Windows. However, some applications may configure the TCP stack flag that requests keep-alive packets. For such configurations, you can lower this value from the default setting of two hours to five minutes to disconnect inactive sessions more quickly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\KeepAliveTime
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds

Default Value:

Not defined

References:

1. CCE-22421-2

1.1.3.9.12 Configure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `TcpMaxDataRetransmissions` for IPv6 was added to the template file in the

`HKEY\_LOCAL\_MACHINE\\System\\CurrentControlSet\\Services\\Tcpip6\\Parameters\\` registry key. The entry appears as `MSS: (TcpMaxDataRetransmissions) IPv6` How many times unacknowledged data is retransmitted (3 recommended, 5 is default) in the SCE. This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

A malicious user could exhaust a target computer's resources if it never sent any acknowledgment messages for data that was transmitted by the target computer.

Impact:

TCP starts a retransmission timer when each outbound segment is passed to the IP. If no acknowledgment is received for the data in a given segment before the timer expires, then the segment is retransmitted up to three times.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip6\Parameters\TcpMaxDataRetransmissions
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)

Default Value:

5

References:

1. CCE-22519-3

ARCHIVE

1.1.3.9.13 Configure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `NoNameReleaseOnDemand` was added to the template file in the `HKEY\LOCAL_MACHINE\System\CurrentControlSet\Services\Netbt\Parameters` registry key. The entry appears as `MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers` in the SCE. NetBIOS over TCP/IP is a network protocol that among other things provides a way to easily resolve NetBIOS names that are registered on Windows-based systems to the IP addresses that are configured on those systems. This setting determines whether the computer releases its NetBIOS name when it receives a name-release request. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

The NetBT protocol is designed not to use authentication, and is therefore vulnerable to spoofing. Spoofing makes a transmission appear to come from a user other than the user who performed the action. A malicious user could exploit the unauthenticated nature of the protocol to send a name-conflict datagram to a target computer, which would cause the computer to relinquish its name and not respond to queries. The result of such an attack could be to cause intermittent connectivity issues on the target computer, or even to prevent the use of Network Neighborhood, domain logons, the NET SEND command, or additional NetBIOS name resolution. For more information, see the Microsoft Knowledge Base article "MS00-047: NetBIOS Vulnerability May Cause Duplicate Name on the Network Conflicts" at <http://support.microsoft.com/default.aspx?kbid=269239>.

Impact:

An attacker could send a request over the network and query a computer to release its NetBIOS name. As with any change that could affect applications, it is recommended that you test this change in a non-production environment before you change the production environment.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netbt\Parameters\NoNameReleaseOnDemand
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers
```

Default Value:

Not defined

References:

1. CCE-21940-2

1.1.3.9.14 Configure 'MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `Hidden` was added to the template file in the `HKEY\LOCAL_MACHINE\System\CurrentControlSet\Services\Lanmanserver\Parameters\ registry key`. The entry appears as `MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)` in the SCE. You can configure a computer so that it does not send announcements to browsers on the domain. If you do so, you hide the computer from the Browse list, which means that the computer will stop announcing itself to other computers on the same network. An attacker who knows the name of a computer can more easily gather additional information about the system. You can enable this setting to remove one method that an attacker might use to gather information about computers on the network. Also, this setting can help reduce network traffic when enabled. However, the security benefits of this setting are small because attackers can use alternative methods to identify and locate potential targets. For this reason, it is recommended that this setting to set to `Enabled` in high security environments, and to `Not Defined` in enterprise environments. For additional information, see the Knowledge Base article 321710, "HOW TO: Hide a Windows 2000-Based Computer from the Browser List." Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

An attacker who knows the name of a computer can more easily gather additional information about the computer. If you enable this entry, you remove one method that an attacker might use to gather information about computers on the network. Also, if you enable this entry you can help reduce network traffic. However, the vulnerability is small because attackers can use alternative methods to identify and locate potential targets.

Impact:

The computer will no longer appear on the Browser list or in Network Neighborhood on other computers on the same network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Lanmanserver\Parameters\Hidden
```

Remediation:

Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)
```

Default Value:

Not defined

References:

1. CCE-22311-5

1.1.3.9.15 Set 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' to '0' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `ScreenSaverGracePeriod` was added to the template file in the `HKEY\_LOCAL\_MACHINE\\SYSTEM\\Software\\Microsoft\\ Windows NT\\CurrentVersion\\Winlogon\\` registry key. The entry appears as `MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)` in the SCE. Windows includes a grace period between when the screen saver is launched and when the console is actually locked automatically when screen saver locking is enabled. This setting is configured to 0 seconds for both of the environments that are discussed in this guide. The recommended state for this setting is: 0.

Rationale:

The default grace period that is allowed for user movement before the screen saver lock takes effect is five seconds. If you leave the default grace period configuration, your computer is vulnerable to a potential attack from someone who could approach the console and attempt to log on to the computer before the lock takes effect. An entry to the registry can be made to adjust the length of the grace period.

Impact:

Users will have to enter their passwords to resume their console sessions as soon as the screen saver activates.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Winlogon\ScreenSaverGracePeriod
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 0.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)

Default Value:

5 seconds

References:

1. CCE-22617-5

ARCHIVE

1.1.3.9.16 Set 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This entry appears as MSS: (DisableIPSourceRouting) IPv6 source routing protection level (protects against packet spoofing) in the SCE. IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should follow through the network. The recommended state for this setting is: Highest protection, source routing is completely disabled.

Rationale:

An attacker could use source routed packets to obscure their identity and location. Source routing allows a computer that sends a packet to specify the route that the packet takes.

Impact:

If you configure this value to 2, all incoming source routed packets will be dropped.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip6\Parameters\DisableIPSourceRouting
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Highest protection, source routing is completely disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)
```

Default Value:

Not defined

References:

1. CCE-22578-9

ARCHIVE

1.1.3.9.17 Configure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The registry value entry `PerformRouterDiscovery` was added to the template file in the `HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\` registry key. The entry appears as `MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)` in the SCE. This setting is used to enable or disable the Internet Router Discovery Protocol (IRDP), which allows the system to detect and configure default gateway addresses automatically as described in RFC 1256 on a per-interface basis. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

An attacker who has gained control of a computer on the same network segment could configure a computer on the network to impersonate a router. Other computers with IRDP enabled would then attempt to route their traffic through the already compromised computer.

Impact:

If you disable this entry, Windows Server 2003 (which supports the IRDP) cannot automatically detect and configure default gateway addresses on the computer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\PerformRouterDiscovery
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)

Default Value:

Enable only if DHCP sends the Perform Router Discovery option

References:

1. CCE-21660-6

1.1.3.10 Network access

ARCHIVE

1.1.3.10.1 Set 'Network access: Let Everyone permissions apply to anonymous users' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines what additional permissions are assigned for anonymous connections to the computer. If you enable this policy setting, anonymous Windows users are allowed to perform certain activities, such as enumerate the names of domain accounts and network shares. An unauthorized user could anonymously list account names and shared resources and use the information to guess passwords or perform social engineering attacks. The recommended state for this setting is: *Disabled*.

Rationale:

An unauthorized user could anonymously list account names and shared resources and use the information to attempt to guess passwords, perform social engineering attacks, or launch DoS attacks.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\EveryoneIncludesAnonymous
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Let Everyone permissions apply to anonymous users
```

Default Value:

Disabled

References:

1. CCE-22447-7

ARCHIVE

1.1.3.10.2 Set 'Network access: Allow anonymous SID/Name translation' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether an anonymous user can request security identifier (SID) attributes for another user, or use a SID to obtain its corresponding user name. Disable this policy setting to prevent unauthenticated users from obtaining user names that are associated with their respective SIDs. The recommended state for this setting is: *Disabled*.

Rationale:

If this policy setting is enabled, a user with local access could use the well-known Administrator's SID to learn the real name of the built-in Administrator account, even if it has been renamed. That person could then use the account name to initiate a password guessing attack.

Impact:

Disabled is the default configuration for this policy setting on member computers; therefore it will have no impact on them. The default configuration for domain controllers is Enabled. If you disable this policy setting on domain controllers, legacy computers may be unable to communicate with Windows Server 2003–based domains. For example, the following computers may not work:

- Windows NT 4.0–based Remote Access Service servers.
- Microsoft SQL Servers™ that run on Windows NT 3.x–based or Windows NT 4.0–based computers.
- Remote Access Service or Microsoft SQL servers that run on Windows 2000–based computers and are located in Windows NT 3.x domains or Windows NT 4.0 domains.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network access: Allow anonymous SID/Name  
translation
```

Default Value:

Disabled

References:

1. CCE-22042-6

ARCHIVE

1.1.3.10.3 Set 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the ability of anonymous users to enumerate SAM accounts as well as shares. If you enable this policy setting, anonymous users will not be able to enumerate domain account user names and network share names on the workstations in your environment. The Network access: Do not allow anonymous enumeration of SAM accounts and shares setting is configured to Enabled for the two environments that are discussed in this guide. The recommended state for this setting is: `Enabled`.

Rationale:

An unauthorized user could anonymously list account names and shared resources and use the information to attempt to guess passwords or perform social engineering attacks.

Impact:

It will be impossible to grant access to users of another domain across a one-way trust because administrators in the trusting domain will be unable to enumerate lists of accounts in the other domain. Users who access file and print servers anonymously will be unable to list the shared network resources on those servers; the users will have to authenticate before they can view the lists of shared folders and printers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\RestrictAnonymous

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Do not allow anonymous enumeration of SAM accounts and shares

Default Value:

Disabled

References:

1. CCE-22585-4

ARCHIVE

1.1.3.10.4 Configure 'Network access: Named Pipes that can be accessed anonymously' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which communication sessions, or pipes, will have attributes and permissions that allow anonymous access. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale:

You can restrict access over named pipes such as COMNAP and LOCATOR to help prevent unauthorized access to the network. The default list of named pipes and their purpose is provided in the following list: COMNAP - SNABase named pipe. Systems Network Architecture (SNA) is a collection of network protocols that were originally developed for IBM mainframe computers. COMNODE - SNA Server named pipe. SQL\QUERY - Default named pipe for SQL Server. SPOOLSS - Named pipe for the Print Spooler service. EPMAPPER - End Point Mapper named pipe. LOCATOR - Remote Procedure Call Locator service named pipe. TrkWks - Distributed Link Tracking Client named pipe. TrkSvr - Distributed Link Tracking Server named pipe.

Impact:

This configuration will disable null session access over named pipes, and applications that rely on this feature or on unauthenticated access to named pipes will no longer function. For example, with Microsoft Commercial Internet System 1.0, the Internet Mail Service runs under the Inetinfo process. Inetinfo starts in the context of the System account. When Internet Mail Service needs to query the Microsoft SQL Server database, it uses the System account, which uses null credentials to access a SQL pipe on the computer that runs SQL Server. To avoid this problem, refer to the Microsoft Knowledge Base article "How to access network files from IIS applications," which is located at <http://support.microsoft.com/default.aspx?scid=207671>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\NullSessionPipes
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Named Pipes that can be accessed anonymously
```

Default Value:

None

References:

1. CCE-23597-8

1.1.3.10.5 Set 'Network access: Restrict anonymous access to Named Pipes and Shares' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

When enabled, this policy setting restricts anonymous access to only those shares and pipes that are named in the Network access: Named pipes that can be accessed anonymously and Network access: Shares that can be accessed anonymously settings. This policy setting controls null session access to shares on your computers by adding RestrictNullSessAccess with the value 1 in the HKLM\System\CurrentControlSet\Services\LanManServer\Parameters registry key. This registry value toggles null session shares on or off to control whether the server service restricts unauthenticated clients' access to named resources. Null sessions are a weakness that can be exploited through shares (including the default shares) on computers in your environment. The recommended state for this setting is: *Enabled*.

Rationale:

Null sessions are a weakness that can be exploited through shares (including the default shares) on computers in your environment.

Impact:

You can enable this policy setting to restrict null session access for unauthenticated users to all server pipes and shared folders except those that are listed in the NullSessionPipes and NullSessionShares entries. If you choose to enable this setting and are supporting Windows NT 4.0 domains, you should check if any of the named pipes are required to maintain trust relationships between the domains, and then add the pipe to the Network access: Named pipes that can be accessed anonymously: - COMNAP-SNA session access - COMNODE-SNA session access - SQL\QUERY-SQL instance access - SPOOLSS-Spooler service - LLSRPC-License Logging service - Netlogon-Net Logon service - Lsarpc-LSA access - Samr-Remote access to SAM objects - browser-Computer Browser service Previous to the release of Windows Server 2003 with Service Pack 1 (SP1) these named pipes were allowed anonymous access by default, but with the increased hardening in Windows Server 2003 with SP1 these pipes must be explicitly added if needed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\restrictnullsessaccess
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Restrict anonymous access to Named Pipes and Shares
```

Default Value:

Enabled

References:

1. CCE-22658-9

1.1.3.10.6 Set 'Network access: Sharing and security model for local accounts' to 'Classic - local users authenticate as themselves' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines how network logons that use local accounts are authenticated. The Classic option allows precise control over access to resources, including the ability to assign different types of access to different users for the same resource. The Guest only option allows you to treat all users equally. In this context, all users authenticate as Guest only to receive the same access level to a given resource. The recommended state for this setting is: `Classic - local users authenticate as themselves`.

Rationale:

With the Guest only model, any user who can authenticate to your computer over the network does so with guest privileges, which probably means that they will not have write access to shared resources on that computer. Although this restriction does increase security, it makes it more difficult for authorized users to access shared resources on those computers because ACLs on those resources must include access control entries (ACEs) for the Guest account. With the Classic model, local accounts should be password protected. Otherwise, if Guest access is enabled, anyone can use those user accounts to access shared system resources.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\ForceGuest
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to Classic - local users authenticate as themselves.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Sharing and security model for local accounts

Default Value:

Classic - local users authenticate as themselves

References:

1. CCE-21740-6

1.1.3.10.7 Set 'Network access: Remotely accessible registry paths and sub-paths' to the following list (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which registry paths and sub-paths will be accessible when an application or process references the WinReg key to determine access permissions. Note: In Windows XP this setting is called "Network access: Remotely accessible registry paths," the setting with that same name in Windows Vista, Windows Server 2008, and Windows Server 2003 does not exist in Windows XP. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value. The recommended state for this setting is:

```
System\CurrentControlSet\Control\Print\Printers
System\CurrentControlSet\Services\Eventlog
Software\Microsoft\OLAP Server
Software\Microsoft\Windows NT\CurrentVersion\Print
Software\Microsoft\Windows NT\CurrentVersion\Windows
System\CurrentControlSet\Control\ContentIndex
System\CurrentControlSet\Control\Terminal Server
System\CurrentControlSet\Control\Terminal Server\UserConfig
System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration
Software\Microsoft\Windows NT\CurrentVersion\Perflib
System\CurrentControlSet\Services\SysmonLog
```

Rationale:

The registry contains sensitive computer configuration information that could be used by an attacker to facilitate unauthorized activities. The fact that the default ACLs assigned throughout the registry are fairly restrictive and help to protect the registry from access by unauthorized users reduces the risk of such an attack.

Impact:

Remote management tools such as the Microsoft Baseline Security Analyzer and Microsoft Systems Management Server require remote access to the registry to properly monitor and manage those computers. If you remove the default registry paths from the list of accessible ones, such remote management tools could fail. Note: If you want to allow remote access, you must also enable the Remote Registry service.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurePipeServers\Winreg\
AllowedPaths\Machine
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to

```
System\\CurrentControlSet\\Control\\Print\\Printers
System\\CurrentControlSet\\Services\\Eventlog Software\\Microsoft\\OLAP
Server Software\\Microsoft\\Windows NT\\CurrentVersion\\Print
Software\\Microsoft\\Windows NT\\CurrentVersion\\Windows
System\\CurrentControlSet\\Control\\ContentIndex
System\\CurrentControlSet\\Control\\Terminal Server
System\\CurrentControlSet\\Control\\Terminal Server\\UserConfig
System\\CurrentControlSet\\Control\\Terminal Server\\DefaultUserConfiguration
Software\\Microsoft\\Windows NT\\CurrentVersion\\Perflib
System\\CurrentControlSet\\Services\\SysmonLog.
```

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Remotely accessible registry paths
and sub-paths
```

Default Value:

```
System\CurrentControlSet\Control\Print\Printers,System\CurrentControlSet\Services\Ev
entlog,Software\Microsoft\OLAP Server,Software\Microsoft\Windows
NT\CurrentVersion\Print,Software\Microsoft\Windows
NT\CurrentVersion\Windows,System\CurrentControlSet\Control\ContentIndex,System\C
urrentControlSet\Control\Terminal Server,System\CurrentControlSet\Control\Terminal
Server\UserConfig,System\CurrentControlSet\Control\Terminal
Server\DefaultUserConfiguration,Software\Microsoft\Windows
NT\CurrentVersion\Perflib,System\CurrentControlSet\Services\SysmonLog
```

References:

1. CCE-22977-3

1.1.3.10.8 Set 'Network access: Shares that can be accessed anonymously' to 'Not Defined' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which network shares can be accessed by anonymous users. The default configuration for this policy setting has little effect because all users have to be authenticated before they can access shared resources on the server. Note: It can be very dangerous to add other shares to this Group Policy setting. Any network user can access any shares that are listed, which could exposure or corrupt sensitive data. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value. The recommended state for this setting is: Not Defined.

Rationale:

It is very dangerous to enable this setting. Any shares that are listed can be accessed by any network user, which could lead to the exposure or corruption of sensitive data.

Impact:

There should be little impact because this is the default configuration. Only authenticated users will have access to shared resources on the server.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\NullSessionShares
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Defined`.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network access: Shares that can be accessed  
anonymously
```

Default Value:

Not defined

References:

1. CCE-23257-9

ARCHIVE

1.1.3.10.9 Set 'Network access: Do not allow anonymous enumeration of SAM accounts' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the ability of anonymous users to enumerate the accounts in the Security Accounts Manager (SAM). If you enable this policy setting, users with anonymous connections cannot enumerate domain account user names on the workstations in your environment. This policy setting also allows additional restrictions on anonymous connections. The recommended state for this setting is: `Enabled`.

Rationale:

An unauthorized user could anonymously list account names and use the information to perform social engineering attacks or attempt to guess passwords. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information.)

Impact:

It will be impossible to establish trusts with Windows NT 4.0–based domains. Also, client computers that run older versions of the Windows operating system such as Windows NT 3.51 and Windows 95 will experience problems when they try to use resources on the server.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\RestrictAnonymousSAM
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Enabled`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Do not allow anonymous enumeration of SAM accounts
```

Default Value:

`Enabled`

References:

1. CCE-21546-7

ARCHIVE

1.1.3.10.10 Set 'Network access: Remotely accessible registry paths' to the following list (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which registry paths will be accessible after referencing the WinReg key to determine access permissions to the paths. Note: This setting does not exist in Windows XP. There was a setting with that name in Windows XP, but it is called "Network access: Remotely accessible registry paths and subpaths" in Windows Server 2003, Windows Vista, and Windows Server 2008. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value. The recommended state for this setting is:

```
System\CurrentControlSet\Control\ProductOptions  
System\CurrentControlSet\Control\Server Applications  
Software\Microsoft\Windows NT\CurrentVersion
```

Rationale:

The registry is a database that contains computer configuration information, and much of the information is sensitive. An attacker could use this information to facilitate unauthorized activities. To reduce the risk of such an attack, suitable ACLs are assigned throughout the registry to help protect it from access by unauthorized users.

Impact:

Remote management tools such as the Microsoft Baseline Security Analyzer and Microsoft Systems Management Server require remote access to the registry to properly monitor and manage those computers. If you remove the default registry paths from the list of accessible ones, such remote management tools could fail. Note: If you want to allow remote access, you must also enable the Remote Registry service.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurePipeServers\Winreg\
AllowedExactPaths\Machine
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to

```
System\\CurrentControlSet\\Control\\ProductOptions
System\\CurrentControlSet\\Control\\Server Applications
Software\\Microsoft\\Windows NT\\CurrentVersion.
```

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Remotely accessible registry paths
```

Default Value:

System\CurrentControlSet\Control\ProductOptions, System\CurrentControlSet\Control\Server Applications, Software\Microsoft\Windows NT\CurrentVersion

References:

1. CCE-21504-6

1.1.3.10.11 Configure 'Network access: Do not allow storage of passwords and credentials for network authentication' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the Stored User Names and Passwords feature may save passwords or credentials for later use when it gains domain authentication. If you enable this policy setting, the Stored User Names and Passwords feature of Windows does not store passwords and credentials. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Passwords that are cached can be accessed by the user when logged on to the computer. Although this information may sound obvious, a problem can arise if the user unknowingly executes hostile code that reads the passwords and forwards them to another, unauthorized user.

Impact:

Users will be forced to enter passwords whenever they log on to their Passport account or other network resources that aren't accessible to their domain account. Testing has shown that clients running Windows Vista or Windows Server 2008 will be unable to connect to Distributed File System (DFS) shares in untrusted domains. Enabling this setting also makes it impossible to specify alternate credentials for scheduled tasks, this can cause a variety of problems. For example, some third party backup products will no longer work. This policy setting should have no impact on users who access network resources that are configured to allow access with their Active Directory-based domain account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\DisableDomainCreds
--

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Do not allow storage of passwords and credentials for network authentication

Default Value:

Disabled

References:

1. CCE-21921-2

ARCHIVE

1.1.3.11 Network security

ARCHIVE

1.1.3.11.1 Set 'Network security: Do not store LAN Manager hash value on next password change' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the LAN Manager (LM) hash value for the new password is stored when the password is changed. The LM hash is relatively weak and prone to attack compared to the cryptographically stronger Microsoft Windows NT' hash. Note Older operating systems and some third-party applications may fail when this policy setting is enabled. Also you will need to change the password on all accounts after you enable this setting. The recommended state for this setting is: *Enabled*.

Rationale:

The SAM file can be targeted by attackers who seek access to username and password hashes. Such attacks use special tools to crack passwords, which can then be used to impersonate users and gain access to resources on your network. These types of attacks will not be prevented if you enable this policy setting, but it will be much more difficult for these types of attacks to succeed.

Impact:

Earlier operating systems such as Windows 95, Windows 98, and Windows ME as well as some third-party applications will fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\NoLMHash
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Do not store LAN Manager hash value on next password change
```

Default Value:

Enabled

References:

1. CCE-22552-4

ARCHIVE

1.1.3.11.2 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' to 'Require NTLMv2 session security,Require 128-bit encryption' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which behaviors are allowed for applications using the NTLM Security Support Provider (SSP). The SSP Interface (SSPI) is used by applications that need authentication services. The setting does not modify how the authentication sequence works but instead require certain behaviors in applications that use the SSPI. The possible values for the Network security: Minimum session security for NTLM SSP based (including secure RPC) servers setting are: - Require message confidentiality. This option is only available in Windows XP and Windows Server 2003, the connection will fail if encryption is not negotiated. Encryption converts data into a form that is not readable until decrypted. - Require message integrity. This option is only available in Windows XP and Windows Server 2003, the connection will fail if message integrity is not negotiated. The integrity of a message can be assessed through message signing. Message signing proves that the message has not been tampered with; it attaches a cryptographic signature that identifies the sender and is a numeric representation of the contents of the message. - Require 128-bit encryption. The connection will fail if strong encryption (128-bit) is not negotiated. - Require NTLMv2 session security. The connection will fail if the NTLMv2 protocol is not negotiated. - Not Defined. The recommended state for this setting is: `Require NTLMv2 session security,Require 128-bit encryption`.

Rationale:

You can enable all of the options for this policy setting to help protect network traffic that uses the NTLM Security Support Provider (NTLM SSP) from being exposed or tampered with by an attacker who has gained access to the same network. That is, these options help protect against man-in-the-middle attacks.

Impact:

Server applications that are enforcing these settings will be unable to communicate with older servers that do not support them. This setting could impact Windows Clustering when applied to servers running Windows Server 2003, see "How to apply more restrictive security settings on a Windows Server 2003-based cluster server" at <http://support.microsoft.com/default.aspx?scid=kb;en-us;891597> and "You receive an "Error 0x8007042b" error message when you add or join a node to a cluster if you use NTLM version 2 in Windows Server 2003" at <http://support.microsoft.com/kb/890761/> for more information on possible issues and how to resolve them.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\NTLMMinServerSec
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Require NTLMv2 session security, Require 128-bit encryption.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Minimum session security for NTLM SSP based (including secure RPC) servers
```

Default Value:

Require 128-bit encryption

References:

1. CCE-23391-6

1.1.3.11.3 Set 'Network security: Allow Local System to use computer identity for NTLM' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

When enabled, this policy setting causes Local System services that use Negotiate to use the computer identity when NTLM authentication is selected by the negotiation. This policy is supported on at least Windows 7 or Windows Server 2008 R2. The recommended state for this setting is: *Enabled*.

Rationale:

When connecting to computers running versions of Windows earlier than Windows Vista or Windows Server 2008, services running as Local System and using SPNEGO (Negotiate) that revert to NTLM use the computer identity. In Windows 7, if you are connecting to a computer running Windows Server 2008 or Windows Vista, then a system service uses either the computer identity or a NULL session. When connecting with a NULL session, a system-generated session key is created, which provides no protection but allows applications to sign and encrypt data without errors. When connecting with the computer identity, both signing and encryption is supported in order to provide data protection.

Impact:

If you enable this policy setting, services running as Local System that use Negotiate will use the computer identity. This might cause some authentication requests between Windows operating systems to fail and log an error. If you disable this policy setting, services running as Local System that use Negotiate when reverting to NTLM authentication will authenticate anonymously. This was the behavior in previous versions of Windows.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\UseMachineId
--

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network security: Allow Local System to use  
computer identity for NTLM
```

Default Value:

Not defined

References:

1. CCE-23578-8

ARCHIVE

1.1.3.11.4 Set 'Network security: Allow LocalSystem NULL session fallback' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Allow NTLM to fall back to NULL session when used with LocalSystem. The default is TRUE up to Windows Vista and FALSE in Windows 7. The recommended state for this setting is: Disabled.

Rationale:

NULL sessions are less secure because by definition they are unauthenticated.

Impact:

Any applications that require NULL sessions for LocalSystem will not work as designed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\allownullsessionsfallback
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Allow LocalSystem NULL session fallback
```

Default Value:

Not defined

References:

1. CCE-23261-1

1.1.3.11.5 'Network Security: Restrict NTLM: NTLM authentication in this domain' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to deny or allow NTLM authentication within a domain from this domain controller. This policy does not affect interactive logon to this domain controller. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

NTLM is a Microsoft-developed authentication protocol that uses a challenge-response mechanism for authentication, in which client computers can prove their identities without sending a password to the server. The protocol employs three types of messages to negotiate the request, challenge the authenticity of the sender, and perform the authentication. Kerberos is a more robust protocol and is the preferred method of authentication when available.

Impact:

If you select "Disabled" or do not configure this policy setting, the domain controller will allow all NTLM pass-through authentication requests within the domain. If you select "Deny for domain accounts to domain servers" the domain controller will deny all NTLM authentication logon attempts to all servers in the domain that are using domain accounts and return an NTLM blocked error unless the server name is on the exception list in the "Network security: Restrict NTLM: Add server exceptions for NTLM authentication in this domain" policy setting. If you select "Deny for domain account" the domain controller will deny all NTLM authentication logon attempts from domain accounts and return an NTLM blocked error unless the server name is on the exception list in the "Network security: Restrict NTLM: Add server exceptions for NTLM authentication in this domain" policy setting. If you select "Deny for domain servers" the domain controller will deny NTLM authentication requests to all servers in the domain and return an NTLM blocked error unless the server name is on the exception list in the "Network security: Restrict NTLM: Add server exceptions for NTLM authentication in this domain" policy setting. If you select "Deny all," the domain controller will deny all NTLM pass-through authentication requests from its servers and for its accounts and return an NTLM blocked error unless the server name is on the exception list in the "Network security: Restrict NTLM: Add server exceptions for NTLM authentication in this domain" policy setting.

Audit:

Set the following group policy to a value that is consistent with the security

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\RestrictNTLMInDomain
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Defined`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network Security: Restrict NTLM: NTLM authentication in this domain
```

Default Value:

Not defined

References:

1. CCE-23636-4

1.1.3.11.6 Configure 'Network Security: Restrict NTLM: Add server exceptions in this domain' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to create an exception list of servers in this domain to which clients are allowed to use NTLM pass-through authentication if the "Network Security: Restrict NTLM: Deny NTLM authentication in this domain" is set. The naming format for servers on this exception list is the fully qualified domain name (FQDN) or NetBIOS server name used by the calling application listed one per line. A single asterisk (*) can be used at the beginning or end of the string as a wildcard character. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

NTLM is a Microsoft-developed authentication protocol that uses a challenge-response mechanism for authentication, in which client computers can prove their identities without sending a password to the server. The protocol employs three types of messages to negotiate the request, challenge the authenticity of the sender, and perform the authentication. Kerberos is a more robust protocol and is the preferred method of authentication when available.

Impact:

If you configure this policy setting, you can define a list of servers in this domain to which clients are allowed to use NTLM authentication. If you do not configure this policy setting, no exceptions will be applied.

Audit:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\DCAllowedNTLMServers

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Defined`.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network Security: Restrict NTLM: Add server  
exceptions in this domain
```

Default Value:

Not defined

References:

1. CCE-22367-7

ARCHIVE

1.1.3.11.7 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' to 'Require NTLMv2 session security,Require 128-bit encryption' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which behaviors are allowed for applications using the NTLM Security Support Provider (SSP). The SSP Interface (SSPI) is used by applications that need authentication services. The setting does not modify how the authentication sequence works but instead require certain behaviors in applications that use the SSPI. The possible values for the Network security: Minimum session security for NTLM SSP based (including secure RPC) clients setting are: - Require message confidentiality. This option is only available in Windows XP and Windows Server 2003, the connection will fail if encryption is not negotiated. Encryption converts data into a form that is not readable until decrypted. - Require message integrity. This option is only available in Windows XP and Windows Server 2003, the connection will fail if message integrity is not negotiated. The integrity of a message can be assessed through message signing. Message signing proves that the message has not been tampered with; it attaches a cryptographic signature that identifies the sender and is a numeric representation of the contents of the message. - Require 128-bit encryption. The connection will fail if strong encryption (128-bit) is not negotiated. - Require NTLMv2 session security. The connection will fail if the NTLMv2 protocol is not negotiated. - Not Defined. The recommended state for this setting is: `Require NTLMv2 session security,Require 128-bit encryption`.

Rationale:

You can enable all of the options for this policy setting to help protect network traffic that uses the NTLM Security Support Provider (NTLM SSP) from being exposed or tampered with by an attacker who has gained access to the same network. In other words, these options help protect against man-in-the-middle attacks.

Impact:

Client applications that are enforcing these settings will be unable to communicate with older servers that do not support them. This setting could impact Windows Clustering when applied to servers running Windows Server 2003, see "How to apply more restrictive security settings on a Windows Server 2003-based cluster server" at <http://support.microsoft.com/default.aspx?scid=kb;en-us;891597> and "You receive an "Error 0x8007042b" error message when you add or join a node to a cluster if you use NTLM version 2 in Windows Server 2003" at <http://support.microsoft.com/kb/890761/> for more information on possible issues and how to resolve them.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\NTLMMinClientSec
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Require NTLMv2 session security, Require 128-bit encryption.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Minimum session security for NTLM SSP based (including secure RPC) clients
```

Default Value:

Require 128-bit encryption

References:

1. CCE-22749-6

1.1.3.11.8 Configure 'Network Security: Restrict NTLM: Outgoing NTLM traffic to remote servers' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to deny or audit outgoing NTLM traffic from this Windows 7 or this Windows Server 2008 R2 computer to any Windows remote server. This policy is supported on at least Windows 7 or Windows Server 2008 R2. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Note: Audit and block events are recorded on this computer in the "Operational" Log located under Applications and Services Log/Microsoft/Windows/NTLM.

Rationale:

NTLM is a Microsoft-developed authentication protocol that uses a challenge-response mechanism for authentication, in which client computers can prove their identities without sending a password to the server. The protocol employs three types of messages to negotiate the request, challenge the authenticity of the sender, and perform the authentication. Kerberos is a more robust protocol and is the preferred method of authentication when available.

Impact:

If you select "Allow all" or do not configure this policy setting, the client computer can authenticate identities to a remote server by using NTLM authentication.

If you select "Audit all," the client computer logs an event for each NTLM authentication request to a remote server. This allows you to identify those servers receiving NTLM authentication requests from the client computer.

If you select "Deny all," the client computer cannot authenticate identities to a remote server by using NTLM authentication. You can use the "Network security: Restrict NTLM: Add remote server exceptions for NTLM authentication" policy setting to define a list of remote servers to which clients are allowed to use NTLM authentication.

Audit:

Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\RestrictSendin  
gNTLMTraffic
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network Security: Restrict NTLM: Outgoing NTLM  
traffic to remote servers
```

Default Value:

Not defined

References:

1. CCE-23115-9

1.1.3.11.9 Configure 'Network Security: Restrict NTLM: Add remote server exceptions for NTLM authentication' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to create an exception list of remote servers to which clients are allowed to use NTLM authentication if the "Network Security: Restrict NTLM: Outgoing NTLM traffic to remote servers" policy setting is configured. The naming format for servers on this exception list is the fully qualified domain name (FQDN) or NetBIOS server name used by the application, listed one per line. To ensure exceptions the name used by all applications needs to be in the list, and to ensure an exception is accurate, the server name should be listed in both naming formats . A single asterisk (*) can be used anywhere in the string as a wildcard character. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

NTLM is a Microsoft-developed authentication protocol that uses a challenge-response mechanism for authentication, in which client computers can prove their identities without sending a password to the server. The protocol employs three types of messages to negotiate the request, challenge the authenticity of the sender, and perform the authentication. Kerberos is a more robust protocol and is the preferred method of authentication when available.

Impact:

If you configure this policy setting, you can define a list of remote servers to which clients are allowed to use NTLM authentication. If you do not configure this policy setting, no exceptions will be applied.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\ClientAllowedNTLMServers
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network Security: Restrict NTLM: Add remote server exceptions for NTLM authentication

Default Value:

Not defined

References:

1. CCE-22868-4

ARCHIVE

1.1.3.11.10 Set 'Network Security: Restrict NTLM: Audit Incoming NTLM Traffic' to 'Not Defined' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to audit incoming NTLM traffic. This policy is supported on at least Windows 7 or Windows Server 2008 R2. Note: Audit events are recorded on this computer in the "Operational" Log located under the Applications and Services Log/Microsoft/Windows/NTLM. The recommended state for this setting is: Not Defined.

Rationale:

NTLM is a Microsoft-developed authentication protocol that uses a challenge-response mechanism for authentication, in which client computers can prove their identities without sending a password to the server. The protocol employs three types of messages to negotiate the request, challenge the authenticity of the sender, and perform the authentication. Kerberos is a more robust protocol and is the preferred method of authentication when available.

Impact:

If you select "Disable", or do not configure this policy setting, the server will not log events for incoming NTLM traffic. If you select "Enable auditing for domain accounts", the server will log events for NTLM pass-through authentication requests that would be blocked when the "Network Security: Restrict NTLM: Incoming NTLM traffic" policy setting is set to the "Deny all domain accounts" option. If you select "Enable auditing for all accounts", the server will log events for all NTLM authentication requests that would be blocked when the "Network Security: Restrict NTLM: Incoming NTLM traffic" policy setting is set to the "Deny all accounts" option.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\AuditReceivingNTLMTraffic
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Defined`.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network Security: Restrict NTLM: Audit Incoming  
NTLM Traffic
```

Default Value:

Not defined

References:

1. CCE-21941-0

ARCHIVE

1.1.3.11.11 Set 'Network security: LAN Manager authentication level' to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

LAN Manager (LM) is a family of early Microsoft client/server software that allows users to link personal computers together on a single network. Network capabilities include transparent file and print sharing, user security features, and network administration tools. In Active Directory domains, the Kerberos protocol is the default authentication protocol. However, if the Kerberos protocol is not negotiated for some reason, Active Directory will use LM, NTLM, or NTLMv2. LAN Manager authentication includes the LM, NTLM, and NTLM version 2 (NTLMv2) variants, and is the protocol that is used to authenticate all Windows clients when they perform the following operations:

- Join a domain
- Authenticate between Active Directory forests
- Authenticate to down-level domains
- Authenticate to computers that do not run Windows 2000, Windows Server 2003, or Windows XP)
- Authenticate to computers that are not in the domain

The possible values for the Network security: LAN Manager authentication level setting are:

- Send LM & NTLM responses
- Send LM & NTLM — use NTLMv2 session security if negotiated
- Send NTLM responses only
- Send NTLMv2 responses only
- Send NTLMv2 responses only\refuse LM
- Send NTLMv2 responses only\refuse LM & NTLM
- Not Defined

The Network security: LAN Manager authentication level setting determines which challenge/response authentication protocol is used for network logons. This choice affects the authentication protocol level that clients use, the session security level that the computers negotiate, and the authentication level that servers accept as follows:

- Send LM & NTLM responses. Clients use LM and NTLM authentication and never use NTLMv2 session security. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
- Send LM & NTLM – use NTLMv2 session security if negotiated. Clients use LM and NTLM authentication and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
- Send NTLM response only. Clients use NTLM authentication only and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
- Send NTLMv2 response only. Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
- Send NTLMv2 response only\refuse LM. Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it. Domain controllers refuse LM (accept only NTLM and NTLMv2 authentication).
- Send NTLMv2 response only\refuse LM & NTLM. Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it. Domain controllers refuse LM and NTLM (accept only NTLMv2 authentication).
- These settings correspond to the levels discussed in other Microsoft documents as follows:
 - Level 0 – Send LM and NTLM response; never use NTLMv2 session security. Clients use LM and NTLM authentication, and never use NTLMv2 session security. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
 - Level 1 – Use NTLMv2 session security if negotiated. Clients use LM and NTLM authentication, and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
 - Level 2 – Send NTLM response only. Clients use only NTLM authentication, and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
 - Level 3 – Send NTLMv2 response only. Clients use NTLMv2 authentication, and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication.
 - Level 4 – Domain controllers refuse LM responses. Clients use NTLM authentication, and use NTLMv2 session security if the server supports it. Domain controllers refuse LM authentication, that is, they accept NTLM and NTLMv2.
 - Level 5 – Domain controllers refuse LM and NTLM responses (accept only NTLMv2). Clients use NTLMv2 authentication, use and NTLMv2 session security if the server supports it. Domain controllers refuse NTLM and LM authentication (they accept only NTLMv2). The recommended state for this setting is: `Send NTLMv2 response only. Refuse LM & NTLM.`

Rationale:

In Windows Vista, this setting is undefined. However, in Windows 2000, Windows Server 2003, and Windows XP clients are configured by default to send LM and NTLM authentication responses (Windows 95-based and Windows 98-based clients only send LM). The default setting on servers allows all clients to authenticate with servers and use their resources. However, this means that LM responses—the weakest form of authentication response—are sent over the network, and it is potentially possible for attackers to sniff that traffic to more easily reproduce the user's password. The Windows 95, Windows 98, and Windows NT operating systems cannot use the Kerberos version 5 protocol for authentication. For this reason, in a Windows Server 2003 domain, these computers authenticate by default with both the LM and NTLM protocols for network authentication. You can enforce a more secure authentication protocol for Windows 95, Windows 98, and Windows NT by using NTLMv2. For the logon process, NTLMv2 uses a secure channel to protect the authentication process. Even if you use NTLMv2 for earlier clients and servers, Windows-based clients and servers that are members of the domain will use the Kerberos authentication protocol to authenticate with Windows Server 2003 domain controllers.

Impact:

Clients that do not support NTLMv2 authentication will not be able to authenticate in the domain and access domain resources by using LM and NTLM. Note: For information about a hotfix to ensure that this setting works in networks that include Windows NT 4.0-based computers along with Windows 2000, Windows XP, and Windows Server 2003-based computers, see article 305379, Authentication Problems in Windows 2000 with NTLM 2 Levels Above 2 in a Windows NT 4.0 Domain, in the Microsoft Knowledge Base (<http://go.microsoft.com/fwlink/?LinkId=100907>).

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\LmCompatibilityLevel
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Send NTLMv2 response only`. Refuse LM & NTLM.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: LAN Manager authentication level
```

Default Value:

Send NTLMv2 response only

References:

1. CCE-22639-9

ARCHIVE

1.1.3.11.12 Set 'Network Security: Allow PKU2U authentication requests to this computer to use online identities' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Windows 7 and Windows Server 2008 R2 introduce an extension to the Negotiate authentication package, Spnego.dll. In previous versions of Windows, Negotiate decides whether to use Kerberos or NTLM for authentication. The extension SSP for Negotiate, Negoexts, which is treated as an authentication protocol by Windows, supports Microsoft SSPs including PKU2U. You can also develop or add other SSPs. When computers are configured to accept authentication requests by using online IDs, Negoexts.dll calls the PKU2U SSP on the computer that is used to log on. The PKU2U SSP obtains a local certificate and exchanges the policy between the peer computers. When validated on the peer computer, the certificate within the metadata is sent to the logon peer for validation and associates the user's certificate to a security token and the logon process completes. This policy will be turned off by default on domain joined machines. This would disallow the online identities to be able to authenticate to the domain joined machine in Windows 7. The recommended state for this setting is:

Disabled.

Rationale:

The PKU2U protocol is a peer-to-peer authentication protocol, in most managed networks authentication should be managed centrally.

Impact:

Disabling this setting will disallow the online identities to be able to authenticate to the domain joined machine in Windows 7.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\pku2u\AllowOnlineID

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network Security: Allow PKU2U authentication  
requests to this computer to use online identities
```

Default Value:

Not defined

References:

1. CCE-22829-6

ARCHIVE

1.1.3.11.13 Configure 'Network Security: Restrict NTLM: Audit NTLM authentication in this domain' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to audit NTLM authentication in a domain from this domain controller. This policy is supported on at least Windows Server 2008 R2. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Note: Audit events are recorded on this computer in the "Operational" Log located under the Applications and Services Log/Microsoft/Windows/NTLM.

Rationale:

NTLM is a Microsoft-developed authentication protocol that uses a challenge-response mechanism for authentication, in which client computers can prove their identities without sending a password to the server. The protocol employs three types of messages to negotiate the request, challenge the authenticity of the sender, and perform the authentication. Kerberos is a more robust protocol and is the preferred method of authentication when available.

Impact:

If you select "Disable" or do not configure this policy setting, the domain controller will not log events for NTLM authentication in this domain. If you select "Enable for domain accounts to domain servers," the domain controller will log events for NTLM authentication logon attempts for domain accounts to domain servers when NTLM authentication would be denied because "Deny for domain accounts to domain servers" is selected in the "Network security: Restrict NTLM: NTLM authentication in this domain" policy setting. If you select "Enable for domain accounts," the domain controller will log events for NTLM authentication logon attempts that use domain accounts when NTLM authentication would be denied because "Deny for domain accounts" is selected in the "Network security: Restrict NTLM: NTLM authentication in this domain" policy setting. If you select "Enable for domain servers" the domain controller will log events for NTLM authentication requests to all servers in the domain when NTLM authentication would be denied because "Deny for domain servers" is selected in the "Network security: Restrict NTLM: NTLM authentication in this domain" policy setting. If you select "Enable all" the domain controller will log events for NTLM pass-through authentication requests from its servers and for its accounts which would be denied because "Deny all" is selected in the "Network security: Restrict NTLM: NTLM authentication in this domain" policy setting.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\AuditNTLMInDomain
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network Security: Restrict NTLM: Audit NTLM authentication in this domain
```

Default Value:

Not defined

References:

1. CCE-22036-8

1.1.3.11.14 Configure 'Network Security: Restrict NTLM: Incoming NTLM traffic' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to deny or allow incoming NTLM traffic. This policy is supported on at least Windows 7 or Windows Server 2008 R2. Note: Block events are recorded on this computer in the "Operational" Log located under the Applications and Services Log/Microsoft/Windows/NTLM. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

NTLM is a Microsoft-developed authentication protocol that uses a challenge-response mechanism for authentication, in which client computers can prove their identities without sending a password to the server. The protocol employs three types of messages to negotiate the request, challenge the authenticity of the sender, and perform the authentication. Kerberos is a more robust protocol and is the preferred method of authentication when available.

Impact:

If you select "Allow all" or do not configure this policy setting, the server will allow all NTLM authentication requests. If you select "Deny all domain accounts," the server will deny NTLM authentication requests for domain logon and display an NTLM blocked error, but allow local account logon. If you select "Deny all accounts," the server will deny NTLM authentication requests from incoming traffic and display an NTLM blocked error.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\RestrictReceivingNTLMTraffic

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Network Security: Restrict NTLM: Incoming NTLM  
traffic
```

Default Value:

Not defined

References:

1. CCE-22935-1

ARCHIVE

1.1.3.11.15 Set 'Network Security: Configure encryption types allowed for Kerberos' to 'RC4\AES128\AES256\Future types' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to set the encryption types that Kerberos is allowed to use. This policy is supported on at least Windows 7 or Windows Server 2008 R2. The recommended state for this setting is: RC4\AES128\AES256\Future types.

Rationale:

The strength of each encryption algorithm varies from one to the next, choosing stronger algorithms will reduce the risk of compromise however doing so may cause issues when the computer attempts to authenticate with systems that do not support them.

Impact:

If not selected, the encryption type will not be allowed. This setting may affect compatibility with client computers or services and applications. Multiple selections are permitted.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\Kerberos\Parameters\SupportedEncryptionTypes
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to RC4\AES128\AES256\Future types.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network Security: Configure encryption types allowed for Kerberos
```

Default Value:

Not defined

References:

1. CCE-22301-6

ARCHIVE

1.1.3.11.16 Set 'Network security: LDAP client signing requirements' to 'Negotiate signing' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the level of data signing that is requested on behalf of clients that issue LDAP BIND requests, as follows: - None. The LDAP BIND request is issued with the caller-specified options. - Negotiate signing. If Transport Layer Security/Secure Sockets Layer (TLS/SSL) has not been started, the LDAP BIND request is initiated with the LDAP data signing option set in addition to the caller-specified options. If TLS/SSL has been started, the LDAP BIND request is initiated with the caller-specified options. - Require signature. This level is the same as Negotiate signing. However, if the LDAP server's intermediate saslBindInProgress response does not indicate that LDAP traffic signing is required, the caller is told that the LDAP BIND command request failed. Note: This policy setting does not have any impact on ldap_simple_bind or ldap_simple_bind_s. No Microsoft LDAP clients that are included with Windows XP Professional use ldap_simple_bind or ldap_simple_bind_s to communicate with a domain controller. The possible values for the Network security: LDAP client signing requirements setting are: - None - Negotiate signing - Require signature - Not Defined The recommended state for this setting is: *Negotiate signing*.

Rationale:

Unsigned network traffic is susceptible to man-in-the-middle attacks in which an intruder captures the packets between the client and server, modifies them, and then forwards them to the server. For an LDAP server, this susceptibility means that an attacker could cause a server to make decisions that are based on false or altered data from the LDAP queries. To lower this risk in your network, you can implement strong physical security measures to protect the network infrastructure. Also, you can make all types of man-in-the-middle attacks extremely difficult if you require digital signatures on all network packets by means of IPsec authentication headers.

Impact:

If you configure the server to require LDAP signatures you must also configure the client. If you do not configure the client it will not be able to communicate with the server, which could cause many features to fail, including user authentication, Group Policy, and logon scripts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LDAP\LDAPClientIntegrity
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Negotiate signing.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: LDAP client signing requirements
```

Default Value:

Negotiate signing

References:

1. CCE-23400-5

1.1.3.11.17 Configure 'Network security: Force logoff when logon hours expire' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting, which determines whether to disconnect users who are connected to the local computer outside their user account's valid logon hours, affects the SMB component. If you enable this policy setting, client sessions with the SMB server will be disconnected when the client's logon hours expire. If you disable this policy setting, established client sessions will be maintained after the client's logon hours expire. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

If you disable this policy setting, a user could remain connected to the computer outside of their allotted logon hours.

Impact:

When a user's logon time expires, SMB sessions will terminate. The user will be unable to log on to the computer until their next scheduled access time commences.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Force logoff when logon hours expire
```

Default Value:

Disabled

References:

1. CCE-23549-9

1.1.3.12 Recovery console

ARCHIVE

1.1.3.12.1 Set 'Recovery console: Allow automatic administrative logon' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The recovery console is a command-line environment that is used to recover from system problems. If you enable this policy setting, the administrator account is automatically logged on to the recovery console when it is invoked during startup. The recommended state for this setting is: *Disabled*.

Rationale:

The Recovery Console can be very useful when you need to troubleshoot and repair computers that do not start. However, it is dangerous to allow automatic logon to the console. Anyone could walk up to the server, disconnect the power to shut it down, restart it, select Recover Console from the Restart menu, and then assume full control of the server.

Impact:

Users will have to enter a user name and password to access the Recovery Console.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows  
NT\CurrentVersion\Setup\RecoveryConsole\securitylevel
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\Recovery console: Allow automatic administrative  
logon
```

Default Value:

Disabled

References:

1. CCE-22384-2

ARCHIVE

1.1.3.12.2 Set 'Recovery console: Allow floppy copy and access to all drives and all folders' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting makes the Recovery Console SET command available, which allows you to set the following recovery console environment variables:

- `AllowWildCards`. Enables wildcard support for some commands (such as the `DEL` command).
- `AllowAllPaths`. Allows access to all files and folders on the computer.
- `AllowRemovableMedia`. Allows files to be copied to removable media, such as a floppy disk.
- `NoCopyPrompt`. Does not prompt when overwriting an existing file.

The recommended state for this setting is: `Disabled`.

Rationale:

An attacker who can cause the system to restart into the Recovery Console could steal sensitive data and leave no audit or access trail.

Impact:

Users who have started a server through the Recovery Console and logged in with the built-in Administrator account will not be able to copy files and folders to a floppy disk.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Setup\RecoveryConsole\setcommand

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Recovery console: Allow floppy copy and access to all drives and all folders

Default Value:

Disabled

References:

1. CCE-23133-2

ARCHIVE

1.1.3.13 Shutdown

ARCHIVE

1.1.3.13.1 Set 'Shutdown: Clear virtual memory pagefile' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the virtual memory pagefile is cleared when the system is shut down. When this policy setting is enabled, the system pagefile is cleared each time that the system shuts down properly. If you enable this security setting, the hibernation file (Hiberfil.sys) is zeroed out when hibernation is disabled on a portable computer system. It will take longer to shut down and restart the computer, and will be especially noticeable on computers with large paging files. The recommended state for this setting is: *Disabled*.

Rationale:

Important information that is kept in real memory may be written periodically to the page file to help Windows Server 2003 handle multitasking functions. An attacker who has physical access to a server that has been shut down could view the contents of the paging file. The attacker could move the system volume into a different computer and then analyze the contents of the paging file. Although this process is time consuming, it could expose data that is cached from random access memory (RAM) to the paging file. **Caution** An attacker who has physical access to the server could bypass this countermeasure by simply unplugging the server from its power source.

Impact:

It will take longer to shut down and restart the server, especially on servers with large paging files. For a server with 2 gigabytes (GB) of RAM and a 2-GB paging file, this policy setting could increase the shutdown process by 20 to 30 minutes, or more. For some organizations, this downtime violates their internal service level agreements. Therefore, use caution before you implement this countermeasure in your environment.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager\Memory Management\ClearPageFileAtShutdown
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Shutdown: Clear virtual memory pagefile
```

Default Value:

Disabled

References:

1. CCE-22950-0

1.1.3.13.2 Set 'Shutdown: Allow system to be shut down without having to log on' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether a computer can be shut down when a user is not logged on. If this policy setting is enabled, the shutdown command is available on the Windows logon screen. It is recommended to disable this policy setting to restrict the ability to shut down the computer to users with credentials on the system. The recommended state for this setting is: *Enabled*.

Rationale:

Users who can access the console locally could shut down the computer. Attackers could also walk to the local console and restart the server, which would cause a temporary DoS condition. Attackers could also shut down the server and leave all of its applications and services unavailable.

Impact:

Operators will have to log on to servers to shut them down or restart them.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\ShutdownWithoutLogon
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Shutdown: Allow system to be shut down without having to log on
```

Default Value:

Enabled

References:

1. CCE-22913-8

ARCHIVE

1.1.3.14 System cryptography

ARCHIVE

1.1.3.14.1 Configure 'System cryptography: Force strong key protection for user keys stored on the computer' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether users' private keys (such as their S-MIME keys) require a password to be used. If you configure this policy setting so that users must provide a password—distinct from their domain password—every time that they use a key, then it will be more difficult for an attacker to access locally stored keys, even an attacker who discovers logon passwords. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

If a user's account is compromised or their computer is inadvertently left unsecured the malicious user can use the keys stored for the user to access protected resources. You can configure this policy setting so that users must provide a password that is distinct from their domain password every time they use a key. This configuration makes it more difficult for an attacker to access locally stored user keys, even if the attacker takes control of the user's computer and determines their logon password.

Impact:

Users will have to enter their password every time they access a key that is stored on their computer. For example, if users use an S-MIME certificate to digitally sign their e-mail they will be forced to enter the password for that certificate every time they send a signed e-mail message. For some organizations the overhead that is involved using this configuration may be too high. For end user computers that are used to access sensitive data this setting could be set to "User is prompted when the key is first used," but Microsoft does not recommend enforcing this setting on servers due to the significant impact on manageability. For example, if this setting is configured to "User is prompted when the key is first used" you may not be able to configure Remote Desktop Services to use SSL certificates. More information is available in the Windows PKI blog: <http://blogs.technet.com/b/pki/archive/2009/06/17/what-is-a-strong-key-protection-in-windows.aspx>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Cryptography\ForceKeyProtection
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\System cryptography: Force strong key protection for user keys stored on the computer
```

Default Value:

Disabled

References:

1. CCE-21543-4

1.1.3.14.2 Set 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether the Transport Layer Security/Secure Sockets Layer (TLS/SSL) Security Provider supports only the `TLS\RSA\WITH_3DES\EDE\CBC\SHA` cipher suite. Although this policy setting increases security, most public Web sites that are secured with TLS or SSL do not support these algorithms. Client computers that have this policy setting enabled will also be unable to connect to Terminal Services on servers that are not configured to use the FIPS compliant algorithms. Note If you enable this policy setting, computer performance will be slower because the 3DES process is performed on each block of data in the file three times. This policy setting should only be enabled if your organization is required to be FIPS compliant. Important: This setting is recorded in different registry locations depending upon the version of Windows being used. For Windows XP and Windows Server 2003 it is stored at `HKLM\System\CurrentControlSet\Control\Lsa\FIPSAAlgorithmPolicy`, with Windows Vista and later versions of Windows it is stored at `HKLM\System\CurrentControlSet\Control\Lsa\FIPSAAlgorithmPolicy\Enabled`. This means that you must use Windows XP or Windows Server 2003 to edit group policies and security templates which will be applied to computers running Windows XP or Windows Server 2003. However, when editing group policies or security templates which will be applied to computers running Windows Vista or Windows Server 2008 you must use Windows Vista or Windows Server 2008. The recommended state for this setting is: `Enabled`.

Rationale:

You can enable this policy setting to ensure that the computer will use the most powerful algorithms that are available for digital encryption, hashing and signing. Use of these algorithms will minimize the risk of compromise of digitally encrypted or signed data by an unauthorized user.

Impact:

Client computers that have this policy setting enabled will be unable to communicate by means of digitally encrypted or signed protocols with servers that do not support these algorithms. Network clients that do not support these algorithms will not be able to use servers that require them for network communications. For example, many Apache-based Web servers are not configured to support TLS. If you enable this setting, you also need to configure Internet Explorer to use TLS. This policy setting also affects the encryption level that is used for the Remote Desktop Protocol (RDP). The Remote Desktop Connection tool uses the RDP protocol to communicate with servers that run Terminal Services and client computers that are configured for remote control; RDP connections will fail if both computers are not configured to use the same encryption algorithms. To enable Internet Explorer to use TLS 1. On the Internet Explorer Tools menu, click Internet Options. 2. Click the Advanced tab. 3. Select the Use TLS 1.0 check box. It is also possible to configure this policy setting through Group Policy or by using the Internet Explorer Administrators Kit. Client computers running Windows XP, Windows XP SP1 and Windows XP SP2 that try to connect to a Terminal Services server that has this setting enabled will be unable to communicate with the server until an updated version of the Terminal Services client is installed. This issue could also affect Remote Assistance and Remote Desktop connections. For more information about the issue and how to resolve it see "Remote Assistance connection to Windows Server 2003 with FIPS encryption does not work" at <http://support.microsoft.com/default.aspx?scid=kb;en-us;811770>. Microsoft .NET Framework applications such as Microsoft ASP.NET that use cryptographic algorithms which are not validated by NIST to be FIPS 140 compliant may fail. Use of cryptographic algorithm classes that are not FIPS validated will cause an InvalidOperationException exception to occur. See "System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing" security setting effects in Windows XP and in later versions of Windows" for more information: <http://support.microsoft.com/kb/811833>. For more information about the impact of this setting see "FIPS 140 Evaluation" available at: <http://technet.microsoft.com/en-us/library/cc750357.aspx>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\FIPSAlgorithmPolicy\Enabled

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing

Default Value:

Disabled

References:

1. CCE-21453-6

ARCHIVE

1.1.3.15 System objects

ARCHIVE

1.1.3.15.1 Set 'System objects: Strengthen default permissions of internal system objects (e.g' Symbolic Links)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the strength of the default discretionary access control list (DACL) for objects. The setting helps secure objects that can be located and shared among processes and its default configuration strengthens the DACL, because it allows users who are not administrators to read shared objects but does not allow them to modify any that they did not create. The recommended state for this setting is: `Enabled`.

Rationale:

This setting determines the strength of the default DACL for objects. Windows Server 2003 maintains a global list of shared computer resources so that objects can be located and shared among processes. Each type of object is created with a default DACL that specifies who can access the objects and with what permissions. If you enable this setting, the default DACL is strengthened because non-administrator users are allowed to read shared objects but not modify shared objects that they did not create.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session  
Manager\ProtectionMode
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)

Default Value:

Enabled

References:

1. CCE-22783-5

ARCHIVE

1.1.3.15.2 Set 'System objects: Require case insensitivity for non-Windows subsystems' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether case insensitivity is enforced for all subsystems. The Microsoft Win32' subsystem is case insensitive. However, the kernel supports case sensitivity for other subsystems, such as the Portable Operating System Interface for UNIX (POSIX). Because Windows is case insensitive (but the POSIX subsystem will support case sensitivity), failure to enforce this policy setting makes it possible for a user of the POSIX subsystem to create a file with the same name as another file by using mixed case to label it. Such a situation can block access to these files by another user who uses typical Win32 tools, because only one of the files will be available. The recommended state for this setting is: *Enabled*.

Rationale:

Because Windows is case-insensitive but the POSIX subsystem will support case sensitivity, failure to enable this policy setting would make it possible for a user of that subsystem to create a file with the same name as another file but with a different mix of upper and lower case letters. Such a situation could potentially confuse users when they try to access such files from normal Win32 tools because only one of the files will be available.

Impact:

All subsystems will be forced to observe case insensitivity. This configuration may confuse users who are familiar with any UNIX-based operating systems that is case-sensitive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session  
Manager\Kernel\ObCaseInsensitive
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\System objects: Require case insensitivity for non-Windows subsystems

Default Value:

Enabled

References:

1. CCE-22786-8

ARCHIVE

1.1.3.16 System settings

ARCHIVE

1.1.3.16.1 Configure 'System settings: Optional subsystems' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which subsystems are used to support applications in your environment. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

The POSIX subsystem is an Institute of Electrical and Electronic Engineers (IEEE) standard that defines a set of operating system services. The POSIX subsystem is required if the server supports applications that use that subsystem. The POSIX subsystem introduces a security risk that relates to processes that can potentially persist across logons. If a user starts a process and then logs out, there is a potential that the next user who logs on to the computer could access the previous user's process. This potential is dangerous, because anything the second user does with that process will be performed with the privileges of the first user.

Impact:

Applications that rely on the POSIX subsystem will no longer operate. For example, Microsoft Services for Unix (SFU) installs an updated version of the POSIX subsystem that is required, so you would need to reconfigure this setting in a Group Policy for any servers that use SFU.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session  
Manager\SubSystems\optional
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

```
Computer Configuration\Windows Settings\Security Settings\Local  
Policies\Security Options\System settings: Optional subsystems
```

Default Value:

Posix

References:

1. CCE-22551-6

1.1.3.16.2 Configure 'System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether digital certificates are processed when software restriction policies are enabled and a user or process attempts to run software with an .exe file name extension. It enables or disables certificate rules (a type of software restriction policies rule). With software restriction policies, you can create a certificate rule that will allow or disallow the execution of Authenticode'-signed software, based on the digital certificate that is associated with the software. For certificate rules to take effect in software restriction policies, you must enable this policy setting. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Software restriction policies help to protect users and computers because they can prevent the execution of unauthorized code, such as viruses and Trojans horses.

Impact:

If you enable certificate rules, software restriction policies check a certificate revocation list (CRL) to ensure that the software's certificate and signature are valid. This checking process may negatively affect performance when signed programs start. To disable this feature you can edit the software restriction policies in the desired GPO. On the Trusted Publishers Properties dialog box, clear the Publisher and Timestamp check boxes.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Safer\CodeIdentifiers\
AuthenticodeEnabled
```

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies

Default Value:

Disabled

References:

1. CCE-22340-4

ARCHIVE

1.1.3.17 User Account Control

ARCHIVE

1.1.3.17.1 Set 'User Account Control: Admin Approval Mode for the Built-in Administrator account' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the behavior of Admin Approval Mode for the built-in Administrator account. The options are: - Enabled: The built-in Administrator account uses Admin Approval Mode. By default, any operation that requires elevation of privilege will prompt the user to approve the operation. - Disabled: (Default) The built-in Administrator account runs all applications with full administrative privilege. The recommended state for this setting is: *Enabled*.

Rationale:

One of the risks that the User Account Control feature introduced with Windows Vista is trying to mitigate is that of malicious software running under elevated credentials without the user or administrator being aware of its activity. An attack vector for these programs was to discover the password of the account named "Administrator" because that user account was created for all installations of Windows. To address this risk, in Windows Vista the built-in Administrator account is disabled. In a default installation of a new computer, accounts with administrative control over the computer are initially set up in one of two ways: - If the computer is not joined to a domain, the first user account you create has the equivalent permissions as a local administrator. - If the computer is joined to a domain, no local administrator accounts are created. The Enterprise or Domain Administrator must log on to the computer and create one if a local administrator account is warranted. Once Windows Vista is installed, the built-in Administrator account may be enabled, but we strongly recommend that this account remain disabled.

Impact:

Users that log on using the local Administrator account will be prompted for consent whenever a program requests an elevation in privilege.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
FilterAdministratorToken
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\User Account Control: Admin Approval Mode for the
Built-in Administrator account
```

Default Value:

Disabled

References:

1. CCE-22294-3

1.1.3.17.2 Set 'User Account Control: Detect application installations and prompt for elevation' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the behavior of application installation detection for the computer. The options are: - Enabled: (Default for home) When an application installation package is detected that requires elevation of privilege, the user is prompted to enter an administrative user name and password. If the user enters valid credentials, the operation continues with the applicable privilege. - Disabled: (Default for enterprise) Application installation packages are not detected and prompted for elevation. Enterprises that are running standard user desktops and use delegated installation technologies such as Group Policy Software Installation or Systems Management Server (SMS) should disable this policy setting. In this case, installer detection is unnecessary. The recommended state for this setting is: `Enabled`.

Rationale:

Some malicious software will attempt to install itself after being given permission to run. For example, malicious software with a trusted application shell. The user may have given permission for the program to run because the program is trusted, but if they are then prompted for installation of an unknown component this provides another way of trapping the software before it can do damage

Impact:

Users will need to provide administrative passwords to be able to install programs.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
EnableInstallerDetection
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Detect application installations and prompt for elevation

Default Value:

Enabled

References:

1. CCE-22466-7

ARCHIVE

1.1.3.17.3 Set 'User Account Control: Behavior of the elevation prompt for standard users' to 'Automatically deny elevation requests' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the behavior of the elevation prompt for standard users. The options are: - Prompt for credentials: When an operation requires elevation of privilege, the user is prompted to enter an administrative user name and password. If the user enters valid credentials, the operation continues with the applicable privilege. - Automatically deny elevation requests: When an operation requires elevation of privilege, a configurable access denied error message is displayed. An enterprise that is running desktops as standard user may choose this setting to reduce help desk calls. - Prompt for credentials on the secure desktop: (Default) When an operation requires elevation of privilege, the user is prompted on the secure desktop to enter a different user name and password. If the user enters valid credentials, the operation continues with the applicable privilege. Note that this option was introduced in Windows 7 and it is not applicable to computers running Windows Vista or Windows Server 2008. The recommended state for this setting is: *Automatically deny elevation requests*.

Rationale:

One of the risks that the User Account Control feature introduced with Windows Vista is trying to mitigate is that of malicious programs running under elevated credentials without the user or administrator being aware of their activity. This setting raises awareness to the user that a program requires the use of elevated privilege operations and requires that the user be able to supply administrative credentials in order for the program to run.

Impact:

Users will need to provide administrative passwords to be able to run programs with elevated privileges. This could cause an increased load on IT staff while the programs that are impacted are identified and standard operating procedures are modified to support least privilege operations.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
ConsentPromptBehaviorUser
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Automatically deny elevation requests.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\User Account Control: Behavior of the elevation
prompt for standard users
```

Default Value:

Prompt for credentials

References:

1. CCE-21703-4

1.1.3.17.4 Set 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' to 'Prompt for consent on the secure desktop' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the behavior of the elevation prompt for administrators. The options are: - Elevate without prompting: Allows privileged accounts to perform an operation that requires elevation without requiring consent or credentials. Note: Use this option only in the most constrained environments. - Prompt for credentials on the secure desktop: When an operation requires elevation of privilege, the user is prompted on the secure desktop to enter a privileged user name and password. If the user enters valid credentials, the operation continues with the user's highest available privilege. - Prompt for consent on the secure desktop: When an operation requires elevation of privilege, the user is prompted on the secure desktop to select either Permit or Deny. If the user selects Permit, the operation continues with the user's highest available privilege. - Prompt for credentials: When an operation requires elevation of privilege, the user is prompted to enter an administrative user name and password. If the user enters valid credentials, the operation continues with the applicable privilege. - Prompt for consent: When an operation requires elevation of privilege, the user is prompted to select either Permit or Deny. If the user selects Permit, the operation continues with the user's highest available privilege. - Prompt for consent for non-Windows binaries: (Default) When an operation for a non-Microsoft application requires elevation of privilege, the user is prompted on the secure desktop to select either Permit or Deny. If the user selects Permit, the operation continues with the user's highest available privilege. The recommended state for this setting is: `Prompt for consent on the secure desktop`.

Rationale:

One of the risks that the UAC feature introduced with Windows Vista is trying to mitigate is that of malicious software running under elevated credentials without the user or administrator being aware of its activity. This setting raises awareness to the administrator of elevated privilege operations and permits the administrator to prevent a malicious program from elevating its privilege when the program attempts to do so.

Impact:

This policy setting controls the behavior of the elevation prompt for administrators.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
ConsentPromptBehaviorAdmin
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Prompt` for consent on the secure desktop.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\User Account Control: Behavior of the elevation
prompt for administrators in Admin Approval Mode
```

Default Value:

Prompt for consent for non-Windows binaries

References:

1. CCE-22243-0

1.1.3.17.5 Set 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls whether applications that request to run with a User Interface Accessibility (UIAccess) integrity level must reside in a secure location in the file system. Secure locations are limited to the following: - ...\\Program Files\\, including subfolders - ...\\Windows\\system32\\ - ...\\Program Files (x86)\\, including subfolders for 64-bit versions of Windows Note: Windows enforces a public key infrastructure (PKI) signature check on any interactive application that requests to run with a UIAccess integrity level regardless of the state of this security setting. The options are: - Enabled: (Default) If an application resides in a secure location in the file system, it runs only with UIAccess integrity. - Disabled: An application runs with UIAccess integrity even if it does not reside in a secure location in the file system. The recommended state for this setting is: *Enabled*.

Rationale:

UIAccess Integrity allows an application to bypass User Interface Privilege Isolation (UIPI) restrictions when an application is elevated in privilege from a standard user to an administrator. This is required to support accessibility features such as screen readers that are transmitting user interfaces to alternative forms. A process that is started with UIAccess rights has the following abilities: - To set the foreground window. - To drive any application window using SendInput function. - To use read input for all integrity levels using low-level hooks, raw input, GetKeyState, GetAsyncKeyState, and GetKeyboardInput. - To set journal hooks. - To uses AttachThreadInput to attach a thread to a higher integrity input queue.

Impact:

If the application that requests UIAccess meets the UIAccess setting requirements, Windows Vista starts the application with the ability to bypass most of the UIPI restrictions. If the application does not meet the security restrictions, the application will be started without UIAccess rights and can interact only with applications at the same or lower privilege level.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
EnableSecureUIAPaths
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\User Account Control: Only elevate UIAccess
applications that are installed in secure locations
```

Default Value:

Enabled

References:

1. CCE-22553-2

1.1.3.17.6 Set 'User Account Control: Virtualize file and registry write failures to per-user locations' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls whether application write failures are redirected to defined registry and file system locations. This policy setting mitigates applications that run as administrator and write run-time application data to %ProgramFiles%, %Windir%, %Windir%\system32, or HKLM\Software. The options are: - Enabled: (Default) Application write failures are redirected at run time to defined user locations for both the file system and registry. - Disabled: Applications that write data to protected locations fail. The recommended state for this setting is: *Enabled*.

Rationale:

This setting reduces vulnerabilities by ensuring that legacy applications only write data to permitted locations.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\EnableVirtualization

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Virtualize file and registry write failures to per-user locations

Default Value:

Enabled

References:

1. CCE-22126-7

ARCHIVE

1.1.3.17.7 Set 'User Account Control: Switch to the secure desktop when prompting for elevation' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls whether the elevation request prompt is displayed on the interactive user's desktop or the secure desktop. The options are: - Enabled: (Default) All elevation requests go to the secure desktop regardless of prompt behavior policy settings for administrators and standard users. - Disabled: All elevation requests go to the interactive user's desktop. Prompt behavior policy settings for administrators and standard users are used. The recommended state for this setting is: *Enabled*.

Rationale:

Elevation prompt dialog boxes can be spoofed, causing users to disclose their passwords to malicious software.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
PromptOnSecureDesktop
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\User Account Control: Switch to the secure desktop
when prompting for elevation
```

Default Value:

Enabled

References:

1. CCE-21801-6

1.1.3.17.8 Set 'User Account Control: Allow UIAccess applications to prompt for elevation without using the secure desktop' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls whether User Interface Accessibility (UIAccess or UIA) programs can automatically disable the secure desktop for elevation prompts used by a standard user. - Enabled: UIA programs, including Windows Remote Assistance, automatically disable the secure desktop for elevation prompts. If you do not disable the "User Account Control: Switch to the secure desktop when prompting for elevation" policy setting, the prompts appear on the interactive user's desktop instead of the secure desktop. - Disabled: (Default) The secure desktop can be disabled only by the user of the interactive desktop or by disabling the "User Account Control: Switch to the secure desktop when prompting for elevation" policy setting. The recommended state for this setting is: *Disabled*.

Rationale:

One of the risks that the UAC feature introduced with Windows Vista is trying to mitigate is that of malicious software running under elevated credentials without the user or administrator being aware of its activity. This setting allows the administrator to perform operations that require elevated privileges while connected via Remote Assistance. This increases security in that organizations can use UAC even when end user support is provided remotely. However, it also reduces security by adding the risk that an administrator might allow an unprivileged user to share elevated privileges for an application that the administrator needs to use during the Remote Desktop session.

Impact:

If you enable this setting, ("User Account Control: Allow UIAccess applications to prompt for elevation without using the secure desktop"), requests for elevation are automatically sent to the interactive desktop (not the secure desktop) and also appear on the remote administrator's view of the desktop during a Windows Remote Assistance session, and the remote administrator is able to provide the appropriate credentials for elevation. This setting does not change the behavior of the UAC elevation prompt for administrators.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\
EnableUIADesktopToggle
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\User Account Control: Allow UIAccess applications
to prompt for elevation without using the secure desktop
```

Default Value:

Disabled

References:

1. CCE-21458-5

1.1.3.17.9 Set 'User Account Control: Only elevate executables that are signed and validated' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting enforces public key infrastructure (PKI) signature checks for any interactive applications that request elevation of privilege. Enterprise administrators can control which applications are allowed to run by adding certificates to the Trusted Publishers certificate store on local computers. The options are: - Enabled: Enforces the PKI certification path validation for a given executable file before it is permitted to run. - Disabled: (Default) Does not enforce PKI certification path validation before a given executable file is permitted to run. The recommended state for this setting is: `Disabled`.

Rationale:

Intellectual property, personally identifiable information, and other confidential data are normally manipulated by applications on the computer and require elevated credentials to get access to the information. Users and administrators inherently trust applications used with these information sources and provide their credentials. If one of these applications is replaced by a rogue application that appears identical to the trusted application the confidential data could be compromised and the user's administrative credentials would also be compromised.

Impact:

Enabling this setting requires that you have a PKI infrastructure and that your Enterprise administrators have populated the Trusted Root Store with the certificates for the allowed applications. Some older applications are not signed and will not be able to be used in an environment that is hardened with this setting. You should carefully test your applications in a pre-production environment before implementing this setting. For information about the steps required to test application compatibility, make application compatibility fixes, and sign installer packages to prepare your organization for deployment of Windows Vista User Account Control, see Understanding and Configuring User Account Control in Windows Vista (<http://go.microsoft.com/fwlink/?LinkID=79026>). Control over the applications that are installed on the desktops and the hardware that is able to join your domain should provide similar protection from the vulnerability addressed by this setting. Additionally, the level of protection provided by this setting is not an assurance that all rogue applications will be found

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
ValidateAdminCodeSignatures
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\User Account Control: Only elevate executables that
are signed and validated
```

Default Value:

Disabled

References:

1. CCE-22436-0

1.1.3.17.10 Set 'User Account Control: Run all administrators in Admin Approval Mode' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the behavior of all User Account Control (UAC) policy settings for the computer. If you change this policy setting, you must restart your computer. The options are: - Enabled: (Default) Admin Approval Mode is enabled. This policy must be enabled and related UAC policy settings must also be set appropriately to allow the built-in Administrator account and all other users who are members of the Administrators group to run in Admin Approval Mode. - Disabled: Admin Approval Mode and all related UAC policy settings are disabled. Note: If this policy setting is disabled, the Security Center notifies you that the overall security of the operating system has been reduced. The recommended state for this setting is: *Enabled*.

Rationale:

This is the setting that turns on or off UAC. If this setting is disabled, UAC will not be used and any security benefits and risk mitigations that are dependent on UAC will not be present on the system.

Impact:

Users and administrators will need to learn to work with UAC prompts and adjust their work habits to use least privilege operations.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\
EnableLUA
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Run all administrators in Admin Approval Mode

Default Value:

Enabled

References:

1. CCE-21534-3

ARCHIVE

1.1.4 User Rights Assignment

ARCHIVE

1.1.4.1 Configure 'Allow log on through Remote Desktop Services' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users or groups have the right to log on as a Terminal Services client. Remote desktop users require this user right. If your organization uses Remote Assistance as part of its help desk strategy, create a group and assign it this user right through Group Policy. If the help desk in your organization does not use Remote Assistance, assign this user right only to the Administrators group or use the restricted groups feature to ensure that no user accounts are part of the Remote Desktop Users group. Restrict this user right to the Administrators group, and possibly the Remote Desktop Users group, to prevent unwanted users from gaining access to computers on your network by means of the Remote Assistance feature. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Any account with the Allow log on through Terminal Services user right can log on to the remote console of the computer. If you do not restrict this user right to legitimate users who need to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

Impact:

Removal of the Allow log on through Terminal Services user right from other groups or membership changes in these default groups could limit the abilities of users who perform specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Allow log on through Remote Desktop Services

Default Value:

Administrators, Remote Desktop Users

References:

1. CCE-21927-9

ARCHIVE

1.1.4.2 Set 'Deny log on through Remote Desktop Services' to 'Guests' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether users can log on as Terminal Services clients. After the baseline member server is joined to a domain environment, there is no need to use local accounts to access the server from the network. Domain accounts can access the server for administration and end-user processing. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Guests`.

Rationale:

Any account with the right to log on through Terminal Services could be used to log on to the remote console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

Impact:

If you assign the Deny log on through Terminal Services user right to other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. Accounts that have this user right will be unable to connect to the computer through either Terminal Services or Remote Assistance. You should confirm that delegated tasks will not be negatively impacted.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Guests`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on through Remote Desktop Services
```

Default Value:

No one

References:

1. CCE-21638-2

ARCHIVE

1.1.4.3 Set 'Deny access to this computer from the network' to 'Guests' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting prohibits users from connecting to a computer from across the network, which would allow users to access and potentially modify data remotely. In high security environments, there should be no need for remote users to access data on a computer. Instead, file sharing should be accomplished through the use of network servers. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Guests`.

Rationale:

Users who can log on to the computer over the network can enumerate lists of account names, group names, and shared resources. Users with permission to access shared folders and files can connect over the network and possibly view or modify data.

Impact:

If you configure the Deny access to this computer from the network user right for other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should verify that delegated tasks will not be negatively affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Guests`.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny access to this computer from the network

Default Value:

Guest

References:

1. CCE-21840-4

ARCHIVE

1.1.4.4 Set 'Create a pagefile' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to change the size of the pagefile. By making the pagefile extremely large or extremely small, an attacker could easily affect the performance of a compromised computer. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

Users who can change the page file size could make it extremely small or move the file to a highly fragmented storage volume, which could cause reduced computer performance.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create a pagefile
```

Default Value:

`Administrators`

References:

1. CCE-21617-6

1.1.4.5 Set 'Create permanent shared objects' to 'No One' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This user right is useful to kernel-mode components that extend the object namespace. However, components that run in kernel mode have this user right inherently. Therefore, it is typically not necessary to specifically assign this user right. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: No One.

Rationale:

Users who have the Create permanent shared objects user right could create new shared objects and expose sensitive data to the network.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to No One.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create permanent shared objects
```

Default Value:

No one

References:

1. CCE-22141-6

1.1.4.6 Set 'Increase scheduling priority' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether users can increase the base priority class of a process. (It is not a privileged operation to increase relative priority within a priority class.) This user right is not required by administrative tools that are supplied with the operating system but might be required by software development tools. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

A user who is assigned this user right could increase the scheduling priority of a process to Real-Time, which would leave little processing time for all other processes and could lead to a DoS condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Increase scheduling priority
```

Default Value:

`Administrators`

References:

1. CCE-22960-9

1.1.4.7 Set 'Access this computer from the network' to 'Users, Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows other users on the network to connect to the computer and is required by various network protocols that include Server Message Block (SMB)–based protocols, NetBIOS, Common Internet File System (CIFS), and Component Object Model Plus (COM+). When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Users, Administrators.`

Rationale:

Users who can connect from their computer to the network can access resources on target computers for which they have permission. For example, the Access this computer from the network user right is required for users to connect to shared printers and folders. If this user right is assigned to the Everyone group, then anyone in the group will be able to read the files in those shared folders. However, this situation is unlikely for new installations of Windows Server 2003 with Service Pack 1 (SP1), because the default share and NTFS permissions in Windows Server 2003 do not include the Everyone group. This vulnerability may have a higher level of risk for computers that you upgrade from Windows NT 4.0 or Windows 2000, because the default permissions for these operating systems are not as restrictive as the default permissions in Windows Server 2003.

Impact:

If you remove the Access this computer from the network user right on domain controllers for all users, no one will be able to log on to the domain or use network resources. If you remove this user right on member servers, users will not be able to connect to those servers through the network. Successful negotiation of IPsec connections requires that the initiating machine has this right, therefore it is recommended that it be assigned to the Users group. If you have installed optional components such as ASP.NET or Internet Information Services (IIS), you may need to assign this user right to additional accounts that are required by those components. It is important to verify that authorized users are assigned this user right for the computers they need to access the network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Users, Administrators`.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Access this computer from the network

Default Value:

Everyone, Administrators, Users, Backup Operators

References:

1. CCE-22976-5

1.1.4.8 Set 'Force shutdown from a remote system' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to shut down Windows Vista–based computers from remote locations on the network. Anyone who has been assigned this user right can cause a denial of service (DoS) condition, which would make the computer unavailable to service user requests. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is:

Administrators.

Rationale:

Any user who can shut down a computer could cause a DoS condition to occur. Therefore, this user right should be tightly restricted.

Impact:

If you remove the Force shutdown from a remote system user right from the Server Operator group you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Force shutdown from a remote system

Default Value:

Administrators

References:

1. CCE-22886-6

ARCHIVE

1.1.4.9 Set 'Change the time zone' to 'LOCAL SERVICE, Administrators, Users' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting determines which users can change the time zone of the computer. This ability holds no great danger for the computer and may be useful for mobile workers. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `LOCAL SERVICE, Administrators, Users`.

Rationale:

Changing the time zone represents little vulnerability because the system time is not affected. This setting merely enables users to display their preferred time zone while being synchronized with domain controllers in different time zones.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `LOCAL SERVICE, Administrators, Users`.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Change the time zone

Default Value:

LOCAL SERVICE, Administrators, Users

References:

1. CCE-22291-9

1.1.4.10 Set 'Create global objects' to 'Administrators, SERVICE, LOCAL SERVICE, NETWORK SERVICE' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines whether users can create global objects that are available to all sessions. Users can still create objects that are specific to their own session if they do not have this user right. Users who can create global objects could affect processes that run under other users' sessions. This capability could lead to a variety of problems, such as application failure or data corruption. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: Administrators, SERVICE, LOCAL SERVICE, NETWORK SERVICE.

Rationale:

Users who can create global objects could affect Windows services and processes that run under other user or system accounts. This capability could lead to a variety of problems, such as application failure, data corruption and elevation of privilege.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators, SERVICE, LOCAL SERVICE, NETWORK SERVICE.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create global objects

Default Value:

Administrators, SERVICE, Local Service, Network Service

References:

1. CCE-21432-0

ARCHIVE

1.1.4.11 Set 'Enable computer and user accounts to be trusted for delegation' to 'No One' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to change the Trusted for Delegation setting on a computer object in Active Directory. Abuse of this privilege could allow unauthorized users to impersonate other users on the network. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: No One.

Rationale:

Misuse of the Enable computer and user accounts to be trusted for delegation user right could allow unauthorized users to impersonate other users on the network. An attacker could exploit this privilege to gain access to network resources and make it difficult to determine what has happened after a security incident.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to No One.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Enable computer and user accounts to be trusted for delegation
```

Default Value:

No one

References:

1. CCE-23258-7

1.1.4.12 Set 'Profile single process' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users can use tools to monitor the performance of non-system processes. Typically, you do not need to configure this user right to use the Microsoft Management Console (MMC) Performance snap-in. However, you do need this user right if System Monitor is configured to collect data using Windows Management Instrumentation (WMI). Restricting the Profile single process user right prevents intruders from gaining additional information that could be used to mount an attack on the system. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is:

Administrators.

Rationale:

The Profile single process user right presents a moderate vulnerability. An attacker with this user right could monitor a computer's performance to help identify critical processes that they might wish to attack directly. The attacker may also be able to determine what processes run on the computer so that they could identify countermeasures that they may need to avoid, such as antivirus software, an intrusion-detection system, or which other users are logged on to a computer.

Impact:

If you remove the Profile single process user right from the Power Users group or other accounts, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should ensure that delegated tasks will not be negatively affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Profile single process

Default Value:

Administrators

References:

1. CCE-21895-8

ARCHIVE

1.1.4.13 Set 'Shut down the system' to 'Administrators, Users' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users who are logged on locally to the computers in your environment can shut down the operating system with the Shut Down command. Misuse of this user right can result in a denial of service condition. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators, Users`.

Rationale:

The ability to shut down domain controllers should be limited to a very small number of trusted administrators. Although the Shut down the system user right requires the ability to log on to the server, you should be very careful about which accounts and groups you allow to shut down a domain controller. When a domain controller is shut down, it is no longer available to process logons, serve Group Policy, and answer Lightweight Directory Access Protocol (LDAP) queries. If you shut down domain controllers that possess Flexible SingleMaster Operations (FSMO) roles, you can disable key domain functionality, such as processing logons for new passwords—the Primary Domain Controller (PDC) Emulator role.

Impact:

The impact of removing these default groups from the Shut down the system user right could limit the delegated abilities of assigned roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators, Users.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Shut down the system

Default Value:

Administrators, Backup Operators, Users

References:

1. CCE-21391-8

1.1.4.14 Set 'Take ownership of files or other objects' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to take ownership of files, folders, registry keys, processes, or threads. This user right bypasses any permissions that are in place to protect objects to give ownership to the specified user. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

Any users with the Take ownership of files or other objects user right can take control of any object, regardless of the permissions on that object, and then make any changes they wish to that object. Such changes could result in exposure of data, corruption of data, or a DoS condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Take ownership of files or other objects
```

Default Value:

`Administrators`

References:

1. CCE-23192-8

1.1.4.15 Set 'Create symbolic links' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users can create symbolic links. In Windows Vista, existing NTFS file system objects, such as files and folders, can be accessed by referring to a new kind of file system object called a symbolic link. A symbolic link is a pointer (much like a shortcut or .lnk file) to another file system object, which can be a file, folder, shortcut or another symbolic link. The difference between a shortcut and a symbolic link is that a shortcut only works from within the Windows shell. To other programs and applications, shortcuts are just another file, whereas with symbolic links, the concept of a shortcut is implemented as a feature of the NTFS file system. Symbolic links can potentially expose security vulnerabilities in applications that are not designed to use them. For this reason, the privilege for creating symbolic links should only be assigned to trusted users. By default, only Administrators can create symbolic links. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

Users who have the Create Symbolic Links user right could inadvertently or maliciously expose your system to symbolic link attacks. Symbolic link attacks can be used to change the permissions on a file, to corrupt data, to destroy data, or as a Denial of Service attack.

Impact:

In most cases there will be no impact because this is the default configuration, however, on Windows Servers with the Hyper-V server role installed this user right should also be granted to the special group "Virtual Machines" otherwise you will not be able to create new virtual machines.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create symbolic links

Default Value:

Administrators

References:

1. CCE-22166-3

ARCHIVE

1.1.4.16 Set 'Act as part of the operating system' to 'No One' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows a process to assume the identity of any user and thus gain access to the resources that the user is authorized to access. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: No One.

Rationale:

The Act as part of the operating system user right is extremely powerful. Anyone with this user right can take complete control of the computer and erase evidence of their activities.

Impact:

There should be little or no impact because the Act as part of the operating system user right is rarely needed by any accounts other than the Local System account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to No One.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Act as part of the operating system

Default Value:

No one

References:

1. CCE-23381-7

1.1.4.17 Set 'Modify firmware environment values' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to configure the system-wide environment variables that affect hardware configuration. This information is typically stored in the Last Known Good Configuration. Modification of these values and could lead to a hardware failure that would result in a denial of service condition. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

Anyone who is assigned the Modify firmware environment values user right could configure the settings of a hardware component to cause it to fail, which could lead to data corruption or a DoS condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Modify firmware environment values
```

Default Value:

Administrators

References:

1. CCE-23145-6

1.1.4.18 Set 'Back up files and directories' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to circumvent file and directory permissions to back up the system. This user right is enabled only when an application (such as NTBACKUP) attempts to access a file or directory through the NTFS file system backup application programming interface (API). Otherwise, the assigned file and directory permissions apply. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is:

Administrators.

Rationale:

Users who are able to back up data from a computer could take the backup media to a non-domain computer on which they have administrative privileges and restore the data. They could take ownership of the files and view any unencrypted data that is contained within the backup set.

Impact:

Changes in the membership of the groups that have the Back up files and directories user right could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that authorized backup administrators are still able to perform backup operations.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Back up files and directories

Default Value:

Administrators, Backup Operators

References:

1. CCE-23314-8

ARCHIVE

1.1.4.19 Set 'Debug programs' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which user accounts will have the right to attach a debugger to any process or to the kernel, which provides complete access to sensitive and critical operating system components. Developers who are debugging their own applications do not need to be assigned this user right; however, developers who are debugging new system components will need it. Note Microsoft released several security updates in October 2003 that used a version of Update.exe that required the administrator to have the Debug programs user right. Administrators who did not have this user right were unable to install these security updates until they reconfigured their user rights. This is not typical behavior for operating system updates. For more information, see Knowledge Base article 830846: "Windows Product Updates may stop responding or may use most or all the CPU resources." When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

The Debug programs user right can be exploited to capture sensitive computer information from system memory, or to access and modify kernel or application structures. Some attack tools exploit this user right to extract hashed passwords and other private security information, or to insert rootkit code. By default, the Debug programs user right is assigned only to administrators, which helps to mitigate the risk from this vulnerability.

Impact:

If you revoke this user right, no one will be able to debug programs. However, typical circumstances rarely require this capability on production computers. If a problem arises that requires an application to be debugged on a production server, you can move the server to a different OU temporarily and assign the Debug programs user right to a separate Group Policy for that OU. The service account that is used for the cluster service needs the Debug programs privilege; if it does not have it, Windows Clustering will fail. For additional information about how to configure Windows Clustering in conjunction with computer hardening, see article 891597, How to apply more restrictive security settings on a Windows Server 2003-based cluster server, in the Microsoft Knowledge Base (<http://go.microsoft.com/fwlink/?LinkId=100746>). Tools that are used to manage processes will be unable to affect processes that are not owned by the person who runs the tools. For example, the Windows Server 2003 Resource Kit tool Kill.exe requires this user right for administrators to terminate processes that they did not start. Also, some older versions of Update.exe (which is used to install Windows product updates) require the account that applies the update to have this user right. If you install one of the patches that uses this version of Update.exe, the computer could become unresponsive. For more information, see article 830846, Windows Product Updates may stop responding or may use most or all the CPU resources, in the Microsoft Knowledge Base (<http://go.microsoft.com/fwlink/?LinkId=100747>).

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Debug programs
```

Default Value:

Administrators

References:

1. CCE-21982-4

1.1.4.20 Set 'Access Credential Manager as a trusted caller' to 'No One' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This security setting is used by Credential Manager during Backup and Restore. No accounts should have this user right, as it is only assigned to Winlogon. Users' saved credentials might be compromised if this user right is assigned to other entities. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: No One.

Rationale:

If an account is given this right the user of the account may create an application that calls into Credential Manager and is returned the credentials for another user.

Impact:

None, this is the default configuration

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to No One.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Access Credential Manager as a trusted caller
```

Default Value:

No one

References:

1. CCE-23439-3

1.1.4.21 Set 'Deny log on locally' to 'Guests' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This security setting determines which users are prevented from logging on at the computer. This policy setting supersedes the Allow log on locally policy setting if an account is subject to both policies. Important: If you apply this security policy to the Everyone group, no one will be able to log on locally. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Guests`.

Rationale:

Any account with the ability to log on locally could be used to log on at the console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

Impact:

If you assign the Deny log on locally user right to additional accounts, you could limit the abilities of users who are assigned to specific roles in your environment. However, this user right should explicitly be assigned to the ASPNET account on computers that run IIS 6.0. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Guests`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on locally
```

Default Value:

Guest

References:

1. CCE-22816-3

ARCHIVE

1.1.4.22 Set 'Profile system performance' to 'NT SERVICE\WdiServiceHost,Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to use tools to view the performance of different system processes, which could be abused to allow attackers to determine a system's active processes and provide insight into the potential attack surface of the computer. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: NT

SERVICE\WdiServiceHost,Administrators.

Rationale:

The Profile system performance user right poses a moderate vulnerability. Attackers with this user right could monitor a computer's performance to help identify critical processes that they might wish to attack directly. Attackers may also be able to determine what processes are active on the computer so that they could identify countermeasures that they may need to avoid, such as antivirus software or an intrusion detection system.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to NT
SERVICE\WdiServiceHost,Administrators.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Profile system performance

Default Value:

Administrators,NT SERVICE\WdiServiceHost

References:

1. CCE-21755-4

ARCHIVE

1.1.4.23 Set 'Restore files and directories' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users can bypass file, directory, registry, and other persistent object permissions when restoring backed up files and directories on computers that run Windows Vista in your environment. This user right also determines which users can set valid security principals as object owners; it is similar to the Back up files and directories user right. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

An attacker with the Restore files and directories user right could restore sensitive data to a computer and overwrite data that is more recent, which could lead to loss of important data, data corruption, or a denial of service. Attackers could overwrite executable files that are used by legitimate administrators or system services with versions that include malicious software to grant themselves elevated privileges, compromise data, or install backdoors for continued access to the computer. Note Even if the following countermeasure is configured, an attacker could still restore data to a computer in a domain that is controlled by the attacker. Therefore, it is critical that organizations carefully protect the media that are used to back up data.

Impact:

If you remove the Restore files and directories user right from the Backup Operators group and other accounts you could make it impossible for users who have been delegated specific tasks to perform those tasks. You should verify that this change won't negatively affect the ability of your organization's personnel to do their jobs.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Restore files and directories

Default Value:

Administrators, Backup Operators

References:

1. CCE-23442-7

ARCHIVE

1.1.4.24 Set 'Perform volume maintenance tasks' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to manage the system's volume or disk configuration, which could allow a user to delete a volume and cause data loss as well as a denial-of-service condition. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is:

Administrators.

Rationale:

A user who is assigned the Perform volume maintenance tasks user right could delete a volume, which could result in the loss of data or a DoS condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Perform volume maintenance tasks
```

Default Value:

Administrators

References:

1. CCE-22904-7

1.1.4.25 Set 'Impersonate a client after authentication' to 'Administrators, SERVICE, Local Service, Network Service' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The policy setting allows programs that run on behalf of a user to impersonate that user (or another specified account) so that they can act on behalf of the user. If this user right is required for this kind of impersonation, an unauthorized user will not be able to convince a client to connect—for example, by remote procedure call (RPC) or named pipes—to a service that they have created to impersonate that client, which could elevate the unauthorized user's permissions to administrative or system levels. Services that are started by the Service Control Manager have the built-in Service group added by default to their access tokens. COM servers that are started by the COM infrastructure and configured to run under a specific account also have the Service group added to their access tokens. As a result, these processes are assigned this user right when they are started. Also, a user can impersonate an access token if any of the following conditions exist: - The access token that is being impersonated is for this user. - The user, in this logon session, logged on to the network with explicit credentials to create the access token. - The requested level is less than Impersonate, such as Anonymous or Identify. An attacker with the Impersonate a client after authentication user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators, SERVICE, Local Service, Network Service`.

Rationale:

An attacker with the Impersonate a client after authentication user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client.

Impact:

In most cases this configuration will have no impact. If you have installed optional components such as ASP.NET or IIS, you may need to assign the Impersonate a client after authentication user right to additional accounts that are required by those components, such as `IUSR_<ComputerName>`, `IIS_WPG`, `ASP.NET` or `IWAM_<ComputerName>`.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators, SERVICE, Local Service, Network Service.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Impersonate a client after authentication

Default Value:

Administrators, SERVICE, Local Service, Network Service

References:

1. CCE-21887-5

1.1.4.26 Configure 'Log on as a batch job' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows accounts to log on using the task scheduler service. Because the task scheduler is often used for administrative purposes, it may be needed in enterprise environments. However, its use should be restricted in high security environments to prevent misuse of system resources or to prevent attackers from using the right to launch malicious code after gaining user level access to a computer. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

The Log on as a batch job user right presents a low-risk vulnerability. For most organizations, the default settings are sufficient.

Impact:

If you configure the Log on as a batch job setting through domain-based Group Policies, the computer will not be able to assign the user right to accounts that are used for scheduled jobs in the Task Scheduler. If you install optional components such as ASP.NET or IIS, you might need to assign this user right to additional accounts that are required by those components. For example, IIS requires assignment of this user right to the IIS_WPG group and the IUSR_<ComputerName>, ASPNET, and IWAM_<ComputerName> accounts. If this user right is not assigned to this group and these accounts, IIS will be unable to run some COM objects that are necessary for proper functionality.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Log on as a batch job

Default Value:

Administrators, Backup Operators, Performance Log Users

References:

1. CCE-21687-9

ARCHIVE

1.1.4.27 Set 'Adjust memory quotas for a process' to 'Administrators, Local Service, Network Service' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows a user to adjust the maximum amount of memory that is available to a process. The ability to adjust memory quotas is useful for system tuning, but it can be abused. In the wrong hands, it could be used to launch a denial of service (DoS) attack. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is:

Administrators, Local Service, Network Service.

Rationale:

A user with the Adjust memory quotas for a process privilege can reduce the amount of memory that is available to any process, which could cause business-critical network applications to become slow or to fail. In the wrong hands, this privilege could be used to start a denial of service (DoS) attack.

Impact:

Organizations that have not restricted users to roles with limited privileges will find it difficult to impose this countermeasure. Also, if you have installed optional components such as ASP.NET or IIS, you may need to assign the Adjust memory quotas for a process user right to additional accounts that are required by those components. IIS requires that this privilege be explicitly assigned to the IWAM_<ComputerName>, Network Service, and Service accounts. Otherwise, this countermeasure should have no impact on most computers. If this user right is necessary for a user account, it can be assigned to a local computer account instead of a domain account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators, Local Service, Network Service.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Adjust memory quotas for a process

Default Value:

LOCAL SERVICE, NETWORK SERVICE, Administrators

References:

1. CCE-22688-6

1.1.4.28 Set 'Manage auditing and security log' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users can change the auditing options for files and directories and clear the Security log. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators`.

Rationale:

The ability to manage the Security event log is a powerful user right and it should be closely guarded. Anyone with this user right can clear the Security log to erase important evidence of unauthorized activity.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Administrators`.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Manage auditing and security log
--

Default Value:

Administrators

References:

1. CCE-21788-5

1.1.4.29 Set 'Deny log on as a batch job' to 'Guests' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which accounts will not be able to log on to the computer as a batch job. A batch job is not a batch (.bat) file, but rather a batch-queue facility. Accounts that use the Task Scheduler to schedule jobs need this user right. The Deny log on as a batch job user right overrides the Log on as a batch job user right, which could be used to allow accounts to schedule jobs that consume excessive system resources. Such an occurrence could cause a DoS condition. Failure to assign this user right to the recommended accounts can be a security risk. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Guests`.

Rationale:

Accounts that have the Deny log on as a batch job user right could be used to schedule jobs that could consume excessive computer resources and cause a DoS condition.

Impact:

If you assign the Deny log on as a batch job user right to other accounts, you could deny users who are assigned to specific administrative roles the ability to perform their required job activities. You should confirm that delegated tasks will not be affected adversely. For example, if you assign this user right to the IWAM_<ComputerName> account, the MSM Management Point will fail. On a newly installed computer that runs Windows Server 2003 this account does not belong to the Guests group, but on a computer that was upgraded from Windows 2000 this account is a member of the Guests group. Therefore, it is important that you understand which accounts belong to any groups that you assign the Deny log on as a batch job user right.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Guests`.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on as a batch job

Default Value:

No one

References:

1. CCE-22936-9

ARCHIVE

1.1.4.30 Set 'Bypass traverse checking' to 'Users, NETWORK SERVICE, LOCAL SERVICE, Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users who do not have the Traverse Folder access permission to pass through folders when they browse an object path in the NTFS file system or the registry. This user right does not allow users to list the contents of a folder. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Users, NETWORK SERVICE, LOCAL SERVICE, Administrators`.

Rationale:

The default configuration for the Bypass traverse checking setting is to allow all users, including the Everyone group, to bypass traverse checking. Permissions to files and folders are controlled through appropriate configuration of file system access control lists (ACLs), as the ability to traverse the folder does not provide any read or write permissions to the user. The only scenario in which the default configuration could lead to a mishap would be if the administrator who configures permissions does not understand how this policy setting works. For example, the administrator might expect that users who are unable to access a folder will be unable to access the contents of any child folders. Such a situation is unlikely, and therefore this vulnerability presents little risk.

Impact:

The Windows operating systems, as well as many applications, were designed with the expectation that anyone who can legitimately access the computer will have this user right. Therefore, we recommend that you thoroughly test any changes to assignments of the Bypass traverse checking user right before you make such changes to production systems. In particular, IIS requires this user right to be assigned to the Network Service, Local Service, IIS_WPG, IUSR_<ComputerName>, and IWAM_<ComputerName> accounts. (It must also be assigned to the ASPNET account through its membership in the Users group.) We recommend that you leave this policy setting at its default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Users, NETWORK SERVICE, LOCAL SERVICE, Administrators`.

`Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Bypass traverse checking`

Default Value:

Everyone, Administrators, Users, Backup Operators, Local Service, Network Service

References:

1. CCE-23566-3

1.1.4.31 Set 'Increase a process working set' to 'Administrators, Local Service' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This privilege determines which user accounts can increase or decrease the size of a process's working set. The working set of a process is the set of memory pages currently visible to the process in physical RAM memory. These pages are resident and available for an application to use without triggering a page fault. The minimum and maximum working set sizes affect the virtual memory paging behavior of a process. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: `Administrators, Local Service`.

Rationale:

This right is granted to all users by default. However, increasing the working set size for a process decreases the amount of physical memory available to the rest of the system. It would be possible for malicious code to increase the process working set to a level that could severely degrade system performance and potentially cause a denial of service.

Impact:

Users will be unable to increase the working set for their processes, which could degrade performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators, Local Service.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Increase a process working set

Default Value:

Users

References:

1. CCE-21894-1

ARCHIVE

1.1.4.32 Set 'Change the system time' to 'LOCAL SERVICE, Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users and groups can change the time and date on the internal clock of the computers in your environment. Users who are assigned this user right can affect the appearance of event logs. When a computer's time setting is changed, logged events reflect the new time, not the actual time that the events occurred. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. Note: Discrepancies between the time on the local computer and on the domain controllers in your environment may cause problems for the Kerberos authentication protocol, which could make it impossible for users to log on to the domain or obtain authorization to access domain resources after they are logged on. Also, problems will occur when Group Policy is applied to client computers if the system time is not synchronized with the domain controllers. The recommended state for this setting is: `LOCAL SERVICE, Administrators`.

Rationale:

Users who can change the time on a computer could cause several problems. For example, time stamps on event log entries could be made inaccurate, time stamps on files and folders that are created or modified could be incorrect, and computers that belong to a domain may not be able to authenticate themselves or users who try to log on to the domain from them. Also, because the Kerberos authentication protocol requires that the requestor and authenticator have their clocks synchronized within an administrator-defined skew period, an attacker who changes a computer's time may cause that computer to be unable to obtain or grant Kerberos tickets.

The risk from these types of events is mitigated on most domain controllers, member servers, and end-user computers because the Windows Time service automatically synchronizes time with domain controllers in the following ways:

- All client desktop computers and member servers use the authenticating domain controller as their inbound time partner.
- All domain controllers in a domain nominate the primary domain controller (PDC) emulator operations master as their inbound time partner.
- All PDC emulator operations masters follow the hierarchy of domains in the selection of their inbound time partner.
- The PDC emulator operations master at the root of the domain is authoritative for the organization. Therefore it is recommended that you configure this computer to synchronize with a reliable external time server.

This vulnerability becomes much more serious if an attacker is able to change the system time and then stop the Windows Time service or reconfigure it to synchronize with a time server that is not accurate.

Impact:

There should be no impact, because time synchronization for most organizations should be fully automated for all computers that belong to the domain. Computers that do not belong to the domain should be configured to synchronize with an external source.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `LOCAL SERVICE, Administrators`.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Change the system time
--

Default Value:

LOCAL SERVICE, Administrators

References:

1. CCE-21990-7

ARCHIVE

1.1.4.33 Configure 'Deny log on as a service' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This security setting determines which service accounts are prevented from registering a process as a service. This policy setting supersedes the Log on as a service policy setting if an account is subject to both policies.

Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Note: This security setting does not apply to the System, Local Service, or Network Service accounts.

Rationale:

Accounts that can log on as a service could be used to configure and start new unauthorized services, such as a keylogger or other malicious software. The benefit of the specified countermeasure is somewhat reduced by the fact that only users with administrative privileges can install and configure services, and an attacker who has already attained that level of access could configure the service to run with the System account.

Impact:

If you assign the Deny log on as a service user right to specific accounts, services may not be able to start and a DoS condition could result.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on as a service
--

Default Value:

No one

References:

1. CCE-21620-0

ARCHIVE

1.1.4.34 Configure 'Log on as a service' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows accounts to launch network services or to register a process as a service running on the system. This user right should be restricted on any computer in a high security environment, but because many applications may require this privilege, it should be carefully evaluated and tested before configuring it in an enterprise environment. On Windows Vista-based computers, no users or groups have this privilege by default. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Log on as a service is a powerful user right because it allows accounts to launch network services or services that run continuously on a computer, even when no one is logged on to the console. The risk is reduced by the fact that only users with administrative privileges can install and configure services. An attacker who has already attained that level of access could configure the service to run with the Local System account.

Impact:

On most computers, this is the default configuration and there will be no negative impact. However, if you have installed optional components such as ASP.NET or IIS, you may need to assign the Log on as a service user right to additional accounts that are required by those components. IIS requires that this user right be explicitly granted to the ASPNET user account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Log on as a service

Default Value:

NT SERVICE\ALL SERVICES

References:

1. CCE-23218-1

ARCHIVE

1.1.4.35 Set 'Generate security audits' to 'Local Service, Network Service' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users or processes can generate audit records in the Security log. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: Local Service, Network Service.

Rationale:

An attacker could use this capability to create a large number of audited events, which would make it more difficult for a system administrator to locate any illicit activity. Also, if the event log is configured to overwrite events as needed, any evidence of unauthorized activities could be overwritten by a large number of unrelated events.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Local Service, Network Service.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Generate security audits

Default Value:

Local Service, Network Service

References:

1. CCE-21774-5

1.1.4.36 Set 'Allow log on locally' to 'Administrators, Users' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines which users can interactively log on to computers in your environment. Logons that are initiated by pressing the CTRL+ALT+DEL key sequence on the client computer keyboard require this user right. Users who attempt to log on through Terminal Services or IIS also require this user right. The Guest account is assigned this user right by default. Although this account is disabled by default, it's recommended that you enable this setting through Group Policy. However, this user right should generally be restricted to the Administrators and Users groups. Assign this user right to the Backup Operators group if your organization requires that they have this capability. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is:

Administrators, Users.

Rationale:

Any account with the Allow log on locally user right can log on at the console of the computer. If you do not restrict this user right to legitimate users who need to be able to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

Impact:

If you remove these default groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. If you have installed optional components such as ASP.NET or Internet Information Services, you may need to assign Allow log on locally user right to additional accounts that are required by those components. For example, IIS 6 requires that this user right be assigned to the IUSR_`<ComputerName>` account for certain features; see "Default permissions and user rights for IIS 6.0" for more information: <http://support.microsoft.com/?id=812614>. You should confirm that delegated activities will not be adversely affected by any changes that you make to the Allow log on locally user rights assignments.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators, Users.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Allow log on locally

Default Value:

Guest, Administrators, Users, Backup Operators

References:

1. CCE-23296-7

ARCHIVE

1.1.4.37 Set 'Lock pages in memory' to 'No One' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows a process to keep data in physical memory, which prevents the system from paging the data to virtual memory on disk. If this user right is assigned, significant degradation of system performance can occur. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: No One.

Rationale:

Users with the Lock pages in memory user right could assign physical memory to several processes, which could leave little or no RAM for other processes and result in a DoS condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to No One.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Lock pages in memory
```

Default Value:

No one

References:

1. CCE-21994-9

1.1.4.38 Set 'Load and unload device drivers' to 'Administrators' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows users to dynamically load a new device driver on a system. An attacker could potentially use this capability to install malicious code that appears to be a device driver. This user right is required for users to add local printers or printer drivers in Windows Vista. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is:

Administrators.

Rationale:

Device drivers run as highly privileged code. A user who has the Load and unload device drivers user right could unintentionally install malicious code that masquerades as a device driver. Administrators should exercise greater care and install only drivers with verified digital signatures.

Impact:

If you remove the Load and unload device drivers user right from the Print Operators group or other accounts you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should ensure that delegated tasks will not be negatively affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Administrators.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Load and unload device drivers
--

Default Value:

Administrators

References:

1. CCE-23181-1

ARCHIVE

1.1.4.39 Configure 'Remove computer from docking station' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows the user of a portable computer to click Eject PC on the Start menu to undock the computer. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Anyone who has the Remove computer from docking station user right can log on and then remove a portable computer from its docking station. If this setting is not defined, it has the same effect as if everyone was granted this right. However, the value of implementing this countermeasure is reduced by the following factors:

- If attackers can restart the computer, they could remove it from the docking station after the BIOS starts but before the operating system starts.
- This setting does not affect servers, because they typically are not installed in docking stations.
- An attacker could steal the computer and the docking station together.

Impact:

By default, only members of the local Administrator group are granted this right. Other user accounts must be explicitly granted the right as necessary. If your organization's users are not members of the local Administrators groups on their portable computers, they will be unable to remove their own portable computers from their docking stations without shutting them down first. Therefore, you may want to assign the Remove computer from docking station privilege to the local Users group for portable computers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Remove computer from docking station

Default Value:

Administrators, Users

References:

1. CCE-22135-8

ARCHIVE

1.1.4.40 Set 'Replace a process level token' to 'Local Service, Network Service' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows one process or service to start another service or process with a different security access token, which can be used to modify the security access token of that sub-process and result in the escalation of privileges. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: Local Service, Network Service.

Rationale:

User with the Replace a process level token privilege are able to start processes as other users whose credentials they know. They could use this method to hide their unauthorized actions on the computer. (On Windows 2000-based computers, use of the Replace a process level token user right also requires the user to have the Adjust memory quotas for a process user right that is discussed earlier in this section.)

Impact:

On most computers, this is the default configuration and there will be no negative impact. However, if you have installed optional components such as ASP.NET or IIS, you may need to assign the Replace a process level token privilege to additional accounts. For example, IIS requires that the Service, Network Service, and IWAM_<ComputerName> accounts be explicitly granted this user right.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to Local Service, Network Service.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Replace a process level token

Default Value:

LOCAL SERVICE, NETWORK SERVICE

References:

1. CCE-22472-5

ARCHIVE

1.1.4.41 Set 'Create a token object' to 'No One' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows a process to create an access token, which may provide elevated rights to access sensitive data. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: No One.

Rationale:

A user account that is given this user right has complete control over the system and can lead to the system being compromised. It is highly recommended that you do not assign any user accounts this right. The operating system examines a user's access token to determine the level of the user's privileges. Access tokens are built when users log on to the local computer or connect to a remote computer over a network. When you revoke a privilege, the change is immediately recorded, but the change is not reflected in the user's access token until the next time the user logs on or connects. Users with the ability to create or modify tokens can change the level of access for any currently logged on account. They could escalate their own privileges or create a DoS condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to No One.

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create a token object

Default Value:

No one

References:

1. CCE-22082-2

ARCHIVE

1.1.4.42 Set 'Modify an object label' to 'No one' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This privilege determines which user accounts can modify the integrity label of objects, such as files, registry keys, or processes owned by other users. Processes running under a user account can modify the label of an object owned by that user to a lower level without this privilege. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. The recommended state for this setting is: No one.

Rationale:

By modifying the integrity label of an object owned by an other user a malicious user may cause them to execute code at a higher level of privilege than intended.

Impact:

None, by default the Administrators group has this user right.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to No one.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Modify an object label
```

Default Value:

None

References:

1. CCE-22469-1

1.1.5 Windows Firewall With Advanced Security

1.1.5.1 Domain Profile

ARCHIVE

1.1.5.1.1 Set 'Windows Firewall: Domain: Display a notification' to 'Yes (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections.

Note: When the Apply local firewall rules setting is configured to **No**, it's recommended to also configure the **Display a notification** setting to **No**. Otherwise, users will continue to receive messages that ask if they want to unblock a restricted inbound connection, but the user's response will be ignored. The recommended state for this setting is: **Yes (default)**.

Rationale:

Some organizations may prefer to avoid alarming users when firewall rules block certain types of network activity. However, notifications can be helpful when troubleshooting network issues involving the firewall.

Impact:

If you configure this policy setting to **Yes**, Windows Firewall will display these notifications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\DisableNotifications

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Yes` (default).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Domain Profile\Windows Firewall: Domain: Display a  
notification
```

Default Value:

Yes

References:

1. CCE-23450-0

1.1.5.1.2 Set 'Windows Firewall: Domain: Logging: Size limit (KB)' to '16384 KB or greater ' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to specify the size limit of the file in which Windows Firewall will write its log information. The recommended state for this setting is: 16384 KB or greater.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

The log file size will be limited to the specified size, old events will be overwritten by newer ones when the limit is reached

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogFileSize
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 16384 KB or greater.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging\Windows Firewall: Domain: Logging: Size limit (KB)
```

Default Value:

Not configured

References:

1. CCE-22458-4

1.1.5.1.3 Set 'Windows Firewall: Domain: Logging: Name' to '%SYSTEMROOT%\System32\logfiles\firewall\domainfw.log' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to specify the path and name of the file in which Windows Firewall will write its log information. The recommended state for this setting is:

%SYSTEMROOT%\System32\logfiles\firewall\domainfw.log.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

The log file will be stored in the specified file.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogFilePath
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to

%SYSTEMROOT%\System32\logfiles\firewall\domainfw.log.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging\Windows Firewall: Domain: Logging: Name
```

Default Value:

Not configured

References:

1. CCE-23521-8

1.1.5.1.4 Set 'Windows Firewall: Domain: Apply local firewall rules' to 'Yes (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting controls whether local administrators are allowed to create local firewall rules that apply together with firewall rules configured by Group Policy. The recommended state for this setting is: `Yes (default)`.

Rationale:

Users with administrative privileges might create firewall rules that expose the system to remote attack.

Impact:

If you configure this setting to No, administrators can still create firewall rules, but the rules will not be applied. This setting is available only when configuring the policy through Group Policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\AllowLocalPolicyMerge
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Yes (default)`.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Windows Firewall: Domain: Apply local firewall rules
```

Default Value:

Yes

References:

1. CCE-21968-3

ARCHIVE

1.1.5.1.5 Set 'Windows Firewall: Domain: Apply local connection security rules' to 'Yes (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting controls whether local administrators are allowed to create connection security rules that apply together with connection security rules configured by Group Policy. The recommended state for this setting is: *Yes (default)*.

Rationale:

Users with administrative privileges might create firewall rules that expose the system to remote attack.

Impact:

If you configure this setting to No, administrators can still create firewall rules, but the rules will not be applied. This setting is available only when configuring the policy through Group Policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\AllowLocalIPsecPolicyMerge
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes (default)*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Windows Firewall: Domain: Apply local connection security rules
```

Default Value:

Yes

References:

1. CCE-23253-8

ARCHIVE

1.1.5.1.6 Set 'Windows Firewall: Domain: Allow unicast response' to 'No' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This option is useful if you need to control whether this computer receives unicast responses to its outgoing multicast or broadcast messages. The recommended state for this setting is: **No**.

Rationale:

An attacker could respond to broadcast or multicast message with malicious payloads.

Impact:

If you enable this setting and this computer sends multicast or broadcast messages to other computers, Windows Firewall with Advanced Security waits as long as three seconds for unicast responses from the other computers and then blocks all later responses. If you disable this setting and this computer sends a multicast or broadcast message to other computers, Windows Firewall with Advanced Security blocks the unicast responses sent by those other computers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\DisableUnicastResponsesToMulticastBroadcast
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No**.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Windows Firewall: Domain: Allow unicast response
```

Default Value:

Yes

References:

1. CCE-23201-7

ARCHIVE

1.1.5.1.7 Set 'Windows Firewall: Domain: Outbound connections' to 'Allow (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting determines the behavior for outbound connections that do not match an outbound firewall rule. In Windows Vista, the default behavior is to allow connections unless there are firewall rules that block the connection. The recommended state for this setting is: `Allow (default)`.

Rationale:

Some people believe that it is prudent to block all outbound connections except those specifically approved by the user or administrator. Microsoft disagrees with this opinion, blocking outbound connections by default will force users to deal with a large number of dialog boxes prompting them to authorize or block applications such as their web browser or instant messaging software. Additionally, blocking outbound traffic has little value because if an attacker has compromised the system they can reconfigure the firewall anyway.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\DefaultOutboundAction
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to `Allow` (default).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Domain Profile\Windows Firewall: Domain: Outbound  
connections
```

Default Value:

`Allow`

References:

1. CCE-22324-8

1.1.5.1.8 Set 'Windows Firewall: Domain: Logging: Log dropped packets' to 'Yes' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. The recommended state for this setting is: *Yes*.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

Information about dropped packets will be recorded in the firewall log file

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogDroppedPackets
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging\Windows Firewall: Domain: Logging: Log dropped packets
```

Default Value:

Not configured

References:

1. CCE-23030-0

1.1.5.1.9 Set 'Windows Firewall: Domain: Logging: Log successful connections' to 'Yes' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. The recommended state for this setting is: *Yes*.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

Information about successful connections will be recorded in the firewall log file

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogSuccessfulConnections
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging\Windows Firewall: Domain: Logging: Log successful connections
```

Default Value:

Not configured

References:

1. CCE-21810-7

1.1.5.1.10 Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting determines the behavior for inbound connections that do not match an inbound firewall rule. The default behavior is to block connections unless there are firewall rules to allow the connection. The recommended state for this setting is:

Enabled:Block (default).

Rationale:

If the firewall allows all traffic to access the system then an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\DefaultInboundAction
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Windows Firewall: Domain: Inbound connections
```

Then set the Inbound Connections option to Block (default).

Default Value:

Block

References:

1. CCE-22387-5

ARCHIVE

1.1.5.1.11 Set 'Windows Firewall: Domain: Firewall state' to 'On (recommended)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile. The recommended state for this setting is: On (recommended).

Rationale:

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\EnableFirewall
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to On (recommended).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Windows Firewall: Domain: Firewall state
```

Default Value:

On

References:

1. CCE-23090-4

1.1.5.2 Private Profile

ARCHIVE

1.1.5.2.1 Set 'Windows Firewall: Private: Firewall state' to 'On (recommended)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile. The recommended state for this setting is: On (recommended).

Rationale:

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\EnableFirewall
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to On (recommended).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Windows Firewall: Private: Firewall state
```

Default Value:

On

References:

1. CCE-21714-1

1.1.5.2.2 Set 'Windows Firewall: Private: Outbound connections' to 'Allow (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting determines the behavior for outbound connections that do not match an outbound firewall rule. The default behavior is to allow connections unless there are firewall rules that block the connection. Important If you set Outbound connections to Block and then deploy the firewall policy by using a GPO, computers that receive the GPO settings cannot receive subsequent Group Policy updates unless you create and deploy an outbound rule that enables Group Policy to work. Predefined rules for Core Networking include outbound rules that enable Group Policy to work. Ensure that these outbound rules are active, and thoroughly test firewall profiles before deploying. The recommended state for this setting is: `Allow (default)`.

Rationale:

Some people believe that it is prudent to block all outbound connections except those specifically approved by the user or administrator. Microsoft disagrees with this opinion, blocking outbound connections by default will force users to deal with a large number of dialog boxes prompting them to authorize or block applications such as their web browser or instant messaging software. Additionally, blocking outbound traffic has little value because if an attacker has compromised the system they can reconfigure the firewall anyway.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DefaultOutboundAction
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Allow` (default).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Private Profile\Windows Firewall: Private: Outbound  
connections
```

Default Value:

`Allow`

References:

1. CCE-23180-3

1.1.5.2.3 Set 'Windows Firewall: Private: Apply local firewall rules' to 'Yes (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting controls whether local administrators are allowed to create local firewall rules that apply together with firewall rules configured by Group Policy. The recommended state for this setting is: *Yes (default)*.

Rationale:

Users with administrative privileges might create firewall rules that expose the system to remote attack.

Impact:

If you configure this setting to No, administrators can still create firewall rules, but the rules will not be applied. This setting is available only when configuring the policy through Group Policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\AllowLocalPolicyMerge
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes (default)*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Windows Firewall: Private: Apply local firewall rules
```

Default Value:

Yes

References:

1. CCE-22676-1

ARCHIVE

1.1.5.2.4 Set 'Windows Firewall: Private: Logging: Size limit (KB)' to '16384 KB or greater' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to specify the size limit of the file in which Windows Firewall will write its log information. The recommended state for this setting is: 16384 KB or greater.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

The log file size will be limited to the specified size, old events will be overwritten by newer ones when the limit is reached

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile  
\Logging\LogFileSize
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 16384 KB or greater.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Private Profile\Logging\Windows Firewall: Private:  
Logging: Size limit (KB)
```

Default Value:

Not configured

References:

1. CCE-23447-6

1.1.5.2.5 Set 'Windows Firewall: Private: Apply local connection security rules' to 'Yes (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting controls whether local administrators are allowed to create connection security rules that apply together with connection security rules configured by Group Policy. The recommended state for this setting is: *Yes (default)*.

Rationale:

Users with administrative privileges might create firewall rules that expose the system to remote attack.

Impact:

If you configure this setting to No, administrators can still create firewall rules, but the rules will not be applied. This setting is available only when configuring the policy through Group Policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\AllowLocalIPsecPolicyMerge
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes (default)*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Windows Firewall: Private: Apply local connection security rules
```

Default Value:

Yes

References:

1. CCE-22915-3

ARCHIVE

1.1.5.2.6 Set 'Windows Firewall: Private: Display a notification' to 'Yes (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections.

Note: When the `Apply local firewall rules` setting is configured to `No`, it's recommended to also also configure the `Display a notification` setting to `No`. Otherwise, users will continue to receive messages that ask if they want to unblock a restricted inbound connection, but the user's response will be ignored. The recommended state for this setting is: `Yes (default)`.

Rationale:

Some organizations may prefer to avoid alarming users when firewall rules block certain types of network activity. However, notifications can be helpful when troubleshooting network issues involving the firewall.

Impact:

If you configure this policy setting to `Yes`, Windows Firewall will display these notifications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DisableNotifications
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to `Yes` (default).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Private Profile\Windows Firewall: Private: Display a  
notification
```

Default Value:

Yes

References:

1. CCE-22877-5

1.1.5.2.7 Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting determines the behavior for inbound connections that do not match an inbound firewall rule. The default behavior is to block connections unless there are firewall rules to allow the connection. The recommended state for this setting is:

Enabled:Block (default).

Rationale:

If the firewall allows all traffic to access the system then an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DefaultInboundAction
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Windows Firewall: Private: Inbound connections
```

Then set the Inbound Connections option to Block (default).

Default Value:

Block

References:

1. CCE-21826-3

ARCHIVE

1.1.5.2.8 Set 'Windows Firewall: Private: Logging: Name' to '%SYSTEMROOT%\System32\logfiles\firewall\privatefw.log' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to specify the path and name of the file in which Windows Firewall will write its log information. The recommended state for this setting is:

%SYSTEMROOT%\System32\logfiles\firewall\privatefw.log.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

The log file will be stored in the specified file.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogFilePath
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to

%SYSTEMROOT%\System32\logfiles\firewall\privatefw.log.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Logging\Windows Firewall: Private: Logging: Name
```

Default Value:

Not configured

References:

1. CCE-21460-1

1.1.5.2.9 Set 'Windows Firewall: Private: Allow unicast response' to 'No' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This option is useful if you need to control whether this computer receives unicast responses to its outgoing multicast or broadcast messages. The recommended state for this setting is: No.

Rationale:

An attacker could respond to broadcast or multicast message with malicious payloads.

Impact:

If you enable this setting and this computer sends multicast or broadcast messages to other computers, Windows Firewall with Advanced Security waits as long as three seconds for unicast responses from the other computers and then blocks all later responses. If you disable this setting and this computer sends a multicast or broadcast message to other computers, Windows Firewall with Advanced Security blocks the unicast responses sent by those other computers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DisableUnicastResponsesToMulticastBroadcast
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to No.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Windows Firewall: Private: Allow unicast response
```

Default Value:

Yes

References:

1. CCE-22003-8

ARCHIVE

1.1.5.2.10 Set 'Windows Firewall: Private: Logging: Log successful connections' to 'Yes' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. The recommended state for this setting is: *Yes*.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

Information about successful connections will be recorded in the firewall log file

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile  
\Logging\LogSuccessfulConnections
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Private Profile\Logging\Windows Firewall: Private:  
Logging: Log successful connections
```

Default Value:

Not configured

References:

1. CCE-23120-9

1.1.5.2.11 Set 'Windows Firewall: Private: Logging: Log dropped packets' to 'Yes' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. The recommended state for this setting is: *Yes*.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

Information about dropped packets will be recorded in the firewall log file

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile  
\Logging\LogDroppedPackets
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Private Profile\Logging\Windows Firewall: Private:  
Logging: Log dropped packets
```

Default Value:

Not configured

References:

1. CCE-21256-3

1.1.5.3 Public Profile

ARCHIVE

1.1.5.3.1 Set 'Windows Firewall: Public: Outbound connections' to 'Allow (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting determines the behavior for outbound connections that do not match an outbound firewall rule. The default behavior is to allow connections unless there are firewall rules that block the connection. Important If you set Outbound connections to Block and then deploy the firewall policy by using a GPO, computers that receive the GPO settings cannot receive subsequent Group Policy updates unless you create and deploy an outbound rule that enables Group Policy to work. Predefined rules for Core Networking include outbound rules that enable Group Policy to work. Ensure that these outbound rules are active, and thoroughly test firewall profiles before deploying. The recommended state for this setting is: Allow (default).

Rationale:

Some people believe that it is prudent to block all outbound connections except those specifically approved by the user or administrator. Microsoft disagrees with this opinion, blocking outbound connections by default will force users to deal with a large number of dialog boxes prompting them to authorize or block applications such as their web browser or instant messaging software. Additionally, blocking outbound traffic has little value because if an attacker has compromised the system they can reconfigure the firewall anyway.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\DefaultOutboundAction
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Allow` (default).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall  
with Advanced Security\Windows Firewall with Advanced Security\Windows  
Firewall Properties\Public Profile\Windows Firewall: Public: Outbound  
connections
```

Default Value:

`Allow`

References:

1. CCE-22181-2

1.1.5.3.2 Set 'Windows Firewall: Public: Apply local firewall rules' to 'Yes (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting controls whether local administrators are allowed to create local firewall rules that apply together with firewall rules configured by Group Policy. The recommended state for this setting is: *Yes (default)*.

Rationale:

Users with administrative privileges might create firewall rules that expose the system to remote attack.

Impact:

If you configure this setting to No, administrators can still create firewall rules, but the rules will not be applied. This setting is available only when configuring the policy through Group Policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\AllowLocalPolicyMerge
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes (default)*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Windows Firewall: Public: Apply local firewall rules
```

Default Value:

Yes

References:

1. CCE-23240-5

ARCHIVE

1.1.5.3.3 Set 'Windows Firewall: Public: Apply local connection security rules' to 'No' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting controls whether local administrators are allowed to create connection security rules that apply together with connection security rules configured by Group Policy. The recommended state for this setting is: **No**.

Rationale:

Users with administrative privileges might create firewall rules that expose the system to remote attack.

Impact:

If you configure this setting to No, administrators can still create firewall rules, but the rules will not be applied. This setting is available only when configuring the policy through Group Policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\AllowLocalIPsecPolicyMerge
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **No**.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Windows Firewall: Public: Apply local connection security rules
```

Default Value:

Yes

References:

1. CCE-21508-7

1.1.5.3.4 Set 'Windows Firewall: Public: Logging: Log dropped packets' to 'Yes' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. The recommended state for this setting is: *Yes*.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

Information about dropped packets will be recorded in the firewall log file

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogDroppedPackets
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging\Windows Firewall: Public: Logging: Log dropped packets
```

Default Value:

Not configured

References:

1. CCE-23017-7

1.1.5.3.5 Set 'Windows Firewall: Public: Display a notification' to 'No' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections.

Note: When the `Apply local firewall rules` setting is configured to `No`, it is also recommended to also configure the `Display a notification` setting to `No`. Otherwise, users will continue to receive messages that ask if they want to unblock a restricted inbound connection, but the user's response will be ignored. The recommended state for this setting is: `No`.

Rationale:

Some organizations may prefer to avoid alarming users when firewall rules block certain types of network activity. However, notifications can be helpful when troubleshooting network issues involving the firewall.

Impact:

If you configure this policy setting to `Yes`, Windows Firewall will display these notifications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\DisableNotifications
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `No`.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Windows Firewall: Public: Display a notification
```

Default Value:

Yes

References:

1. CCE-22028-5

ARCHIVE

1.1.5.3.6 Set 'Windows Firewall: Public: Allow unicast response' to 'No' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This option is useful if you need to control whether this computer receives unicast responses to its outgoing multicast or broadcast messages. The recommended state for this setting is: No.

Rationale:

An attacker could respond to broadcast or multicast message with malicious payloads.

Impact:

If you enable this setting and this computer sends multicast or broadcast messages to other computers, Windows Firewall with Advanced Security waits as long as three seconds for unicast responses from the other computers and then blocks all later responses. If you disable this setting and this computer sends a multicast or broadcast message to other computers, Windows Firewall with Advanced Security blocks the unicast responses sent by those other computers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\DisableUnicastResponsesToMulticastBroadcast
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to No.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Windows Firewall: Public: Allow unicast response
```

Default Value:

Yes

References:

1. CCE-22993-0

ARCHIVE

1.1.5.3.7 Set 'Windows Firewall: Public: Logging: Name' to '%SYSTEMROOT%\System32\logfiles\firewall\publicfw.log' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to specify the path and name of the file in which Windows Firewall will write its log information. The recommended state for this setting is:

%SYSTEMROOT%\System32\logfiles\firewall\publicfw.log.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

The log file will be stored in the specified file.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogFilePath
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to

%SYSTEMROOT%\System32\logfiles\firewall\publicfw.log.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging\Windows Firewall: Public: Logging: Name
```

Default Value:

Not configured

References:

1. CCE-22267-9

1.1.5.3.8 Set 'Windows Firewall: Public: Logging: Log successful connections' to 'Yes' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. The recommended state for this setting is: *Yes*.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

Information about successful connections will be recorded in the firewall log file

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogSuccessfulConnections
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Yes*.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging\Windows Firewall: Public: Logging: Log successful connections
```

Default Value:

Not configured

References:

1. CCE-21530-1

1.1.5.3.9 Set 'Windows Firewall: Public: Logging: Size limit (KB)' to '16384 KB or greater' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Use this option to specify the size limit of the file in which Windows Firewall will write its log information. The recommended state for this setting is: 16384 KB or greater.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

The log file size will be limited to the specified size, old events will be overwritten by newer ones when the limit is reached

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogFileSize
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 16384 KB or greater.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging\Windows Firewall: Public: Logging: Size limit (KB)
```

Default Value:

Not configured

References:

1. CCE-22460-0

1.1.5.3.10 Set 'Windows Firewall: Public: Firewall state' to 'On (recommended)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile. The recommended state for this setting is: On (recommended).

Rationale:

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\EnableFirewall
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to On (recommended).

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Windows Firewall: Public: Firewall state
```

Default Value:

On

References:

1. CCE-21359-5

1.1.5.3.11 Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This setting determines the behavior for inbound connections that do not match an inbound firewall rule. The default behavior is to block connections unless there are firewall rules to allow the connection. The recommended state for this setting is:

Enabled:Block (default).

Rationale:

If the firewall allows all traffic to access the system then an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\DefaultInboundAction
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Windows Firewall: Public: Inbound connections
```

Then set the Inbound Connections option to Block (default).

Default Value:

Block

References:

1. CCE-22517-7

ARCHIVE

1.2 Administrative Templates

1.2.1 Network

ARCHIVE

1.2.1.1 Configure 'Set IP Stateless Autoconfiguration Limits State' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to configure IP Stateless Autoconfiguration Limits. If you enable or do not configure this policy setting, IP Stateless Autoconfiguration Limits will be enabled and system will limit the number of autoconfigured addresses and routes. If you disable this policy setting, IP Stateless Autoconfiguration Limits will be disabled and system will not limit the number of autoconfigured addresses and routes. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

No known vulnerabilities at the time of this writing.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\EnableIPAutoConfigurationLimits
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Network\TCPIP  
Settings\Parameters\Set IP Stateless Autoconfiguration Limits State
```

Default Value:

Not configured

References:

1. CCE-22213-3

1.2.1.2 Configure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting prevents computers from establishing multiple simultaneous connections to either the Internet or to a Windows domain. If this policy setting is enabled, when the computer has at least one active connection to the Internet, a new automatic connection attempt to the Internet is blocked. When the computer has at least one active connection to a Windows domain, a new automatic connection to the same Windows domain is also blocked. Additional manual connection attempts by users to the Internet or to a Windows domain are not blocked by this policy setting. In circumstances where there are multiple simultaneous connections to either the Internet or to a Windows domain, Windows disconnects the less preferred connection when the amount of network traffic over the less preferred connection drops below a certain threshold. For example, when a computer is connected to Internet using a WiFi connection and the user plugs in to an Ethernet network, network traffic is routed through the faster Ethernet connection, and the WiFi traffic diminishes. Windows detects this circumstance and responds by disconnecting the WiFi connection. If this policy setting is not configured or is disabled, multiple simultaneous connections to the Internet or to a Windows domain are allowed. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

The potential concern is that a user would unknowingly allow network traffic to flow between the insecure public network and the managed corporate network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WcmSvc\GroupPolicy\fm  
inimizeConnections
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

Computer Configuration\Administrative Templates\Network\Windows Connection Manager\Minimize the number of simultaneous connections to the Internet or a Windows Domain

Default Value:

Not configured

References:

1. CCE-21215-9

1.2.1.3 Configure 'Prohibit connection to non-domain networks when connected to domain authenticated network' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting prevents computers from connecting to both a domain based network and a non-domain based network at the same time. If this policy setting is enabled, the computer responds to automatic and manual network connection attempts based on the following circumstances: Automatic connection attempts - When the computer is already connected to a domain based network, all automatic connection attempts to non-domain networks are blocked. - When the computer is already connected to a non-domain based network, automatic connection attempts to domain based networks are blocked. Manual connection attempts - When the computer is already connected to either a non-domain based network or a domain based network over media other than Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing network connection is disconnected and the manual connection is allowed. - When the computer is already connected to either a non-domain based network or a domain based network over Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing Ethernet connection is maintained and the manual connection attempt is blocked. If this policy setting is not configured or is disabled, computers are allowed to connect simultaneously to both domain and non-domain networks. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

The potential concern is that a user would unknowingly allow network traffic to flow between the insecure public network and the managed corporate network.

Impact:

If this policy setting is enabled, the computer responds to automatic and manual network connection attempts based on the following circumstances: - Automatic connection attempts - When the computer is already connected to a domain based network, all automatic connection attempts to non-domain networks are blocked. - When the computer is already connected to a non-domain based network, automatic connection attempts to domain based networks are blocked. - Manual connection attempts - When the computer is already connected to either a non-domain based network or a domain based network over media other than Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing network connection is disconnected and the manual connection is allowed. - When the computer is already connected to either a non-domain based network or a domain based network over Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing Ethernet connection is maintained and the manual connection attempt is blocked. If this policy setting is not configured or is disabled, computers are allowed to connect simultaneously to both domain and non-domain networks.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WcmSvc\GroupPolicy\fb1ockNonDomain
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Network\Windows Connection Manager\Prohibit connection to non-domain networks when connected to domain authenticated network
```

Default Value:

Not configured

References:

1. CCE-22893-2

1.2.2 Printers

ARCHIVE

1.2.2.1 Configure 'Point and Print Restrictions' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls the client Point and Print behavior, including the security prompts for Windows Vista computers. The policy setting applies only to non-Print Administrator clients, and only to computers that are members of a domain. When the policy setting is enabled: -Windows XP and later clients will only download print driver components from a list of explicitly named servers. If a compatible print driver is available on the client, a printer connection will be made. If a compatible print driver is not available on the client, no connection will be made. -You can configure Windows Vista clients so that security warnings and elevated command prompts do not appear when users Point and Print, or when printer connection drivers need to be updated. When the policy setting is not configured: -Windows Vista client computers can point and print to any server. -Windows Vista computers will show a warning and an elevated command prompt when users create a printer connection to any server using Point and Print. -Windows Vista computers will show a warning and an elevated command prompt when an existing printer connection driver needs to be updated. -Windows Server 2003 and Windows XP client computers can create a printer connection to any server in their forest using Point and Print. When the policy setting is disabled: -Windows Vista client computers can create a printer connection to any server using Point and Print. -Windows Vista computers will not show a warning or an elevated command prompt when users create a printer connection to any server using Point and Print. -Windows Vista computers will not show a warning or an elevated command prompt when an existing printer connection driver needs to be updated. -Windows Server 2003 and Windows XP client computers can create a printer connection to any server using Point and Print. -The "Users can only point and print to computers in their forest" setting applies only to Windows Server 2003 and Windows XP SP1 (and later service packs). Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

A client could connect to a print server that is hosting drivers which include malicious software.

Impact:

When the policy setting is enabled: - Windows XP and later clients will only download print driver components from a list of explicitly named servers. If a compatible print driver is available on the client, a printer connection will be made. If a compatible print driver is not available on the client, no connection will be made. - You can configure Windows Vista clients so that security warnings and elevated command prompts do not appear when users Point and Print, or when printer connection drivers need to be updated. When the policy setting is not configured: - Windows Vista client computers can point and print to any server. - Windows Vista computers will show a warning and an elevated command prompt when users create a printer connection to any server using Point and Print. - Windows Vista computers will show a warning and an elevated command prompt when an existing printer connection driver needs to be updated. - Windows Server 2003 and Windows XP client computers can create a printer connection to any server in their forest using Point and Print. When the policy setting is disabled: -Windows Vista client computers can create a printer connection to any server using Point and Print. -Windows Vista computers will not show a warning or an elevated command prompt when users create a printer connection to any server using Point and Print. -Windows Vista computers will not show a warning or an elevated command prompt when an existing printer connection driver needs to be updated. -Windows Server 2003 and Windows XP client computers can create a printer connection to any server using Point and Print. -The "Users can only point and print to computers in their forest" setting applies only to Windows Server 2003 and Windows XP SP1 (and later service packs).

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Printers\PointAndPrint\Restricted
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Printers\Point and Print  
Restrictions
```

Default Value:

Not configured

References:

1. CCE-22489-9

1.2.3 System

ARCHIVE

1.2.3.1 Internet Communication Management

ARCHIVE

1.2.3.1.1 Configure 'Turn off access to the Store' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether to use the Store service for finding an application to open a file with an unhandled file type or protocol association. When a user opens a file type or protocol that is not associated with any applications on the computer, the user is given the choice to select a local application or use the Store service to find an application. If you enable this policy setting, the "Look for an app in the Store" item in the Open With dialog is removed. If you disable or do not configure this policy setting, the user is allowed to use the Store service and the Store item is available in the Open With dialog. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Organizations that manage user computers may want to prevent users from accessing the Store application.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Explorer\NoUseStoreOpenWith
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off access to the Store
```

Default Value:

Not configured

References:

1. CCE-22919-5

1.2.3.1.2 Set 'Turn off downloading of print drivers over HTTP' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls whether the computer can download print driver packages over HTTP. To set up HTTP printing, printer drivers that are not available in the standard operating system installation might need to be downloaded over HTTP. The recommended state for this setting is: *Enabled*.

Rationale:

Users might download drivers that include malicious code.

Impact:

This policy setting does not prevent the client computer from printing to printers on the intranet or the Internet over HTTP. It only prohibits drivers that are not already installed locally from downloading.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Printers\DisableWebPnPDownload
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\System\Internet Communication  
Management\Internet Communication settings\Turn off downloading of print  
drivers over HTTP
```

Default Value:

Not configured

References:

1. CCE-22183-8

ARCHIVE

1.2.3.1.3 Set 'Turn off Windows Update device driver searching' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether Windows will search Windows Update for device drivers when no local drivers for a device are present. Note See also Turn off Windows Update device driver search prompt in Administrative Templates/System, which governs whether an administrator is prompted before Windows Update is searched for device drivers if a driver is not found locally. The recommended state for this setting is:

Enabled.

Rationale:

If users are able to download and install device drivers there is a small chance that they will install a driver that reduces system stability. There is an even smaller possibility that they will install a driver that includes malicious code. These risks are very low because Microsoft requires vendors to test drivers extensively before they can be published on Windows Update.

Impact:

Users will not be able to download new or updated device drivers from Windows Update.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\DriverSearching\DontSearchWindowsUpdate
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Windows Update device driver searching

Default Value:

Disabled

References:

1. CCE-22310-7

1.2.3.1.4 Set 'Turn off the "Publish to Web" task for files and folders' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether the tasks Publish this file to the Web, Publish this folder to the Web, and Publish the selected items to the Web are available from File and Folder Tasks in Windows folders. The recommended state for this setting is: *Enabled*.

Rationale:

Users may publish confidential or sensitive information to a public service outside of the control of the organization.

Impact:

The Web Publishing wizard is used to download a list of providers and allow users to publish content to the Web.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoPublishingWizard
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off the "Publish to Web" task for files and folders
```

Default Value:

Not configured

References:

1. CCE-21949-3

1.2.3.1.5 Set 'Turn off the Windows Messenger Customer Experience Improvement Program' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether Windows Messenger can collect anonymous information about how the Windows Messenger software and service is used. The recommended state for this setting is: *Enabled*.

Rationale:

Large enterprise environments may not want to have information collected from managed client computers.

Impact:

Microsoft uses information collected through the Customer Experience Improvement Program to detect software flaws so that they can be corrected more quickly, enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Messenger\Client\CEIP
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off the Windows Messenger Customer Experience Improvement Program
```

Default Value:

Not configured

References:

1. CCE-23062-3

1.2.3.1.6 Set 'Turn off Search Companion content file updates' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether Search Companion should automatically download content updates during local and Internet searches. The recommended state for this setting is: `Enabled`.

Rationale:

There is a small risk that users will unknowingly reveal sensitive information because of the topics they are searching for. This risk is very low because even if this setting is enabled users still must submit search queries to the desired search engine in order to perform searches.

Impact:

Internet searches will still send the search text and information about the search to Microsoft and the chosen search provider. If you select Classic Search, the Search Companion feature will be unavailable. You can select Classic Search by clicking Start, Search, Change Preferences, and then Change Internet Search Behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\SearchCompanion\DisableContentFileUpdates
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Enabled`.

```
Computer Configuration\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Search Companion content file updates
```

Default Value:

Not configured

References:

1. CCE-21785-1

ARCHIVE

1.2.3.1.7 Configure 'Turn off Event Viewer "Events.asp" links' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Specifies whether "Events.asp" hyperlinks are available for events within the Event Viewer application. The Event Viewer normally makes all HTTP(S) URLs into hot links that activate the Internet browser when clicked. In addition, "More Information" is placed at the end of the description text if the event is created by a Microsoft component. This text contains a link (URL) that, if clicked, sends information about the event to Microsoft, and allows users to learn more about why that event occurred. If you enable this setting, event description URL links are not activated and the text "More Information" is not displayed at the end of the description. If you disable or do not configure this setting, the user can click the hyperlink which prompts the user and then sends information about the event over the internet to Microsoft. Also, see "Events.asp URL", "Events.asp program", and "Events.asp Program Command Line Parameters" settings in "Administrative Templates/Windows Components/Event Viewer". Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Some business information will be sent to Microsoft, although this information will normally be innocuous some organizations may prefer to ensure that no information is shared externally.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\EventViewer\MicrosoftEventVwrD  
isableLinks
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Event Viewer "Events.asp" links
```

Default Value:

Not configured

References:

1. CCE-21419-7

ARCHIVE

1.2.3.1.8 Set 'Turn off Internet download for Web publishing and online ordering wizards' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls whether Windows will download a list of providers for the Web publishing and online ordering wizards. The recommended state for this setting is: Enabled.

Rationale:

Although the risk is minimal, enabling this setting will reduce the possibility of a user unknowingly downloading malicious content through this feature.

Impact:

If this policy setting is enabled, Windows is prevented from downloading providers; only the service providers cached in the local registry will display.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoWebServices
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Internet download for Web publishing and online ordering wizards
```

Default Value:

Not configured

References:

1. CCE-22152-3

1.2.3.1.9 Set 'Turn off printing over HTTP' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to disable the client computer's ability to print over HTTP, which allows the computer to print to printers on the intranet as well as the Internet. The recommended state for this setting is: *Enabled*.

Rationale:

Information that is transmitted over HTTP through this capability is not protected and can be intercepted by malicious users. For this reason, it is not often used in enterprise environments.

Impact:

If you enable this policy setting, the client computer will not be able to print to Internet printers over HTTP. This policy setting affects the client side of Internet printing only. Regardless of how it is configured, a computer could act as an Internet Printing server and make its shared printers available through HTTP.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Printers\DisableHTTPPrinting
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\System\Internet Communication  
Management\Internet Communication settings\Turn off printing over HTTP
```

Default Value:

Not configured

References:

1. CCE-22539-1

ARCHIVE

1.2.3.2 Logon

ARCHIVE

1.2.3.2.1 Set 'Turn on PIN sign-in' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to control whether a domain user can sign in using a PIN. If you enable this policy setting, a domain user can set up and sign in with a PIN. If you disable or don't configure this policy setting, a domain user can't set up and use a PIN. Note that the user's domain password will be cached in the system vault when using this feature. The recommended state for this setting is: *Disabled*.

Rationale:

A PIN are created from a much smaller selection of characters than a password, so in most cases a PIN will be much less robust than a password.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\AllowDomainPINLogon
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Administrative Templates\System\Logon\Turn on PIN sign-in
```

Default Value:

Not configured

References:

1. CCE-21641-6

1.2.3.2.2 Configure 'Do not process the run once list' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting causes the run once list, which is the list of programs that Windows Vista runs automatically when it starts, to be ignored. This policy setting differs from the Do not process the legacy run list setting in that programs on this list will run once the next time the client computer restarts and an administrator logs on. Setup and installation programs are sometimes added to this list to complete installations after a client computer restarts. If you enable this policy setting, attackers generally cannot use the run once list to launch rogue applications, which was a common method of attack in the past. A malicious user can exploit the run once list to install a program that may compromise the security of Windows Vista-based client computers, however since editing this list requires administrator privileges the importance of configuring this setting is not high. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

A malicious user can exploit the run once list to install a program that may compromise the security of Windows clients.

Impact:

If you enable the Do not process the run once list setting you should experience minimal functionality loss for users in your environment, especially if the clients have been configured with all of your organization's standard software before you apply this setting through Group Policy. However, this configuration may prevent some setup and installation programs, such as Internet Explorer, from working properly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer\DisableLocalMachineRunOnce
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\System\Logon\Do not process  
the run once list
```

Default Value:

Disabled

References:

1. CCE-22666-2

ARCHIVE

1.2.3.2.3 Configure 'Do not process the legacy run list' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting causes the run list, which is a list of programs that Windows runs automatically when it starts, to be ignored. The customized run lists for Windows Vista are stored in the registry at the following locations: -
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run -
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run You can enable the Do not process the legacy run list setting to help prevent a malicious user from running a program each time Windows Vista starts, which could compromise data on the computer or cause other harm. When this policy setting is enabled, certain system programs are prevented from running, such as antivirus software, and software distribution and monitoring software. It is recommended to evaluate the threat level to your environment before you determine whether to use this policy setting for your organization. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

A malicious user could configure a program to be run each time Windows starts that could compromise data on the computer or cause other harm.

Impact:

If you enable this setting, certain computer programs such as antivirus software and software distribution and monitoring software are also prevented from execution. You should evaluate the threat level to your environment that this setting is designed to safeguard against before you decide on a strategy to use this setting for your organization.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer\DisableLocalMachineRun
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\System\Logon\Do not process  
the legacy run list
```

Default Value:

Disabled

References:

1. CCE-22265-3

1.2.3.2.4 Set 'Do not enumerate connected users on domain-joined computers' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting prevents connected users from being enumerated on domain-joined computers. If you enable this policy setting, the Logon UI will not enumerate any connected users on domain-joined computers. If you disable or do not configure this policy setting, connected users will be enumerated on domain-joined computers. The recommended state for this setting is: *Enabled*.

Rationale:

A malicious user could use this feature to gather account names of other users, that information could then be used in conjunction with other types of attacks such as guessing passwords or social engineering. The value of this countermeasure is small because a user with domain credentials could gather the same account information using other methods.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\DontEnumerateConnectedUsers
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\System\Logon\Do not enumerate connected users on domain-joined computers
```

Default Value:

Not configured

References:

1. CCE-22562-3

1.2.3.2.5 Configure 'Turn off app notifications on the lock screen' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to prevent app notifications from appearing on the lock screen. If you enable this policy setting, no app notifications are displayed on the lock screen. If you disable or do not configure this policy setting, users can choose which apps display notifications on the lock screen. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

App notifications might display sensitive business or personal data.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\DisableLockScreenAppNotifications
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\System\Logon\Turn off app notifications on the lock screen
```

Default Value:

Not configured

References:

1. CCE-22246-3

1.2.3.2.6 Set 'Enumerate local users on domain-joined computers' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows local users to be enumerated on domain-joined computers. If you enable this policy setting, Logon UI will enumerate all local users on domain-joined computers. If you disable or do not configure this policy setting, the Logon UI will not enumerate local users on domain-joined computers. The recommended state for this setting is: *Disabled*.

Rationale:

A malicious user could use this feature to gather account names of other users, that information could then be used in conjunction with other types of attacks such as guessing passwords or social engineering. The value of this countermeasure is small because a user with domain credentials could gather the same account information using other methods.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\EnumerateLocalUsers
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Administrative Templates\System\Logon\Enumerate local users on domain-joined computers
```

Default Value:

Not configured

References:

1. CCE-21626-7

1.2.3.3 Power Management

ARCHIVE

1.2.3.3.1 Configure 'Turn Off the Display (seconds):' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Specifies the period of inactivity before Windows turns off the display. If you enable this policy, you must provide a value, in seconds, indicating how much idle time should elapse before Windows turns off the display. If you disable this policy or do not configure it, users can see and change this setting. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

No known vulnerabilities at the time of this writing.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\3C0BC021-C8A8-4E07-A973-6B14CBCB2B7E\ACSettingIndex
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\System\Power Management\Video and Display Settings\Turn Off the Display (Plugged In): Turn Off the Display (seconds):
```

Default Value:

Not configured

References:

1. CCE-21831-3

1.2.3.3.2 Configure 'Turn Off the Display (seconds):' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Specifies the period of inactivity before Windows turns off the display. If you enable this policy, you must provide a value, in seconds, indicating how much idle time should elapse before Windows turns off the display. If you disable this policy or do not configure it, users can see and change this setting. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

No known vulnerabilities at the time of this writing.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\3C0BC021-C8A8-4E07-A973-6B14CBCB2B7E\DCSettingIndex
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\System\Power Management\Video and Display Settings\Turn Off the Display (On Battery): Turn Off the Display (seconds) :
```

Default Value:

Not configured

References:

1. CCE-22949-2

1.2.3.3.3 Set 'Require a Password When a Computer Wakes (Plugged In)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Specifies whether or not the user is prompted for a password when the system resumes from sleep. The recommended state for this setting is: `Enabled`.

Rationale:

Enabling this setting ensures that anyone who wakes an unattended computer from sleep state will have to provide logon credentials before they can access the system.

Impact:

If you enable this policy, or if it is not configured, the user is prompted for a password when the system resumes from sleep. If you disable this policy, the user is not prompted for a password when the system resumes from sleep.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51\ACSettingIndex
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Enabled`.

```
Computer Configuration\Administrative Templates\System\Power Management\Sleep Settings\Require a Password When a Computer Wakes (Plugged In)
```

Default Value:

Not configured

References:

1. CCE-21635-8

1.2.3.3.4 Set 'Require a Password When a Computer Wakes (On Battery)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Specifies whether or not the user is prompted for a password when the system resumes from sleep. The recommended state for this setting is: `Enabled`.

Rationale:

Enabling this setting ensures that anyone who wakes an unattended computer from sleep state will have to provide logon credentials before they can access the system.

Impact:

If you enable this policy, or if it is not configured, the user is prompted for a password when the system resumes from sleep. If you disable this policy, the user is not prompted for a password when the system resumes from sleep.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51\DCSettingIndex
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Enabled`.

```
Computer Configuration\Administrative Templates\System\Power Management\Sleep Settings\Require a Password When a Computer Wakes (On Battery)
```

Default Value:

Not configured

References:

1. CCE-22157-2

1.2.3.4 Remote Assistance

ARCHIVE

1.2.3.4.1 Set 'Configure Solicited Remote Assistance' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to turn on or turn off Solicited (Ask for) Remote Assistance on this computer. If you enable this policy setting, users on this computer can use email or file transfer to ask someone for help. Also, users can use instant messaging programs to allow connections to this computer, and you can configure additional Remote Assistance settings. If you disable this policy setting, users on this computer cannot use email or file transfer to ask someone for help. Also, users cannot use instant messaging programs to allow connections to this computer. If you do not configure this policy setting, users can turn on or turn off Solicited (Ask for) Remote Assistance themselves in System Properties in Control Panel. Users can also configure Remote Assistance settings. If you enable this policy setting, you have two ways to allow helpers to provide Remote Assistance: "Allow helpers to only view the computer" or "Allow helpers to remotely control the computer." The "Maximum ticket time" policy setting sets a limit on the amount of time that a Remote Assistance invitation created by using email or file transfer can remain open. The "Select the method for sending email invitations" setting specifies which email standard to use to send Remote Assistance invitations. Depending on your email program, you can use either the Mailto standard (the invitation recipient connects through an Internet link) or the SMAIL (Simple MAPI) standard (the invitation is attached to your email message). This policy setting is not available in Windows Vista since SMAIL is the only method supported. If you enable this policy setting you should also enable appropriate firewall exceptions to allow Remote Assistance communications. The recommended state for this setting is: *Disabled*.

Rationale:

There is slight risk that a rogue administrator will gain access to another user's desktop session, however, they cannot connect to a user's computer unannounced or control it without permission from the user. When an expert tries to connect, the user can still choose to deny the connection or give the expert view-only privileges. The user must explicitly click the Yes button to allow the expert to remotely control the workstation.

Impact:

If you enable this policy, users on this computer can use e-mail or file transfer to ask someone for help. Also, users can use instant messaging programs to allow connections to this computer, and you can configure additional Remote Assistance settings. If you disable this policy, users on this computer cannot use e-mail or file transfer to ask someone for help. Also, users cannot use instant messaging programs to allow connections to this computer. If you don't configure this policy, users can enable or disable Solicited (Ask for) Remote Assistance themselves in System Properties in Control Panel. Users can also configure Remote Assistance settings.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\Windows NT\Terminal  
Services\fAllowToGetHelp
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\System\Remote  
Assistance\Configure Solicited Remote Assistance
```

Default Value:

Not configured

References:

1. CCE-23317-1

1.2.3.4.2 Set 'Configure Offer Remote Assistance' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to turn on or turn off Offer (Unsolicited) Remote Assistance on this computer. If you enable this policy setting, users on this computer can get help from their corporate technical support staff using Offer (Unsolicited) Remote Assistance. If you disable this policy setting, users on this computer cannot get help from their corporate technical support staff using Offer (Unsolicited) Remote Assistance. If you do not configure this policy setting, users on this computer cannot get help from their corporate technical support staff using Offer (Unsolicited) Remote Assistance. If you enable this policy setting, you have two ways to allow helpers to provide Remote Assistance: "Allow helpers to only view the computer" or "Allow helpers to remotely control the computer." When you configure this policy setting, you also specify the list of users or user groups that are allowed to offer remote assistance. To configure the list of helpers, click "Show." In the window that opens, you can enter the names of the helpers. Add each user or group one by one. When you enter the name of the helper user or user groups, use the following format: <Domain Name>\<User Name> or <Domain Name>\<Group Name> If you enable this policy setting, you should also enable firewall exceptions to allow Remote Assistance communications. The firewall exceptions required for Offer (Unsolicited) Remote Assistance depend on the version of Windows you are running. Windows Vista and later Enable the Remote Assistance exception for the domain profile. The exception must contain: Port 135:TCP %WINDIR%\System32\msra.exe %WINDIR%\System32\raserver.exe Windows XP with Service Pack 2 (SP2) and Windows XP Professional x64 Edition with Service Pack 1 (SP1) Port 135:TCP %WINDIR%\PCHealth\HelpCtr\Binaries\Helpsvc.exe %WINDIR%\PCHealth\HelpCtr\Binaries\Helpctr.exe %WINDIR%\System32\Sessmgr.exe For computers running Windows Server 2003 with Service Pack 1 (SP1) Port 135:TCP %WINDIR%\PCHealth\HelpCtr\Binaries\Helpsvc.exe %WINDIR%\PCHealth\HelpCtr\Binaries\Helpctr.exe Allow Remote Desktop Exception The recommended state for this setting is: Disabled.

Rationale:

A user might be tricked and accept an unsolicited Remote Assistance offer from a malicious user.

Impact:

Help desk and support personnel will not be able to proactively offer assistance, although they can still respond to user assistance requests.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\Windows NT\Terminal  
Services\AllowUnsolicited
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\System\Remote  
Assistance\Configure Offer Remote Assistance
```

Default Value:

Not configured

References:

1. CCE-21152-4

1.2.3.4.3 Configure 'Customize Warning Messages' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

The "Display warning message before sharing control" policy setting allows you to specify a custom message to display before a user shares control of his or her computer. The "Display warning message before connecting" policy setting allows you to specify a custom message to display before a user allows a connection to his or her computer. If you enable this policy setting, the warning message you specify will override the default message that is seen by the novice. If you disable this policy setting, the user will see the default warning message. If you do not configure this setting, the user will see the default warning message. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

No known vulnerabilities at the time of this writing.

Impact:

If you enable this policy setting, the warning message you specify will override the default message that is seen by the user. If you disable this policy setting, the user will see the default warning message. If you do not configure this setting, the user will see the default warning message.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\Windows NT\Terminal  
Services\UseCustomMessages
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

Computer Configuration\Administrative Templates\System\Remote Assistance\Customize Warning Messages

Default Value:

Not configured

References:

1. CCE-22462-6

ARCHIVE

1.2.3.5 Set 'RPC Runtime Unauthenticated Client Restriction to Apply:' to 'Enabled:Authenticated' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls how the RPC server runtime handles unauthenticated RPC clients connecting to RPC servers. This policy setting impacts all RPC applications. In a domain environment this policy setting should be used with caution as it can impact a wide range of functionality including group policy processing itself. Reverting a change to this policy setting can require manual intervention on each affected machine. This policy setting should never be applied to a domain controller. If you disable this policy setting, the RPC server runtime uses the value of "Authenticated" on Windows Client, and the value of "None" on Windows Server versions that support this policy setting. If you do not configure this policy setting, it remains disabled. The RPC server runtime will behave as though it was enabled with the value of "Authenticated" used for Windows Client and the value of "None" used for Server SKUs that support this policy setting. If you enable this policy setting, it directs the RPC server runtime to restrict unauthenticated RPC clients connecting to RPC servers running on a machine. A client will be considered an authenticated client if it uses a named pipe to communicate with the server or if it uses RPC Security. RPC Interfaces that have specifically requested to be accessible by unauthenticated clients may be exempt from this restriction, depending on the selected value for this policy setting. -- "None" allows all RPC clients to connect to RPC Servers running on the machine on which the policy setting is applied. -- "Authenticated" allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. Exemptions are granted to interfaces that have requested them. -- "Authenticated without exceptions" allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. No exceptions are allowed. Note: This policy setting will not be applied until the system is rebooted. The recommended state for this setting is: `Enabled:Authenticated`.

Rationale:

Unauthenticated RPC communication can create a security vulnerability.

Impact:

If you enable this policy setting, the following values are available: - None. Allows all RPC clients to connect to RPC servers that run on the computer on which the policy is applied. - Authenticated. Allows only authenticated RPC clients to connect to RPC servers that run on the computer on which the policy is applied. Interfaces that have asked to be exempt from this restriction will be granted an exemption. - Authenticated without exceptions. Allows only authenticated RPC clients to connect to RPC servers that run on the computer on which the policy is applied. No exceptions are allowed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Rpc\RestrictRemoteClients
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\System\Remote Procedure  
Call\Restrict Unauthenticated RPC clients
```

Then set the RPC Runtime Unauthenticated Client Restriction to Apply: option to Authenticated.

Default Value:

Not configured

References:

1. CCE-23021-9

1.2.3.6 Set 'Enable RPC Endpoint Mapper Client Authentication' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls whether RPC clients authenticate with the Endpoint Mapper Service when the call they are making contains authentication information. The Endpoint Mapper Service on computers running Windows NT4 (all service packs) cannot process authentication information supplied in this manner. If you disable this policy setting, RPC clients will not authenticate to the Endpoint Mapper Service, but they will be able to communicate with the Endpoint Mapper Service on Windows NT4 Server. If you enable this policy setting, RPC clients will authenticate to the Endpoint Mapper Service for calls that contain authentication information. Clients making such calls will not be able to communicate with the Windows NT4 Server Endpoint Mapper Service. If you do not configure this policy setting, it remains disabled. RPC clients will not authenticate to the Endpoint Mapper Service, but they will be able to communicate with the Windows NT4 Server Endpoint Mapper Service. Note: This policy will not be applied until the system is rebooted. The recommended state for this setting is:

Disabled.

Rationale:

Anonymous access to RPC services could result in accidental disclosure of information to unauthenticated users.

Impact:

RPC clients will be forced to authenticate before they can begin communicating with the desired RPC service, this means that anonymous access will not be available and RPC clients that do not support authentication will fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Rpc\EnableAuthEpResolution
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Administrative Templates\System\Remote Procedure Call\Enable RPC Endpoint Mapper Client Authentication

Default Value:

Not configured

References:

1. CCE-22863-5

ARCHIVE

1.2.3.7 Set 'Do not apply during periodic background processing' to 'Enabled:FALSE' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines when registry policies are updated. This policy setting affects all policies in the Administrative Templates folder and any other policies that store values in the registry. It overrides customized settings that the program implementing a registry policy set when it was installed. If you enable this policy setting, you can use the check boxes provided to change the options. If you disable or do not configure this policy setting, it has no effect on the system. The "Do not apply during periodic background processing" option prevents the system from updating affected policies in the background while the computer is in use. When background updates are disabled, policy changes will not take effect until the next user logon or system restart. The "Process even if the Group Policy objects have not changed" option updates and reapplies the policies even if the policies have not changed. Many policy implementations specify that they are updated only when changed. However, you might want to update unchanged policies, such as reapplying a desired policy setting in case a user has changed it. The recommended state for this setting is: `Enabled:FALSE`.

Rationale:

You can enable this setting and then select the Process even if the Group Policy objects have not changed option to ensure that the policies will be reprocessed even if none have been changed. This way, any unauthorized changes that might have been configured locally are forced to match the domainbased Group Policy settings again.

Impact:

Group Policies will be reapplied every time they are refreshed, which could have a slight impact on performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Group  
Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}\NoBackgroundPolicy
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\System\Group Policy\Configure  
registry policy processing
```

Then set the Do not apply during periodic background processing option to FALSE.

Default Value:

Not configured

References:

1. CCE-22964-1

1.2.3.8 Set 'Process even if the Group Policy objects have not changed' to 'Enabled:TRUE' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines when registry policies are updated. This policy setting affects all policies in the Administrative Templates folder and any other policies that store values in the registry. It overrides customized settings that the program implementing a registry policy set when it was installed. If you enable this policy setting, you can use the check boxes provided to change the options. If you disable or do not configure this policy setting, it has no effect on the system. The "Do not apply during periodic background processing" option prevents the system from updating affected policies in the background while the computer is in use. When background updates are disabled, policy changes will not take effect until the next user logon or system restart. The "Process even if the Group Policy objects have not changed" option updates and reapplies the policies even if the policies have not changed. Many policy implementations specify that they are updated only when changed. However, you might want to update unchanged policies, such as reapplying a desired policy setting in case a user has changed it. The recommended state for this setting is: `Enabled:TRUE`.

Rationale:

You can enable this setting and then select the Process even if the Group Policy objects have not changed option to ensure that the policies will be reprocessed even if none have been changed. This way, any unauthorized changes that might have been configured locally are forced to match the domainbased Group Policy settings again.

Impact:

Group Policies will be reapplied every time they are refreshed, which could have a slight impact on performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Group  
Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}\NoGPListChanges
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\System\Group Policy\Configure  
registry policy processing
```

Then set the Process even if the Group Policy objects have not changed option to TRUE.

1.2.3.9 Set 'Choose the boot-start drivers that can be initialized:' to 'Enabled:Good, unknown and bad but critical' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to specify which boot-start drivers are initialized based on a classification determined by an Early Launch Antimalware boot-start driver. The Early Launch Antimalware boot-start driver can return the following classifications for each boot-start driver:

- **Good:** The driver has been signed and has not been tampered with.
- **Bad:** The driver has been identified as malware. It is recommended that you do not allow known bad drivers to be initialized.
- **Bad, but required for boot:** The driver has been identified as malware, but the computer cannot successfully boot without loading this driver.
- **Unknown:** This driver has not been attested to by your malware detection application and has not been classified by the Early Launch Antimalware boot-start driver.

If you enable this policy setting you will be able to choose which boot-start drivers to initialize the next time the computer is started. If you disable or do not configure this policy setting, the boot start drivers determined to be Good, Unknown or Bad but Boot Critical are initialized and the initialization of drivers determined to be Bad is skipped. If your malware detection application does not include an Early Launch Antimalware boot-start driver or if your Early Launch Antimalware boot-start driver has been disabled, this setting has no effect and all boot-start drivers are initialized. The recommended state for this setting is: `Enabled:Good, unknown and bad but critical`.

Rationale:

This policy setting helps reduce the impact of malware that has already infected your system.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Policies\EarlyLaunch\DriverLoadPolicy
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\System\Early Launch  
Antimalware\Boot-Start Driver Initialization Policy
```

Then set the Choose the boot-start drivers that can be initialized: option to Good, unknown and bad but critical.

Default Value:

Not configured

References:

1. CCE-23349-4

1.2.3.10 Configure 'Detect compatibility issues for applications and drivers' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting configures the Program Compatibility Assistant (PCA) to diagnose failures with application and driver compatibility. If you enable this policy setting, the PCA is configured to detect failures during application installation, failures during application runtime, and drivers blocked due to compatibility issues. When failures are detected, the PCA will provide options to run the application in a compatibility mode or get help online through a Microsoft website. If you disable this policy setting, the PCA does not detect compatibility issues for applications and drivers. If you do not configure this policy setting, the PCA is configured to detect failures during application installation, failures during application runtime, and drivers blocked due to compatibility issues. Note: This policy setting has no effect if the "Turn off Program Compatibility Assistant" policy setting is enabled. The Diagnostic Policy Service (DPS) and Program Compatibility Assistant Service must be running for the PCA to run. These services can be configured by using the Services snap-in to the Microsoft Management Console. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

The PCA can help troubleshoot software issues, however some organizations may prefer to disable the feature in order to reduce the risk of a newly discovered vulnerability in the feature being exploited. There are no known vulnerabilities with PCA at the time of this writing.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\AppCompat\DisablePcaUI
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\System\Troubleshooting and  
Diagnostics\Application Compatibility Diagnostics\Detect compatibility issues  
for applications and drivers
```

Default Value:

Not configured

References:

1. CCE-22207-5

1.2.3.11 Set 'Select update server:' to 'Enabled:Search Managed Server' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to specify the search server that Windows uses to find updates for device drivers. If you enable this policy setting, you can select whether Windows searches Windows Update (WU), searches a Managed Server, or a combination of both. Note that if both are specified, then Windows will first search the Managed Server, such as a Windows Server Update Services (WSUS) server. Only if no update is found will Windows then also search Windows Update. If you disable or do not configure this policy setting, members of the Administrators group can determine the server used in the search for device drivers. The recommended state for this setting is:

Enabled:Search Managed Server.

Rationale:

No known vulnerabilities at the time of this writing however many organizations prefer to manage installation packages for device drivers. Another potential advantage may be a reduction in the traffic volume over the organization's Internet connection.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\DriverSearching\Driver  
ServerSelection
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\System\Device  
Installation\Specify the search server for device driver updates
```

Then set the **Select update server:** option to **Search Managed Server**.

Default Value:

Not configured

References:

1. CCE-23227-2

ARCHIVE

1.2.3.12 Configure 'Specify settings for optional component installation and component repair' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies the network locations that will be used for the repair of operating system corruption and for enabling optional features that have had their payload files removed. If you enable this policy setting and specify the new location, the files in that location will be used to repair operating system corruption and for enabling optional features that have had their payload files removed. You must enter the fully qualified path to the new location in the ""Alternate source file path"" text box. Multiple locations can be specified when each path is separated by a semicolon. The network location can be either a folder, or a WIM file. If it is a WIM file, the location should be specified by prefixing the path with wim: and include the index of the image to use in the WIM file. For example wim:\\server\share\install.wim:3. If you disable or do not configure this policy setting, or if the required files cannot be found at the locations specified in this policy setting, the files will be downloaded from Windows Update, if that is allowed by the policy settings for the computer. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

No known vulnerabilities at the time of this writing however many organizations prefer to manage installation images and files. Another potential advantage may be a reduction in the traffic volume over the organization's Internet connection.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

Computer Configuration\Administrative Templates\System\Specify settings for optional component installation and component repair
--

Default Value:

Not configured

References:

1. CCE-21903-0

ARCHIVE

1.2.3.13 Set 'Prevent installation of devices using drivers that match these device setup classes' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to specify a list of device setup class globally unique identifiers (GUIDs) for device drivers that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device. If you enable this policy setting, Windows is prevented from installing or updating device drivers whose device setup class GUIDs appear in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server. If you disable or do not configure this policy setting, Windows can install and update devices as allowed or prevented by other policy settings. The recommended state for this setting is: `Enabled`.

Rationale:

Organizations may wish to block certain types of devices in order to reduce the risk of users copying sensitive data to removable media or prevent users from installing or running unauthorized software from removable media.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\DeviceInstall\Restrictions\DenyDeviceClasses
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Enabled`.

```
Computer Configuration\Administrative Templates\System\Device Installation\Device Installation Restrictions\Prevent installation of devices using drivers that match these device setup classes
```

References:

1. CCE-21694-5

1.2.3.14 Set 'Also apply to matching devices that are already installed' to 'True' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to specify a list of device setup class globally unique identifiers (GUIDs) for device drivers that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device. If you enable this policy setting, Windows is prevented from installing or updating device drivers whose device setup class GUIDs appear in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server. If you disable or do not configure this policy setting, Windows can install and update devices as allowed or prevented by other policy settings. The recommended state for this setting is: `True`.

Rationale:

Organizations may wish to block certain types of devices in order to reduce the risk of users copying sensitive data to removable media or prevent users from installing or running unauthorized software from removable media.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\DeviceInstall\Restrictions\DenyDeviceClassesRetroactive
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\System\Device Installation\Device Installation Restrictions\Prevent installation of devices using drivers that match these device setup classes: Also apply to matching devices that are already installed.
```

1.2.3.15 Configure 'Prevent installation of devices using drivers for these device setup classes:' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to specify a list of device setup class globally unique identifiers (GUIDs) for device drivers that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device. If you enable this policy setting, Windows is prevented from installing or updating device drivers whose device setup class GUIDs appear in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server. If you disable or do not configure this policy setting, Windows can install and update devices as allowed or prevented by other policy settings. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Organizations may wish to block certain types of devices in order to reduce the risk of users copying sensitive data to removable media or prevent users from installing or running unauthorized software from removable media.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\System\Device
Installation\Device Installation Restrictions\Prevent installation of devices
using drivers that match these device setup classes: Prevent installation of
devices using drivers for these device setup classes:
```

1.2.4 Windows Components

1.2.4.1 AutoPlay Policies

ARCHIVE

1.2.4.1.1 Set 'Turn off Autoplay on' to 'Enabled:All drives' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Autoplay starts to read from a drive as soon as you insert media in the drive, which causes the setup file for programs or audio media to start immediately. An attacker could use this feature to launch a program to damage the computer or data on the computer. You can enable the Turn off Autoplay setting to disable the Autoplay feature. Autoplay is disabled by default on some removable drive types, such as floppy disk and network drives, but not on CD-ROM drives. Note You cannot use this policy setting to enable Autoplay on computer drives in which it is disabled by default, such as floppy disk and network drives. The recommended state for this setting is: `Enabled:All drives`.

Rationale:

An attacker could use this feature to launch a program to damage a client computer or data on the computer.

Impact:

Users will have to manually launch setup or installation programs that are provided on removable media.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoDriveTypeAutoRun
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Enabled`.

```
Computer Configuration\Administrative Templates\Windows Components\AutoPlay Policies\Turn off Autoplay
```

Then set the `Turn off Autoplay on` option to `All drives`.

Default Value:

Not configured

References:

1. CCE-22150-7

ARCHIVE

1.2.4.2 BitLocker

1.2.4.2.1 Fixed Data Drives

ARCHIVE

1.2.4.2.1.1 Set 'Configure use of hardware-based encryption for fixed data drives' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on fixed data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is:

Enabled.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVHardwareEncryption
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Configure use of hardware-based encryption  
for fixed data drives
```

References:

1. CCE-22446-9

1.2.4.2.1.2 Configure 'Enforce drive encryption type on fixed data drives' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure the encryption type used by BitLocker Drive Encryption. This policy setting is applied when you turn on BitLocker. Changing the encryption type has no effect if the drive is already encrypted or if encryption is in progress. Choose full encryption to require that the entire drive be encrypted when BitLocker is turned on. Choose used space only encryption to require that only the portion of the drive used to store data is encrypted when BitLocker is turned on. If you enable this policy setting the encryption type that BitLocker will use to encrypt drives is defined by this policy and the encryption type option will not be presented in the BitLocker setup wizard. If you disable or do not configure this policy setting, the BitLocker setup wizard will ask the user to select the encryption type before turning on BitLocker. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

For new drives there are no known vulnerabilities with choosing to only encrypt used space. The potential issue arises when configuring BitLocker on drives that have been used previously because the unused space may contain remnants of files that were used in the past but are no inaccessible to standard Windows applications such as Explorer. An attacker with physical access to the drive may be able to use specially designed data recovery tools to retrieve this data.

Impact:

If you choose to only encrypt used space the initial encryption of the drive will proceed much more quickly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Enforce drive encryption type on fixed  
data drives
```

References:

1. CCE-22197-8

ARCHIVE

1.2.4.2.1.3 Set 'Configure use of passwords for fixed data drives' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting specifies whether a password is required to unlock BitLocker-protected fixed data drives. If you choose to permit the use of a password, you can require that a password be used, enforce complexity requirements on the password, and configure a minimum length for the password. For the complexity requirement setting to be effective the Group Policy setting "Password must meet complexity requirements" located in Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy\ must be also enabled. Note: These settings are enforced when turning on BitLocker, not when unlocking a volume. BitLocker will allow unlocking a drive with any of the protectors available on the drive. If you enable this policy setting, users can configure a password that meets the requirements you define. To require the use of a password, select "Require password for fixed data drive". To enforce complexity requirements on the password, select "Require complexity". When set to "Require complexity" a connection to a domain controller is necessary when BitLocker is enabled to validate the complexity the password. When set to "Allow complexity" a connection to a domain controller will be attempted to validate the complexity adheres to the rules set by the policy, but if no domain controllers are found the password will still be accepted regardless of actual password complexity and the drive will be encrypted using that password as a protector. When set to "Do not allow complexity", no password complexity validation will be done. Passwords must be at least 8 characters. To configure a greater minimum length for the password, enter the desired number of characters in the "Minimum password length" box. If you disable this policy setting, the user is not allowed to use a password. If you do not configure this policy setting, passwords will be supported with the default settings, which do not include password complexity requirements and require only 8 characters. Note: Passwords cannot be used if FIPS-compliance is enabled. The "System cryptography: Use FIPS-compliant algorithms for encryption, hashing, and signing" policy setting in Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options specifies whether FIPS-compliance is enabled. The recommended state for this setting is: *Disabled*.

Rationale:

Using a dictionary-style attack, passwords can be guessed or discovered by repeatedly attempting to unlock a drive. Since this type of BitLocker password does include anti-dictionary attack protections provided by a TPM, for example, there is no mechanism to slow down rapid brute-force attacks against them.

Impact:

The password option will not be available when configuring BitLocker.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\FDVPassphrase
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Configure use of passwords for fixed data  
drives
```

Default Value:

Not Configured

References:

1. CCE-21590-5

1.2.4.2.1.4 Set 'Recovery Key' to 'Allow 256-bit recovery key' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: Allow 256-bit recovery key.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVRecoveryKey
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Allow 256-bit recovery key`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed  
drives can be recovered: Recovery Key
```

1.2.4.2.1.5 Set 'Recovery Password' to 'Allow 48-digit recovery password' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `Allow 48-digit recovery password`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVRecoveryPassword
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Allow 48-digit recovery password`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed  
drives can be recovered: Recovery Password
```


1.2.4.2.1.6 Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on fixed data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is:

True.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVAllowSoftwareEncryptionFailover
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Fixed Data Drives\Configure use of hardware-based encryption for fixed data drives: Use BitLocker software-based encryption when hardware encryption is not available
```

1.2.4.2.1.7 Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on fixed data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is: 2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVAAllowedHardwareEncryptionAlgorithms
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Fixed Data Drives\Configure use of hardware-based encryption for fixed data drives: Restrict crypto algorithms or cipher suites to the following:
```

1.2.4.2.1.8 Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on fixed data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is:

False.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVRestrictHardwareEncryptionAlgorithms
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Configure use of hardware-based encryption  
for fixed data drives: Restrict encryption algorithms and cipher suites  
allowed for hardware-based encryption
```

1.2.4.2.1.9 Set 'Allow data recovery agent' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `True`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVManageDRA
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed  
drives can be recovered: Allow data recovery agent
```


1.2.4.2.1.10 Set 'Choose how BitLocker-protected fixed drives can be recovered' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is:

Enabled.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVRecovery
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed  
drives can be recovered
```

Default Value:

Not Configured

References:

1. CCE-22244-8

1.2.4.2.1.11 Set 'Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is:

False.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVRequireActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed  
drives can be recovered: Do not enable BitLocker until recovery information  
is stored to AD DS for fixed data drives
```

1.2.4.2.1.12 Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Backup recovery passwords and key packages' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is:

Backup recovery passwords and key packages.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVActiveDirectoryInfoToStore
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Backup recovery passwords and key packages.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed drives can be recovered: Configure storage of BitLocker recovery information to AD DS:
```

1.2.4.2.1.13 Set 'Save BitLocker recovery information to AD DS for fixed data drives' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is:

False.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed  
drives can be recovered: Save BitLocker recovery information to AD DS for  
fixed data drives
```


1.2.4.2.1.14 Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected fixed data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected fixed data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `True`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\FDVHideRecoveryPage
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed  
drives can be recovered: Omit recovery options from the BitLocker setup  
wizard
```

1.2.4.2.1.15 Set 'Configure use of smart cards on fixed data drives' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to specify whether smart cards can be used to authenticate user access to the BitLocker-protected fixed data drives on a computer. If you enable this policy setting smart cards can be used to authenticate user access to the drive. You can require a smart card authentication by selecting the "Require use of smart cards on fixed data drives" check box. Note: These settings are enforced when turning on BitLocker, not when unlocking a drive. BitLocker will allow unlocking a drive with any of the protectors available on the drive. If you disable this policy setting, users are not allowed to use smart cards to authenticate their access to BitLocker-protected fixed data drives. If you do not configure this policy setting, smart cards can be used to authenticate user access to a BitLocker-protected drive. The recommended state for this setting is: *Enabled*.

Rationale:

A drive can be compromised by guessing or finding the authentication information used to access the drive. For example, a password could be guessed, or a drive set to automatically unlock could be lost or stolen with the computer it automatically unlocks with.

Impact:

Enable this setting and select "Require use of smart cards on fixed data drives." Use of smart cards requires PKI infrastructure. Users will need to authenticate with the smart card to unlock the fixed drive every time they restart the computer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\FDVAAllowUserCert
--

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Fixed Data Drives\Configure use of smart cards on fixed data drives

Default Value:

Not Configured

References:

1. CCE-22648-0

ARCHIVE

1.2.4.2.1.16 Set 'Require use of smart cards on fixed data drives' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to specify whether smart cards can be used to authenticate user access to the BitLocker-protected fixed data drives on a computer. If you enable this policy setting smart cards can be used to authenticate user access to the drive. You can require a smart card authentication by selecting the "Require use of smart cards on fixed data drives" check box. Note: These settings are enforced when turning on BitLocker, not when unlocking a drive. BitLocker will allow unlocking a drive with any of the protectors available on the drive. If you disable this policy setting, users are not allowed to use smart cards to authenticate their access to BitLocker-protected fixed data drives. If you do not configure this policy setting, smart cards can be used to authenticate user access to a BitLocker-protected drive. The recommended state for this setting is: `True`.

Rationale:

A drive can be compromised by guessing or finding the authentication information used to access the drive. For example, a password could be guessed, or a drive set to automatically unlock could be lost or stolen with the computer it automatically unlocks with.

Impact:

Enable this setting and select "Require use of smart cards on fixed data drives." Use of smart cards requires PKI infrastructure. Users will need to authenticate with the smart card to unlock the fixed drive every time they restart the computer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\FDVENforceUserCert
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Configure use of smart cards on fixed data  
drives: Require use of smart cards on fixed data drives
```

1.2.4.2.1.17 Configure 'Deny write access to fixed drives not protected by BitLocker' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting determines whether BitLocker protection is required for fixed data drives to be writable on a computer. This policy setting is applied when you turn on BitLocker. If you enable this policy setting, all fixed data drives that are not BitLocker-protected will be mounted as read-only. If the drive is protected by BitLocker, it will be mounted with read and write access. If you disable or do not configure this policy setting, all fixed data drives on the computer will be mounted with read and write access. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Users may not voluntarily encrypt fixed data drives prior to saving important data to the drive.

Impact:

Drives without BitLocker protection or are BitLocker protected but we not encrypting in your organization will be read-only. Drives encrypted with BitLocker in another organization will be read-only. This policy cannot be used in conjunction with Startup Keys or Recovery Keys.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Policies\Microsoft\FVE\FDVEDenyWriteAccess
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Fixed Data Drives\Deny write access to fixed drives not protected by BitLocker
```

Default Value:

Not Configured

References:

1. CCE-23242-1

ARCHIVE

1.2.4.2.1.18 Set 'Allow access to BitLocker-protected fixed data drives from earlier versions of Windows' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting configures whether or not fixed data drives formatted with the FAT file system can be unlocked and viewed on computers running Windows Server 2008, Windows Vista, Windows XP with Service Pack 3 (SP3), or Windows XP with Service Pack 2 (SP2) operating systems. If this policy setting is enabled or not configured, fixed data drives formatted with the FAT file system can be unlocked on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2, and their content can be viewed. These operating systems have read-only access to BitLocker-protected drives. When this policy setting is enabled, select the "Do not install BitLocker To Go Reader on FAT formatted fixed drives" check box to help prevent users from running BitLocker To Go Reader from their fixed drives. If BitLocker To Go Reader (bitlockertogo.exe) is present on a drive that does not have an identification field specified, or if the drive has the same identification field as specified in the "Provide unique identifiers for your organization" policy setting, the user will be prompted to update BitLocker and BitLocker To Go Reader will be deleted from the drive. In this situation, for the fixed drive to be unlocked on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2, BitLocker To Go Reader must be installed on the computer. If this check box is not selected, BitLocker To Go Reader will be installed on the fixed drive to enable users to unlock the drive on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2 that do not have BitLocker To Go Reader installed. If this policy setting is disabled, fixed data drives formatted with the FAT file system that are BitLocker-protected cannot be unlocked on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2. Bitlockertogo.exe will not be installed. Note: This policy setting does not apply to drives that are formatted with the NTFS file system. The recommended state for this setting is: *Disabled*.

Rationale:

By default BitLocker virtualizes FAT formatted drives to permit access via the BitLocker To Go Reader on previous versions of Windows. Additionally the BitLocker To Go Reader application is applied to the unencrypted portion of the drive. The BitLocker To Go Reader application, like any other application, is subject to spoofing and could be a mechanism to propagate malware. .

Impact:

Users will not be able to access BitLocker protected fixed drives on previous versions on Windows.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\FDDiscoveryVolumeType
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Fixed Data Drives\Allow access to BitLocker-protected fixed  
data drives from earlier versions of Windows
```

Default Value:

Not Configured

References:

1. CCE-22706-6

1.2.4.2.2 Operating System Drives

ARCHIVE

1.2.4.2.2.1 Set 'Configure use of hardware-based encryption for operating system drives' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on operating system drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is: *Enabled*.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSHardwareEncryption
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Configure use of hardware-based  
encryption for operating system drives
```

References:

1. CCE-22121-8

1.2.4.2.2.2 Configure 'Enforce drive encryption type on operating system drives' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure the encryption type used by BitLocker Drive Encryption. This policy setting is applied when you turn on BitLocker. Changing the encryption type has no effect if the drive is already encrypted or if encryption is in progress. Choose full encryption to require that the entire drive be encrypted when BitLocker is turned on. Choose used space only encryption to require that only the portion of the drive used to store data is encrypted when BitLocker is turned on. If you enable this policy setting the encryption type that BitLocker will use to encrypt drives is defined by this policy and the encryption type option will not be presented in the BitLocker setup wizard. If you disable or do not configure this policy setting, the BitLocker setup wizard will ask the user to select the encryption type before turning on BitLocker. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

For new drives there are no known vulnerabilities with choosing to only encrypt used space. The potential issue arises when configuring BitLocker on drives that have been used previously because the unused space may contain remnants of files that were used in the past but are no inaccessible to standard Windows applications such as Explorer. An attacker with physical access to the drive may be able to use specially designed data recovery tools to retrieve this data.

Impact:

If you choose to only encrypt used space the initial encryption of the drive will proceed much more quickly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Enforce drive encryption type on  
operating system drives
```

References:

1. CCE-23452-6

ARCHIVE

1.2.4.2.2.3 Set 'Configure use of passwords for operating system drives' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting specifies the constraints for passwords used to unlock BitLocker-protected operating system drives. If non-TPM protectors are allowed on operating system drives, you can provision a password, enforce complexity requirements on the password, and configure a minimum length for the password. For the complexity requirement setting to be effective the Group Policy setting "Password must meet complexity requirements" located in Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy\ must be also enabled. Note: These settings are enforced when turning on BitLocker, not when unlocking a volume. BitLocker will allow unlocking a drive with any of the protectors available on the drive. If you enable this policy setting, users can configure a password that meets the requirements you define. To enforce complexity requirements on the password, select "Require complexity". When set to "Require complexity" a connection to a domain controller is necessary when BitLocker is enabled to validate the complexity the password. When set to "Allow complexity" a connection to a domain controller will be attempted to validate the complexity adheres to the rules set by the policy, but if no domain controllers are found the password will still be accepted regardless of actual password complexity and the drive will be encrypted using that password as a protector. When set to "Do not allow complexity", no password complexity validation will be done. Passwords must be at least 8 characters. To configure a greater minimum length for the password, enter the desired number of characters in the "Minimum password length" box. If you disable or do not configure this policy setting, the default length constraint of 8 characters will apply to operating system drive passwords and no complexity checks will occur. Note: Passwords cannot be used if FIPS-compliance is enabled. The "System cryptography: Use FIPS-compliant algorithms for encryption, hashing, and signing" policy setting in Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options specifies whether FIPS-compliance is enabled. The recommended state for this setting is: *Disabled*.

Rationale:

Using a dictionary-style attack, passwords can be guessed or discovered by repeatedly attempting to unlock a drive. Since this type of BitLocker password does include anti-dictionary attack protections provided by a TPM, for example, there is no mechanism to slow down rapid brute-force attacks against them.

Impact:

The password option will not be available when configuring BitLocker.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\OSPassphrase
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Configure use of passwords for  
operating system drives
```

References:

1. CCE-21427-0

1.2.4.2.2.4 Set 'Recovery Key' to 'Do not allow 256-bit recovery key' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `Do not allow 256-bit recovery key.`

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSRecoveryKey
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Do not allow 256-bit recovery key.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Choose how BitLocker-protected  
operating system drives can be recovered: Recovery Key
```

1.2.4.2.2.5 Set 'Recovery Password' to 'Require 48-digit recovery password' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `Require 48-digit recovery password`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSRecoveryPassword
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Require 48-digit recovery password.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Choose how BitLocker-protected  
operating system drives can be recovered: Recovery Password
```

1.2.4.2.2.6 Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on operating system drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is: `True`.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSAllowSoftwareEncryptionF  
ailover
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Configure use of hardware-based  
encryption for operating system drives: Use BitLocker software-based  
encryption when hardware encryption is not available
```

1.2.4.2.2.7 Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on operating system drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is:

2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSAllowedHardwareEncryptionAlgorithms
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Configure use of hardware-based encryption for operating system drives: Restrict crypto algorithms or cipher suites to the following:
```


1.2.4.2.2.8 Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on operating system drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is: `False`.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSRestrictHardwareEncryptionAlgorithms
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Configure use of hardware-based  
encryption for operating system drives: Restrict encryption algorithms and  
cipher suites allowed for hardware-based encryption
```

1.2.4.2.2.9 Set 'Allow data recovery agent' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `False`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS compliant.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSManagedDRA
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Choose how BitLocker-protected  
operating system drives can be recovered: Allow data recovery agent
```

1.2.4.2.2.10 Set 'Choose how BitLocker-protected operating system drives can be recovered' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `Enabled`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSRecovery
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Choose how BitLocker-protected  
operating system drives can be recovered
```

Default Value:

Not Configured

References:

1. CCE-23589-5

1.2.4.2.2.11 Set 'Do not enable BitLocker until recovery information is stored to AD DS for operating system drives' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `True`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSRequireActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Choose how BitLocker-protected  
operating system drives can be recovered: Do not enable BitLocker until  
recovery information is stored to AD DS for operating system drives
```


1.2.4.2.2.12 Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Store recovery passwords and key packages' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `Store recovery passwords and key packages`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSActiveDirectoryInfoToStore
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Store recovery passwords and key packages`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Choose how BitLocker-protected operating system drives can be recovered: Configure storage of BitLocker recovery information to AD DS:
```

1.2.4.2.2.13 Set 'Save BitLocker recovery information to AD DS for operating system drives' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `True`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS compliant.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Choose how BitLocker-protected  
operating system drives can be recovered: Save BitLocker recovery information  
to AD DS for operating system drives
```

1.2.4.2.2.14 Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker. The "Allow certificate-based data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected operating system drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only," only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected operating system drives. If this policy setting is disabled or not configured, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `True`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS compliant.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSHideRecoveryPage
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Choose how BitLocker-protected  
operating system drives can be recovered: Omit recovery options from the  
BitLocker setup wizard
```

1.2.4.2.2.15 Set 'Require additional authentication at startup' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether BitLocker requires additional authentication each time the computer starts and whether you are using BitLocker with or without a Trusted Platform Module (TPM). This policy setting is applied when you turn on BitLocker. Note: Only one of the additional authentication options can be required at startup, otherwise a policy error occurs. If you want to use BitLocker on a computer without a TPM, select the "Allow BitLocker without a compatible TPM" check box. In this mode a USB drive is required for start-up and the key information used to encrypt the drive is stored on the USB drive, creating a USB key. When the USB key is inserted the access to the drive is authenticated and the drive is accessible. If the USB key is lost or unavailable you will need to use one of the BitLocker recovery options to access the drive. On a computer with a compatible TPM, four types of authentication methods can be used at startup to provide added protection for encrypted data. When the computer starts, it can use only the TPM for authentication, or it can also require insertion of a USB flash drive containing a startup key, the entry of a 4-digit to 20-digit personal identification number (PIN), or both. If you enable this policy setting, users can configure advanced startup options in the BitLocker setup wizard. If you disable or do not configure this policy setting, users can configure only basic options on computers with a TPM. Note: If you want to require the use of a startup PIN and a USB flash drive, you must configure BitLocker settings using the command-line tool manage-bde instead of the BitLocker Drive Encryption setup wizard. The recommended state for this setting is: `Enabled`.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A PIN requires physical presence to restart the computer. This functionality is not compatible with Wake on LAN solutions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\UseAdvancedStartup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Require additional authentication at  
startup
```

Default Value:

Not Configured

References:

1. CCE-22308-1

1.2.4.2.2.16 Set 'Allow BitLocker without a compatible TPM' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether BitLocker requires additional authentication each time the computer starts and whether you are using BitLocker with or without a Trusted Platform Module (TPM). This policy setting is applied when you turn on BitLocker. Note: Only one of the additional authentication options can be required at startup, otherwise a policy error occurs. If you want to use BitLocker on a computer without a TPM, select the "Allow BitLocker without a compatible TPM" check box. In this mode a USB drive is required for start-up and the key information used to encrypt the drive is stored on the USB drive, creating a USB key. When the USB key is inserted the access to the drive is authenticated and the drive is accessible. If the USB key is lost or unavailable you will need to use one of the BitLocker recovery options to access the drive. On a computer with a compatible TPM, four types of authentication methods can be used at startup to provide added protection for encrypted data. When the computer starts, it can use only the TPM for authentication, or it can also require insertion of a USB flash drive containing a startup key, the entry of a 4-digit to 20-digit personal identification number (PIN), or both. If you enable this policy setting, users can configure advanced startup options in the BitLocker setup wizard. If you disable or do not configure this policy setting, users can configure only basic options on computers with a TPM. Note: If you want to require the use of a startup PIN and a USB flash drive, you must configure BitLocker settings using the command-line tool manage-bde instead of the BitLocker Drive Encryption setup wizard. The recommended state for this setting is: `False`.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A PIN requires physical presence to restart the computer. This functionality is not compatible with Wake on LAN solutions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\EnableBDEWithNoTPM
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Require additional authentication at  
startup: Allow BitLocker without a compatible TPM
```

1.2.4.2.2.17 Set 'Configure TPM startup key and PIN:' to 'Do not allow startup key and PIN with TPM' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether BitLocker requires additional authentication each time the computer starts and whether you are using BitLocker with or without a Trusted Platform Module (TPM). This policy setting is applied when you turn on BitLocker. Note: Only one of the additional authentication options can be required at startup, otherwise a policy error occurs. If you want to use BitLocker on a computer without a TPM, select the "Allow BitLocker without a compatible TPM" check box. In this mode a USB drive is required for start-up and the key information used to encrypt the drive is stored on the USB drive, creating a USB key. When the USB key is inserted the access to the drive is authenticated and the drive is accessible. If the USB key is lost or unavailable you will need to use one of the BitLocker recovery options to access the drive. On a computer with a compatible TPM, four types of authentication methods can be used at startup to provide added protection for encrypted data. When the computer starts, it can use only the TPM for authentication, or it can also require insertion of a USB flash drive containing a startup key, the entry of a 4-digit to 20-digit personal identification number (PIN), or both. If you enable this policy setting, users can configure advanced startup options in the BitLocker setup wizard. If you disable or do not configure this policy setting, users can configure only basic options on computers with a TPM. Note: If you want to require the use of a startup PIN and a USB flash drive, you must configure BitLocker settings using the command-line tool manage-bde instead of the BitLocker Drive Encryption setup wizard. The recommended state for this setting is: Do not allow startup key and PIN with TPM.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A PIN requires physical presence to restart the computer. This functionality is not compatible with Wake on LAN solutions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\UseTPMKeyPIN
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Do not allow startup key and PIN with TPM.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Require additional authentication at  
startup: Configure TPM startup key and PIN:
```

1.2.4.2.2.18 Set 'Configure TPM startup PIN:' to 'Require startup PIN with TPM' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether BitLocker requires additional authentication each time the computer starts and whether you are using BitLocker with or without a Trusted Platform Module (TPM). This policy setting is applied when you turn on BitLocker. Note: Only one of the additional authentication options can be required at startup, otherwise a policy error occurs. If you want to use BitLocker on a computer without a TPM, select the "Allow BitLocker without a compatible TPM" check box. In this mode a USB drive is required for start-up and the key information used to encrypt the drive is stored on the USB drive, creating a USB key. When the USB key is inserted the access to the drive is authenticated and the drive is accessible. If the USB key is lost or unavailable you will need to use one of the BitLocker recovery options to access the drive. On a computer with a compatible TPM, four types of authentication methods can be used at startup to provide added protection for encrypted data. When the computer starts, it can use only the TPM for authentication, or it can also require insertion of a USB flash drive containing a startup key, the entry of a 4-digit to 20-digit personal identification number (PIN), or both. If you enable this policy setting, users can configure advanced startup options in the BitLocker setup wizard. If you disable or do not configure this policy setting, users can configure only basic options on computers with a TPM. Note: If you want to require the use of a startup PIN and a USB flash drive, you must configure BitLocker settings using the command-line tool manage-bde instead of the BitLocker Drive Encryption setup wizard. The recommended state for this setting is: Require startup PIN with TPM.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A PIN requires physical presence to restart the computer. This functionality is not compatible with Wake on LAN solutions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\UseTPMPIN
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Require startup PIN with TPM.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Require additional authentication at  
startup: Configure TPM startup PIN:
```

1.2.4.2.2.19 Set 'Configure TPM startup:' to 'Do not allow TPM' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether BitLocker requires additional authentication each time the computer starts and whether you are using BitLocker with or without a Trusted Platform Module (TPM). This policy setting is applied when you turn on BitLocker. Note: Only one of the additional authentication options can be required at startup, otherwise a policy error occurs. If you want to use BitLocker on a computer without a TPM, select the "Allow BitLocker without a compatible TPM" check box. In this mode a USB drive is required for start-up and the key information used to encrypt the drive is stored on the USB drive, creating a USB key. When the USB key is inserted the access to the drive is authenticated and the drive is accessible. If the USB key is lost or unavailable you will need to use one of the BitLocker recovery options to access the drive. On a computer with a compatible TPM, four types of authentication methods can be used at startup to provide added protection for encrypted data. When the computer starts, it can use only the TPM for authentication, or it can also require insertion of a USB flash drive containing a startup key, the entry of a 4-digit to 20-digit personal identification number (PIN), or both. If you enable this policy setting, users can configure advanced startup options in the BitLocker setup wizard. If you disable or do not configure this policy setting, users can configure only basic options on computers with a TPM. Note: If you want to require the use of a startup PIN and a USB flash drive, you must configure BitLocker settings using the command-line tool manage-bde instead of the BitLocker Drive Encryption setup wizard. The recommended state for this setting is: Do not allow TPM.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A PIN requires physical presence to restart the computer. This functionality is not compatible with Wake on LAN solutions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\UseTPM
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Do not allow TPM.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Require additional authentication at  
startup: Configure TPM startup:
```


1.2.4.2.2.20 Set 'Configure TPM startup key:' to 'Do not allow startup key with TPM' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether BitLocker requires additional authentication each time the computer starts and whether you are using BitLocker with or without a Trusted Platform Module (TPM). This policy setting is applied when you turn on BitLocker. Note: Only one of the additional authentication options can be required at startup, otherwise a policy error occurs. If you want to use BitLocker on a computer without a TPM, select the "Allow BitLocker without a compatible TPM" check box. In this mode a USB drive is required for start-up and the key information used to encrypt the drive is stored on the USB drive, creating a USB key. When the USB key is inserted the access to the drive is authenticated and the drive is accessible. If the USB key is lost or unavailable you will need to use one of the BitLocker recovery options to access the drive. On a computer with a compatible TPM, four types of authentication methods can be used at startup to provide added protection for encrypted data. When the computer starts, it can use only the TPM for authentication, or it can also require insertion of a USB flash drive containing a startup key, the entry of a 4-digit to 20-digit personal identification number (PIN), or both. If you enable this policy setting, users can configure advanced startup options in the BitLocker setup wizard. If you disable or do not configure this policy setting, users can configure only basic options on computers with a TPM. Note: If you want to require the use of a startup PIN and a USB flash drive, you must configure BitLocker settings using the command-line tool manage-bde instead of the BitLocker Drive Encryption setup wizard. The recommended state for this setting is: Do not allow startup key with TPM.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A PIN requires physical presence to restart the computer. This functionality is not compatible with Wake on LAN solutions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\UseTPMKey
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Do not allow startup key with TPM.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Require additional authentication at  
startup: Configure TPM startup key:
```

1.2.4.2.2.21 Configure 'Use enhanced Boot Configuration Data validation profile' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to choose specific Boot Configuration Data (BCD) settings to verify during platform validation. If you enable this policy setting, you will be able to add additional settings, remove the default settings, or both. If you disable this policy setting, the computer will revert to a BCD profile similar to the default BCD profile used by Windows 7. If you do not configure this policy setting, the computer will verify the default Windows BCD settings. Note: When BitLocker is using Secured Boot for platform and Boot Configuration Data (BCD) integrity validation, as defined by the "Allow Secured Boot for integrity validation" group policy, the "Use enhanced Boot Configuration Data validation profile" group policy is ignored. The setting that controls boot debugging (0x16000010) will always be validated and will have no effect if it is included in the provided fields. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Some organizations may want to specify which BCD settings are verified by BitLocker during the platform validation process.

Impact:

If you enable this policy setting, you will be able to add additional settings, remove the default settings, or both.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\OSUseEnhancedBcdProfile
--

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Use enhanced Boot Configuration Data validation profile

References:

1. CCE-21353-8

ARCHIVE

1.2.4.2.22 Configure 'Enable use of BitLocker authentication requiring preboot keyboard input on slates' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows users to enable authentication options that require user input from the pre-boot environment even if the platform indicates lack of pre-boot input capability. The Windows on-screen touch keyboard (such as used by slates) is not available in the pre-boot environment where BitLocker requires additional information such as a PIN or Password. It is recommended that administrators enable this policy only for devices that are verified to have an alternative means of pre-boot input (such as by attaching a USB keyboard). Note that if this option is not enabled, options in the "Require additional authentication at startup" policy may not be available on such devices. These options include:

- Configure TPM startup PIN: Required/Allowed
- Configure TPM startup key and PIN: Required/Allowed
- Configure use of passwords for operating system drives.

Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

Users will be required to authenticate in order to boot computers that rely primarily on touch keyboards, if they do not have access to a USB keyboard or other alternative means to enter their PIN or password they will be unable to boot the system.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\OSEnablePrebootInputProtectionsOnSlates
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Enable use of BitLocker authentication requiring preboot keyboard input on slates
```

References:

1. CCE-22535-9

1.2.4.2.2.23 Configure 'Configure TPM platform validation profile for BIOS-based firmware configurations' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure how the computer's Trusted Platform Module (TPM) security hardware secures the BitLocker encryption key. This policy setting does not apply if the computer does not have a compatible TPM or if BitLocker has already been turned on with TPM protection. Important: This group policy only applies to computers with BIOS configurations or to computers with UEFI firmware with a Compatibility Service Module (CSM) enabled. Computers using a native UEFI firmware configuration store different values into the Platform Configuration Registers (PCRs). Use the "Configure TPM platform validation profile for native UEFI firmware configurations" group policy setting to configure the TPM PCR profile for computers using native UEFI firmware. If you enable this policy setting before turning on BitLocker, you can configure the boot components that the TPM will validate before unlocking access to the BitLocker-encrypted operating system drive. If any of these components change while BitLocker protection is in effect, the TPM will not release the encryption key to unlock the drive and the computer will instead display the BitLocker Recovery console and require that either the recovery password or recovery key be provided to unlock the drive. If you disable or do not configure this policy setting, BitLocker uses the default platform validation profile or the platform validation profile specified by the setup script. A platform validation profile consists of a set of Platform Configuration Register (PCR) indices ranging from 0 to 23. The default platform validation profile secures the encryption key against changes to the Core Root of Trust of Measurement (CRTM), BIOS, and Platform Extensions (PCR 0), the Option ROM Code (PCR 2), the Master Boot Record (MBR) Code (PCR 4), the NTFS Boot Sector (PCR 8), the NTFS Boot Block (PCR 9), the Boot Manager (PCR 10), and the BitLocker Access Control (PCR 11). Warning: Changing from the default platform validation profile affects the security and manageability of your computer. BitLocker's sensitivity to platform modifications (malicious or authorized) is increased or decreased depending upon inclusion or exclusion (respectively) of the PCRs. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

For most organizations the default PCRs are sufficiently secure. If you are thoroughly familiar with each PCR and the impact disabling specific ones may have on computers in your network then enforcing this policy setting can provide an additional layer of protection for the BitLocker encryption key. BitLocker Drive Encryption Deployment Guide on Microsoft TechNet contains a complete list of PCR settings for both EFI and standard BIOS, it is available here:

<http://www.microsoft.com/downloads/details.aspx?FamilyID=41BA0CF0-57D6-4C38-9743-B7F4DDBE25CD&displaylang=e&displaylang=en>.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSPlatformValidation_BIOS\Enabled
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Configure TPM platform validation profile for BIOS-based firmware configurations
```

References:

1. CCE-22835-3

1.2.4.2.2.24 Configure 'Configure TPM platform validation profile for native UEFI firmware configurations' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure how the computer's Trusted Platform Module (TPM) security hardware secures the BitLocker encryption key. This policy setting does not apply if the computer does not have a compatible TPM or if BitLocker has already been turned on with TPM protection. Important: This group policy only applies to computers with a native UEFI firmware configuration. Computers with BIOS or UEFI firmware with a Compatibility Service Module (CSM) enabled store different values into the Platform Configuration Registers (PCRs). Use the "Configure TPM platform validation profile for BIOS-based firmware configurations" group policy setting to configure the TPM PCR profile for computers with BIOS configurations or computers with UEFI firmware with a CSM enabled. If you enable this policy setting before turning on BitLocker, you can configure the boot components that the TPM will validate before unlocking access to the BitLocker-encrypted operating system drive. If any of these components change while BitLocker protection is in effect, the TPM will not release the encryption key to unlock the drive and the computer will instead display the BitLocker Recovery console and require that either the recovery password or recovery key be provided to unlock the drive. If you disable or do not configure this policy setting, BitLocker uses the default platform validation profile or the platform validation profile specified by the setup script. A platform validation profile consists of a set of Platform Configuration Register (PCR) indices ranging from 0 to 23. The default platform validation profile secures the encryption key against changes to the core system firmware executable code (PCR 0), extended or pluggable executable code (PCR 2), boot manager (PCR 4), and the BitLocker access control (PCR 11). Warning: Changing from the default platform validation profile affects the security and manageability of your computer. BitLocker's sensitivity to platform modifications (malicious or authorized) is increased or decreased depending upon inclusion or exclusion (respectively) of the PCRs. Specifically, setting this policy with PCR 7 omitted, will override the "Allow Secured Boot for integrity validation" group policy, preventing BitLocker from using Secured Boot for platform or Boot Configuration Data (BCD) integrity validation. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

For most organizations the default PCRs are sufficiently secure. If you are thoroughly familiar with each PCR and the impact disabling specific ones may have on computers in your network then enforcing this policy setting can provide an additional layer of protection for the BitLocker encryption key. See the UEFI Firmware page for Windows 8 at <http://technet.microsoft.com/en-us/library/hh824898> for more information.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSPlatformValidation_UEFI\Enabled
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Configure TPM platform validation profile for native UEFI firmware configurations
```

References:

1. CCE-21235-7

1.2.4.2.2.25 Set 'Allow enhanced PINs for startup' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether or not enhanced startup PINs are used with BitLocker. Enhanced startup PINs permit the use of characters including uppercase and lowercase letters, symbols, numbers, and spaces. This policy setting is applied when you turn on BitLocker. If you enable this policy setting, all new BitLocker startup PINs set will be enhanced PINs. Note: Not all computers may support enhanced PINs in the pre-boot environment. It is strongly recommended that users perform a system check during BitLocker setup. If you disable or do not configure this policy setting, enhanced PINs will not be used. The recommended state for this setting is:

Enabled.

Rationale:

A numeric-only PIN provide less entropy than a PIN that is alpha-numeric. When not using enhanced PIN for startup, BitLocker requires the use of the function keys [F1-F10] for PIN entry since the PIN is entered in the pre-OS environment before localization support is available. This limits each PIN digit to one of ten possibilities. The TPM has an anti-hammering feature that includes a mechanism to exponentially increase the delay for PIN retry attempts; however, an attacker is able to more effectively mount a brute force attack using a domain of 10 digits of the function keys.

Impact:

Not all computers enable full keyboard support in the PreOS environment. Some keys may not be available. It is recommended this functionality be tested using the computers in your environment prior to it being deployed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\UseEnhancedPin

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Allow enhanced PINs for startup

Default Value:

Not Configured

References:

1. CCE-22054-1

ARCHIVE

1.2.4.2.2.26 Configure 'Disallow standard users from changing the PIN or password' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether or not standard users are allowed to change BitLocker volume PINs, provided they are able to provide the existing PIN first. This policy setting is applied when you turn on BitLocker. If you enable this policy setting, standard users will not be allowed to change BitLocker PINs or passwords. If you disable or do not configure this policy setting, standard users will be permitted to change BitLocker PINs and passwords. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Disabling this policy setting gives users the ability to choose PINs and passwords that correspond to a personal mnemonic instead of requiring the user remember a randomly generated character set and allows IT professionals to use the same initial PIN or password setting for all PC images. This also presents the opportunity for users to choose passwords and PINs that are more susceptible to password guessing, dictionary attacks, and social engineering attacks and gives users the ability unlock any PC that still uses the original PIN or password assignment. Requiring password complexity and PIN complexity by Group Policy is recommended to help ensure that users take appropriate care when setting passwords and PINs.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\DisallowStandardUserPINReset
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Disallow standard users from changing the PIN or password
```

References:

1. CCE-22817-1

1.2.4.2.2.27 Set 'Allow Secure Boot for integrity validation' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure whether Secure Boot will be allowed as the platform integrity provider for BitLocker operating system drives. Secure Boot ensures that the PC's pre-boot environment only loads firmware that is digitally signed by authorized software publishers. Secure Boot also provides more flexibility for managing pre-boot configuration than legacy BitLocker integrity checks. If you enable or do not configure this policy setting, BitLocker will use Secure Boot for platform integrity if the platform is capable of Secure Boot-based integrity validation. If you disable this policy setting, BitLocker will use legacy platform integrity validation, even on systems capable of Secure Boot-based integrity validation. When this policy is enabled and the hardware is capable of using Secure Boot for BitLocker scenarios, the "Use enhanced Boot Configuration Data validation profile" group policy setting is ignored and Secure Boot verifies BCD settings according to the Secure Boot policy setting, which is configured separately from BitLocker. Note: If the group policy setting "Configure TPM platform validation profile for native UEFI firmware configurations" is enabled and has PCR 7 omitted, BitLocker will be prevented from using Secure Boot for platform or Boot Configuration Data (BCD) integrity validation. The recommended state for this setting is: Enabled.

Rationale:

Secure Boot ensures that only firmware digitally signed by authorized software publishers is loaded during computer startup, which reduces the risk of rootkits and other types of malware from gaining control of the system. It also helps provide protection against malicious users booting from an alternate operating system.

Impact:

Secure Boot requires a system that meets the UEFI 2.3.1 Specifications for Class 2 and Class 3 computers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\OSAllowSecureBootForIntegrity
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Allow Secure Boot for integrity  
validation
```

References:

1. CCE-22777-7

1.2.4.2.2.28 Set 'Minimum characters:' to 'Enabled:7 or more characters' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure a minimum length for a Trusted Platform Module (TPM) startup PIN. This policy setting is applied when you turn on BitLocker. The startup PIN must have a minimum length of 4 digits and can have a maximum length of 20 digits. If you enable this policy setting, you can require a minimum number of digits to be used when setting the startup PIN. If you disable or do not configure this policy setting, users can configure a startup PIN of any length between 4 and 20 digits. The recommended state for this setting is: *Enabled:7 or more characters*.

Rationale:

BitLocker requires the use of the function keys [F1-F10] for PIN entry since the PIN is entered in the pre-OS environment before localization support is available. This limits each PIN digit to one of ten possibilities. The TPM has an anti-hammering feature that includes a mechanism to exponentially increase the delay for PIN retry attempts; however, using a PIN that is short in length improves an attacker's chances of guessing the correct PIN.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\MinimumPIN
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Configure minimum PIN length for  
startup
```

Then set the *Minimum characters:* option to *7 or more characters*.

Default Value:

Not Configured

References:

1. CCE-22966-6

1.2.4.2.2.29 Configure 'Allow network unlock at startup' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting controls whether a BitLocker-protected computer that is connected to a trusted wired Local Area Network (LAN) and joined to a domain can create and use Network Key Protectors on TPM-enabled computers to automatically unlock the operating system drive when the computer is started. If you enable this policy, clients configured with a BitLocker Network Unlock certificate will be able to create and use Network Key Protectors. To use a Network Key Protector to unlock the computer, both the computer and the BitLocker Drive Encryption Network Unlock server must be provisioned with a Network Unlock certificate. The Network Unlock certificate is used to create Network Key Protectors, and protects the information exchanged with the server to unlock the computer. You can use the group policy setting "Computer Configuration\Windows Settings\Security Settings\Public Key Policies\BitLocker Drive Encryption Network Unlock Certificate" on the domain controller to distribute this certificate to computers in your organization. This unlock method uses the TPM on the computer, so computers that do not have a TPM cannot create Network Key Protectors to automatically unlock with Network Unlock. If you disable or do not configure this policy setting, BitLocker clients will not be able to create and use Network Key Protectors. Note: For reliability and security, computers should also have a TPM startup PIN that can be used when the computer is disconnected from the wired network or the server at startup. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

By allowing automatic unlock of operating system volumes this feature makes it possible for unauthorized users with physical access to the computers to attempt to log into the computer. This risk is mitigated by the fact that the computer must be connected to a trusted wired corporate network, so an attacker would have to have gained access to the organization's premises.

Impact:

Network Unlock enables easier management for BitLocker enabled desktops and servers in a domain environment by providing automatic unlock of operating system volumes at system reboot when connected to a trusted wired corporate network. This feature requires the client hardware to have a DHCP driver implemented in its UEFI firmware. This feature facilitates enterprise management tasks such as deploying patches to unattended systems.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\OSManageNKP
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Allow network unlock at startup
```

References:

1. CCE-22103-6

1.2.4.2.2.30 Configure 'Reset platform validation data after BitLocker recovery' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control whether or not platform validation data is refreshed when Windows is started following BitLocker recovery. If you enable this policy setting, platform validation data will be refreshed when Windows is started following BitLocker recovery. If you disable this policy setting, platform validation data will not be refreshed when Windows is started following BitLocker recovery. If you do not configure this policy setting, platform validation data will be refreshed when Windows is started following BitLocker recovery. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Preventing BitLocker from refreshing the platform validation data reduces the risk of system compromise by preventing the system from booting if changes have been made, however this configuration is very restrictive and its not suitable for most organizations because managing OS and hardware upgrades will be more complex.

Impact:

If you disable this policy setting, platform validation data will not be refreshed when Windows is started following BitLocker recovery.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\TPMAutoReseal
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Operating System Drives\Reset platform validation data after  
BitLocker recovery
```

References:

1. CCE-23060-7

1.2.4.2.3 Removable Data Drives

ARCHIVE

1.2.4.2.3.1 Set 'Configure use of hardware-based encryption for removable data drives' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on removable data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is: *Enabled*.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVHardwareEncryption
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Configure use of hardware-based  
encryption for removable data drives
```

References:

1. CCE-22580-5

1.2.4.2.3.2 Configure 'Enforce drive encryption type on removable data drives' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure the encryption type used by BitLocker Drive Encryption. This policy setting is applied when you turn on BitLocker. Changing the encryption type has no effect if the drive is already encrypted or if encryption is in progress. Choose full encryption to require that the entire drive be encrypted when BitLocker is turned on. Choose used space only encryption to require that only the portion of the drive used to store data is encrypted when BitLocker is turned on. If you enable this policy setting the encryption type that BitLocker will use to encrypt drives is defined by this policy and the encryption type option will not be presented in the BitLocker setup wizard. If you disable or do not configure this policy setting, the BitLocker setup wizard will ask the user to select the encryption type before turning on BitLocker. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

For new drives there are no known vulnerabilities with choosing to only encrypt used space. The potential issue arises when configuring BitLocker on drives that have been used previously because the unused space may contain remnants of files that were used in the past but are no inaccessible to standard Windows applications such as Explorer. An attacker with physical access to the drive may be able to use specially designed data recovery tools to retrieve this data.

Impact:

If you choose to only encrypt used space the initial encryption of the drive will proceed much more quickly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Enforce drive encryption type on removable data drives

References:

1. CCE-21716-6

ARCHIVE

1.2.4.2.3.3 Set 'Configure use of passwords for removable data drives' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to specify whether smart cards can be used to authenticate user access to BitLocker-protected removable data drives on a computer. If you enable this policy setting smart cards can be used to authenticate user access to the drive. You can require a smart card authentication by selecting the "Require use of smart cards on removable data drives" check box. Note: These settings are enforced when turning on BitLocker, not when unlocking a drive. BitLocker will allow unlocking a drive with any of the protectors available on the drive. If you disable this policy setting, users are not allowed to use smart cards to authenticate their access to BitLocker-protected removable data drives. If you do not configure this policy setting, smart cards are available to authenticate user access to a BitLocker-protected removable data drive. The recommended state for this setting is: *Disabled*.

Rationale:

Using a dictionary-style attack, passwords can be guessed or discovered by repeatedly attempting to unlock a drive. Since this type of BitLocker password does not include anti-dictionary attack protections provided by a TPM, for example, there is no mechanism to slow down rapid brute-force attacks against them.

Impact:

Users will not be able to use a password with BitLocker. This will prevent users from accessing their drives on previous versions of Windows.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\RDVPassphrase
--

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Configure use of passwords for removable data drives

Default Value:

Not Configured

References:

1. CCE-23529-1

ARCHIVE

1.2.4.2.3.4 Set 'Recovery Key' to 'Do not allow 256-bit recovery key' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: Do not allow 256-bit recovery key.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVRecoveryKey
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Do not allow 256-bit recovery key.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Choose how BitLocker-protected  
removable drives can be recovered: Recovery Key
```

1.2.4.2.3.5 Set 'Recovery Password' to 'Do not allow 48-digit recovery password' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: Do not allow 48-digit recovery password.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVRecoveryPassword

Remediation:

To establish the recommended configuration via GP, set the following UI path to Do not allow 48-digit recovery password.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Choose how BitLocker-protected removable drives can be recovered: Recovery Password

1.2.4.2.3.6 Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on removable data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is: `True`.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVAllowSoftwareEncryption  
Failover
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Configure use of hardware-based  
encryption for removable data drives: Use BitLocker software-based encryption  
when hardware encryption is not available
```


1.2.4.2.3.7 Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on removable data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is:

2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVAllowedHardwareEncryptionAlgorithms
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Configure use of hardware-based encryption for removable data drives: Restrict crypto algorithms or cipher suites to the following:
```

1.2.4.2.3.8 Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to manage BitLocker's use of hardware-based encryption on removable data drives and specify which encryption algorithms it can use with hardware-based encryption. Using hardware-based encryption can improve performance of drive operations that involve frequent reading or writing of data to the drive. If you enable this policy setting, you can specify additional options that control whether BitLocker software-based encryption is used instead of hardware-based encryption on computers that do not support hardware-based encryption and whether you want to restrict the encryption algorithms and cipher suites used with hardware-based encryption. If you disable this policy setting, BitLocker cannot use hardware-based encryption with operating system drives and BitLocker software-based encryption will be used by default when the drive is encrypted. If you do not configure this policy setting, BitLocker will use hardware-based encryption with the encryption algorithm set for the drive. If hardware-based encryption is not available BitLocker software-based encryption will be used instead. Note: The "Choose drive encryption method and cipher strength" policy setting does not apply to hardware-based encryption. The encryption algorithm used by hardware-based encryption is set when the drive is partitioned. By default, BitLocker uses the algorithm configured on the drive to encrypt the drive. The "Restrict encryption algorithms and cipher suites allowed for hardware-based encryption" option enables you to restrict the encryption algorithms that BitLocker can use with hardware encryption. If the algorithm set for the drive is not available, BitLocker will disable the use of hardware-based encryption. Encryption algorithms are specified by object identifiers (OID). For example: - AES 128 in CBC mode OID: 2.16.840.1.101.3.4.1.2 - AES 256 in CBC mode OID: 2.16.840.1.101.3.4.1.42 The recommended state for this setting is: `False`.

Rationale:

From a strict security perspective the hardware-based encryption may offer the same, greater, or less protection than what is provided by BitLocker's software-based encryption depending on how the algorithms and key lengths compare.

Impact:

Hardware-based encryption can improve performance of both read and write operations to the storage drive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVRestrictHardwareEncryptionAlgorithms
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Configure use of hardware-based  
encryption for removable data drives: Restrict encryption algorithms and  
cipher suites allowed for hardware-based encryption
```

1.2.4.2.3.9 Set 'Allow data recovery agent' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `True`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVManageDRA
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Choose how BitLocker-protected  
removable drives can be recovered: Allow data recovery agent
```

1.2.4.2.3.10 Set 'Choose how BitLocker-protected removable drives can be recovered' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: *Enabled*.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVRecovery

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Choose how BitLocker-protected removable drives can be recovered

Default Value:

Not Configured

References:

1. CCE-21612-7

1.2.4.2.3.11 Set 'Do not enable BitLocker until recovery information is stored to AD DS for removable data drives' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `False`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVRequireActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Choose how BitLocker-protected  
removable drives can be recovered: Do not enable BitLocker until recovery  
information is stored to AD DS for removable data drives
```

1.2.4.2.3.12 Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Backup recovery passwords and key packages' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: Backup recovery passwords and key packages.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVActiveDirectoryInfoToStore
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Backup recovery passwords and key packages.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Choose how BitLocker-protected removable drives can be recovered: Configure storage of BitLocker recovery information to AD DS:
```

1.2.4.2.3.13 Set 'Save BitLocker recovery information to AD DS for removable data drives' to 'False' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: `False`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `False`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Choose how BitLocker-protected  
removable drives can be recovered: Save BitLocker recovery information to AD  
DS for removable data drives
```

1.2.4.2.3.14 Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to control how BitLocker-protected removable data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker. The "Allow data recovery agent" check box is used to specify whether a data recovery agent can be used with BitLocker-protected removable data drives. Before a data recovery agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding data recovery agents. In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key. Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting. In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for removable data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. If you select "Backup recovery password only" only the recovery password is stored in AD DS. Select the "Do not enable BitLocker until recovery information is stored in AD DS for removable data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds. Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated. If you enable this policy setting, you can control the methods available to users to recover data from BitLocker-protected removable data drives. If this policy setting is not configured or disabled, the default recovery options are supported for BitLocker recovery. By default a DRA is allowed, the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS. The recommended state for this setting is: *True*.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker a Data Recovery Agent will need to be configured for removable drives. To recover a drive will require controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\RDVHideRecoveryPage
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Choose how BitLocker-protected  
removable drives can be recovered: Omit recovery options from the BitLocker  
setup wizard
```


1.2.4.2.3.15 Set 'Configure use of smart cards on removable data drives' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting specifies whether a password is required to unlock BitLocker-protected removable data drives. If you choose to allow use of a password, you can require a password to be used, enforce complexity requirements, and configure a minimum length. For the complexity requirement setting to be effective the Group Policy setting "Password must meet complexity requirements" located in Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy\ must be also enabled. Note: These settings are enforced when turning on BitLocker, not when unlocking a volume. BitLocker will allow unlocking a drive with any of the protectors available on the drive. If you enable this policy setting, users can configure a password that meets the requirements that you define. To require the use of a password, select "Require password for removable data drive". To enforce complexity requirements on the password, select "Require complexity". When set to "Require complexity" a connection to a domain controller is necessary when BitLocker is enabled to validate the complexity the password. When set to "Allow complexity" a connection to a domain controller will be attempted to validate the complexity adheres to the rules set by the policy, but if no domain controllers are found the password will still be accepted regardless of actual password complexity and the drive will be encrypted using that password as a protector. When set to "Do not allow complexity", no password complexity validation will be done. Passwords must be at least 8 characters. To configure a greater minimum length for the password, enter the desired number of characters in the "Minimum password length" box. If you disable this policy setting, the user is not allowed to use a password. If you do not configure this policy setting, passwords will be supported with the default settings, which do not include password complexity requirements and require only 8 characters. Note: Passwords cannot be used if FIPS-compliance is enabled. The "System cryptography: Use FIPS-compliant algorithms for encryption, hashing, and signing" policy setting in Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options specifies whether FIPS-compliance is enabled. The recommended state for this setting is: *Enabled*.

Rationale:

A drive can be compromised by guessing or finding the authentication information used to access the drive. For example, a password could be guessed, or a drive set to automatically unlock could be lost or stolen with the computer it automatically unlocks with.

Impact:

Users will need a smart card reader to unlock the drive. PKI infrastructure is also required.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\RDVAllowUserCert
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Configure use of smart cards on  
removable data drives
```

Default Value:

Not Configured

References:

1. CCE-22982-3

1.2.4.2.3.16 Set 'Require use of smart cards on removable data drives' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting specifies whether a password is required to unlock BitLocker-protected removable data drives. If you choose to allow use of a password, you can require a password to be used, enforce complexity requirements, and configure a minimum length. For the complexity requirement setting to be effective the Group Policy setting "Password must meet complexity requirements" located in Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy\ must be also enabled. Note: These settings are enforced when turning on BitLocker, not when unlocking a volume. BitLocker will allow unlocking a drive with any of the protectors available on the drive. If you enable this policy setting, users can configure a password that meets the requirements that you define. To require the use of a password, select "Require password for removable data drive". To enforce complexity requirements on the password, select "Require complexity". When set to "Require complexity" a connection to a domain controller is necessary when BitLocker is enabled to validate the complexity the password. When set to "Allow complexity" a connection to a domain controller will be attempted to validate the complexity adheres to the rules set by the policy, but if no domain controllers are found the password will still be accepted regardless of actual password complexity and the drive will be encrypted using that password as a protector. When set to "Do not allow complexity", no password complexity validation will be done. Passwords must be at least 8 characters. To configure a greater minimum length for the password, enter the desired number of characters in the "Minimum password length" box. If you disable this policy setting, the user is not allowed to use a password. If you do not configure this policy setting, passwords will be supported with the default settings, which do not include password complexity requirements and require only 8 characters. Note: Passwords cannot be used if FIPS-compliance is enabled. The "System cryptography: Use FIPS-compliant algorithms for encryption, hashing, and signing" policy setting in Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options specifies whether FIPS-compliance is enabled. The recommended state for this setting is: `True`.

Rationale:

A drive can be compromised by guessing or finding the authentication information used to access the drive. For example, a password could be guessed, or a drive set to automatically unlock could be lost or stolen with the computer it automatically unlocks with.

Impact:

Users will need a smart card reader to unlock the drive. PKI infrastructure is also required.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\RDVEnforceUserCert
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Configure use of smart cards on  
removable data drives: Require use of smart cards on removable data drives
```

1.2.4.2.3.17 Set 'Deny write access to removable drives not protected by BitLocker' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting configures whether BitLocker protection is required for a computer to be able to write data to a removable data drive. If you enable this policy setting, all removable data drives that are not BitLocker-protected will be mounted as read-only. If the drive is protected by BitLocker, it will be mounted with read and write access. If the "Deny write access to devices configured in another organization" option is selected, only drives with identification fields matching the computer's identification fields will be given write access. When a removable data drive is accessed it will be checked for valid identification field and allowed identification fields. These fields are defined by the "Provide the unique identifiers for your organization" policy setting. If you disable or do not configure this policy setting, all removable data drives on the computer will be mounted with read and write access. The recommended state for this setting is:

Enabled.

Rationale:

Users may not voluntarily encrypt removable drives prior to saving important data to the drive.

Impact:

Drives without BitLocker protection or are BitLocker protected but we not encrypting in your organization will be read-only. Drives encrypted with BitLocker in another organization will be read-only. This policy cannot be used in conjunction with Startup Keys or Recovery Keys.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Policies\Microsoft\FVE\RDVDenyWriteAccess
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Deny write access to removable drives not protected by BitLocker

Default Value:

Not Configured

References:

1. CCE-21802-4

ARCHIVE

1.2.4.2.3.18 Set 'Allow access to BitLocker-protected removable data drives from earlier versions of Windows' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting configures whether or not removable data drives formatted with the FAT file system can be unlocked and viewed on computers running Windows Server 2008, Windows Vista, Windows XP with Service Pack 3 (SP3), or Windows XP with Service Pack 2 (SP2) operating systems. If this policy setting is enabled or not configured, removable data drives formatted with the FAT file system can be unlocked on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2, and their content can be viewed. These operating systems have read-only access to BitLocker-protected drives. When this policy setting is enabled, select the "Do not install BitLocker To Go Reader on FAT formatted removable drives" check box to help prevent users from running BitLocker To Go Reader from their removable drives. If BitLocker To Go Reader (bitlockertogo.exe) is present on a drive that does not have an identification field specified, or if the drive has the same identification field as specified in the "Provide unique identifiers for your organization" policy setting, the user will be prompted to update BitLocker and BitLocker To Go Reader will be deleted from the drive. In this situation, for the removable drive to be unlocked on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2, BitLocker To Go Reader must be installed on the computer. If this check box is not selected, BitLocker To Go Reader will be installed on the removable drive to enable users to unlock the drive on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2 that do not have BitLocker To Go Reader installed. If this policy setting is disabled, removable data drives formatted with the FAT file system that are BitLocker-protected cannot be unlocked on computers running Windows Server 2008, Windows Vista, Windows XP with SP3, or Windows XP with SP2. Bitlockertogo.exe will not be installed. Note: This policy setting does not apply to drives that are formatted with the NTFS file system. The recommended state for this setting is: *Disabled*.

Rationale:

By default BitLocker virtualizes FAT formatted drives to permit access via the BitLocker To Go Reader on previous versions of Windows. Additionally the BitLocker To Go Reader application is applied to the unencrypted portion of the drive. The BitLocker To Go Reader application, like any other application, is subject to spoofing and could be a mechanism to propagate malware.

Impact:

BitLocker protected drives will not be able to be accessed on previous versions of Windows.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\RDVDiscoveryVolumeType
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Allow access to BitLocker-protected  
removable data drives from earlier versions of Windows
```

Default Value:

Not Configured

References:

1. CCE-23623-2

1.2.4.2.3.19 Configure 'Control use of BitLocker on removable drives' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting controls the use of BitLocker on removable data drives. This policy setting is applied when you turn on BitLocker. When this policy setting is enabled you can select property settings that control how users can configure BitLocker. Choose "Allow users to apply BitLocker protection on removable data drives" to permit the user to run the BitLocker setup wizard on a removable data drive. Choose "Allow users to suspend and decrypt BitLocker on removable data drives" to permit the user to remove BitLocker Drive encryption from the drive or suspend the encryption while maintenance is performed. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information on suspending BitLocker protection. If you do not configure this policy setting, users can use BitLocker on removable disk drives. If you disable this policy setting, users cannot use BitLocker on removable disk drives. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

In some environments, users could suspend Bitlocker on removable drives, and access the drives using unauthorized computers. In other environments, BitLocker could be used to encrypt removable drives making them unreadable from other computers.

Impact:

By default, users are able to configure BitLocker for removable drives. Modifying these defaults could prevent users from accessing desired functionality.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\RDVConfigureBDE
--

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Control use of BitLocker on removable  
drives
```

Default Value:

Not Configured

References:

1. CCE-21981-6

ARCHIVE

1.2.4.2.3.20 Set 'Do not allow write access to devices configured in another organization' to 'True' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting configures whether BitLocker protection is required for a computer to be able to write data to a removable data drive. If you enable this policy setting, all removable data drives that are not BitLocker-protected will be mounted as read-only. If the drive is protected by BitLocker, it will be mounted with read and write access. If the "Deny write access to devices configured in another organization" option is selected, only drives with identification fields matching the computer's identification fields will be given write access. When a removable data drive is accessed it will be checked for valid identification field and allowed identification fields. These fields are defined by the "Provide the unique identifiers for your organization" policy setting. If you disable or do not configure this policy setting, all removable data drives on the computer will be mounted with read and write access. The recommended state for this setting is: `True`.

Rationale:

Users may not voluntarily encrypt removable drives prior to saving important data to the drive.

Impact:

Drives without BitLocker protection or are BitLocker protected but we not encrypting in your organization will be read-only. Drives encrypted with BitLocker in another organization will be read-only. This policy cannot be used in conjunction with Startup Keys or Recovery Keys.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\RDVDenyCrossOrg
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `True`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Removable Data Drives\Deny write access to removable drives  
not protected by BitLocker: Do not allow write access to devices configured  
in another organization
```

1.2.4.2.4 Configure 'Validate smart card certificate usage rule compliance' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to associate an object identifier from a smart card certificate to a BitLocker-protected drive. This policy setting is applied when you turn on BitLocker. The object identifier is specified in the enhanced key usage (EKU) of a certificate. BitLocker can identify which certificates may be used to authenticate a user certificate to a BitLocker-protected drive by matching the object identifier in the certificate with the object identifier that is defined by this policy setting. Default object identifier is 1.3.6.1.4.1.311.67.1.1 Note: BitLocker does not require that a certificate have an EKU attribute, but if one is configured for the certificate it must be set to an object identifier (OID) that matches the OID configured for BitLocker. If you enable this policy setting, the object identifier specified in the "Object identifier" box must match the object identifier in the smart card certificate. If you disable or do not configure this policy setting, a default object identifier is used. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

This policy setting allows you to associate an object identifier from a smart card certificate to a BitLocker-protected drive, for organizations that have deployed smart cards this may be a more secure configuration than relying on PINs.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Validate smart card certificate usage rule compliance
```

Default Value:

Not Configured

References:

1. CCE-23309-8

1.2.4.2.5 Set 'Select the encryption method:' to 'Enabled:AES 256-bit' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to configure the algorithm and cipher strength used by BitLocker Drive Encryption. This policy setting is applied when you turn on BitLocker. Changing the encryption method has no effect if the drive is already encrypted or if encryption is in progress. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about the encryption methods available. This policy is only applicable to computers running Windows 8 Consumer Preview and later. If you enable this policy setting you will be able to choose an encryption algorithm and key cipher strength for BitLocker to use to encrypt drives. If you disable or do not configure this policy setting, BitLocker will use AES with the same bit strength (128-bit or 256-bit) as the "Choose drive encryption method and cipher strength (Windows Vista, Windows Server 2008, Windows 7)" policy setting, if it is set. If neither policy is set, BitLocker will use the default encryption method of AES 128-bit or the encryption method specified by the setup script. The recommended state for this setting is:

Enabled:AES 256-bit.

Rationale:

The use of AES 128 bit key is likely to be strong enough for the majority of applications, but those requiring the highest level of security may find this setting suboptimal.

Impact:

Using AES 256 will in most cases not significantly impact initial encryption speed and overall computer performance when used.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE\EncryptionMethodNoDiffuser
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Choose drive encryption method and cipher strength
```

Then set the Select the encryption method: option to AES 256-bit.

References:

1. CCE-22425-3

ARCHIVE

1.2.4.2.6 Configure 'Prevent memory overwrite on restart' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting controls computer restart performance at the risk of exposing BitLocker secrets. This policy setting is applied when you turn on BitLocker. BitLocker secrets include key material used to encrypt data. This policy setting applies only when BitLocker protection is enabled. If you enable this policy setting, memory will not be overwritten when the computer restarts. Preventing memory overwrite may improve restart performance but will increase the risk of exposing BitLocker secrets. If you disable or do not configure this policy setting, BitLocker secrets are removed from memory when the computer restarts. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

BitLocker secrets that are stored in memory could be exposed during a restart.

Impact:

Enabling this setting could reduce the amount of time a computer takes to restart, but doing so will increase the risk of BitLocker secrets being exposed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\MorBehavior
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Prevent memory overwrite on restart
```

Default Value:

Not Configured

References:

1. CCE-21814-9

1.2.4.2.7 Configure 'Choose default folder for recovery password' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to specify the default path that is displayed when the BitLocker Drive Encryption setup wizard prompts the user to enter the location of a folder in which to save the recovery password. This policy setting is applied when you turn on BitLocker. If you enable this policy setting, you can specify the path that will be used as the default folder location when the user chooses the option to save the recovery password in a folder. You can specify either a fully qualified path or include the target computer's environment variables in the path. If the path is not valid, the BitLocker setup wizard will display the computer's top-level folder view. If you disable or do not configure this policy setting, the BitLocker setup wizard will display the computer's top-level folder view when the user chooses the option to save the recovery password in a folder. Note: This policy setting does not prevent the user from saving the recovery password in another folder. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Recovery keys could inadvertently be stored in an insecure location.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption\Choose default folder for recovery password

Default Value:

Not Configured

References:

1. CCE-21775-2

1.2.4.2.8 Configure 'Provide the unique identifiers for your organization' (Manual)

Profile Applicability:

- Level 1 + BitLocker

Description:

This policy setting allows you to associate unique organizational identifiers to a new drive that is enabled with BitLocker. These identifiers are stored as the identification field and allowed identification field. The identification field allows you to associate a unique organizational identifier to BitLocker-protected drives. This identifier is automatically added to new BitLocker-protected drives and can be updated on existing BitLocker-protected drives using the Manage-BDE command-line tool. An identification field is required for management of certificate-based data recovery agents on BitLocker-protected drives and for potential updates to the BitLocker To Go Reader. BitLocker will only manage and update data recovery agents when the identification field on the drive matches the value configured in the identification field. In a similar manner, BitLocker will only update the BitLocker To Go Reader when the identification field on the drive matches the value configured for the identification field. The allowed identification field is used in combination with the "Deny write access to removable drives not protected by BitLocker" policy setting to help control the use of removable drives in your organization. It is a comma separated list of identification fields from your organization or other external organizations. You can configure the identification fields on existing drives by using manage-BDE.exe. If you enable this policy setting, you can configure the identification field on the BitLocker-protected drive and any allowed identification field used by your organization. When a BitLocker-protected drive is mounted on another BitLocker-enabled computer the identification field and allowed identification field will be used to determine whether the drive is from an outside organization. If you disable or do not configure this policy setting, the identification field is not required. Note: Identification fields are required for management of certificate-based data recovery agents on BitLocker-protected drives. BitLocker will only manage and update certificate-based data recovery agents when the identification field is present on a drive and is identical to the value configured on the computer. The identification field can be any value of 260 characters or fewer. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

BitLocker protection will be configured by different organizations to meet different security needs. A BitLocker protected drive could enter your organization with a configuration that is less secure than your own.

Impact:

The identification field must be provided by the Administrator.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\FVE\IdentificationField
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Not Configured.

```
Computer Configuration\Administrative Templates\Windows Components\BitLocker  
Drive Encryption\Provide the unique identifiers for your organization
```

Default Value:

Not Configured

References:

1. CCE-22698-5

1.2.4.2.9 Set 'Allow Standby States (S1-S3) When Sleeping (On Battery)' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

Dictates whether or not Windows is allowed to use standby states when sleeping the computer. When this policy is enabled, Windows may use standby states to sleep the computer. If this policy is disabled, the only sleep state a computer may enter is hibernate. The recommended state for this setting is: `Disabled`.

Rationale:

System sleep states (S1-S3) keep power to the RAM which may contain secrets, such as the BitLocker volume encryption key. An attacker finding a computer in sleep states (S1-S3) could directly attack the memory of the computer and gain access to the secrets through techniques such as RAM reminisce and direct memory access (DMA).

Impact:

Users will not be able to use Sleep (S3) which resumes faster than Hibernation (S4).

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\abfc2519-3608-4c2a-94ea-171b0ed546ab\DCSettingIndex
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Disabled`.

```
Computer Configuration\Administrative Templates\System\Power Management\Sleep Settings\Allow Standby States (S1-S3) When Sleeping (On Battery)
```

Default Value:

Not Configured

References:

1. CCE-21627-5

1.2.4.2.10 Set 'Allow Standby States (S1-S3) When Sleeping (Plugged In)' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 + BitLocker

Description:

Dictates whether or not Windows is allowed to use standby states when sleeping the computer. When this policy is enabled, Windows may use standby states to sleep the computer. If this policy is disabled, the only sleep state a computer may enter is hibernate. The recommended state for this setting is: `Disabled`.

Rationale:

System sleep states (S1-S3) keep power to the RAM which may contain secrets, such as the BitLocker volume encryption key. An attacker finding a computer in sleep states (S1-S3) could directly attack the memory of the computer and gain access to the secrets through techniques such as RAM reminisce and direct memory access (DMA).

Impact:

Users will not be able to use Sleep (S3) which resumes faster than Hibernation (S4).

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\abfc2519-3608-4c2a-94ea-171b0ed546ab\ACSettingIndex
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Disabled`.

```
Computer Configuration\Administrative Templates\System\Power Management\Sleep Settings\Allow Standby States (S1-S3) When Sleeping (Plugged In)
```

Default Value:

Not Configured

References:

1. CCE-22787-6

1.2.4.3 Credential User Interface

ARCHIVE

1.2.4.3.1 Configure 'Require trusted path for credential entry' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

If you enable this policy setting, users are required to enter Windows credentials on the Secure Desktop by means of the trusted path mechanism. This means that before entering account and password information to authorize an elevation request, a user first need to press CTRL+ALT+DEL. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Requiring the use of a trusted path helps prevent a Trojan horse or other types of malicious code from stealing the user's Windows credentials.

Impact:

If you disable or do not configure this policy setting, users can enter Windows credentials within the user's desktop session, potentially allowing malicious code access to the user's Windows credentials.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\CredUI\
EnableSecureCredentialPrompting
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\Credential
User Interface\Require trusted path for credential entry
```

Default Value:

Not configured

References:

1. CCE-22844-5

ARCHIVE

1.2.4.3.2 Configure 'Do not display the password reveal button' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to configure the display of the password reveal button in password entry user experiences. If you enable this policy setting, the password reveal button will not be displayed after a user types a password in the password entry text box. If you disable or do not configure this policy setting, the password reveal button will be displayed after a user types a password in the password entry text box. By default, the password reveal button is displayed after a user types a password in the password entry text box. To display the password, click the password reveal button. The policy applies to all Windows components and applications that use the Windows system controls, including Windows 8 applications, and Internet Explorer 10 and later. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

This is a useful feature when entering a long and complex password, especially when using a touchscreen. The potential risk is that someone else may see your password while surreptitiously observing your screen.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\CredUI\DisablePasswordReveal
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\Credential User Interface\Do not display the password reveal button
```

Default Value:

Not configured

References:

1. CCE-25575-2

ARCHIVE

1.2.4.3.3 Set 'Enumerate administrator accounts on elevation' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

By default, all administrator accounts are displayed when you attempt to elevate a running application. The recommended state for this setting is: `Disabled`.

Rationale:

Users could see the list of administrator accounts, making it slightly easier for a malicious user who has logged onto a console session to try to crack the passwords of those accounts.

Impact:

If you enable this policy setting, all local administrator accounts on the machine will be displayed so the user can choose one and enter the correct password. If you disable this policy setting, users will be required to always type in a username and password to elevate.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\CredUI\EnumerateAdministrators
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Disabled`.

```
Computer Configuration\Administrative Templates\Windows Components\Credential User Interface\Enumerate administrator accounts on elevation
```

Default Value:

Disabled

References:

1. CCE-21675-4

ARCHIVE

1.2.4.4 Event Log

ARCHIVE

1.2.4.4.1 Set 'Security: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies the maximum size of the log file in kilobytes. If you enable this policy setting, you can configure the maximum log file size to be between 1 megabyte (1024 kilobytes) and 2 terabytes (2147483647 kilobytes) in kilobyte increments. If you disable or do not configure this policy setting, the maximum size of the log file will be set to the locally configured value. This value can be changed by the local administrator using the Log Properties dialog and it defaults to 20 megabytes. The recommended state for this setting is: `Enabled:20480 or greater`.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed. The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data. Ideally, all specifically monitored events should be sent to a server that uses Microsoft Operations Manager (MOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Security\MaxSize
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\Event Log Service\Security\Specify the maximum log file size (KB)
```

Then set the Maximum Log Size (KB) option to 20480 or greater.

Default Value:

20480 KB

References:

1. CCE-22581-3

1.2.4.4.2 Set 'System: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls Event Log behavior when the log file reaches its maximum size. If you enable this policy setting and a log file reaches its maximum size, new events are not written to the log and are lost. If you disable or do not configure this policy setting and a log file reaches its maximum size, new events overwrite old events. Note: Old events may or may not be retained according to the "Backup log automatically when full" policy setting. The recommended state for this setting is: *Disabled*.

Rationale:

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\System\Retention
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Administrative Templates\Windows Components\Event Log Service\System\Control Event Log behavior when the log file reaches its maximum size
```

Default Value:

Disabled

References:

1. CCE-22242-2

1.2.4.4.3 Set 'Security: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls Event Log behavior when the log file reaches its maximum size. If you enable this policy setting and a log file reaches its maximum size, new events are not written to the log and are lost. If you disable or do not configure this policy setting and a log file reaches its maximum size, new events overwrite old events. Note: Old events may or may not be retained according to the "Backup log automatically when full" policy setting. The recommended state for this setting is: *Disabled*.

Rationale:

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Security\Retention
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Administrative Templates\Windows Components\Event Log Service\Security\Control Event Log behavior when the log file reaches its maximum size
```

Default Value:

Disabled

References:

1. CCE-22637-3

1.2.4.4.4 Set 'Application: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies the maximum size of the log file in kilobytes. If you enable this policy setting, you can configure the maximum log file size to be between 1 megabyte (1024 kilobytes) and 2 terabytes (2147483647 kilobytes) in kilobyte increments. If you disable or do not configure this policy setting, the maximum size of the log file will be set to the locally configured value. This value can be changed by the local administrator using the Log Properties dialog and it defaults to 20 megabytes. The recommended state for this setting is: `Enabled:20480 or greater`.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed. The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data. Ideally, all specifically monitored events should be sent to a server that uses Microsoft Operations Manager (MOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Application\MaxSize
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\Event Log Service\Application\Specify the maximum log file size (KB)
```

Then set the Maximum Log Size (KB) option to 20480 or greater.

Default Value:

20480 KB

References:

1. CCE-22632-4

1.2.4.4.5 Set 'System: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies the maximum size of the log file in kilobytes. If you enable this policy setting, you can configure the maximum log file size to be between 1 megabyte (1024 kilobytes) and 2 terabytes (2147483647 kilobytes) in kilobyte increments. If you disable or do not configure this policy setting, the maximum size of the log file will be set to the locally configured value. This value can be changed by the local administrator using the Log Properties dialog and it defaults to 20 megabytes. The recommended state for this setting is: `Enabled:20480 or greater`.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed. The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data. Ideally, all specifically monitored events should be sent to a server that uses Microsoft Operations Manager (MOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\System\MaxSize
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\Event Log Service\System\Specify the maximum log file size (KB)
```

Then set the Maximum Log Size (KB) option to 20480 or greater.

Default Value:

20480 KB

References:

1. CCE-22528-4

1.2.4.4.6 Set 'Application: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting controls Event Log behavior when the log file reaches its maximum size. If you enable this policy setting and a log file reaches its maximum size, new events are not written to the log and are lost. If you disable or do not configure this policy setting and a log file reaches its maximum size, new events overwrite old events.

Note: Old events may or may not be retained according to the "Backup log automatically when full" policy setting. The recommended state for this setting is: Disabled.

Rationale:

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Application\Retention
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\Event Log Service\Application\Control Event Log behavior when the log file reaches its maximum size
```

Default Value:

Disabled

References:

1. CCE-21736-4

1.2.4.5 Remote Desktop Services

ARCHIVE

1.2.4.5.1 Set 'Do not allow drive redirection' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting prevents users from sharing the local drives on their client computers to Terminal Servers that they access. Mapped drives appear in the session folder tree in Windows Explorer in the following format: \\TSCClient\$. If local drives are shared they are left vulnerable to intruders who want to exploit the data that is stored on them. The recommended state for this setting is: *Enabled*.

Rationale:

Data could be forwarded from the user's Terminal Server session to the user's local computer without any direct user interaction.

Impact:

Drive redirection will not be possible.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services\fdDisableCdm
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\Windows Components\Remote  
Desktop Services\Remote Desktop Session Host\Device and Resource  
Redirection\Do not allow drive redirection
```

Default Value:

Disabled

References:

1. CCE-23088-8

ARCHIVE

1.2.4.5.2 Configure 'Allow users to connect remotely by using Remote Desktop Services' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to configure remote access to computers by using Remote Desktop Services. If you enable this policy setting, users who are members of the Remote Desktop Users group on the target computer can connect remotely to the target computer by using Remote Desktop Services. If you disable this policy setting, users cannot connect remotely to the target computer by using Remote Desktop Services. The target computer will maintain any current connections, but will not accept any new incoming connections. If you do not configure this policy setting, Remote Desktop Services uses the Remote Desktop setting on the target computer to determine whether the remote connection is allowed. This setting is found on the Remote tab in the System properties sheet. By default, remote connections are not allowed. Note: You can limit which clients are able to connect remotely by using Remote Desktop Services by configuring the policy setting at Computer Configuration\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Require user authentication for remote connections by using Network Level Authentication. You can limit the number of users who can connect simultaneously by configuring the policy setting at Computer Configuration\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Connections\Limit number of connections, or by configuring the policy setting Maximum Connections by using the Remote Desktop Session Host WMI Provider. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Any account with the Allow log on through Remote Desktop Services user right can log on to the remote console of the computer. If you do not restrict access to legitimate users who need to log on to the console of the computer, unauthorized users could download and execute malicious code to elevate their privileges.

Impact:

If this setting is enabled legitimate users will be unable to use Terminal Services or Remote Desktop, this could make it more difficult for help desk technicians to troubleshoot and resolve problems remotely. It would also make it impossible to use Remote Desktop Services for hosting shared applications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\Remote
Desktop Services\Remote Desktop Session Host\Connections\Allow users to
connect remotely by using Remote Desktop Services
```

Default Value:

Not configured

References:

1. CCE-21550-9

1.2.4.5.3 Set 'Encryption Level' to 'Enabled:High Level' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether the computer that is about to host the remote connection will enforce an encryption level for all data sent between it and the client computer for the remote session. The recommended state for this setting is:

Enabled:High Level.

Rationale:

If Terminal Server client connections are allowed that use low level encryption, it is more likely that an attacker will be able to decrypt any captured Terminal Services network traffic.

Impact:

Clients that do not support 128-bit encryption will be unable to establish Terminal Server sessions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services\MinEncryptionLevel
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\Remote  
Desktop Services\Remote Desktop Session Host\Security\Set client connection  
encryption level
```

Then set the Encryption Level option to High Level.

Default Value:

Not configured

References:

1. CCE-22847-8

ARCHIVE

1.2.4.5.4 Set 'Always prompt for password upon connection' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether Terminal Services always prompts the client computer for a password upon connection. You can use this policy setting to enforce a password prompt for users who log on to Terminal Services, even if they already provided the password in the Remote Desktop Connection client. By default, Terminal Services allows users to automatically log on if they enter a password in the Remote Desktop Connection client. Note If you do not configure this policy setting, the local computer administrator can use the Terminal Services Configuration tool to either allow or prevent passwords from being automatically sent. The recommended state for this setting is: *Enabled*.

Rationale:

Users have the option to store both their username and password when they create a new Remote Desktop connection shortcut. If the server that runs Terminal Services allows users who have used this feature to log on to the server but not enter their password, then it is possible that an attacker who has gained physical access to the user's computer could connect to a Terminal Server through the Remote Desktop connection shortcut, even though they may not know the user's password.

Impact:

Users will always have to enter their password when they establish new Terminal Server sessions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services\fpromptForPassword
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Always prompt for password upon connection

Default Value:

Not configured

References:

1. CCE-23127-4

1.2.4.5.5 Set 'Do not allow passwords to be saved' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting helps prevent Terminal Services clients from saving passwords on a computer. Note If this policy setting was previously configured as Disabled or Not configured, any previously saved passwords will be deleted the first time a Terminal Services client disconnects from any server. The recommended state for this setting is: Enabled.

Rationale:

An attacker with physical access to the computer may be able to break the protection guarding saved passwords. An attacker who compromises a user's account and connects to their computer could use saved passwords to gain access to additional hosts.

Impact:

If you enable this policy setting, the password saving checkbox is disabled for Terminal Services clients and users will not be able to save passwords.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services\DisablePasswordSaving
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\Remote  
Desktop Services\Remote Desktop Connection Client\Do not allow passwords to  
be saved
```

Default Value:

Disabled

References:

1. CCE-21696-0

ARCHIVE

1.2.4.6 Windows Remote Management

ARCHIVE

1.2.4.6.1 Set 'Disallow Digest authentication' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client will not use Digest authentication. If you enable this policy setting, the WinRM client will not use Digest authentication. If you disable or do not configure this policy setting, the WinRM client will use Digest authentication. The recommended state for this setting is: *Enabled*.

Rationale:

Digest authentication is less robust than other authentication methods available in WinRM, an attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Client\AllowDigest
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Client\Disallow Digest authentication
```

Default Value:

Not configured

References:

1. CCE-23167-0

1.2.4.6.2 Set 'Allow Basic authentication' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client uses Basic authentication. If you enable this policy setting, the WinRM client will use Basic authentication. If WinRM is configured to use HTTP transport, then the user name and password are sent over the network as clear text. If you disable or do not configure this policy setting, then the WinRM client will not use Basic authentication. The recommended state for this setting is: *Disabled*.

Rationale:

Basic authentication is less robust than other authentication methods available in WinRM because credentials including passwords are transmitted in plain text. An attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Client\AllowBasic
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Client\Allow Basic authentication
```

Default Value:

Not configured

References:

1. CCE-22490-7

1.2.4.6.3 Set 'Allow Basic authentication' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service accepts Basic authentication from a remote client. If you enable this policy setting, the WinRM service will accept Basic authentication from a remote client. If you disable or do not configure this policy setting, the WinRM service will not accept Basic authentication from a remote client. The recommended state for this setting is:

Disabled.

Rationale:

Basic authentication is less robust than other authentication methods available in WinRM because credentials including passwords are transmitted in plain text. An attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Service\AllowBasic
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service\Allow Basic authentication
```

Default Value:

Not configured

References:

1. CCE-22475-8

1.2.4.6.4 Set 'Disallow WinRM from storing RunAs credentials' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service will not allow RunAs credentials to be stored for any plug-ins. If you enable this policy setting, the WinRM service will not allow the RunAsUser or RunAsPassword configuration values to be set for any plug-ins. If a plug-in has already set the RunAsUser and RunAsPassword configuration values, the RunAsPassword configuration value will be erased from the credential store on this computer. If you disable or do not configure this policy setting, the WinRM service will allow the RunAsUser and RunAsPassword configuration values to be set for plug-ins and the RunAsPassword value will be stored securely. If you enable and then disable this policy setting, any values that were previously configured for RunAsPassword will need to be reset. The recommended state for this setting is: *Enabled*.

Rationale:

Although the ability to store RunAs credentials is a convenient feature it increases the risk of account compromise slightly. For example, if you forget to lock your desktop before leaving it unattended for a few minutes another person could access not only the desktop of your computer but also any hosts you manage via WinRM with cached RunAs credentials.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Service\DisableRunAs
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service\Disallow WinRM from storing RunAs credentials

Default Value:

Not configured

References:

1. CCE-21701-8

1.2.4.6.5 Set 'Allow unencrypted traffic' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service sends and receives unencrypted messages over the network. If you enable this policy setting, the WinRM client sends and receives unencrypted messages over the network. If you disable or do not configure this policy setting, the WinRM client sends or receives only encrypted messages over the network. The recommended state for this setting is: *Disabled*.

Rationale:

Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Service\AllowUnencryptedTraffic
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service\Allow unencrypted traffic
```

Default Value:

Not configured

References:

1. CCE-23319-7

1.2.4.6.6 Set 'Allow unencrypted traffic' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client sends and receives unencrypted messages over the network. If you enable this policy setting, the WinRM client sends and receives unencrypted messages over the network. If you disable or do not configure this policy setting, the WinRM client sends or receives only encrypted messages over the network. The recommended state for this setting is: *Disabled*.

Rationale:

Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Client\AllowUnencryptedTraffic
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Disabled*.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Client\Allow unencrypted traffic
```

Default Value:

Not configured

References:

1. CCE-20903-1

1.2.4.7 Windows Update

ARCHIVE

1.2.4.7.1 Configure 'Specify intranet Microsoft update service location' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to specify an intranet server to host updates from the Microsoft Update Web site. You can then use this update service location to automatically update computers on your network. The Automatic Updates client will search this service for updates that apply to the computers on your network. To use the Specify intranet Microsoft update service location setting, you must set two server name values: the server from which the Automatic Updates client detects and downloads updates, and the server to which updated workstations upload statistics. You can set both values to be the same server. If you enable the Specify intranet Microsoft update service location setting, the Automatic Updates client will connect to the specified intranet Microsoft update service server (instead of Windows Update) to search for and download updates. This configuration allows end users in your organization to avoid firewall issues, and provides you with an opportunity to test updates before you deploy them. If you disable or do not configure this policy setting, the Automatic Updates client will connect directly to the Windows Update site on the Internet (if Automatic Updates is not disabled by Group Policy or user preference). Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

By default, Automatic Updates will attempt to download updates from the Microsoft Windows Update Web site. Some organizations want to verify that all new updates are compatible with their particular environment before they are deployed. Also, if you configure an internal Software Update Services (SUS) server you will help reduce the load on perimeter firewalls, routers, and proxy servers, as well as the load on external network links.

Impact:

Critical updates and service packs will have to be proactively managed by the organization's IT staff.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Update\Specify intranet Microsoft update service location
```

Default Value:

Disabled

References:

1. CCE-21392-6

1.2.4.7.2 Set 'Reschedule Automatic Updates scheduled installations' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting determines the amount of time before previously scheduled Automatic Update installations will proceed after system startup. If you configure this policy setting to Enabled, a previously scheduled installation will begin after a specified number of minutes when you next start the computer. If you configure this policy setting to Disabled or Not configured, previously scheduled installations will occur during the next regularly scheduled installation time. Note: This policy setting only works when Automatic Updates is configured to perform scheduled update installations. If the Configure Automatic Updates setting is Disabled, the Reschedule Automatic Updates scheduled installations setting has no effect. You can enable the latter two settings to ensure that previously missed installations will be scheduled to install each time the computer restarts. The recommended state for this setting is: *Enabled*.

Rationale:

If Automatic Updates is not forced to wait a few minutes after a restart, computers in your environment might not have enough time to completely start all of their applications and services. If you specify enough time after a restart, new update installations should not conflict with the computer's startup procedures.

Impact:

Automatic Updates will not start until 10 minutes after the computer restarts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\RescheduleWaitTimeEnabled
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\Windows Update\Reschedule Automatic Updates scheduled installations

Default Value:

Disabled

References:

1. CCE-21394-2

ARCHIVE

1.2.4.7.3 Set 'Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows dialog box' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the 'Install Updates and Shut Down' option is allowed to be the default choice in the Shut Down Windows dialog. Note that this policy setting has no impact if the Computer Configuration\Administrative Templates\Windows Components\Windows Update\Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box policy setting is enabled. The recommended state for this setting is: *Disabled*.

Rationale:

Updates are important for maintaining the ongoing security of a computer, therefore this setting should not be enabled.

Impact:

If you enable this policy setting, the user's last shut down choice (Hibernate, Restart, etc.) is the default option in the Shut Down Windows dialog box, regardless of whether the 'Install Updates and Shut Down' option is available in the 'What do you want the computer to do?' list. If you disable or do not configure this policy setting, the 'Install Updates and Shut Down' option will be the default option in the Shut Down Windows dialog box if updates are available for installation at the time the user selects the Shut Down option in the Start menu.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\NoAUsDefaultShutdownOption
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

Computer Configuration\Administrative Templates\Windows Components\Windows Update\Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows dialog box

Default Value:

Disabled

References:

1. CCE-22748-8

1.2.4.7.4 Set 'Configure Automatic Updates' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether computers in your environment will receive security updates from Windows Update or WSUS. If you configure this policy setting to Enabled, the operating system will recognize when a network connection is available and then use the network connection to search Windows Update or your designated intranet site for updates that apply to them. After you configure this policy setting to Enabled, select one of the following three options in the Configure Automatic Updates Properties dialog box to specify how the service will work: - Notify before downloading any updates and notify again before installing them. - Download the updates automatically and notify when they are ready to be installed. (Default setting) - Automatically download updates and install them on the schedule specified below. If you disable this policy setting, you will need to download and manually install any available updates from Windows Update. The recommended state for this setting is: *Enabled*.

Rationale:

Although each version of Windows is thoroughly tested before release, it is possible that problems will be discovered after the products are shipped. The Configure Automatic Updates setting can help you ensure that the computers in your environment will always have the most recent critical operating system updates and service packs installed.

Impact:

Critical operating system updates and service packs will automatically download and install at 3:00 A.M. daily.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\NoAutoUpdate
```


Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\Windows Update\Configure Automatic Updates

Default Value:

Download the updates automatically and notify when they are ready to be installed

References:

1. CCE-22199-4

1.2.4.7.5 Set 'Configure automatic updating' to '3 - Auto download and notify for install' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether computers in your environment will receive security updates from Windows Update or WSUS. If you configure this policy setting to Enabled, the operating system will recognize when a network connection is available and then use the network connection to search Windows Update or your designated intranet site for updates that apply to them. After you configure this policy setting to Enabled, select one of the following three options in the Configure Automatic Updates Properties dialog box to specify how the service will work: - Notify before downloading any updates and notify again before installing them. - Download the updates automatically and notify when they are ready to be installed. (Default setting) - Automatically download updates and install them on the schedule specified below. If you disable this policy setting, you will need to download and manually install any available updates from Windows Update. The recommended state for this setting is: 3 - Auto download and notify for install.

Rationale:

Although each version of Windows is thoroughly tested before release, it is possible that problems will be discovered after the products are shipped. The Configure Automatic Updates setting can help you ensure that the computers in your environment will always have the most recent critical operating system updates and service packs installed.

Impact:

Critical operating system updates and service packs will automatically download and install at 3:00 A.M. daily.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\AUOptions
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 3 - Auto download and notify for install.

Computer Configuration\Administrative Templates\Windows Components\Windows Update\Configure Automatic Updates: Configure automatic updating

Default Value:

Download the updates automatically and notify when they are ready to be installed

ARCHIVE

1.2.4.7.6 Set 'Scheduled install day' to '0 - Every day' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies whether computers in your environment will receive security updates from Windows Update or WSUS. If you configure this policy setting to Enabled, the operating system will recognize when a network connection is available and then use the network connection to search Windows Update or your designated intranet site for updates that apply to them. After you configure this policy setting to Enabled, select one of the following three options in the Configure Automatic Updates Properties dialog box to specify how the service will work: - Notify before downloading any updates and notify again before installing them. - Download the updates automatically and notify when they are ready to be installed. (Default setting) - Automatically download updates and install them on the schedule specified below. If you disable this policy setting, you will need to download and manually install any available updates from Windows Update. The recommended state for this setting is: 0 - Every day.

Rationale:

Although each version of Windows is thoroughly tested before release, it is possible that problems will be discovered after the products are shipped. The Configure Automatic Updates setting can help you ensure that the computers in your environment will always have the most recent critical operating system updates and service packs installed.

Impact:

Critical operating system updates and service packs will automatically download and install at 3:00 A.M. daily.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\ScheduledInstallDay
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to 0 - Every day.

Computer Configuration\Administrative Templates\Windows Components\Windows Update\Configure Automatic Updates: Scheduled install day

Default Value:

Not Defined

ARCHIVE

1.2.4.7.7 Set 'No auto-restart with logged on users for scheduled automatic updates installations' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting specifies that Automatic Updates will wait for computers to be restarted by the users who are logged on to them to complete a scheduled installation. If you enable the No auto-restart for scheduled Automatic Updates installations setting, Automatic Updates does not restart computers automatically during scheduled installations. Instead, Automatic Updates notifies users to restart their computers to complete the installations. You should note that Automatic Updates will not be able to detect future updates until restarts occur on the affected computers. If you disable or do not configure this setting, Automatic Updates will notify users that their computers will automatically restart in 5 minutes to complete the installations. The possible values for the No auto-restart for scheduled Automatic Updates installations setting are: - Enabled - Disabled - Not Configured Note: This setting applies only when you configure Automatic Updates to perform scheduled update installations. If you configure the Configure Automatic Updates setting to Disabled, this setting has no effect. The recommended state for this setting is: *Disabled*.

Rationale:

Sometimes updates require updated computers to be restarted to complete an installation. If the computer cannot restart automatically, then the most recent update will not completely install and no new updates will download to the computer until it is restarted.

Impact:

If you enable this policy setting, the operating systems on the servers in your environment will restart themselves automatically. For critical servers this could lead to a temporary denial of service (DoS) condition.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\NoAutoRebootWithLoggedOnUsers
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Update\No auto-restart with logged on users for scheduled automatic updates installations
```

Default Value:

Enabled

References:

1. CCE-22096-2

1.2.4.7.8 Set 'Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether the Install Updates and Shut Down option is displayed in the Shut Down Windows dialog box. This policy setting works in conjunction with the following Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows Dialog box setting. The recommended state for this setting is: Disabled.

Rationale:

Updates are important for maintaining the ongoing security of a computer, therefore this setting should not be enabled.

Impact:

If you disable this policy setting, the Install Updates and Shut Down option will display in the Shut Down Windows dialog box if updates are available when the user selects the Shut Down option in the Start menu.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\NoAUShutdownOption
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Update\Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box
```

Default Value:

Disabled

References:

1. CCE-22285-1

ARCHIVE

1.2.4.8 Configure 'Allow the use of biometrics' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

If you enable (or do not configure) this policy setting, the Windows Biometric Service will be available, and users will be able to run applications that use biometrics on Windows. If you want to enable the ability to log on with biometrics, you must also configure the "Allow users to log on using biometrics" policy setting. If you disable this policy setting, the Windows Biometric Service will not be available, and users will be unable to use any biometric features in Windows. Note: Users who log on using biometrics should create a password-recovery disk; this will prevent data loss in the event that someone forgets their logon credentials. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Biometric authentication is often more robust than passwords, however if low quality biometric technology is used it may actually be less secure than password authentication.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Biometrics\Enabled
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows  
Components\Biometrics\Allow the use of biometrics
```

Default Value:

Not configured

References:

1. CCE-22729-8

1.2.4.9 Set 'Turn off Data Execution Prevention for Explorer' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Disabling data execution prevention can allow certain legacy plug-in applications to function without terminating Explorer. The recommended state for this setting is:

Disabled.

Rationale:

Data Execution Prevention is an important security feature supported by Explorer that helps to limit the impact of certain types of malware.

Impact:

Enabling this policy setting may allow certain legacy plug-in applications to function. Disabling this policy setting will ensure that Data Execution Prevention blocks certain types of malware from exploiting Explorer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Explorer\NoDataExecutionPrevention
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\File Explorer\Turn off Data Execution Prevention for Explorer
```

Default Value:

Not configured

References:

1. CCE-23124-1

1.2.4.10 Configure 'Turn off the Store application' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Denies or allows access to the Store application. If you enable this setting, access to the Store application is denied. If you disable or do not configure this setting, access to the Store application is allowed. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Organizations that manage user computers may want to prevent users from accessing the Store application.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsStore\RemoveWindowsStore
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
Computer Configuration\Administrative Templates\Windows Components\Store\Turn off the Store application
```

Default Value:

Not configured

References:

1. CCE-22288-5

1.2.4.11 Set 'Always install with elevated privileges' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Directs Windows Installer to use system permissions when it installs any program on the system. This setting extends elevated privileges to all programs. These privileges are usually reserved for programs that have been assigned to the user (offered on the desktop), assigned to the computer (installed automatically), or made available in Add or Remove Programs in Control Panel. This setting lets users install programs that require access to directories that the user might not have permission to view or change, including directories on highly restricted computers. If you disable this setting or do not configure it, the system applies the current user's permissions when it installs programs that a system administrator does not distribute or offer. Note: This setting appears both in the Computer Configuration and User Configuration folders. To make this setting effective, you must enable the setting in both folders. Caution: Skilled users can take advantage of the permissions this setting grants to change their privileges and gain permanent access to restricted files and folders. Note that the User Configuration version of this setting is not guaranteed to be secure. The recommended state for this setting is: *Disabled*.

Rationale:

Users with limited privileges can exploit this feature by creating a Windows Installer installation package that creates a new local account that belongs to the local built-in Administrators group, adds their current account to the local built-in Administrators group, installs malicious software, or performs other unauthorized activities.

Impact:

Windows Installer will apply the current user's permissions when it installs programs, this will prevent standard users from installing applications that affect system-wide configuration items.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Installer\AlwaysInstallElevated
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Installer\Always install with elevated privileges
```

Default Value:

Not configured

References:

1. CCE-22116-8

1.2.4.12 Configure 'Allow deployment operations in special profiles' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage the deployment operations of app packages when the user is logged in under special profiles. Deployment operation refers to adding, registering, staging, updating or removing an app package. Special profiles refer to profiles with the following types: mandatory, super-mandatory, temporary or system. Local and roaming profiles are not special profiles. When the user is logged in to a guest account, the profile type is temporary. If you enable this policy setting, the system allows deployment operations when the user is using a special profile. If you disable or do not configure this policy setting, the system blocks deployment operations when the user is using a special profile. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

No known vulnerabilities at the time of this writing.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Appx\AllowDeploymentInSpecialProfiles
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\App Package Deployment\Allow deployment operations in special profiles
```

Default Value:

Not configured

References:

1. CCE-21354-6

1.2.4.13 Configure 'Allow all trusted apps to install' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage the installation of app packages that do not originate from the Windows Store. If you enable this policy setting, you can install any trusted app package. A trusted app package is one that is signed with a certificate chain that can be successfully validated by the local computer. This can include line-of-business app packages signed by the enterprise in addition to app packages that originate from the Windows Store. If you disable or do not configure this policy setting, you can only install trusted app packages that come from the Windows Store. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Preventing installation of app packages from sources other than the Windows Store may help reduce the risk of malware infecting managed computers. The risk of malware infections originating in digitally signed app packages from trusted sources is small, nevertheless, if your organization only acquires app packages via the Windows Store disabling this policy setting will reduce the risk slightly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Appx\AllowAllTrustedApps
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\App Package Deployment\Allow all trusted apps to install
```

Default Value:

Not configured

References:

1. CCE-22163-0

ARCHIVE

1.2.4.14 Set 'Pick one of the following settings' to 'Enabled:Require approval from an administrator before running downloaded unknown software' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage the behavior of Windows SmartScreen. Windows SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. Some information is sent to Microsoft about files and programs run on PCs with this feature enabled. If you enable this policy setting, Windows SmartScreen behavior may be controlled by setting one of the following options: - Require approval from an administrator before running downloaded unknown software - Give user a warning before running downloaded unknown software - Turn off SmartScreen If you disable or do not configure this policy setting, Windows SmartScreen behavior is managed by administrators on the PC by using Windows SmartScreen Settings in Action Center. Options: - Require approval from an administrator before running downloaded unknown software - Give user a warning before running downloaded unknown software - Turn off SmartScreen The recommended state for this setting is: Enabled:Require approval from an administrator before running downloaded unknown software.

Rationale:

Windows SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. However, due to the fact that some information is sent to Microsoft about files and programs run on PCs some organizations may prefer to disable it.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\EnableSmartScreen
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

Computer Configuration\Administrative Templates\Windows Components\File Explorer\Configure Windows SmartScreen

Then set the Pick one of the following settings option to Require approval from an administrator before running downloaded unknown software.

Default Value:

Not configured

References:

1. CCE-21645-7

1.2.4.15 Configure 'Turn off Automatic Download of updates' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Enables or disables the automatic download of updates. If you enable this settings, automatic download of updates is turned off. If you disable or do not configure this settings, automatic download of updates is turned on. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Organizations that manage user computers may want to prevent automatic update of applications acquired through the Store.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsStore\WindowsUpdate\AutoDownload
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Not Configured.

```
Computer Configuration\Administrative Templates\Windows Components\Store\Turn off Automatic Download of updates
```

Default Value:

Not configured

References:

1. CCE-22412-1

1.2.4.16 Set 'Allow Remote Shell Access' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage configuration of remote access to all supported shells to execute scripts and commands. The recommended state for this setting is:
Enabled.

Rationale:

Any feature is a potential avenue of attack, those that enable inbound network connections are particularly risky. Only enable the use of the Windows Remote Shell on trusted networks and when feasible employ additional controls such as IPsec.

Impact:

If you enable this policy setting, remote access is allowed to all supported shells to execute scripts and commands. If you disable or do not configure this policy setting, remote access is not allowed to all supported shells to execute scripts and commands.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Service\WinRS\AllowRemoteShellAccess
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to
Enabled.

```
Computer Configuration\Administrative Templates\Windows Components\Windows Remote Shell\Allow Remote Shell Access
```

Default Value:

Not configured

References:

1. CCE-22319-8

ARCHIVE

1.2.4.17 Configure 'Turn off location' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting turns off the location feature for this computer. If you enable this policy setting, the location feature will be turned off, and all programs on this computer will not be able to use location information from the location feature. If you disable or do not configure this policy setting, all programs on this computer can use location information from the location feature. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Some applications and websites may share location information with servers that the user visits, some organizations may be concerned that this location information could be exploited by a malicious user who has access to such a server.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\LocationAndSensors\DisableLocation
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\Location and Sensors\Turn off location
```

Default Value:

Not configured

References:

1. CCE-23217-3

1.2.4.18 Configure 'Prevent the computer from joining a homegroup' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

By default, users can add their computer to a homegroup on a home network. If you enable this policy setting, a user on this computer will not be able to add this computer to a homegroup. This setting does not affect other network sharing features. If you disable or do not configure this policy setting, a user can add this computer to a homegroup. However, data on a domain-joined computer is not shared with the homegroup. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

By default, domain joined computers can be joined to a HomeGroup. While resources on a domain-joined computer cannot be shared to the HomeGroup, information from the domain-joined computer can be leaked to other computers in the HomeGroup.

Impact:

Mobile users who access printers and other shared devices on their home networks will not be able to leverage the ease of use provided by HomeGroup functionality.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\HomeGroup\DisableHomeGroup
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\HomeGroup\Prevent the computer from joining a homegroup
```

Default Value:

Not configured

References:

1. CCE-21875-0

ARCHIVE

1.2.4.19 Configure 'Turn off Windows Location Provider' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting turns off the Windows Location Provider feature for this computer. If you enable this policy setting, the Windows Location Provider feature will be turned off, and all programs on this computer will not be able to use the Windows Location Provider feature. If you disable or do not configure this policy setting, all programs on this computer can use the Windows Location Provider feature. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Some applications and websites may share location information with servers that the user visits, some organizations may be concerned that this location information could be exploited by a malicious user who has access to such a server.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\LocationAndSensors\DisableWindowsLocationProvider
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
Computer Configuration\Administrative Templates\Windows Components\Location and Sensors\Windows Location Provider\Turn off Windows Location Provider
```

Default Value:

Not configured

References:

1. CCE-21320-7

2 User Configuration

ARCHIVE

2.1 Configure 'Disable regedit from running silently?' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting disables the Windows registry editors Regedit.exe and Regedt32.exe. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Due to default permissions unprivileged users have little ability to modify sensitive data in the registry, nevertheless, preventing them from using registry editing tools will ensure that they are unable to view or modify any data stored there except through the normal graphical tools. Note that the value of this countermeasure is diminished by the fact that the user may find a third party tool that allows him to do the same thing.

Impact:

If you enable this policy setting, a message will display when users try to use a registry editor that informs them that they cannot use either of these editors. This policy setting removes the ability of users and intruders to access the registry with these tools, but does not prevent access to the registry itself.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Microsoft\Windows\CurrentVersion\Policies\System\DisableRegistryTools
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
User Configuration\Administrative Templates\System\Prevent access to registry editing tools: Disable regedit from running silently?
```

Default Value:

Disabled

References:

1. CCE-22398-2

ARCHIVE

2.2 Configure 'Prevent Codec Download' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to prevent Windows Media Player from downloading codecs. If you enable this policy setting, the Player is prevented from automatically downloading codecs to your computer. In addition, the Download codecs automatically check box on the Player tab in the Player is not available. If you disable this policy setting, codecs are automatically downloaded and the Download codecs automatically check box is not available. If you do not configure this policy setting, users can change the setting for the Download codecs automatically check box. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Codecs could contain malicious code. Although Microsoft and other vendors of codecs used by Windows Media Player take steps to minimize this risk some organizations may want to remove it as a potential path of exploitation.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Policies\Microsoft\WindowsMediaPlayer\PreventCodecDownload
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
User Configuration\Administrative Templates\Windows Components\Windows Media Player\Playback\Prevent Codec Download
```

References:

1. CCE-21882-6

2.3 Set 'Notify antivirus programs when opening attachments' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Antivirus programs are mandatory in many environments and provide a strong defense against attack. The Notify antivirus programs when opening attachments setting allows you to manage how registered antivirus programs are notified. When enabled, this policy setting configures Windows to call the registered antivirus program and have it scan file attachments when they are opened by users. If the antivirus scan fails, the attachments are blocked from being opened. If this policy setting is disabled, Windows does not call the registered antivirus program when file attachments are opened. The recommended state for this setting is: *Enabled*.

Note: An updated antivirus program must be installed for this policy setting to function properly.

Rationale:

Antivirus programs that do not perform on-access checks may not be able to scan downloaded files.

Impact:

When the Notify antivirus programs when opening attachments setting is Enabled, every downloaded file or e-mail attachment that the user opens will be scanned.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Microsoft\Windows\CurrentVersion\Policies\Attachments\ScanWithAntiVirus
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

User Configuration\Administrative Templates\Windows Components\Attachment Manager\Notify antivirus programs when opening attachments

Default Value:

Disabled

References:

1. CCE-23008-6

ARCHIVE

2.4 Set 'Do not preserve zone information in file attachments' to 'Disabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether Windows marks file attachments from Internet Explorer or Microsoft Outlook Express with information about their zone of origin (such as restricted, Internet, intranet, or local). This policy setting requires that files be downloaded to NTFS disk partitions to function correctly. If zone information is not preserved, Windows cannot make proper risk assessments based on the zone where the attachment came from.

If the `Do not preserve zone information in file attachments` setting is enabled, file attachments are not marked with their zone information. If this policy setting is disabled, Windows is forced to store file attachments with their zone information. The recommended state for this setting is: `Disabled`.

Rationale:

A file that is downloaded from a computer in the Internet or Restricted Sites zone may be moved to a location that makes it appear safe, like an intranet file share, and executed by an unsuspecting user.

Impact:

None, this is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Microsoft\Windows\CurrentVersion\Policies\Attachments\SaveZoneInformation
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Disabled.

User Configuration\Administrative Templates\Windows Components\Attachment Manager\Do not preserve zone information in file attachments

Default Value:

Disabled

References:

1. CCE-22010-3

ARCHIVE

2.5 Configure 'Hide mechanisms to remove zone information' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether users can manually remove the zone information from saved file attachments. Typically, users can either click the Unblock button in the file's Property sheet or select a check box in the Security Warning dialog. If the zone information is removed, users can open potentially dangerous file attachments that Windows has prevented users from opening. When the Hide mechanisms to remove zone information setting is enabled, Windows hides the check box and Unblock button. When this policy setting is disabled, Windows displays the check box and the Unblock button. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Note: To configure whether files are saved with zone information, see the Do not preserve zone information in file attachments setting.

Rationale:

A user might remove information that indicates a file came from an untrustworthy location.

Impact:

Users who have a legitimate need to remove zone information from files will not be able to do so.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Microsoft\Windows\CurrentVersion\Policies\Attachments\HideZoneInfoOnProperties
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

User Configuration\Administrative Templates\Windows Components\Attachment Manager\Hide mechanisms to remove zone information
--

Default Value:

Disabled

References:

1. CCE-22599-5

ARCHIVE

2.6 Configure 'Remove CD Burning features' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to remove CD Burning features. File Explorer allows you to create and modify re-writable CDs if you have a CD writer connected to your PC. If you enable this policy setting, all features in the File Explorer that allow you to use your CD writer are removed. If you disable or do not configure this policy setting, users are able to use the File Explorer CD burning features. Note: This policy setting does not prevent users from using third-party applications to create or modify CDs using a CD writer. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Organizations that want to prevent users from copying business data to CDs may want to enable this setting, however they should ensure that other methods of copying data to removable media are also disabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoCDBurning
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
User Configuration\Administrative Templates\Windows Components\File Explorer\Remove CD Burning features
```

Default Value:

Disabled

References:

1. CCE-22357-8

2.7 Configure 'Remove Security tab' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Removes the Security tab from File Explorer. If you enable this setting, users opening the Properties dialog box for all file system objects, including folders, files, shortcuts, and drives, will not be able to access the Security tab. As a result, users will be able to neither change the security settings nor view a list of all users that have access to the resource in question. If you disable or do not configure this setting, users will be able to access the security tab. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

Some organizations may want to prevent users from modifying permissions on files and folders that the users own such as those in their own profile.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoSecurityTab
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
User Configuration\Administrative Templates\Windows Components\File Explorer\Remove Security tab
```

Default Value:

Disabled

References:

1. CCE-23396-5

2.8 Set 'Password protect the screen saver' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

If the Password protect the screen saver setting is enabled, then all screen savers are password protected, if it is disabled then password protection cannot be set on any screen saver. The recommended state for this setting is: Enabled.

Rationale:

If a user forgets to lock their computer when they walk away its possible that a passerby will hijack it.

Impact:

Users will have to provide their logon credentials when they want to access their locked desktop session.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Policies\Microsoft\Windows\Control  
Panel\Desktop\ScreenSaverIsSecure
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
User Configuration\Administrative Templates\Control  
Panel\Personalization>Password protect the screen saver
```

Default Value:

Not Configured

References:

1. CCE-21963-4

2.9 Set 'Enable screen saver' to 'Enabled' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether or not screen savers run. If the Screen Saver setting is disabled screen savers do not run and the screen saver section of the Screen Saver tab in Display in Control Panel is disabled. If this setting is enabled a screen saver will run if the following two conditions are met: first, that a valid screen saver is specified on the client via the Screen Saver Executable Name group policy setting or Control Panel on the client. Second, the screensaver timeout is set to a value greater than zero via the Screen Saver Timeout group policy setting or Control Panel on the client. The recommended state for this setting is: *Enabled*.

Rationale:

If a user forgets to lock their computer when they walk away its possible that a passerby will hijack it.

Impact:

The screen saver will automatically activate when the computer has been unattended for the amount of time specified by the Screen Saver timeout setting. The impact should be minimal since the screen saver is enabled by default.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Policies\Microsoft\Windows\Control  
Panel\Desktop\ScreenSaveActive
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to *Enabled*.

```
User Configuration\Administrative Templates\Control  
Panel\Personalization\Enable screen saver
```

Default Value:

Not Configured

References:

1. CCE-21766-1

ARCHIVE

2.10 Set 'Seconds' to 'Enabled:900 or fewer seconds' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

If the Screen Saver Timeout setting is enabled, then the screen saver will be launched when the specified amount of time has passed since the last user action. Valid values range from 1 to 89,400 seconds (24 hours). The setting has no effect if the wait time is set to zero or no screen saver has been specified. The recommended state for this setting is: `Enabled:900 or fewer seconds`.

Rationale:

If a user forgets to lock their computer when they walk away its possible that a passerby will hijack it.

Impact:

The screen saver will automatically activate when the computer has been unattended for the amount of time specified. The impact should be minimal since the screen saver is enabled by default.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Policies\Microsoft\Windows\Control  
Panel\Desktop\ScreenSaveTimeout
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Enabled`.

```
User Configuration\Administrative Templates\Control  
Panel\Personalization\Screen saver timeout
```

Then set the `Seconds` option to `Enabled:900 or fewer seconds`.

Default Value:

Not Configured

References:

1. CCE-21525-1

ARCHIVE

2.11 Set 'Screen saver executable name' to 'Enabled:scrnsave.scr' (Automated)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting allows you to manage whether or not screen savers run. If the Screen Saver setting is disabled screen savers do not run and the screen saver section of the Screen Saver tab in Display in Control Panel is disabled. If this setting is enabled a screen saver will run if the following two conditions are met: first, that a valid screen saver is specified on the client via the Screen Saver Executable Name group policy setting or Control Panel on the client. Second, the screensaver timeout is set to a value greater than zero via the Screen Saver Timeout group policy setting or Control Panel on the client. The recommended state for this setting is: `Enabled:scrnsave.scr`.

Rationale:

If a user forgets to lock their computer when they walk away its possible that a passerby will hijack it.

Impact:

The screen saver will automatically activate when the computer has been unattended for the amount of time specified by the Screen Saver timeout setting.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\Software\Policies\Microsoft\Windows\Control  
Panel\Desktop\SCRNSAVE.EXE
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled.

```
User Configuration\Administrative Templates\Control  
Panel\Personalization\Force specific screen saver
```

Then set the Screen saver executable name option to `scrnsave.scr`.

Default Value:

Not Configured

References:

1. CCE-22959-1

ARCHIVE

2.12 Configure 'Prevent changing screen saver' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

Prevents the Screen Saver dialog from opening in the Personalization or Display Control Panel. This setting prevents users from using Control Panel to add, configure, or change the screen saver on the computer. It does not prevent a screen saver from running. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

No known vulnerability at the time of this writing, however some organizations may want to ensure all computers use a specific screensaver rather than allowing users to select one from the list of installed screen savers.

Impact:

Enabling this setting will prevent users from using Control Panel to add, configure, or change the screen saver on the computer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<>SID>\Software\Microsoft\Windows\CurrentVersion\Policies\System\NoDispScrSavPage
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to `Not Configured`.

```
User Configuration\Administrative Templates\Control Panel\Personalization\Prevent changing screen saver
```

References:

1. CCE-22179-6

2.13 Configure 'Turn off toast notifications on the lock screen' (Manual)

Profile Applicability:

- Level 1
- Level 1 + BitLocker

Description:

This policy setting turns off toast notifications on the lock screen. If you enable this policy setting, applications will not be able to raise toast notifications on the lock screen. If you disable or do not configure this policy setting, toast notifications on the lock screen are enabled and can be turned off by the administrator or user. No reboots or service restarts are required for this policy setting to take effect. Configure this setting in a manner that is consistent with security and operational requirements of your organization.

Rationale:

While this feature can be handy for users applications that provide toast notifications might display sensitive personal or business data while the device is unattended.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\<SID>\SOFTWARE\Policies\Microsoft\Windows\CurrentVersion\PushNotifications\NoToastApplicationNotificationOnLockScreen
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Not Configured**.

```
User Configuration\Administrative Templates\Start Menu and Taskbar\Notifications\Turn off toast notifications on the lock screen
```

References:

1. CCE-23084-7

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	Computer Configuration		
1.1	Security Settings		
1.1.1	Account Policies		
1.1.1.1	Set 'Account lockout threshold' to '5 invalid logon attempt(s)' (Automated)	☐	☐
1.1.1.2	Set 'Account lockout duration' to '15 or more minute(s)' (Automated)	☐	☐
1.1.1.3	Set 'Reset account lockout counter after' to '15 minute(s)' (Automated)	☐	☐
1.1.1.4	Set 'Minimum password length' to '14 or more character(s)' (Automated)	☐	☐
1.1.1.5	Set 'Enforce password history' to '24 or more password(s)' (Automated)	☐	☐
1.1.1.6	Set 'Password must meet complexity requirements' to 'Enabled' (Automated)	☐	☐
1.1.1.7	Set 'Store passwords using reversible encryption' to 'Disabled' (Automated)	☐	☐
1.1.1.8	Set 'Minimum password age' to '1 or more day(s)' (Automated)	☐	☐
1.1.1.9	Set 'Maximum password age' to '60 or fewer days' (Automated)	☐	☐
1.1.2	Advanced Audit Policy Configuration		
1.1.2.1	Set 'Audit Policy: Privilege Use: Sensitive Privilege Use' to 'Success and Failure' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.2.2	Set 'Audit Policy: Account Management: Other Account Management Events' to 'Success and Failure' (Automated)	☐	☐
1.1.2.3	Set 'Audit Policy: Logon-Logoff: IPsec Quick Mode' to 'No Auditing' (Automated)	☐	☐
1.1.2.4	Set 'Audit Policy: Detailed Tracking: RPC Events' to 'No Auditing' (Automated)	☐	☐
1.1.2.5	Set 'Audit Policy: DS Access: Directory Service Access' to 'No Auditing' (Automated)	☐	☐
1.1.2.6	Set 'Audit Policy: Policy Change: MPSSVC Rule-Level Policy Change' to 'No Auditing' (Automated)	☐	☐
1.1.2.7	Set 'Audit Policy: Account Management: Distribution Group Management' to 'No Auditing' (Automated)	☐	☐
1.1.2.8	Set 'Audit Policy: Detailed Tracking: Process Termination' to 'No Auditing' (Automated)	☐	☐
1.1.2.9	Set 'Audit Policy: Object Access: Detailed File Share' to 'No Auditing' (Automated)	☐	☐
1.1.2.10	Set 'Audit Policy: Account Management: User Account Management' to 'Success and Failure' (Automated)	☐	☐
1.1.2.11	Set 'Audit Policy: Account Management: Computer Account Management' to 'No Auditing' (Automated)	☐	☐
1.1.2.12	Set 'Audit Policy: System: Security System Extension' to 'Success and Failure' (Automated)	☐	☐
1.1.2.13	Set 'Audit Policy: System: Security State Change' to 'Success and Failure' (Automated)	☐	☐
1.1.2.14	Set 'Audit Policy: Logon-Logoff: Network Policy Server' to 'No Auditing' (Automated)	☐	☐
1.1.2.15	Set 'Audit Policy: Detailed Tracking: DPAPI Activity' to 'No Auditing' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.2.16	Set 'Audit Policy: System: IPsec Driver' to 'Success and Failure' (Automated)	☐	☐
1.1.2.17	Set 'Audit Policy: Account Management: Security Group Management' to 'Success and Failure' (Automated)	☐	☐
1.1.2.18	Set 'Audit Policy: Account Logon: Other Account Logon Events' to 'No Auditing' (Automated)	☐	☐
1.1.2.19	Set 'Audit Policy: Object Access: Registry' to 'No Auditing' (Automated)	☐	☐
1.1.2.20	Set 'Audit Policy: Privilege Use: Other Privilege Use Events' to 'No Auditing' (Automated)	☐	☐
1.1.2.21	Set 'Audit Policy: Policy Change: Filtering Platform Policy Change' to 'No Auditing' (Automated)	☐	☐
1.1.2.22	Set 'Audit Policy: Object Access: Central Access Policy Staging' to 'No Auditing' (Automated)	☐	☐
1.1.2.23	Set 'Audit Policy: Policy Change: Authorization Policy Change' to 'No Auditing' (Automated)	☐	☐
1.1.2.24	Set 'Audit Policy: Account Logon: Kerberos Authentication Service' to 'No Auditing' (Automated)	☐	☐
1.1.2.25	Set 'Audit Policy: Logon-Logoff: Logoff' to 'Success' (Automated)	☐	☐
1.1.2.26	Set 'Audit Policy: Account Management: Application Group Management' to 'No Auditing' (Automated)	☐	☐
1.1.2.27	Set 'Audit Policy: DS Access: Directory Service Changes' to 'No Auditing' (Automated)	☐	☐
1.1.2.28	Set 'Audit Policy: Object Access: Kernel Object' to 'No Auditing' (Automated)	☐	☐
1.1.2.29	Set 'Audit Policy: Policy Change: Other Policy Change Events' to 'No Auditing' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.2.30	Set 'Audit Policy: Object Access: Application Generated' to 'No Auditing' (Automated)	☐	☐
1.1.2.31	Set 'Audit Policy: Logon-Logoff: Account Lockout' to 'No Auditing' (Automated)	☐	☐
1.1.2.32	Set 'Audit Policy: Policy Change: Audit Policy Change' to 'Success and Failure' (Automated)	☐	☐
1.1.2.33	Set 'Audit Policy: Object Access: File Share' to 'No Auditing' (Automated)	☐	☐
1.1.2.34	Set 'Audit Policy: System: System Integrity' to 'Success and Failure' (Automated)	☐	☐
1.1.2.35	Set 'Audit Policy: System: Other System Events' to 'No Auditing' (Automated)	☐	☐
1.1.2.36	Set 'Audit Policy: Logon-Logoff: Other Logon/Logoff Events' to 'No Auditing' (Automated)	☐	☐
1.1.2.37	Set 'Audit Policy: DS Access: Directory Service Replication' to 'No Auditing' (Automated)	☐	☐
1.1.2.38	Set 'Audit Policy: Object Access: Filtering Platform Packet Drop' to 'No Auditing' (Automated)	☐	☐
1.1.2.39	Set 'Audit Policy: DS Access: Detailed Directory Service Replication' to 'No Auditing' (Automated)	☐	☐
1.1.2.40	Set 'Audit Policy: Object Access: Other Object Access Events' to 'No Auditing' (Automated)	☐	☐
1.1.2.41	Set 'Audit Policy: Object Access: Filtering Platform Connection' to 'No Auditing' (Automated)	☐	☐
1.1.2.42	Set 'Audit Policy: Privilege Use: Non Sensitive Privilege Use' to 'No Auditing' (Automated)	☐	☐
1.1.2.43	Set 'Audit Policy: Object Access: Certification Services' to 'No Auditing' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.2.44	Set 'Audit Policy: Logon-Logoff: Special Logon' to 'Success' (Automated)	☐	☐
1.1.2.45	Set 'Audit Policy: Object Access: Handle Manipulation' to 'No Auditing' (Automated)	☐	☐
1.1.2.46	Set 'Audit Policy: Object Access: Removable Storage' to 'No Auditing' (Automated)	☐	☐
1.1.2.47	Set 'Audit Policy: Logon-Logoff: IPsec Main Mode' to 'No Auditing' (Automated)	☐	☐
1.1.2.48	Set 'Audit Policy: Account Logon: Credential Validation' to 'Success and Failure' (Automated)	☐	☐
1.1.2.49	Set 'Audit Policy: Account Logon: Kerberos Service Ticket Operations' to 'No Auditing' (Automated)	☐	☐
1.1.2.50	Set 'Audit Policy: Logon-Logoff: Logon' to 'Success and Failure' (Automated)	☐	☐
1.1.2.51	Set 'Audit Policy: Detailed Tracking: Process Creation' to 'Success' (Automated)	☐	☐
1.1.2.52	Set 'Audit Policy: Logon-Logoff: IPsec Extended Mode' to 'No Auditing' (Automated)	☐	☐
1.1.2.53	Set 'Audit Policy: Object Access: SAM' to 'No Auditing' (Automated)	☐	☐
1.1.2.54	Set 'Audit Policy: Object Access: File System' to 'No Auditing' (Automated)	☐	☐
1.1.2.55	Set 'Audit Policy: Policy Change: Authentication Policy Change' to 'Success' (Automated)	☐	☐
1.1.3	Security Options		
1.1.3.1	Accounts		
1.1.3.1.1	Set 'Accounts: Block Microsoft accounts' to 'Users can't add or log on with Microsoft accounts' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.1.2	Configure 'Accounts: Rename guest account' (Automated)	☐	☐
1.1.3.1.3	Set 'Accounts: Administrator account status' to 'Disabled' (Automated)	☐	☐
1.1.3.1.4	Configure 'Accounts: Rename administrator account' (Automated)	☐	☐
1.1.3.1.5	Set 'Accounts: Guest account status' to 'Disabled' (Automated)	☐	☐
1.1.3.1.6	Set 'Accounts: Limit local account use of blank passwords to console logon only' to 'Enabled' (Automated)	☐	☐
1.1.3.2	Audit		
1.1.3.2.1	Set 'Audit: Shut down system immediately if unable to log security audits' to 'Disabled' (Automated)	☐	☐
1.1.3.2.2	Set 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' to 'Enabled' (Automated)	☐	☐
1.1.3.2.3	Configure 'Audit: Audit the use of Backup and Restore privilege' (Manual)	☐	☐
1.1.3.2.4	Configure 'Audit: Audit the access of global system objects' (Manual)	☐	☐
1.1.3.3	DCOM		
1.1.3.3.1	Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)	☐	☐
1.1.3.3.2	Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)	☐	☐
1.1.3.4	Devices		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.4.1	Configure 'Devices: Allow undock without having to log on' (Manual)	☐	☐
1.1.3.4.2	Configure 'Devices: Restrict floppy access to locally logged-on user only' (Manual)	☐	☐
1.1.3.4.3	Set 'Devices: Allowed to format and eject removable media' to 'Administrators and Interactive Users' (Automated)	☐	☐
1.1.3.4.4	Configure 'Devices: Restrict CD-ROM access to locally logged-on user only' (Manual)	☐	☐
1.1.3.4.5	Configure 'Devices: Prevent users from installing printer drivers' (Manual)	☐	☐
1.1.3.5	Domain member		
1.1.3.5.1	Set 'Domain member: Require strong (Windows 2000 or later) session key' to 'Enabled' (Automated)	☐	☐
1.1.3.5.2	Set 'Domain member: Digitally sign secure channel data (when possible)' to 'Enabled' (Automated)	☐	☐
1.1.3.5.3	Set 'Domain member: Digitally encrypt secure channel data (when possible)' to 'Enabled' (Automated)	☐	☐
1.1.3.5.4	Set 'Domain member: Maximum machine account password age' to '30 or fewer day(s)' (Automated)	☐	☐
1.1.3.5.5	Set 'Domain member: Digitally encrypt or sign secure channel data (always)' to 'Enabled' (Automated)	☐	☐
1.1.3.5.6	Set 'Domain member: Disable machine account password changes' to 'Disabled' (Automated)	☐	☐
1.1.3.6	Interactive logon		
1.1.3.6.1	Set 'Interactive logon: Machine account lockout threshold' to 10 or fewer invalid logon attempts (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.6.2	Set 'Interactive logon: Smart card removal behavior' to 'Lock Workstation' (Automated)	☐	☐
1.1.3.6.3	Configure 'Interactive logon: Require smart card' (Manual)	☐	☐
1.1.3.6.4	Set 'startup (minutes)' to '10 or more minute(s)' (Automated)	☐	☐
1.1.3.6.5	Set 'Interactive logon: Do not display last user name' to 'Enabled' (Automated)	☐	☐
1.1.3.6.6	Set 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' to '4 or fewer logon(s)' (Automated)	☐	☐
1.1.3.6.7	Set 'Interactive logon: Require Domain Controller authentication to unlock workstation' to 'Disabled' (Automated)	☐	☐
1.1.3.6.8	Set 'Interactive logon: Prompt user to change password before expiration' to '14 or more day(s)' (Automated)	☐	☐
1.1.3.6.9	Set 'Interactive logon: Do not require CTRL+ALT+DEL' to 'Disabled' (Automated)	☐	☐
1.1.3.6.10	Configure 'Interactive logon: Message text for users attempting to log on' (Automated)	☐	☐
1.1.3.6.11	Set 'Interactive logon: Machine inactivity limit' to '900 or fewer seconds' (Automated)	☐	☐
1.1.3.6.12	Configure 'Interactive logon: Message title for users attempting to log on' (Automated)	☐	☐
1.1.3.6.13	Configure 'Interactive logon: Display user information when the session is locked' (Manual)	☐	☐
1.1.3.7	Microsoft network client		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.7.1	Set 'Microsoft network client: Send unencrypted password to third-party SMB servers' to 'Disabled' (Automated)	☐	☐
1.1.3.7.2	Set 'Microsoft network client: Digitally sign communications (always)' to 'Enabled' (Automated)	☐	☐
1.1.3.7.3	Set 'Microsoft network client: Digitally sign communications (if server agrees)' to 'Enabled' (Automated)	☐	☐
1.1.3.8	Microsoft network server		
1.1.3.8.1	Set 'Microsoft network server: Disconnect clients when logon hours expire' to 'Enabled' (Automated)	☐	☐
1.1.3.8.2	Set 'Microsoft network server: Amount of idle time required before suspending session' to '15 or fewer minute(s)' (Automated)	☐	☐
1.1.3.8.3	Set 'Microsoft network server: Digitally sign communications (if client agrees)' to 'Enabled' (Automated)	☐	☐
1.1.3.8.4	Set 'Microsoft network server: Server SPN target name validation level' to 'Accept if provided by client' (Automated)	☐	☐
1.1.3.8.5	Set 'Microsoft network server: Digitally sign communications (always)' to 'Enabled' (Automated)	☐	☐
1.1.3.9	MSS		
1.1.3.9.1	Configure 'MSS: (AutoShareWks) Enable Administrative Shares (recommended except for highly secure environments)' (Manual)	☐	☐
1.1.3.9.2	Set 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.9.3	Configure 'MSS: (NtfsDisable8dot3NameCreation) Enable the computer to stop generating 8.3 style filenames' (Manual)	☐	☐
1.1.3.9.4	Set 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' to 'Disabled' (Automated)	☐	☐
1.1.3.9.5	Set 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' to '0.9 or less' (Automated)	☐	☐
1.1.3.9.6	Set 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)	☐	☐
1.1.3.9.7	Set 'MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)' to 'Not Defined' (Automated)	☐	☐
1.1.3.9.8	Configure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' (Manual)	☐	☐
1.1.3.9.9	Configure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' (Manual)	☐	☐
1.1.3.9.10	Configure 'MSS: (NoDefaultExempt) Configure IPsec exemptions for various types of network traffic.' (Manual)	☐	☐
1.1.3.9.11	Configure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' (Manual)	☐	☐
1.1.3.9.12	Configure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' (Manual)	☐	☐
1.1.3.9.13	Configure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.9.14	Configure 'MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)' (Manual)	☐	☐
1.1.3.9.15	Set 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' to '0' (Automated)	☐	☐
1.1.3.9.16	Set 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)	☐	☐
1.1.3.9.17	Configure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' (Manual)	☐	☐
1.1.3.10	Network access		
1.1.3.10.1	Set 'Network access: Let Everyone permissions apply to anonymous users' to 'Disabled' (Automated)	☐	☐
1.1.3.10.2	Set 'Network access: Allow anonymous SID/Name translation' to 'Disabled' (Automated)	☐	☐
1.1.3.10.3	Set 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' to 'Enabled' (Automated)	☐	☐
1.1.3.10.4	Configure 'Network access: Named Pipes that can be accessed anonymously' (Manual)	☐	☐
1.1.3.10.5	Set 'Network access: Restrict anonymous access to Named Pipes and Shares' to 'Enabled' (Automated)	☐	☐
1.1.3.10.6	Set 'Network access: Sharing and security model for local accounts' to 'Classic - local users authenticate as themselves' (Automated)	☐	☐
1.1.3.10.7	Set 'Network access: Remotely accessible registry paths and sub-paths' to the following list (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.10.8	Set 'Network access: Shares that can be accessed anonymously' to 'Not Defined' (Automated)	☐	☐
1.1.3.10.9	Set 'Network access: Do not allow anonymous enumeration of SAM accounts' to 'Enabled' (Automated)	☐	☐
1.1.3.10.10	Set 'Network access: Remotely accessible registry paths' to the following list (Automated)	☐	☐
1.1.3.10.11	Configure 'Network access: Do not allow storage of passwords and credentials for network authentication' (Manual)	☐	☐
1.1.3.11	Network security		
1.1.3.11.1	Set 'Network security: Do not store LAN Manager hash value on next password change' to 'Enabled' (Automated)	☐	☐
1.1.3.11.2	Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' to 'Require NTLMv2 session security,Require 128-bit encryption' (Automated)	☐	☐
1.1.3.11.3	Set 'Network security: Allow Local System to use computer identity for NTLM' to 'Enabled' (Automated)	☐	☐
1.1.3.11.4	Set 'Network security: Allow LocalSystem NULL session fallback' to 'Disabled' (Automated)	☐	☐
1.1.3.11.5	'Network Security: Restrict NTLM: NTLM authentication in this domain' (Manual)	☐	☐
1.1.3.11.6	Configure 'Network Security: Restrict NTLM: Add server exceptions in this domain' (Manual)	☐	☐
1.1.3.11.7	Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' to 'Require NTLMv2 session security,Require 128-bit encryption' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.11.8	Configure 'Network Security: Restrict NTLM: Outgoing NTLM traffic to remote servers' (Manual)	☐	☐
1.1.3.11.9	Configure 'Network Security: Restrict NTLM: Add remote server exceptions for NTLM authentication' (Manual)	☐	☐
1.1.3.11.10	Set 'Network Security: Restrict NTLM: Audit Incoming NTLM Traffic' to 'Not Defined' (Automated)	☐	☐
1.1.3.11.11	Set 'Network security: LAN Manager authentication level' to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)	☐	☐
1.1.3.11.12	Set 'Network Security: Allow PKU2U authentication requests to this computer to use online identities' to 'Disabled' (Automated)	☐	☐
1.1.3.11.13	Configure 'Network Security: Restrict NTLM: Audit NTLM authentication in this domain' (Manual)	☐	☐
1.1.3.11.14	Configure 'Network Security: Restrict NTLM: Incoming NTLM traffic' (Manual)	☐	☐
1.1.3.11.15	Set 'Network Security: Configure encryption types allowed for Kerberos' to 'RC4\AES128\AES256\Future types' (Automated)	☐	☐
1.1.3.11.16	Set 'Network security: LDAP client signing requirements' to 'Negotiate signing' (Automated)	☐	☐
1.1.3.11.17	Configure 'Network security: Force logoff when logon hours expire' (Manual)	☐	☐
1.1.3.12	Recovery console		
1.1.3.12.1	Set 'Recovery console: Allow automatic administrative logon' to 'Disabled' (Automated)	☐	☐
1.1.3.12.2	Set 'Recovery console: Allow floppy copy and access to all drives and all folders' to 'Disabled' (Automated)	☐	☐
1.1.3.13	Shutdown		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.13.1	Set 'Shutdown: Clear virtual memory pagefile' to 'Disabled' (Automated)	☐	☐
1.1.3.13.2	Set 'Shutdown: Allow system to be shut down without having to log on' to 'Enabled' (Automated)	☐	☐
1.1.3.14	System cryptography		
1.1.3.14.1	Configure 'System cryptography: Force strong key protection for user keys stored on the computer' (Manual)	☐	☐
1.1.3.14.2	Set 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing' to 'Enabled' (Automated)	☐	☐
1.1.3.15	System objects		
1.1.3.15.1	Set 'System objects: Strengthen default permissions of internal system objects (e.g' Symbolic Links)' to 'Enabled' (Automated)	☐	☐
1.1.3.15.2	Set 'System objects: Require case insensitivity for non-Windows subsystems' to 'Enabled' (Automated)	☐	☐
1.1.3.16	System settings		
1.1.3.16.1	Configure 'System settings: Optional subsystems' (Manual)	☐	☐
1.1.3.16.2	Configure 'System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies' (Manual)	☐	☐
1.1.3.17	User Account Control		
1.1.3.17.1	Set 'User Account Control: Admin Approval Mode for the Built-in Administrator account' to 'Enabled' (Automated)	☐	☐
1.1.3.17.2	Set 'User Account Control: Detect application installations and prompt for elevation' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.3.17.3	Set 'User Account Control: Behavior of the elevation prompt for standard users' to 'Automatically deny elevation requests' (Automated)	☐	☐
1.1.3.17.4	Set 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' to 'Prompt for consent on the secure desktop' (Automated)	☐	☐
1.1.3.17.5	Set 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' to 'Enabled' (Automated)	☐	☐
1.1.3.17.6	Set 'User Account Control: Virtualize file and registry write failures to per-user locations' to 'Enabled' (Automated)	☐	☐
1.1.3.17.7	Set 'User Account Control: Switch to the secure desktop when prompting for elevation' to 'Enabled' (Automated)	☐	☐
1.1.3.17.8	Set 'User Account Control: Allow UIAccess applications to prompt for elevation without using the secure desktop' to 'Disabled' (Automated)	☐	☐
1.1.3.17.9	Set 'User Account Control: Only elevate executables that are signed and validated' to 'Disabled' (Automated)	☐	☐
1.1.3.17.10	Set 'User Account Control: Run all administrators in Admin Approval Mode' to 'Enabled' (Automated)	☐	☐
1.1.4	User Rights Assignment		
1.1.4.1	Configure 'Allow log on through Remote Desktop Services' (Manual)	☐	☐
1.1.4.2	Set 'Deny log on through Remote Desktop Services' to 'Guests' (Automated)	☐	☐
1.1.4.3	Set 'Deny access to this computer from the network' to 'Guests' (Automated)	☐	☐
1.1.4.4	Set 'Create a pagefile' to 'Administrators' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.4.5	Set 'Create permanent shared objects' to 'No One' (Automated)	☐	☐
1.1.4.6	Set 'Increase scheduling priority' to 'Administrators' (Automated)	☐	☐
1.1.4.7	Set 'Access this computer from the network' to 'Users, Administrators' (Automated)	☐	☐
1.1.4.8	Set 'Force shutdown from a remote system' to 'Administrators' (Automated)	☐	☐
1.1.4.9	Set 'Change the time zone' to 'LOCAL SERVICE, Administrators, Users' (Automated)	☐	☐
1.1.4.10	Set 'Create global objects' to 'Administrators, SERVICE, LOCAL SERVICE, NETWORK SERVICE' (Automated)	☐	☐
1.1.4.11	Set 'Enable computer and user accounts to be trusted for delegation' to 'No One' (Automated)	☐	☐
1.1.4.12	Set 'Profile single process' to 'Administrators' (Automated)	☐	☐
1.1.4.13	Set 'Shut down the system' to 'Administrators, Users' (Automated)	☐	☐
1.1.4.14	Set 'Take ownership of files or other objects' to 'Administrators' (Automated)	☐	☐
1.1.4.15	Set 'Create symbolic links' to 'Administrators' (Automated)	☐	☐
1.1.4.16	Set 'Act as part of the operating system' to 'No One' (Automated)	☐	☐
1.1.4.17	Set 'Modify firmware environment values' to 'Administrators' (Automated)	☐	☐
1.1.4.18	Set 'Back up files and directories' to 'Administrators' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.4.19	Set 'Debug programs' to 'Administrators' (Automated)	☐	☐
1.1.4.20	Set 'Access Credential Manager as a trusted caller' to 'No One' (Automated)	☐	☐
1.1.4.21	Set 'Deny log on locally' to 'Guests' (Automated)	☐	☐
1.1.4.22	Set 'Profile system performance' to 'NT SERVICE\WdiServiceHost,Administrators' (Automated)	☐	☐
1.1.4.23	Set 'Restore files and directories' to 'Administrators' (Automated)	☐	☐
1.1.4.24	Set 'Perform volume maintenance tasks' to 'Administrators' (Automated)	☐	☐
1.1.4.25	Set 'Impersonate a client after authentication' to 'Administrators, SERVICE, Local Service, Network Service' (Automated)	☐	☐
1.1.4.26	Configure 'Log on as a batch job' (Manual)	☐	☐
1.1.4.27	Set 'Adjust memory quotas for a process' to 'Administrators, Local Service, Network Service' (Automated)	☐	☐
1.1.4.28	Set 'Manage auditing and security log' to 'Administrators' (Automated)	☐	☐
1.1.4.29	Set 'Deny log on as a batch job' to 'Guests' (Automated)	☐	☐
1.1.4.30	Set 'Bypass traverse checking' to 'Users, NETWORK SERVICE, LOCAL SERVICE, Administrators' (Automated)	☐	☐
1.1.4.31	Set 'Increase a process working set' to 'Administrators, Local Service' (Automated)	☐	☐
1.1.4.32	Set 'Change the system time' to 'LOCAL SERVICE, Administrators' (Automated)	☐	☐
1.1.4.33	Configure 'Deny log on as a service' (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.4.34	Configure 'Log on as a service' (Manual)	☐	☐
1.1.4.35	Set 'Generate security audits' to 'Local Service, Network Service' (Automated)	☐	☐
1.1.4.36	Set 'Allow log on locally' to 'Administrators, Users' (Automated)	☐	☐
1.1.4.37	Set 'Lock pages in memory' to 'No One' (Automated)	☐	☐
1.1.4.38	Set 'Load and unload device drivers' to 'Administrators' (Automated)	☐	☐
1.1.4.39	Configure 'Remove computer from docking station' (Manual)	☐	☐
1.1.4.40	Set 'Replace a process level token' to 'Local Service, Network Service' (Automated)	☐	☐
1.1.4.41	Set 'Create a token object' to 'No One' (Automated)	☐	☐
1.1.4.42	Set 'Modify an object label' to 'No one' (Automated)	☐	☐
1.1.5	Windows Firewall With Advanced Security		
1.1.5.1	Domain Profile		
1.1.5.1.1	Set 'Windows Firewall: Domain: Display a notification' to 'Yes (default)' (Automated)	☐	☐
1.1.5.1.2	Set 'Windows Firewall: Domain: Logging: Size limit (KB)' to '16384 KB or greater ' (Automated)	☐	☐
1.1.5.1.3	Set 'Windows Firewall: Domain: Logging: Name' to '%SYSTEMROOT%\System32\logfiles\firewall\domainfw.log' (Automated)	☐	☐
1.1.5.1.4	Set 'Windows Firewall: Domain: Apply local firewall rules' to 'Yes (default)' (Automated)	☐	☐
1.1.5.1.5	Set 'Windows Firewall: Domain: Apply local connection security rules' to 'Yes (default)' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.5.1.6	Set 'Windows Firewall: Domain: Allow unicast response' to 'No' (Automated)	☐	☐
1.1.5.1.7	Set 'Windows Firewall: Domain: Outbound connections' to 'Allow (default)' (Automated)	☐	☐
1.1.5.1.8	Set 'Windows Firewall: Domain: Logging: Log dropped packets' to 'Yes' (Automated)	☐	☐
1.1.5.1.9	Set 'Windows Firewall: Domain: Logging: Log successful connections' to 'Yes' (Automated)	☐	☐
1.1.5.1.10	Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)	☐	☐
1.1.5.1.11	Set 'Windows Firewall: Domain: Firewall state' to 'On (recommended)' (Automated)	☐	☐
1.1.5.2	Private Profile		
1.1.5.2.1	Set 'Windows Firewall: Private: Firewall state' to 'On (recommended)' (Automated)	☐	☐
1.1.5.2.2	Set 'Windows Firewall: Private: Outbound connections' to 'Allow (default)' (Automated)	☐	☐
1.1.5.2.3	Set 'Windows Firewall: Private: Apply local firewall rules' to 'Yes (default)' (Automated)	☐	☐
1.1.5.2.4	Set 'Windows Firewall: Private: Logging: Size limit (KB)' to '16384 KB or greater' (Automated)	☐	☐
1.1.5.2.5	Set 'Windows Firewall: Private: Apply local connection security rules' to 'Yes (default)' (Automated)	☐	☐
1.1.5.2.6	Set 'Windows Firewall: Private: Display a notification' to 'Yes (default)' (Automated)	☐	☐
1.1.5.2.7	Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.5.2.8	Set 'Windows Firewall: Private: Logging: Name' to 'C:\WINDOWS\system32\logfiles\firewall\privatefw.log' (Automated)	☐	☐
1.1.5.2.9	Set 'Windows Firewall: Private: Allow unicast response' to 'No' (Automated)	☐	☐
1.1.5.2.10	Set 'Windows Firewall: Private: Logging: Log successful connections' to 'Yes' (Automated)	☐	☐
1.1.5.2.11	Set 'Windows Firewall: Private: Logging: Log dropped packets' to 'Yes' (Automated)	☐	☐
1.1.5.3	Public Profile		
1.1.5.3.1	Set 'Windows Firewall: Public: Outbound connections' to 'Allow (default)' (Automated)	☐	☐
1.1.5.3.2	Set 'Windows Firewall: Public: Apply local firewall rules' to 'Yes (default)' (Automated)	☐	☐
1.1.5.3.3	Set 'Windows Firewall: Public: Apply local connection security rules' to 'No' (Automated)	☐	☐
1.1.5.3.4	Set 'Windows Firewall: Public: Logging: Log dropped packets' to 'Yes' (Automated)	☐	☐
1.1.5.3.5	Set 'Windows Firewall: Public: Display a notification' to 'No' (Automated)	☐	☐
1.1.5.3.6	Set 'Windows Firewall: Public: Allow unicast response' to 'No' (Automated)	☐	☐
1.1.5.3.7	Set 'Windows Firewall: Public: Logging: Name' to 'C:\WINDOWS\system32\logfiles\firewall\publicfw.log' (Automated)	☐	☐
1.1.5.3.8	Set 'Windows Firewall: Public: Logging: Log successful connections' to 'Yes' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.5.3.9	Set 'Windows Firewall: Public: Logging: Size limit (KB)' to '16384 KB or greater' (Automated)	☐	☐
1.1.5.3.10	Set 'Windows Firewall: Public: Firewall state' to 'On (recommended)' (Automated)	☐	☐
1.1.5.3.11	Set 'Inbound Connections' to 'Enabled:Block (default)' (Automated)	☐	☐
1.2	Administrative Templates		
1.2.1	Network		
1.2.1.1	Configure 'Set IP Stateless Autoconfiguration Limits State' (Manual)	☐	☐
1.2.1.2	Configure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' (Manual)	☐	☐
1.2.1.3	Configure 'Prohibit connection to non-domain networks when connected to domain authenticated network' (Manual)	☐	☐
1.2.2	Printers		
1.2.2.1	Configure 'Point and Print Restrictions' (Manual)	☐	☐
1.2.3	System		
1.2.3.1	Internet Communication Management		
1.2.3.1.1	Configure 'Turn off access to the Store' (Manual)	☐	☐
1.2.3.1.2	Set 'Turn off downloading of print drivers over HTTP' to 'Enabled' (Automated)	☐	☐
1.2.3.1.3	Set 'Turn off Windows Update device driver searching' to 'Enabled' (Automated)	☐	☐
1.2.3.1.4	Set 'Turn off the "Publish to Web" task for files and folders' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.3.1.5	Set 'Turn off the Windows Messenger Customer Experience Improvement Program' to 'Enabled' (Automated)	☐	☐
1.2.3.1.6	Set 'Turn off Search Companion content file updates' to 'Enabled' (Automated)	☐	☐
1.2.3.1.7	Configure 'Turn off Event Viewer "Events.asp" links' (Manual)	☐	☐
1.2.3.1.8	Set 'Turn off Internet download for Web publishing and online ordering wizards' to 'Enabled' (Automated)	☐	☐
1.2.3.1.9	Set 'Turn off printing over HTTP' to 'Enabled' (Automated)	☐	☐
1.2.3.2	Logon		
1.2.3.2.1	Set 'Turn on PIN sign-in' to 'Disabled' (Automated)	☐	☐
1.2.3.2.2	Configure 'Do not process the run once list' (Manual)	☐	☐
1.2.3.2.3	Configure 'Do not process the legacy run list' (Manual)	☐	☐
1.2.3.2.4	Set 'Do not enumerate connected users on domain-joined computers' to 'Enabled' (Automated)	☐	☐
1.2.3.2.5	Configure 'Turn off app notifications on the lock screen' (Manual)	☐	☐
1.2.3.2.6	Set 'Enumerate local users on domain-joined computers' to 'Disabled' (Automated)	☐	☐
1.2.3.3	Power Management		
1.2.3.3.1	Configure 'Turn Off the Display (seconds):' (Manual)	☐	☐
1.2.3.3.2	Configure 'Turn Off the Display (seconds):' (Manual)	☐	☐
1.2.3.3.3	Set 'Require a Password When a Computer Wakes (Plugged In)' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.3.3.4	Set 'Require a Password When a Computer Wakes (On Battery)' to 'Enabled' (Automated)	☐	☐
1.2.3.4	Remote Assistance		
1.2.3.4.1	Set 'Configure Solicited Remote Assistance' to 'Disabled' (Automated)	☐	☐
1.2.3.4.2	Set 'Configure Offer Remote Assistance' to 'Disabled' (Automated)	☐	☐
1.2.3.4.3	Configure 'Customize Warning Messages' (Manual)	☐	☐
1.2.3.5	Set 'RPC Runtime Unauthenticated Client Restriction to Apply:' to 'Enabled:Authenticated' (Automated)	☐	☐
1.2.3.6	Set 'Enable RPC Endpoint Mapper Client Authentication' to 'Disabled' (Automated)	☐	☐
1.2.3.7	Set 'Do not apply during periodic background processing' to 'Enabled:FALSE' (Automated)	☐	☐
1.2.3.8	Set 'Process even if the Group Policy objects have not changed' to 'Enabled:TRUE' (Automated)	☐	☐
1.2.3.9	Set 'Choose the boot-start drivers that can be initialized:' to 'Enabled:Good, unknown and bad but critical' (Automated)	☐	☐
1.2.3.10	Configure 'Detect compatibility issues for applications and drivers' (Manual)	☐	☐
1.2.3.11	Set 'Select update server:' to 'Enabled:Search Managed Server' (Automated)	☐	☐
1.2.3.12	Configure 'Specify settings for optional component installation and component repair' (Manual)	☐	☐
1.2.3.13	Set 'Prevent installation of devices using drivers that match these device setup classes' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.3.14	Set 'Also apply to matching devices that are already installed' to 'True' (Automated)	☐	☐
1.2.3.15	Configure 'Prevent installation of devices using drivers for these device setup classes:' (Manual)	☐	☐
1.2.4	Windows Components		
1.2.4.1	AutoPlay Policies		
1.2.4.1.1	Set 'Turn off Autoplay on' to 'Enabled:All drives' (Automated)	☐	☐
1.2.4.2	BitLocker		
1.2.4.2.1	Fixed Data Drives		
1.2.4.2.1.1	Set 'Configure use of hardware-based encryption for fixed data drives' to 'Enabled' (Automated)	☐	☐
1.2.4.2.1.2	Configure 'Enforce drive encryption type on fixed data drives' (Manual)	☐	☐
1.2.4.2.1.3	Set 'Configure use of passwords for fixed data drives' to 'Disabled' (Automated)	☐	☐
1.2.4.2.1.4	Set 'Recovery Key' to 'Allow 256-bit recovery key' (Automated)	☐	☐
1.2.4.2.1.5	Set 'Recovery Password' to 'Allow 48-digit recovery password' (Automated)	☐	☐
1.2.4.2.1.6	Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)	☐	☐
1.2.4.2.1.7	Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.2.1.8	Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)	☐	☐
1.2.4.2.1.9	Set 'Allow data recovery agent' to 'True' (Automated)	☐	☐
1.2.4.2.1.10	Set 'Choose how BitLocker-protected fixed drives can be recovered' to 'Enabled' (Automated)	☐	☐
1.2.4.2.1.11	Set 'Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives' to 'False' (Automated)	☐	☐
1.2.4.2.1.12	Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Backup recovery passwords and key packages' (Automated)	☐	☐
1.2.4.2.1.13	Set 'Save BitLocker recovery information to AD DS for fixed data drives' to 'False' (Automated)	☐	☐
1.2.4.2.1.14	Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)	☐	☐
1.2.4.2.1.15	Set 'Configure use of smart cards on fixed data drives' to 'Enabled' (Automated)	☐	☐
1.2.4.2.1.16	Set 'Require use of smart cards on fixed data drives' to 'True' (Automated)	☐	☐
1.2.4.2.1.17	Configure 'Deny write access to fixed drives not protected by BitLocker' (Manual)	☐	☐
1.2.4.2.1.18	Set 'Allow access to BitLocker-protected fixed data drives from earlier versions of Windows' to 'Disabled' (Automated)	☐	☐
1.2.4.2.2	Operating System Drives		
1.2.4.2.2.1	Set 'Configure use of hardware-based encryption for operating system drives' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.2.2.2	Configure 'Enforce drive encryption type on operating system drives' (Manual)	☐	☐
1.2.4.2.2.3	Set 'Configure use of passwords for operating system drives' to 'Disabled' (Automated)	☐	☐
1.2.4.2.2.4	Set 'Recovery Key' to 'Do not allow 256-bit recovery key' (Automated)	☐	☐
1.2.4.2.2.5	Set 'Recovery Password' to 'Require 48-digit recovery password' (Automated)	☐	☐
1.2.4.2.2.6	Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)	☐	☐
1.2.4.2.2.7	Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)	☐	☐
1.2.4.2.2.8	Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)	☐	☐
1.2.4.2.2.9	Set 'Allow data recovery agent' to 'False' (Automated)	☐	☐
1.2.4.2.2.10	Set 'Choose how BitLocker-protected operating system drives can be recovered' to 'Enabled' (Automated)	☐	☐
1.2.4.2.2.11	Set 'Do not enable BitLocker until recovery information is stored to AD DS for operating system drives' to 'True' (Automated)	☐	☐
1.2.4.2.2.12	Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Store recovery passwords and key packages' (Automated)	☐	☐
1.2.4.2.2.13	Set 'Save BitLocker recovery information to AD DS for operating system drives' to 'True' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.2.2.14	Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)	☐	☐
1.2.4.2.2.15	Set 'Require additional authentication at startup' to 'Enabled' (Automated)	☐	☐
1.2.4.2.2.16	Set 'Allow BitLocker without a compatible TPM' to 'False' (Automated)	☐	☐
1.2.4.2.2.17	Set 'Configure TPM startup key and PIN:' to 'Do not allow startup key and PIN with TPM' (Automated)	☐	☐
1.2.4.2.2.18	Set 'Configure TPM startup PIN:' to 'Require startup PIN with TPM' (Automated)	☐	☐
1.2.4.2.2.19	Set 'Configure TPM startup:' to 'Do not allow TPM' (Automated)	☐	☐
1.2.4.2.2.20	Set 'Configure TPM startup key:' to 'Do not allow startup key with TPM' (Automated)	☐	☐
1.2.4.2.2.21	Configure 'Use enhanced Boot Configuration Data validation profile' (Manual)	☐	☐
1.2.4.2.2.22	Configure 'Enable use of BitLocker authentication requiring preboot keyboard input on slates' (Manual)	☐	☐
1.2.4.2.2.23	Configure 'Configure TPM platform validation profile for BIOS-based firmware configurations' (Manual)	☐	☐
1.2.4.2.2.24	Configure 'Configure TPM platform validation profile for native UEFI firmware configurations' (Manual)	☐	☐
1.2.4.2.2.25	Set 'Allow enhanced PINs for startup' to 'Enabled' (Automated)	☐	☐
1.2.4.2.2.26	Configure 'Disallow standard users from changing the PIN or password' (Manual)	☐	☐
1.2.4.2.2.27	Set 'Allow Secure Boot for integrity validation' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.2.2.28	Set 'Minimum characters:' to 'Enabled:7 or more characters' (Automated)	☐	☐
1.2.4.2.2.29	Configure 'Allow network unlock at startup' (Manual)	☐	☐
1.2.4.2.2.30	Configure 'Reset platform validation data after BitLocker recovery' (Manual)	☐	☐
1.2.4.2.3	Removable Data Drives		
1.2.4.2.3.1	Set 'Configure use of hardware-based encryption for removable data drives' to 'Enabled' (Automated)	☐	☐
1.2.4.2.3.2	Configure 'Enforce drive encryption type on removable data drives' (Manual)	☐	☐
1.2.4.2.3.3	Set 'Configure use of passwords for removable data drives' to 'Disabled' (Automated)	☐	☐
1.2.4.2.3.4	Set 'Recovery Key' to 'Do not allow 256-bit recovery key' (Automated)	☐	☐
1.2.4.2.3.5	Set 'Recovery Password' to 'Do not allow 48-digit recovery password' (Automated)	☐	☐
1.2.4.2.3.6	Set 'Use BitLocker software-based encryption when hardware encryption is not available' to 'True' (Automated)	☐	☐
1.2.4.2.3.7	Set 'Restrict crypto algorithms or cipher suites to the following:' to '2.16.840.1.101.3.4.1.2;2.16.840.1.101.3.4.1.42' (Automated)	☐	☐
1.2.4.2.3.8	Set 'Restrict encryption algorithms and cipher suites allowed for hardware-based encryption' to 'False' (Automated)	☐	☐
1.2.4.2.3.9	Set 'Allow data recovery agent' to 'True' (Automated)	☐	☐
1.2.4.2.3.10	Set 'Choose how BitLocker-protected removable drives can be recovered' to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.2.3.11	Set 'Do not enable BitLocker until recovery information is stored to AD DS for removable data drives' to 'False' (Automated)	☐	☐
1.2.4.2.3.12	Set 'Configure storage of BitLocker recovery information to AD DS:' to 'Backup recovery passwords and key packages' (Automated)	☐	☐
1.2.4.2.3.13	Set 'Save BitLocker recovery information to AD DS for removable data drives' to 'False' (Automated)	☐	☐
1.2.4.2.3.14	Set 'Omit recovery options from the BitLocker setup wizard' to 'True' (Automated)	☐	☐
1.2.4.2.3.15	Set 'Configure use of smart cards on removable data drives' to 'Enabled' (Automated)	☐	☐
1.2.4.2.3.16	Set 'Require use of smart cards on removable data drives' to 'True' (Automated)	☐	☐
1.2.4.2.3.17	Set 'Deny write access to removable drives not protected by BitLocker' to 'Enabled' (Automated)	☐	☐
1.2.4.2.3.18	Set 'Allow access to BitLocker-protected removable data drives from earlier versions of Windows' to 'Disabled' (Automated)	☐	☐
1.2.4.2.3.19	Configure 'Control use of BitLocker on removable drives' (Manual)	☐	☐
1.2.4.2.3.20	Set 'Do not allow write access to devices configured in another organization' to 'True' (Automated)	☐	☐
1.2.4.2.4	Configure 'Validate smart card certificate usage rule compliance' (Manual)	☐	☐
1.2.4.2.5	Set 'Select the encryption method:' to 'Enabled:AES 256-bit' (Automated)	☐	☐
1.2.4.2.6	Configure 'Prevent memory overwrite on restart' (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.2.7	Configure 'Choose default folder for recovery password' (Manual)	☐	☐
1.2.4.2.8	Configure 'Provide the unique identifiers for your organization' (Manual)	☐	☐
1.2.4.2.9	Set 'Allow Standby States (S1-S3) When Sleeping (On Battery)' to 'Disabled' (Automated)	☐	☐
1.2.4.2.10	Set 'Allow Standby States (S1-S3) When Sleeping (Plugged In)' to 'Disabled' (Automated)	☐	☐
1.2.4.3	Credential User Interface		
1.2.4.3.1	Configure 'Require trusted path for credential entry' (Manual)	☐	☐
1.2.4.3.2	Configure 'Do not display the password reveal button' (Manual)	☐	☐
1.2.4.3.3	Set 'Enumerate administrator accounts on elevation' to 'Disabled' (Automated)	☐	☐
1.2.4.4	Event Log		
1.2.4.4.1	Set 'Security: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated)	☐	☐
1.2.4.4.2	Set 'System: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated)	☐	☐
1.2.4.4.3	Set 'Security: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated)	☐	☐
1.2.4.4.4	Set 'Application: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated)	☐	☐
1.2.4.4.5	Set 'System: Maximum Log Size (KB)' to 'Enabled:20480 or greater' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.4.6	Set 'Application: Control Event Log behavior when the log file reaches its maximum size' to 'Disabled' (Automated)	☐	☐
1.2.4.5	Remote Desktop Services		
1.2.4.5.1	Set 'Do not allow drive redirection' to 'Enabled' (Automated)	☐	☐
1.2.4.5.2	Configure 'Allow users to connect remotely by using Remote Desktop Services' (Manual)	☐	☐
1.2.4.5.3	Set 'Encryption Level' to 'Enabled:High Level' (Automated)	☐	☐
1.2.4.5.4	Set 'Always prompt for password upon connection' to 'Enabled' (Automated)	☐	☐
1.2.4.5.5	Set 'Do not allow passwords to be saved' to 'Enabled' (Automated)	☐	☐
1.2.4.6	Windows Remote Management		
1.2.4.6.1	Set 'Disallow Digest authentication' to 'Enabled' (Automated)	☐	☐
1.2.4.6.2	Set 'Allow Basic authentication' to 'Disabled' (Automated)	☐	☐
1.2.4.6.3	Set 'Allow Basic authentication' to 'Disabled' (Automated)	☐	☐
1.2.4.6.4	Set 'Disallow WinRM from storing RunAs credentials' to 'Enabled' (Automated)	☐	☐
1.2.4.6.5	Set 'Allow unencrypted traffic' to 'Disabled' (Automated)	☐	☐
1.2.4.6.6	Set 'Allow unencrypted traffic' to 'Disabled' (Automated)	☐	☐
1.2.4.7	Windows Update		
1.2.4.7.1	Configure 'Specify intranet Microsoft update service location' (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.7.2	Set 'Reschedule Automatic Updates scheduled installations' to 'Enabled' (Automated)	☐	☐
1.2.4.7.3	Set 'Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows dialog box' to 'Disabled' (Automated)	☐	☐
1.2.4.7.4	Set 'Configure Automatic Updates' to 'Enabled' (Automated)	☐	☐
1.2.4.7.5	Set 'Configure automatic updating' to '3 - Auto download and notify for install' (Automated)	☐	☐
1.2.4.7.6	Set 'Scheduled install day' to '0 - Every day' (Automated)	☐	☐
1.2.4.7.7	Set 'No auto-restart with logged on users for scheduled automatic updates installations' to 'Disabled' (Automated)	☐	☐
1.2.4.7.8	Set 'Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box' to 'Disabled' (Automated)	☐	☐
1.2.4.8	Configure 'Allow the use of biometrics' (Manual)	☐	☐
1.2.4.9	Set 'Turn off Data Execution Prevention for Explorer' to 'Disabled' (Automated)	☐	☐
1.2.4.10	Configure 'Turn off the Store application' (Manual)	☐	☐
1.2.4.11	Set 'Always install with elevated privileges' to 'Disabled' (Automated)	☐	☐
1.2.4.12	Configure 'Allow deployment operations in special profiles' (Manual)	☐	☐
1.2.4.13	Configure 'Allow all trusted apps to install' (Manual)	☐	☐
1.2.4.14	Set 'Pick one of the following settings' to 'Enabled:Require approval from an administrator before running downloaded unknown software' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.4.15	Configure 'Turn off Automatic Download of updates' (Manual)	☐	☐
1.2.4.16	Set 'Allow Remote Shell Access' to 'Enabled' (Automated)	☐	☐
1.2.4.17	Configure 'Turn off location' (Manual)	☐	☐
1.2.4.18	Configure 'Prevent the computer from joining a homegroup' (Manual)	☐	☐
1.2.4.19	Configure 'Turn off Windows Location Provider' (Manual)	☐	☐
2	User Configuration		
2.1	Configure 'Disable regedit from running silently?' (Manual)	☐	☐
2.2	Configure 'Prevent Codec Download' (Manual)	☐	☐
2.3	Set 'Notify antivirus programs when opening attachments' to 'Enabled' (Automated)	☐	☐
2.4	Set 'Do not preserve zone information in file attachments' to 'Disabled' (Automated)	☐	☐
2.5	Configure 'Hide mechanisms to remove zone information' (Manual)	☐	☐
2.6	Configure 'Remove CD Burning features' (Manual)	☐	☐
2.7	Configure 'Remove Security tab' (Manual)	☐	☐
2.8	Set 'Password protect the screen saver' to 'Enabled' (Automated)	☐	☐
2.9	Set 'Enable screen saver' to 'Enabled' (Automated)	☐	☐
2.10	Set 'Seconds' to 'Enabled:900 or fewer seconds' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.11	Set 'Screen saver executable name' to 'Enabled:scrnsave.scr' (Automated)	☐	☐
2.12	Configure 'Prevent changing screen saver' (Manual)	☐	☐
2.13	Configure 'Turn off toast notifications on the lock screen' (Manual)	☐	☐

Appendix: Change History

Date	Version	Changes for this version
1-31-2013	1.0.0	Initial Release

ARCHIVE